

PROJET DE FIN D'ÉTUDES

DIPLÔME NATIONAL D'INGÉNIEUR

SPÉCIALITÉ : Cycle ingénieur

Socle GCP sécurisé Zero Trust, DevSecOps et détection enrichie par IA

Hébergement et sécurisation des applications MENAL

Réalisé par : **Mansour HABIBOULLAH**

Encadré par :

Encadrant ESPRIT : **Rihem Matoussi**

Encadrant Entreprise : **Houssein Ezzedine**

Année universitaire : 2025–2026



Dédicace

À mes parents, pour leur soutien constant et leurs sacrifices.

À mes frères, pour leurs encouragements.

À tous ceux qui m'ont accompagné jusqu'ici.

Remerciements

Je tiens à remercier Mme Rihem Matoussi, mon encadrante académique à ESPRIT, pour son suivi et ses recommandations tout au long de ce projet de fin d'études. Mes remerciements s'adressent également à M. Houssein Ezzedine, mon encadrant au sein de MENAL-SARL, pour la confiance accordée, la disponibilité et les échanges qui ont accompagné la réalisation de ce travail.

Je remercie l'équipe de MENAL-SARL pour son accueil, ainsi que l'ensemble du corps enseignant d'ESPRIT pour les connaissances et les méthodes acquises durant ma formation. J'adresse également mes remerciements aux membres du jury pour le temps consacré à l'évaluation de ce mémoire.

J'adresse enfin ma reconnaissance la plus profonde à mes parents, pour leur soutien indéfectible et la confiance qu'ils m'ont toujours témoignée, ainsi qu'à mes frères, dont les encouragements ne m'ont jamais fait défaut tout au long de ces années d'études.

Résumé

Ce mémoire présente la conception, la réalisation et l'évaluation d'un socle d'hébergement sécurisé sur Google Cloud pour MENAL-SARL. Le point de départ est une application pilote sur un serveur unique, sans reproductibilité complète ni chaîne de détection. La démarche associe audit technique, analyse de risque, vingt exigences vérifiables, architecture Zero Trust, infrastructure décrite en code et portes de contrôle DevSecOps bloquantes. Le socle obtenu sépare les identités de service, déploie sans clé permanente et exécute sept règles de détection sur une collecte filtrée de journaux ; un modèle spécialisé rapproche les alertes des techniques MITRE ATT&CK, hors du score d'incident. Le 19/08/2026, treize requêtes malveillantes d'un scénario de bout en bout ont toutes été bloquées en HTTP 403, retrouvées dans les journaux et agrégées par la règle R2 quinze minutes plus tard. Le 24/08/2026, une sortie réseau non autorisée et une connexion croisée entre locataires ont été refusées et journalisées, les deux horodatages se recoupant ; le contrôle d'isolation des données du locataire a réussi six vérifications sur six. La restauration de la base a été mesurée à 32 min 45 s, sans perte de données. Les limites principales sont la sortie réseau non gouvernée de deux charges de travail détachées du sous-réseau, un motif de traversée de chemin encore partiellement filtré, l'instance de base de données encore partagée entre locataires et l'absence de mesures complètes de coût et de qualité sémantique. Le socle est reproductible et exploitable en recette ; l'apport principal n'est pas un composant nouveau mais une méthode : chaque contrôle est associé au test qui en démontre l'efficacité, et le mémoire publie les contrôles qui tiennent comme ceux qui ne tiennent pas encore.

Mots-clés : Zero Trust, DevSecOps, Google Cloud, infrastructure as code, SIEM, MITRE ATT&CK, sécurité multi-locataire.

Abstract

This thesis presents the design, implementation, and evaluation of a secure Google Cloud hosting foundation for MENAL-SARL. The starting point is a pilot application on a single server, without full reproducibility or a security detection pipeline. The approach combines technical audit, risk analysis, twenty verifiable requirements, a Zero Trust architecture, infrastructure as code and blocking DevSecOps gates. The resulting foundation separates service identities, deploys without permanent keys and runs seven detection rules over filtered log collection; a domain-specific model maps alerts to MITRE ATT&CK techniques, outside the incident score. On 19 August 2026, thirteen malicious requests from an end-to-end scenario were all blocked with HTTP 403, found in the logs and aggregated by rule R2 fifteen minutes later. On 24 August 2026, an unauthorised outbound connection and a cross-tenant connection were both refused and logged, with matching timestamps on either side; the tenant data-isolation control passed all six checks. Database restoration was measured at 32 min 45 s, with no data loss. The main limitations are the ungoverned network egress of two workloads detached from the subnet, one partially filtered path traversal pattern, the database instance still shared across tenants, and incomplete cost and semantic quality measurements. The foundation is reproducible and operable in the staging environment; its main contribution is not a new component but a method: every control is paired with the test that demonstrates its effectiveness, and the report publishes the controls that hold as well as those that do not hold yet.

Keywords: Zero Trust, DevSecOps, Google Cloud, infrastructure as code, SIEM, MITRE ATT&CK, multi-tenant security.

Liste des acronymes

Sigle	Signification
ADR	Architecture Decision Record — registre de décisions d’architecture
ALB	Application Load Balancer
API	Application Programming Interface
BQ	BigQuery (service d’entrepôt de données GCP)
CI/CD	Continuous Integration / Continuous Deployment
CIS	Center for Internet Security — référentiel de configuration sécurisée
CMEK	Customer-Managed Encryption Keys
CVE	Common Vulnerabilities and Exposures
DevSecOps	Development, Security and Operations
DNS	Domain Name System
EBIOS RM	Expression des besoins et identification des objectifs de sécurité — Risk Manager, méthode d’analyse de risque orientée métier
GCP	Google Cloud Platform
GKE	Google Kubernetes Engine
HA	Haute disponibilité (High Availability)
IaC	Infrastructure as Code
IAM	Identity and Access Management
JWT	JSON Web Token
KMS	Key Management Service
NAT	Network Address Translation
NIST	National Institute of Standards and Technology
OIDC	OpenID Connect
ONNX	Open Neural Network Exchange
OWASP	Open Worldwide Application Security Project
PITR	Point-In-Time Recovery
PSA	Private Service Access
RBAC	Role-Based Access Control
RGPD	Règlement général sur la protection des données
SA	Service Account (compte de service)
SAST	Static Application Security Testing
SCA	Software Composition Analysis — analyse de composition logicielle
SIEM	Security Information and Event Management
SLO	Service Level Objective
SLSA	Supply-chain Levels for Software Artifacts — cadre de provenance
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege — méthode de dérivation de menaces par flux
TLS	Transport Layer Security
VPC	Virtual Private Cloud
VPC-SC	VPC Service Controls
WAF	Web Application Firewall
WIF	Workload Identity Federation
ZTA	Zero Trust Architecture

Les familles d’identifiants employées dans le corps du mémoire — exigences, flux, décisions, écarts, règles de détection, tests — sont récapitulées à la page suivante.

Conventions de notation

Désignation des composants. Les composants du socle sont désignés par leur *capacité* — ce qu'ils font — plutôt que par leur nom commercial, afin que l'architecture reste lisible indépendamment du fournisseur. Le produit qui réalise chaque capacité est indiqué entre parenthèses à sa première occurrence, et la correspondance complète figure au tableau d'inventaire technologique de la section 2.6.2.

Familles d'identifiants. Le mémoire emploie des codes préfixés pour rendre la traçabilité vérifiable d'un chapitre à l'autre : une menace, l'exigence qui la traite, le contrôle qui la met en œuvre et le test qui la vérifie portent chacun un identifiant stable. Chaque famille est *établie* une seule fois, dans le chapitre porté en bandeau du tableau ci-dessous, et le reste du mémoire n'y renvoie plus que par le code. Les séries sont complètes : aucun numéro n'est manquant à l'intérieur d'une série.

Préfixe	Signification	Série
Chapitre 1 — contexte, existant et problématique		
C	Carence structurante de l'existant	C1–C5
Q	Question dérivée de la problématique	Q1–Q6
O	Objectif du projet	O1–O6
PH	Phase du projet	PH0–PH7
Chapitre 2 — état de l'art et choix technologiques		
V	Verrou identifié dans l'état de l'art	V1–V4
Chapitre 3 — besoins et modélisation des menaces		
A	Acteur du modèle, légitime ou hostile	A1–A11
BF	Besoin fonctionnel	BF1–BF13
BNF	Besoin non fonctionnel	BNF1–BNF7
TB	Frontière de confiance	TB1–TB5
SO	Scénario opérationnel de menace	SO1–SO24
EX	Exigence de sécurité	EX1–EX20
Chapitre 4 — conception de l'architecture		
PR	Principe directeur d'architecture	PR1–PR4
L	Niveau du modèle en couches	L1–L7
F	Flux de l'architecture	F1–F7
D	Décision d'architecture	D00–D16
É	Écart entre conception et implémentation	É1–É11
Chapitre 5 — réalisation et industrialisation		
R	Règle de détection	R1–R7
Chapitre 6 — validation et mesure		
T	Protocole de la campagne de validation	T1–T20

Quatre familles ne servent qu'à l'analyse de risque et sont définies là où elles servent, en annexe C : valeurs métier VM1–VM6, biens supports BS1–BS9, sources de risque SR1–SR6 et scénarios stratégiques SS1–SS7. Deux échelles de cotation y emploient les préfixes G et V — gravité G1–G4, vraisemblance V1–V4 — sans rapport avec les verrous V1–V4 du tableau ci-dessus : le contexte est toujours celui d'une case de la cartographie du risque. Les sept jalons M1–M7 du planning sont, eux, définis avec la figure qui les porte, au chapitre 5.

Table des matières

Dédicace	i
Remerciements	ii
Résumé	iii
Abstract	iii
Liste des acronymes	iv
Conventions de notation	v
Table des figures	viii
Liste des tableaux	ix
Introduction générale	1
1 Contexte du projet, étude de l'existant et problématique	4
1.1 Cadre du projet et entreprise d'accueil	4
1.2 L'application pilote	6
1.3 Audit de l'existant et critique	9
1.4 Problématique et objectifs	10
1.5 Périmètre, contraintes et démarche	12
Conclusion du chapitre	13
2 État de l'art et choix technologiques	14
2.1 L'architecture Zero Trust	14
2.2 L'approche DevSecOps	15
2.3 Supervision et ingénierie de la détection	16
2.4 Enrichissement sémantique des alertes	17
2.5 Choix de la plateforme d'hébergement	18
2.6 Inventaire technologique du socle	19
2.7 Référentiels et méthodes mobilisés	25
Conclusion du chapitre	26
3 Analyse des besoins et modélisation des menaces	27
3.1 Acteurs et cas d'utilisation	27
3.2 Spécification des besoins	28
3.3 Flux de données et frontières de confiance	29
3.4 Analyse de risque	31
3.5 Exigences de sécurité et traçabilité	33
3.6 Rattachement aux référentiels	35
Conclusion du chapitre	35
4 Conception de l'architecture	36
4.1 Principes directeurs de conception	36
4.2 Vues d'architecture	36
4.3 Vue dynamique : les sept flux et le cycle de la donnée	47
4.4 De l'attaque à l'incident : fonctionnement de bout en bout	48
4.5 Conception détaillée par couche	49
4.6 Le plan d'identité : la segmentation réelle	54

4.7	Décisions d'architecture et écarts d'implémentation	57
	Conclusion du chapitre	60
5	Réalisation et industrialisation	61
5.1	Environnement de travail et description en code	61
5.2	Chaîne de livraison applicative	63
5.3	Chaîne de provisionnement de l'infrastructure	67
5.4	Chaîne de détection	70
5.5	Couche d'enrichissement sémantique	72
5.6	Tableau de bord et API de supervision	73
5.7	Accueil d'un locataire et frontière de responsabilité	78
5.8	Conduite du projet	82
	Conclusion du chapitre	84
6	Validation, résultats et démonstration	85
6.1	Stratégie de validation	85
6.2	Résultats de la campagne de tests	86
6.3	Évaluation de la chaîne de détection et de l'enrichissement	89
6.4	Performance, résilience et coût	92
6.5	Démonstration de bout en bout et conformité aux référentiels	95
6.6	Ce que le filtrage applicatif ne protège pas	97
6.7	Du socle au service	98
6.8	Conditions de validité et réponse aux objectifs	101
	Conclusion du chapitre	103
	Conclusion générale	104
	Bibliographie/Netographie	106
A	Études comparatives détaillées	109
A.1	Audit de l'existant et positionnement (issus du chapitre 1)	109
A.2	État de l'art et choix technologiques (issus du chapitre 2)	110
A.3	Fiche de version de chaque brique	111
B	Extraits techniques de la réalisation	114
B.1	Dépôt d'infrastructure et protection des ressources	114
B.2	Détection, livraison et fédération d'identité	115
B.3	Provisionnement, isolation et tableau de bord	116
C	Modèle de menaces détaillé	118
C.1	Codification, scénarios stratégiques et échelles de cotation	118
C.2	Scénarios opérationnels	119
C.3	Cartographie et traitement du risque	120
D	Conception détaillée	122
D.1	Registre complet des décisions d'architecture	122
D.2	Composants évalués puis écartés	123
D.3	Prise en charge des vingt exigences par la conception	124
E	Protocoles et preuves de validation	125
F	Jeu d'évaluation de l'enrichissement sémantique	131

Table des figures

1	Carte du mémoire : chaque chapitre consomme le livrable du précédent	3
2	Organigramme de MENAL-SARL et rattachement du projet	5
3	Boucle fonctionnelle de l'application pilote et actifs produits	6
4	Modèle de sécurité de l'hébergement initial	8
5	Répartition des 41 critères de préparation au déploiement	10
6	Diagramme de cas d'utilisation du socle	28
7	Diagramme de flux de données du socle et ses cinq frontières de confiance	30
8	Vue de contexte : le socle, ses acteurs et les systèmes extérieurs	37
9	Modèle en couches : cinq couches empilées et deux plans transversaux	38
10	Vue de déploiement : composants, liens réseau et flux F1 à F5	39
11	Topologie réseau avant la refonte	40
12	Topologie réseau après la refonte appliquée	42
13	Cycle de vie de la donnée de sécurité	49
14	Modèle de données des deux systèmes de stockage	50
15	Requête malveillante refusée au périmètre	52
16	Plan d'identité : droits accordés et interdictions structurantes	55
17	Chaînes de délégation d'identité	56
18	Authentification à deux facteurs	57
19	Chaîne de livraison applicative : étapes, portes bloquantes et refus	64
20	Chaîne de provisionnement de l'infrastructure	68
21	Architecture interne des deux logiciels écrits	74
22	Chaîne de données d'une vue du tableau de bord	74
23	Tableau de bord servi à un compte analyste, page des détections	76
24	Accueil d'un locataire : six étapes et cinq gestes hors du code	79
25	Porte d'analyse statique : le faux vert du 16/08 et l'échec du 19/08	83
26	Planning consolidé du stage, du 03/03/2026 au 07/09/2026	84
27	Fiche d'incident : le candidat sémantique rendu à l'analyste	91
28	Démarrage à froid du service d'encodage	93
29	Scénario de bout en bout du 19/08/2026	95
30	Vue d'ensemble : la chaîne de sécurité se termine par un écran	101

Liste des tableaux

1	Fiche signalétique de l'entreprise d'accueil.	4
2	Catégories de données traitées par l'application pilote et effet d'une exposition.	7
3	Objectifs et critères de succès du projet.	11
4	Les sept principes du NIST SP 800-207 et leur traduction pour le projet	14
5	Comparaison des cinq options de supervision sur les huit critères discriminants. Légende	17
6	Approches d'association alerte → technique ATT&CK	17
7	Comparaison des six options d'hébergement sur les sept critères discriminants	19
8	Application du critère de sélection : deux admissions, deux rejets et un cas frontière	20
9	Les trente-trois briques structurantes, par couche : critère décisif et prix payé	20
10	Acteurs du modèle, A1 à A11	27
11	Besoins fonctionnels	28
12	Besoins non fonctionnels	29
13	Les cinq frontières de confiance et les scénarios qui les franchissent	30
14	Formulation complète des vingt exigences de sécurité	33
15	Matrice de traçabilité menace–exigence–contrôle–test	34
16	Rattachement des exigences aux référentiels	35
17	Plan d'adressage du réseau du socle, en service depuis le 11/08/2026	40
18	Règles de pare-feu en service, ciblées par identité	41
19	Ce que la frontière d'isolation des données arrête, et ce qu'elle n'arrête pas	44
20	Critères de recette des vues d'architecture	47
21	Les sept flux de l'architecture.	47
22	Conception détaillée des sept niveaux : composants, produits, contrôles et exigences	50
23	Matrice des identités et des droits.	54
24	Registre synthétique des décisions d'architecture (justification complète en	58
25	Écarts entre conception et implémentation.	59
26	Familles de contrôles de la chaîne de livraison applicative	64
27	Modèle de données de l'entrepôt de supervision : dix tables, un écrivain chacune	71
28	État d'avancement de la couche d'enrichissement sémantique	73
29	Cartographie des vues du tableau de bord	75
30	Caractérisation quantifiée des deux logiciels écrits, dépôt vérifié le 25/08/2026.	78

31	Frontière de responsabilité entre le socle et l'éditeur	81
32	Synthèse de la campagne de vingt tests, à la date de 25/08/2026	86
33	Plan de validation continue	89
34	Causes connues de non-couverture	90
35	Restauration de la base, test réel du 3 août 2026	93
36	Constats de coût datés	94
37	Auto-évaluation de maturité Zero Trust	96
38	Coût d'accueil d'une application supplémentaire	99
39	Maturité multi-locataire, axe par axe	99
40	Conditions de validité des résultats du chapitre	102
41	Réponse aux six objectifs mesurables du projet	102
42	Positionnement des trois modèles	109
43	Comparaison des trois modes d'exécution étudiés	110
44	Fiche de version des briques structurantes	111
45	Sécurité du fichier d'état d'infrastructure	114
46	Codification des ateliers 1 à 3	118
47	Scénarios stratégiques	118
48	Échelles de gravité et de vraisemblance	119
49	Scénarios opérationnels et frontières	119
50	Décisions de traitement du risque	120
51	Registre complet des décisions d'architecture	122
52	Composants écartés et conditions de réévaluation	123
53	Prise en charge des exigences	124
54	Grandeurs relevées et condition de publication de chacune	132

Introduction générale

Sujet. La sécurité des systèmes d'information repose traditionnellement sur un modèle périmétrique : filtrer en entrée, faire confiance à l'intérieur. Ce modèle a fait ses preuves quand les ressources étaient centralisées et les utilisateurs sur le réseau local. Il ne les fait plus aujourd'hui. Les applications migrent dans le cloud, les données sont accessibles de n'importe où, et les attaques les plus coûteuses exploitent un accès légitime détourné plutôt qu'une intrusion frontale.

MENAL-SARL, entreprise de services informatiques implantée en Mauritanie et en France, a identifié ce risque sur l'une de ses applications clientes : ELSON, une plateforme de collecte participative pour les langues nationales de Mauritanie. Cette application collecte des données d'identité officielle et des enregistrements vocaux, qui constituent des données biométriques. Elle fonctionne, mais elle repose sur un serveur unique, avec confiance implicite entre tous ses composants et sans mécanisme de reproductibilité.

Convention de désignation

Les composants du socle sont désignés par leur *capacité* — ce qu'ils font — plutôt que par leur nom commercial, afin que l'architecture reste lisible indépendamment du fournisseur. Le produit qui réalise chaque capacité est indiqué entre parenthèses à sa première occurrence, et la correspondance complète figure au tableau d'inventaire technologique de section 2.6. Les familles d'identifiants employées dans le corps sont récapitulées dans la page *Conventions de notation*, en tête de document.

Problématique. Comment concevoir, déployer et surtout *prouver* un socle d'hébergement cloud aligné sur les principes Zero Trust et sur une chaîne de livraison DevSecOps ? La question se pose dans les conditions réelles d'une entreprise émergente : une seule personne pour l'exploitation, un budget de quelques dizaines d'euros par mois, aucune solution de supervision commerciale. Et quel prix faut-il payer, en faux positifs, en latence de détection et en complexité, pour atteindre ce résultat ?

La question n'est pas seulement technique. Elle comporte un coût : une architecture qui ne mesure pas ce qu'elle coûte n'est pas une architecture d'ingénieur. Elle comporte aussi une exigence de preuve. Chaque contrôle doit être associé à un test qui établit son efficacité, plutôt qu'à une simple déclaration de conformité.

Démarche. Le projet suit une démarche en huit phases, PH0 à PH7, chacune fermée par un critère de sortie vérifiable et détaillée en section 1.5.3. Un audit technique a d'abord établi l'état réel de l'existant. L'analyse de risque a ensuite identifié les scénarios d'attaque les plus critiques, traduits en vingt exigences vérifiables. L'architecture a été conçue autour de quatre principes directeurs : le principe de justification (PR1), qui impose à tout composant de justifier son existence ; le principe d'identité (PR2), qui fait de l'identité le plan de contrôle ; le principe d'intégrité de la preuve (PR3) ; et le principe de description en code (PR4). La réalisation a

construit le socle en infrastructure décrite en code, avec deux chaînes de livraison et une chaîne de détection enrichie par un modèle de représentation sémantique. Une campagne de validation confronte enfin les résultats aux objectifs mesurables fixés au départ.

Objectifs. Six objectifs mesurables structurent le projet : supprimer la confiance implicite du réseau (O1), rendre l'infrastructure reproductible (O2), contrôler la chaîne de livraison (O3), détecter les événements de sécurité (O4), enrichir les alertes de façon déterministe (O5), rester exploitable et économiquement soutenable (O6). Chaque objectif est associé à un indicateur, une cible et un moyen de vérification. Le chapitre 6 y répond point par point.

Fil conducteur. Une même attaque traverse ce mémoire de bout en bout. Le 19 août 2026, treize requêtes malveillantes ont été envoyées contre l'application hébergée en environnement de recette. Le lecteur les rencontrera successivement sous quatre formes : comme scénario de menace dérivé de l'analyse de risque au chapitre 3, comme séquence de refus au périmètre au chapitre 4, comme règle de détection au chapitre 5, et comme mesure au chapitre 6. Suivre ce cas unique d'un chapitre à l'autre est la façon la plus courte de vérifier que la conception, la réalisation et la mesure parlent bien du même système.

Plan du mémoire. Le chapitre 1 établit le contexte et la problématique sur des faits vérifiés, et présente l'entreprise d'accueil ainsi que l'application qui sert de cas réel. Le chapitre 2 examine l'état de l'art, justifie les choix technologiques et publie l'inventaire des briques structurantes du socle avec, pour chacune, le prix payé. Le chapitre 3 modélise les menaces à partir d'un diagramme de flux de données et de ses frontières de confiance, et en déduit les vingt exigences de sécurité. Le chapitre 4 présente l'architecture Zero Trust qui les réalise, vue par vue et couche par couche. Le chapitre 5 rend compte de la réalisation : infrastructure en code, chaîne de livraison applicative, chaîne de provisionnement de l'infrastructure, chaîne de détection, tableau de bord et API de supervision, accueil d'un locataire. Le chapitre 6 confronte l'ensemble à l'épreuve de la mesure — tests adverses, évaluation de la détection, performance, résilience et coût — puis énonce les conditions d'industrialisation du socle en service.

La figure 1 donne la carte de cette progression. Elle se lit de haut en bas : chaque chapitre consomme le livrable du précédent et en produit un nouveau, de sorte qu'aucun maillon ne repose sur une affirmation non établie en amont. C'est cette chaîne, et non l'accumulation de contrôles techniques, qui fait la démonstration.

Sur le volume de ce document. Ce mémoire est plus long que le format habituel, et c'est un choix assumé plutôt qu'un débordement. La thèse défendue n'est pas qu'un socle a été construit, mais que chaque contrôle qui le compose est adossé à l'épreuve qui en établit l'efficacité : une chaîne qui va d'une menace à une exigence, de l'exigence à une décision d'architecture, de la décision au code qui la réalise, et du code au protocole qui la met à l'épreuve. Une telle chaîne ne se démontre pas par échantillonnage — il suffit d'un maillon manquant pour qu'elle cesse d'en être une. C'est pourquoi les vingt exigences, les dix-sept décisions d'architecture, les écarts d'implémentation et les vingt protocoles sont publiés au complet, y compris lorsqu'ils concluent contre le socle. Le lecteur qui souhaite aller vite peut s'en tenir aux registres, qui donnent l'état du système sous forme tabulaire : la matrice de traçabilité du chapitre 3, le registre des décisions et celui des écarts du chapitre 4, et le tableau de synthèse de la campagne au chapitre 6. Le corps du texte en est le développement argumenté, et les annexes le matériel de reproduction —

protocoles détaillés, extraits de configuration et jeu d'évaluation — tenu hors du fil de lecture précisément pour ne pas l'alourdir.

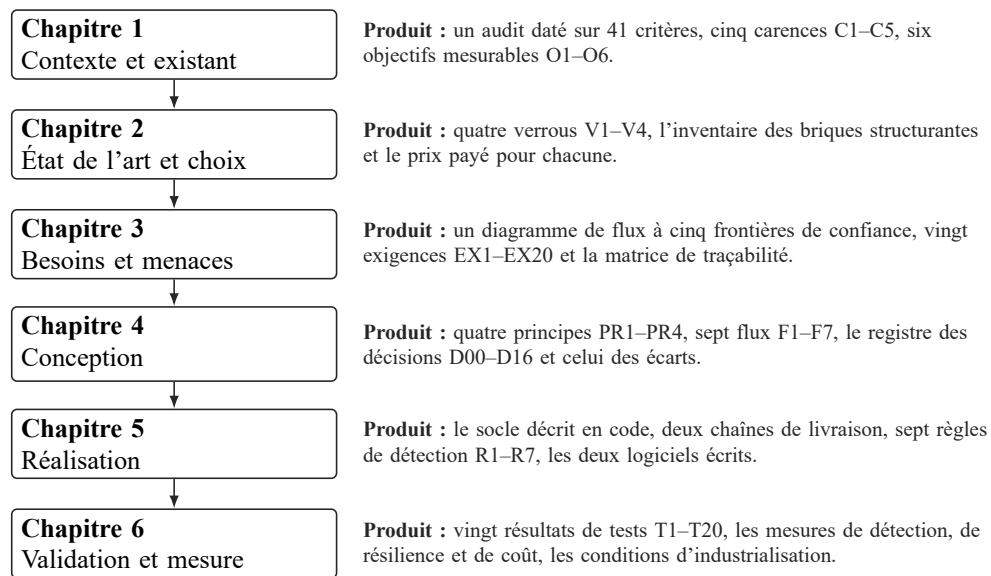


FIG. 1. Carte du mémoire : chaque chapitre consomme le livrable du précédent. Aucun maillon de la démonstration ne repose sur une affirmation qui ne soit établie en amont.

Chapitre 1 Contexte du projet, étude de l'existant et problématique

De l'audit d'une plateforme en exploitation à la formulation d'un besoin de socle

Un projet de sécurité ne se justifie pas par les technologies qu'il emploie, mais par le risque qu'il fait disparaître. Ce chapitre établit sur des faits vérifiés pourquoi celui-ci devait être mené : l'entreprise d'accueil (section 1.1), l'application qui sert de cas réel (section 1.2), l'audit de son hébergement (section 1.3), puis la problématique, les objectifs et la démarche (sections 1.4 et 1.5). L'application fonctionne, mais repose sur un modèle périmétrique et un environnement non reproductible ; le socle corrige ces deux défauts, et il est réutilisable parce que c'est l'intérêt de l'entreprise.

1.1 Cadre du projet et entreprise d'accueil

1.1.1 Fiche signalétique, activités et positionnement

MENAL-SARL est une société de services informatiques à deux axes — services et fourniture de solutions — qui accompagne un client de la conception à l'exploitation. Le tableau 1 en donne l'identité, l'organisation et le périmètre d'accueil du projet.

TAB. 1. Fiche signalétique de l'entreprise d'accueil.

Élément	Information
Raison sociale	MENAL-SARL
Forme juridique et création	Société à responsabilité limitée, créée en 2025
Implantations	Siège social à Nouakchott (Mauritanie) ; implantation secondaire en France
Secteur et marchés	Services et technologies de l'information, pour des organisations mauritaniennes engagées dans la digitalisation et la sécurisation de leur système d'information
Axes d'activité	Services informatiques : architectures cloud, DevSecOps et Zero Trust, applications sécurisées, chaînes de données, audit de systèmes existants. Fourniture de solutions IT : matériels, installation, déploiement, maintenance
Organisation	Trois niveaux : direction générale, trois directions opérationnelles, neuf unités (figure 2)
Domaine institutionnel	menal-sarl.com
Périmètre d'accueil du projet	Direction technique — unités <i>Cloud et DevOps</i> et <i>Cyber et SOC</i>
Encadrement	M. Houssein Ezzedine (entreprise), Mme Rihem Matoussi (académique)
Période du projet	Du 3 mars au 7 septembre 2026

Les organisations que l'entreprise adresse sont des structures émergentes, et l'entreprise elle-même en est une : à cette taille, ni une supervision commerciale, dont la licence est indexée sur le volume de journaux ingérés, ni une équipe de sécurité à demeure ne s'amortissent sur un client unique. Cette contrainte de marché est reprise telle quelle comme **contrainte humaine** et **contrainte économique** du projet (section 1.5.2), puis comme **verrou V1** de l'état de l'art (chapitre 2) : le même fait à trois échelles. Le socle n'est pas la transposition d'un modèle existant, c'est la réponse à un modèle qui ne s'applique pas.

1.1.2 Organisation, gouvernance et périmètre d'accueil

La figure 2 donne l'organigramme à la date de 25/08/2026 : une direction générale, trois directions opérationnelles et neuf unités, dont quatre à la direction technique — hébergement et déploiement, sécurité et supervision, développement applicatif, chaînes de données et modèles.

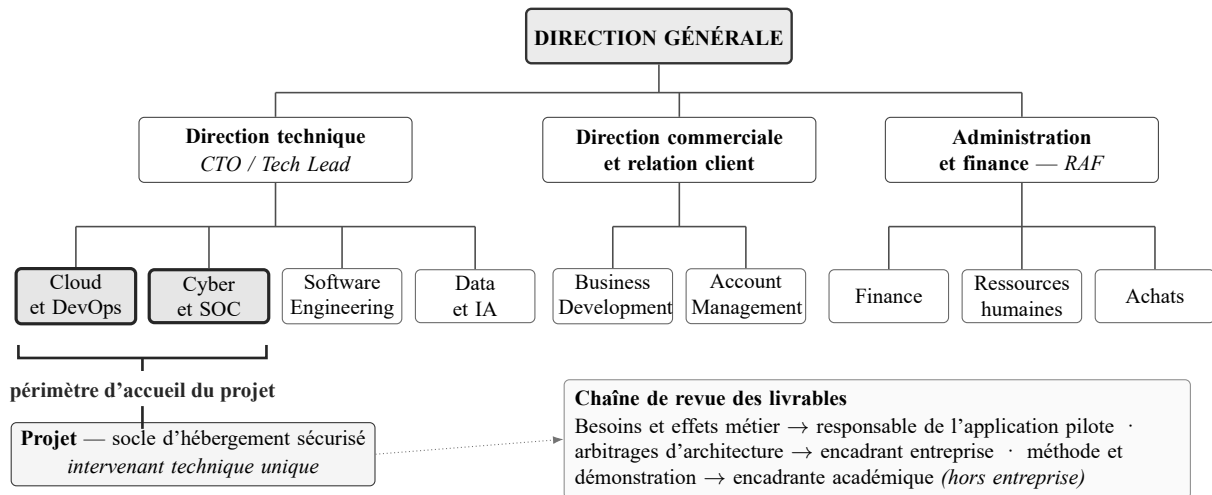


FIG. 2. Organigramme de MENAL-SARL et rattachement du projet, à la date de 25/08/2026. Ce qu'il faut y voir : une réalisation mono-opérateur, portée par deux des neuf unités, validée par trois regards dont un hors de l'entreprise.

Trois faits caractérisent le cadre d'exécution, et chacun est repris tel quel comme donnée d'entrée dans la suite du mémoire. Le **périmètre d'accueil** joint deux unités, *Cloud et DevOps* et *Cyber et SOC*, et ce rattachement double n'est pas une commodité d'organigramme : le socle est précisément l'objet qui les joint — de la première seule relèverait une plateforme d'hébergement, de la seconde seule un outillage de supervision posé sur une infrastructure qu'il ne maîtrise pas. Le projet est ensuite **mono-porteur** — l'élève-ingénieur en assure seul la conception, la réalisation et l'exploitation —, donnée reprise comme contrainte humaine en section 1.5.2, qui écarte par construction tout composant à exploitation permanente. Les livrables suivent enfin une **chaîne de revue à trois niveaux** dont le troisième regard est extérieur à l'entreprise : c'est ce qui compense la faiblesse structurelle d'un contrôle mono-opérateur.

1.1.3 Mission confiée et positionnement stratégique

La mission comporte cinq volets : auditer l'application pilote, formaliser les risques qu'elle porte, concevoir un socle Zero Trust et DevSecOps, l'implémenter en infrastructure décrite en code et confronter ses contrôles à des tests et à des mesures. J'en ai assuré la continuité de bout en bout ; le planning figure en section 5.8.2.

Le point décisif est ailleurs, et il commande l'ampleur du travail. Un prestataire qui héberge les applications de ses clients dispose de deux voies. La première construit un environnement sur mesure par client : rapide au premier contrat, elle fait recommencer à chaque suivant le réseau, les identités, les secrets, la journalisation et la chaîne de livraison, et le niveau de sécurité atteint est celui qu'autorise le budget du client le plus modeste. La seconde construit une fois un socle standardisé dont chaque client devient un locataire : le coût de conception est payé une fois, le niveau de sécurité est celui du socle et non du contrat, et l'accueil d'une application se réduit à

l’instanciation de paramètres. **Le coût de sécurité cesse alors d’être une dépense récurrente pour devenir un actif de l’entreprise** : c’est la voie retenue, et elle justifie qu’un projet de fin d’études porte sur un socle plutôt que sur la sécurisation d’une application. Elle devient une exigence vérifiable au chapitre 3 — le besoin **BF13** interdit à tout composant du socle une logique propre à une application —, confrontée à sa preuve au chapitre 5 par l’accueil d’un second locataire puis discutée au chapitre 6.

1.2 L’application pilote

1.2.1 Nature, publics et modèle fonctionnel

L’application retenue comme premier cas d’usage du socle est ELSON, une plateforme de production participative gamifiée qui construit des jeux de données parallèles, texte et audio, pour les langues nationales de Mauritanie, en commençant par l’arabe hassaniya. Son public est constitué de locuteurs hassanophones de Mauritanie et de la diaspora, mobilisés par une compétition dotée de prix, et ses données de meilleure qualité alimentent des modèles de reconnaissance vocale, de traduction et de synthèse. Le cycle fonctionnel est une boucle à trois temps (figure 3) : un contributeur traduit des phrases sources, enregistre sa voix, puis évalue les contributions d’autrui ; les évaluations font le classement, le classement commande la dotation, et les contributions validées alimentent le corpus. Chacun de ces trois temps produit une donnée d’un genre différent et offre une prise différente à un adversaire.

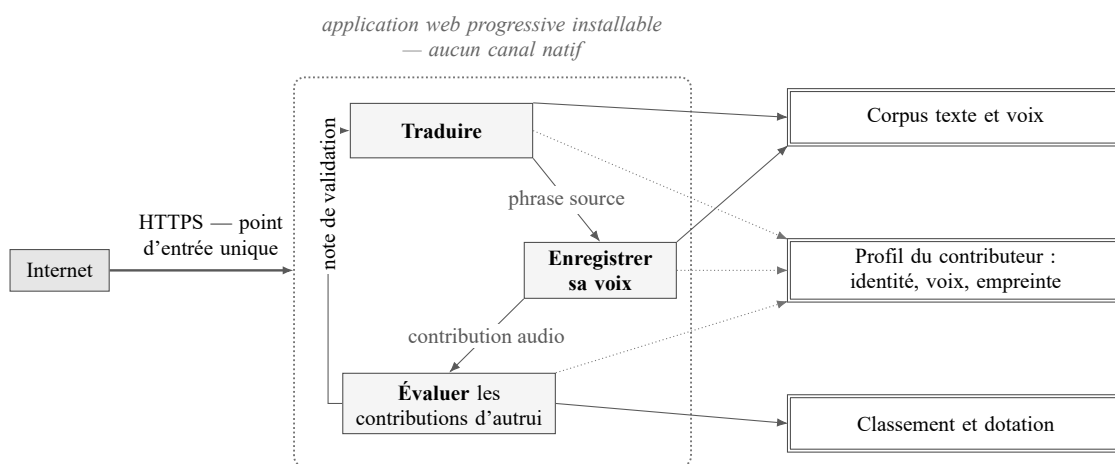


FIG. 3. Boucle fonctionnelle de l’application pilote et actifs produits. Chacun des trois temps produit un actif d’une nature différente — corpus, classement doté, profil de contributeur — alors que tous trois transitent par un seul point d’entrée HTTP.

Une précision d’architecture porte ici un argument et non un détail. ELSON est une **application web progressive installable** servie par un frontend à rendu serveur — ni application native, ni application hybride, le caractère installable tenant à un manifeste et à un agent de service écrits à la main. Toute la surface d’attaque transite donc par HTTP : un **filtrage applicatif** placé au bord la couvre entièrement, et *aucun canal mobile n’échappe au périmètre du socle*.

Il ne s’agit pas d’un prototype mais d’une application en exploitation réelle. À la date de l’audit du 29/07/2026, le dépôt comptait environ 34 600 lignes de code TypeScript et 225 points d’entrée HTTP répartis en onze routeurs, dont environ 165 derrière un contrôle d’administration ;

la base réunissait 54 tables PostgreSQL, 17 vues, 15 fonctions et déclencheurs, définies dans 74 fichiers SQL dont 72 migrations. Ces valeurs sont datées parce qu’elles décrivent un logiciel vivant — au 28/08/2026, environ 245 points d’entrée et 85 migrations —, et l’analyse repose sur l’état du 29/07/2026, celui sur lequel les décisions ont été prises.

1.2.2 Sensibilité des données traitées

Le niveau de sécurité exigé d’un hébergement ne se déduit pas du nombre de ses utilisateurs mais de la nature de ce qu’il conserve. Le tableau 2 recense les catégories manipulées, désignées par le champ qui les porte, et l’effet de leur exposition.

TAB. 2. Catégories de données traitées par l’application pilote et effet d’une exposition.

Champ ou groupe de champs	Nature au sens de la protection des données	Ce que produit son exposition
nni	Identifiant national officiel, unique par compte et rendu immuable par déclencheur	Usurpation d’identité administrative hors de la plateforme ; l’identifiant ne peut pas être réémis
audio_url et fichiers associés	Enregistrement vocal du contributeur, donc donnée biométrique au sens de l’article 9 du RGPD	Identification et imitation vocale ; la voix ne peut pas être changée
whatsapp, first_name, last_name, birthdate, email	Contact direct et état civil	Joindre la personne hors de la plateforme et rapprocher son compte de son identifiant national
signup_ip, signup_geo, signup_ua, device_fingerprint	Adresse de connexion, géolocalisation et empreinte d’appareil, indexées pour le regroupement anti-fraude	Relie des comptes distincts et localise une personne : l’outil anti-fraude devient un outil de surveillance s’il fuit
fraud_score	Décision individuelle automatisée : au-delà d’un seuil, l’inscription est rejetée sans intervention humaine	Relève de l’article 22 du RGPD : la décision doit pouvoir être expliquée et contestée, donc son historique protégé
contributor_credits (nom et numéro d’un tiers)	Données personnelles de personnes <i>non inscrites</i> sur la plateforme	Le consentement est saisi par le contributeur, pas par la personne concernée : l’exposition atteint des tiers sans relation avec le service
audit_log.details	Traces d’administration portant des données personnelles en clair	Étend la portée de toutes les lignes précédentes à la journalisation elle-même

L’irréversibilité d’abord. L’identifiant national et l’empreinte vocale sont les deux seules catégories qui ne se révoquent pas : leur exposition est définitive et le reste après la fin de vie du service. Au 28/08/2026, elles sont protégées par le chiffrement d’infrastructure du socle et, pour l’audio, par des adresses signées à durée courte, sans chiffrement applicatif propre : c’est ce constat qui fixe le niveau d’exigence attendu de l’hébergement.

L’incitation ensuite. Aucun flux de paiement ne transite par l’application, ce qui restreint utilement le périmètre de conformité ; mais la compétition est dotée de prix, et cette incitation crée un adversaire que la plupart des modèles de menace oublient : celui qui *dispose déjà d’un accès légitime*, aux requêtes bien formées et aux quotas respectés — le **participant fraudeur** (acteur A9 du chapitre 3). C’est la justification la plus directe du modèle Zero Trust : un périmètre ne dit rien d’un adversaire déjà admis.

Le cadre juridique enfin. Le traitement s’exécute dans une région européenne et concerne des personnes situées en Mauritanie et dans la diaspora : le RGPD s’applique par le lieu du traitement, et pour la diaspora au titre de son article 3. Trois dispositions se cumulent — articles 9 (biométrie), 22 (décision automatisée) et 35 —, et ce cumul déclenche l’obligation d’analyse d’impact. Le rattachement institutionnel du projet appelle en outre la **loi tunisienne n° 2004-63**

du 27 juillet 2004 : formalité préalable, consentement écrit, droits d'accès et de rectification, encadrement des transferts hors territoire. Reste le droit mauritanien, alors que les personnes concernées sont mauritaniennes et que l'identifiant collecté est un identifiant d'État : aucune norme mauritanienne n'ayant été vérifiée dans ce travail, le mémoire pose la question comme **ouverte et assumée** plutôt que de la refermer par une référence approximative. Son traitement relève du responsable de traitement (section 1.5.1).

1.2.3 Trois actifs, trois adversaires

L'analyse de l'application ne fait pas apparaître un actif à protéger, mais trois, de natures différentes et exposés à des adversaires différents. **Le corpus** est le résultat économique du projet — données texte et voix validées, constituées au prix d'un effort humain long, exportables par un point d'entrée dédié — et il attire l'**acteur intéressé par le corpus**, patient et ciblant délibérément (A8). **L'équité de la compétition** tient au classement, qui commande la dotation : faussé, il ne détourne pas seulement un prix, il pollue le corpus qu'il devait sélectionner ; l'adversaire y est le **participant fraudeur**, disposant d'un accès légitime et d'une incitation financière (A9). **L'identité des contributeurs** — voix et identifiant national — est la seule catégorie dont l'exposition ne se répare pas, et elle expose à l'**attaquant opportuniste** (A7) comme à l'**interne ou prestataire** disposant d'un accès légitime initial (A11).

C'est cette mise en regard, et non une liste de bonnes pratiques, qui justifie le niveau de défense construit ensuite : contrôler ce qui entre (l'opportuniste), contraindre ce qui est déjà admis (le fraudeur), prouver ce qui s'est passé (l'interne). Le chapitre 3 reprend ces trois actifs comme valeurs métier de l'analyse de risque.

1.2.4 L'hébergement initial et son modèle de sécurité

Avant le projet, l'application est déployée sur un serveur unique loué chez un hébergeur européen : des conteneurs orchestrés par un seul fichier de composition — frontend Next.js, API Express en cluster, base PostgreSQL 17, pooler PgBouncer, proxy Caddy (TLS), passerelle WhatsApp tierce et sauvegarde locale. Ce modèle (figure 4) repose sur un pare-feu unique en entrée et une confiance implicite à l'intérieur.

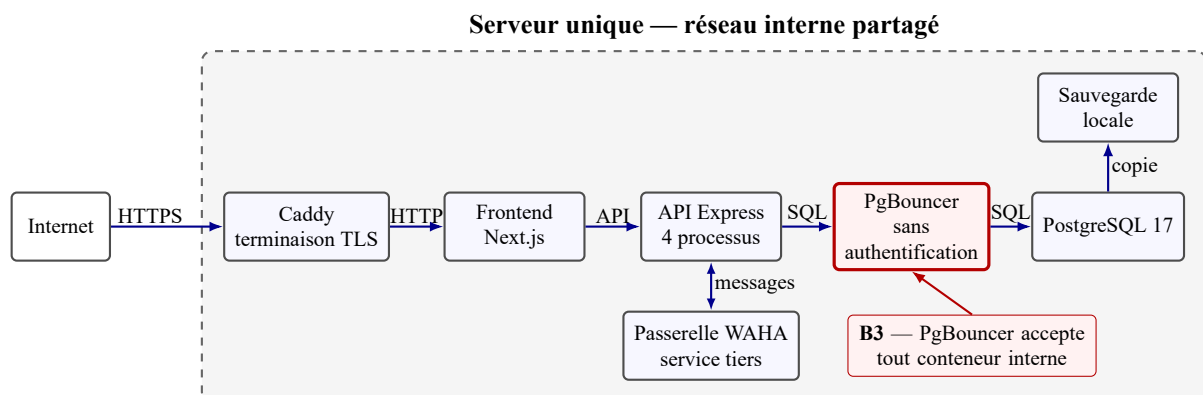


FIG. 4. Modèle de sécurité avant le projet : périmètre unique en entrée, confiance implicite à l'intérieur. Tout composant présent sur le réseau interne est traité comme légitime — c'est la carence C1.

1.3 Audit de l'existant et critique

1.3.1 Méthode et résultats de l'audit

Un audit technique et sécurité a été réalisé le 29 juillet 2026, en amont de toute conception, par analyse statique exhaustive du dépôt — code, configurations, scripts de déploiement et 74 fichiers SQL —, sans exécution ni déploiement. Deux règles l'ont encadré, qui gouvernent aussi l'écriture de ce mémoire : la **règle de preuve** (seul ce qui est dans le dépôt est documenté, chemin et ligne cités) et la **règle de confidentialité** (aucun secret reproduit, valeurs sensibles désignées par leur nom de variable). Chaque constat porte l'un de quatre statuts — *vérifié*, *dépendant de l'exécution* donc non observable dans le dépôt seul, *absent*, *recommandé* ; la répartition des 41 critères par catégorie et par statut est donnée par la figure 5.

L'audit ne conclut pas à un travail de mauvaise qualité : plusieurs mécanismes dépassent ce que l'on observe à cette taille — aucune injection SQL ou système, sessions avec rotation et détection de réutilisation, intégrité de la compétition assurée par quatorze signaux de fraude. La logique applicative est mûre ; le problème est dans la configuration et l'industrialisation. Au 29/07/2026, l'audit retient six constats bloquants.

- **B1** — compte administrateur par défaut, au mot de passe en clair dans le schéma versionné ;
- **B2** — secret unique partagé par sept mécanismes cryptographiques ;
- **B3** — pooler de base de données accessible sans authentification ;
- **B4** — jeton de téléchargement du corpus non lié à un utilisateur, à une adresse IP ou à un usage unique ;
- **B5** — schéma de base non reconstituable depuis le dépôt, avec trois objets sans définition versionnée ;
- **B6** — état applicatif local au processus, incompatible avec la mise à l'échelle horizontale.

Le mémoire conserve ces six constats dans l'état daté où ils ont été relevés, parce que ce sont eux qui fondent le besoin de socle ; plusieurs ont depuis été traités par l'éditeur, en partie à l'occasion de l'accueil de l'application sur le socle (chapitre 5). La figure 5 donne l'écart à lire : l'application fait ce qu'elle doit faire, mais elle n'est ni reproductible, ni observable, ni conforme, ni déployable de façon maîtrisée.

1.3.2 Cinq carences structurantes et positionnement du socle

Reformulés à un niveau d'abstraction plus élevé, ces constats font apparaître cinq carences structurantes qui ne sont pas propres à cette application : elles caractérisent un système construit sans socle.

- **C1** — **Modèle de confiance périmétrique** : barrière d'entrée unique et confiance implicite à l'intérieur ;
- **C2** — **Environnement non reproductible** : infrastructure et schéma de données non décrits en code ;
- **C3** — **Chaîne de livraison non contrôlée** : aucun contrôle automatique entre l'écriture du code et sa mise en production ;

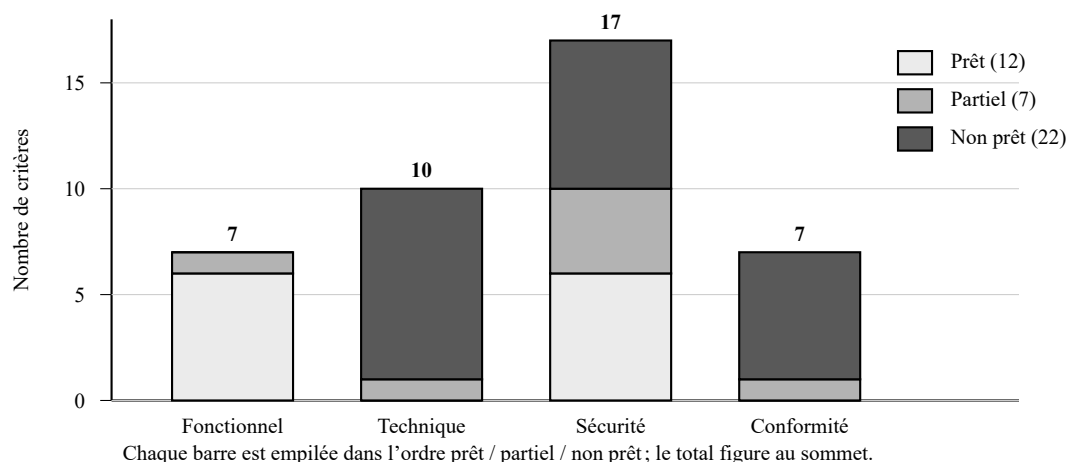


FIG. 5. Répartition des 41 critères de préparation au déploiement, par catégorie et par statut (audit du 29/07/2026).

- **C4 — Absence d'observabilité et de détection** : événements non centralisés, non corrélés, intrusion non détectée;
- **C5 — Absence de cadre de conformité** : données d'identité et biométriques traitées sans base légale, sans durée de conservation ni droit d'effacement.

Une conclusion importante en découle : corriger l'application ne suffit pas. Les carences C1 à C5 ne sont pas des défauts de code mais des propriétés absentes de l'environnement d'exécution ; aucun correctif applicatif ne créera d'identité par charge de travail, de journalisation centralisée, de chaîne de livraison contrôlée ni de reproductibilité. D'où le périmètre : le code applicatif en reste dehors, le socle qui héberge, isole, contrôle, journalise et supervise l'application en est l'objet — et un socle conçu indépendamment d'elle peut en accueillir d'autres (section 1.1.3).

Trois modèles situent la solution visée : le modèle A, l'architecture périmétrique de l'existant (section 1.2.4) ; le modèle B, un hébergement cloud managé sans démarche de sécurité explicite ; le modèle C, le socle Zero Trust visé. La comparaison à quinze critères, issus pour la plupart des principes Zero Trust [27], figure au tableau 42. Le modèle C domine sur la sécurité et la reproductibilité et perd sur trois critères, repris au chapitre 6 : la simplicité initiale, la mise à l'échelle horizontale, écartée des objectifs (section 1.5.1), et la maturité opérationnelle, une supervision sur mesure ne bénéficiant d'aucun support éditeur. Ce sont ces trois pertes qui rendent crédible le reste de la comparaison.

1.4 Problématique et objectifs

1.4.1 Problématique et questions dérivées

Les constats précédents permettent de formuler la question centrale du mémoire.

Comment concevoir, déployer et surtout *prouver* un socle d'hébergement cloud aligné sur les principes Zero Trust et sur une chaîne de livraison DevSecOps? La question se pose dans les conditions réelles d'une entreprise émergente : une seule personne pour l'exploitation, un budget de quelques dizaines d'euros par mois, aucune solution

de supervision commerciale. Et quel prix faut-il payer, en faux positifs, en latence de détection et en complexité, pour atteindre ce résultat ?

Le verbe *prouver* est central : chaque contrôle doit être associé à un test qui démontre son efficacité, non à une déclaration de conformité ; et la question porte un coût explicite, une architecture qui ne mesure pas ce qu'elle coûte n'étant pas une architecture d'ingénieur. Six questions dérivées en découlent, chacune associée à un objectif et à un chapitre. **Q1** (O2 · ch. 5-6) un environnement complet peut-il être détruit puis reconstruit à l'identique depuis le seul dépôt, en combien de temps ? **Q2** (O1 · ch. 4-6) que reste-t-il atteignable depuis Internet quand le point d'entrée unique est contourné ? **Q3** (O1 · ch. 4-6) que peut faire un compte ou un service compromis, jusqu'où peut-il aller ? **Q4** (O4 · ch. 5-6) quelles attaques sont détectées, lesquelles ne le sont pas, en combien de temps ? **Q5** (O3 · ch. 5-6) qu'est-ce qui empêche une régression de sécurité d'atteindre la production, à quel coût en blocages injustifiés ? **Q6** (O5 · ch. 5-6) les vulnérabilités livrées peuvent-elles être priorisées selon les menaces réellement observées ? Toutes portent sur des capacités, non sur des produits ; Q6 est l'axe original du travail, reliant chaîne de développement et détection d'incidents.

1.4.2 Objectifs et critères de succès

Un objectif qui ne peut pas être mesuré ne peut pas être défendu : chacun porte un indicateur, une cible et un moyen de vérification (tableau 3) — contrat d'évaluation du mémoire, auquel le chapitre 6 répond point par point.

TAB. 3. Objectifs et critères de succès du projet.

#	Objectif	Indicateur	Cible et vérification
O1	Supprimer la confiance implicite du réseau	Nombre de tentatives de contournement bloquées lors de la campagne de tests adverses	100 % des scénarios définis ; campagne de tests adverses, chapitre 6
O2	Rendre l'infrastructure reproductible	Part du socle décrite en code d'infrastructure ; durée de reconstruction complète d'un environnement	100 % du socle ; durée mesurée et documentée par destruction puis reconstruction chronométrée
O3	Contrôler la chaîne de livraison	Nombre de portes bloquantes ; nombre de clés de compte de service exportées	3 portes (secrets, analyse statique, vulnérabilités) ; 0 clé ; journaux d'exécution de la chaîne de livraison applicative
O4	Détecter les événements de sécurité	Nombre de règles de détection ; couverture des tactiques de la matrice de référence ; taux de fausses alertes sur 7 jours	Couverture mesurée et publiée, lacunes comprises ; requêtes de détection et mesures, chapitre 6
O5	Enrichir les alertes de façon déterministe	Précision de l'association alerte → technique d'attaque, comparée à une méthode de référence simple	Gain mesuré, positif ou négatif, sur un jeu annoté ; évaluation comparative, chapitre 6
O6	Rester exploitable et économiquement soutenable	Coût mensuel réel ; disponibilité et latence observées ; existence de procédures d'incident exécutées au moins une fois	Quelques dizaines d'euros par mois ; objectifs de service instrumentés ; facturation, supervision et exécution réelle des procédures

Deux précisions : l'objectif O4 demande de publier ce que le système **ne détecte pas**, et l'objectif O5 admet par avance un résultat négatif, condition d'une évaluation rigoureuse.

1.5 Périmètre, contraintes et démarche

1.5.1 Périmètre et hypothèses assumées

Sont dans le périmètre : le socle d'hébergement cloud (filtrage en entrée, identité, exécution des charges, réseau, données, enrichissement, observabilité), la chaîne de livraison applicative, la supervision de sécurité sur un entrepôt de données, l'enrichissement sémantique des alertes, le tableau de bord de l'analyste et des recommandations de conformité. Restent hors périmètre : le code interne de l'application hébergée, le déploiement multi-région et la reprise d'activité inter-région, la mise à l'échelle massive. Le socle prend en charge trois obligations attachées aux données de section 1.2.2 : région unique et documentée, chiffrement par clés gérées des secrets et de l'espace média, journalisation centralisée des accès d'administration. Base légale, durée de conservation et droit d'effacement relèvent du responsable de traitement : c'est la carence C5, formulée ici et non refermée par ce projet.

Trois hypothèses sont assumées. Les deux environnements réels et la production cible sont des projets cloud distincts d'une même région, bâtis sur les mêmes modules, seules les variables de dimensionnement changeant : **la sécurité n'est jamais un paramètre d'environnement**. La mise à l'échelle est écartée des objectifs, ses limites étant mesurées plutôt que contournées. La simplicité est érigée en critère d'architecture : tout composant justifie son existence, et tout retrait se documente au même titre qu'un ajout.

1.5.2 Contraintes du projet

Six contraintes structurent la conception ; les deux premières traduisent, à l'échelle du projet, la contrainte de marché de section 1.1.1.

- **Humaine** : une seule personne conçoit, réalise et exploite le socle — écarte les composants à exploitation permanente, impose des procédures écrites ;
- **Économique** : quelques dizaines d'euros par mois — écarte les solutions de supervision commerciales, impose un filtrage des journaux à la source ;
- **Technique, exécution** : l'application hébergée écrit sur le disque local et conserve son état en mémoire, ce qui conditionne le mode d'exécution retenu ;
- **Technique, données** : le schéma de base n'est pas reconstituable depuis le dépôt, ce qui rend sa consolidation préalable à toute migration ;
- **Réglementaire** : des données d'identité officielle et biométriques imposent une région d'hébergement documentée et un chiffrement par clés gérées ;
- **Temporelle** : la durée du projet de fin d'études impose le phasage à critères de sortie présenté en section 1.5.3.

1.5.3 Démarche méthodologique

La démarche suit une règle unique : rien n'existe dans l'infrastructure qui n'existe d'abord sous forme de code versionné, les commandes interactives étant réservées aux opérations ponctuelles — rotation d'un secret, réponse à un incident — et jamais au provisionnement. Elle répond à la carence C2 : reproductibilité complète, contrôle de la sécurité avant création,

détection de toute dérive. Deux registres accompagnent le projet, tous deux tenus au chapitre 4 : celui des décisions d'architecture et celui des écarts entre conception cible et implémentation réelle. Le projet est organisé en huit phases, chacune fermée par un critère de sortie vérifiable, qui sont le découpage du planning (section 5.8.2).

- **PH0 — Immersion et cadrage** ; sortie : périmètre et interlocuteurs établis ;
- **PH1 — Étude de l'existant**, par analyse statique du dépôt et de l'hébergement en place ; sortie : audit figé sur 41 critères et six constats bloquants ;
- **PH2 — Risques et exigences** : valeurs métier, sources de risque, scénarios, vingt exigences ; sortie : matrice menace — exigence — contrôle — test complète ;
- **PH3 — Architecture Zero Trust** : vues d'architecture, sept flux, registre des décisions ; sortie : conception justifiée par écrit, chaque exigence rattachée à un contrôle ;
- **PH4 — Infrastructure en code et chaînes de livraison** : réseau, identités, données, portes de contrôle, identité fédérée ; sortie : infrastructure entièrement décrite en code et planification sans différence ;
- **PH5 — Détection et enrichissement** : collecte, normalisation, sept règles, couche sémantique ; sortie : chaîne de bout en bout fonctionnelle et détections visibles dans le tableau de bord ;
- **PH6 — Validation et corrections** : tests adverses, mesures de détection, de performance, de résilience et de coût ; sortie : chaque objectif O1 à O6 confronté à une mesure ;
- **PH7 — Rapport, transfert et clôture** ; sortie : mémoire remis et socle exploitable par un tiers à partir du seul dépôt.

Conclusion du chapitre

Ce chapitre a établi le point de départ sur des faits vérifiés. L'entreprise opère sur un marché où ni une supervision commerciale ni une équipe de sécurité dédiée ne s'amortissent sur un client unique : le socle réutilisable y est une décision d'entreprise, non un raffinement technique. L'application retenue traite un identifiant national, des enregistrements vocaux et une décision automatisée, pour trois actifs et trois adversaires distincts ; mature fonctionnellement — 6 critères sur 7 —, elle laisse 22 des 41 critères de préparation au déploiement non remplis au 29 juillet 2026, dont six points bloquants, qui se ramènent à cinq carences structurantes toutes situées dans l'environnement d'exécution. L'objet du mémoire n'est donc pas de corriger une application, mais de construire le socle qui la contraint, la surveille et la rend reproductible. Le chapitre suivant examine l'état de l'art et justifie les choix technologiques.

Chapitre 2 État de l’art et choix technologiques

Zero Trust, DevSecOps, ingénierie de la détection, enrichissement sémantique et inventaire du socle

Aux carences du chapitre précédent, des réponses existent : normes, outils, travaux de recherche. Ce chapitre les expose, justifie par comparaison les choix retenus et identifie ce que l’état de l’art **ne résout pas** — c’est là que se situe la contribution du mémoire. Il le convertit en un **inventaire des trente-trois briques structurantes du socle**, chacune portant son critère décisif *et* son prix.

2.1 L’architecture Zero Trust

2.1.1 Du modèle périmétrique au Zero Trust

Le modèle de sécurité traditionnel repose sur une frontière : intérieur réputé sûr, extérieur hostile, filtrage entre les deux. Trois raisons structurelles l’ont dégradé — ressources dispersées, utilisateurs connectés depuis n’importe où, attaques les plus coûteuses issues d’un accès légitime détourné —, et la question n’est plus « comment empêcher d’entrer ? » mais « que peut faire un intrus une fois entré ? » Le terme *Zero Trust*, popularisé par Forrester Research dès 2010 [20] et mis en œuvre à grande échelle par Google sous le nom *BeyondCorp* à partir de 2014 [33], est formalisé en 2020 par le NIST (**SP 800-207** [27]), aujourd’hui la référence normative : la confiance n’est jamais accordée implicitement, elle est évaluée à chaque accès selon l’identité du demandeur, l’état de son équipement et le contexte.

2.1.2 Les sept principes directeurs

La publication [27] énonce sept principes directeurs — trois sur les ressources et les échanges, deux sur la décision d’accès, deux sur la vérification et l’observation — que le tableau 4 reprend avec leur traduction pour le projet : c’est la grille d’exigences que le chapitre 6 confronte à des mesures, et le premier engagement vérifiable du mémoire.

TAB. 4. Les sept principes du NIST SP 800-207 et leur traduction pour le projet

#	Principe (reformulé)	Traduction pour le projet
P1	Toute ressource de données ou de calcul est une ressource à protéger	Base de données, journaux, images et secrets sont des ressources contrôlées
P2	Toute communication est sécurisée, quelle que soit sa position réseau	Le chiffrement en transit ne dépend pas d’être « à l’intérieur »
P3	L’accès est accordé par session, jamais définitivement	Jetons à durée courte, jamais de clé permanente
P4	L’accès est déterminé par une politique dynamique (identité, contexte)	Une identité par charge de travail, droits au cas par cas
P5	L’organisation mesure et surveille en continu ses ressources	Journalisation centralisée, analyse de posture
P6	Authentification et autorisation appliquées avant chaque accès	Vérification à chaque requête, jamais une seule fois à l’entrée
P7	L’organisation collecte le plus d’informations possible	Détection, mesure et amélioration à partir des observations

2.1.3 Modèle de maturité et limites reconnues

Les principes disent ce qu'il faut atteindre, non où l'on en est. Le **modèle de maturité** de la CISA [10] comble cet écart, et il est retenu pour une raison unique : c'est le seul modèle public qui distingue les *piliers* fonctionnels — identités, équipements, réseaux, applications et charges de travail, données — des *capacités transverses* — visibilité et analyse, automatisation et orchestration, gouvernance —, qui traversent tous les piliers au lieu d'en constituer un. La distinction évite le biais le plus commun d'une auto-évaluation : compenser un pilier vide par un autre particulièrement mûr.

Aucun niveau n'est attribué ici : la présente section installe la grille, l'évaluation pilier par pilier relevant du chapitre 6. Deux précautions accompagnent son emploi : conçu pour des agences fédérales américaines, ses niveaux ne sont pas des seuils opposables et l'évaluation qui en découle reste **déclarative** ; et il évalue une architecture, non un produit, de sorte qu'un pilier noté bas peut l'être par une contrainte de périmètre plutôt que par une carence de conception.

Trois limites du modèle lui-même doivent être mentionnées : le **coût de mise en œuvre** (composants supplémentaires, latence, points de défaillance additionnels) ; le **déplacement du risque vers le fournisseur d'identité**, dont la compromission devient l'unique point de défaillance majeur ; l'**écart entre discours commercial et contenu technique**, un produit portant le nom « Zero Trust » ne rendant pas un système Zero Trust — une déclinaison pratique de 2025 [7] confirmant qu'aucune mise en œuvre n'est valable pour tous les contextes. Le projet retient l'approche progressive et la limite du point de défaillance unique, que le chapitre 6 éprouve par un test de compromission d'identité de service.

2.2 L'approche DevSecOps

2.2.1 Principe et portes de contrôle automatisées

Le DevOps a réduit le délai entre écriture du code et mise en production, au prix d'un goulot d'étranglement : la sécurité, vérifiée jusque-là par audit. Le DevSecOps déplace les contrôles vers l'amont (*shift-left* [31]) et les automatise. Le point souvent négligé est le caractère **bloquant** du contrôle : un avertissement qui n'empêche pas le déploiement ne change rien au comportement des équipes [24].

Quatre familles de contrôles sont couramment intégrées à une chaîne de livraison, chacune posant une question distincte. La **détection de secrets** (Gitleaks, TruffleHog) demande si un secret a été versionné [12] ; l'**analyse statique** ou SAST (Semgrep, CodeQL, SonarQube), si le code contient une vulnérabilité connue ; l'**analyse de composition et d'images** ou SCA (Trivy, Gype, Dependency-Check), si un composant vulnérable est utilisé ; l'**analyse de l'infrastructure en code** (Checkov, tfsec, Terrascan), si la ressource sera créée de façon non sécurisée — famille qui n'existe que parce que l'infrastructure est décrite en code [22], donc analysable avant existence (chapitre 5). Ces quatre questions commandent le choix des quatre briques de la chaîne de livraison (§ 2.6). La grille complète en compte huit, dont le chapitre 5 dresse l'état ; les deux familles de provenance relèvent du § 2.2.2.

2.2.2 Provenance, intégrité et référentiels

La **provenance** des artefacts — prouver qu’un artefact déployé provient du code et de la chaîne attendus — est une préoccupation récente, rendue concrète par des compromissions documentées [9]. Trois réponses coexistent : la **nomenclature logicielle** (SPDX, CycloneDX), la **signature d’artefacts** (Sigstore) et le cadre **SLSA** [23]; toutes trois ont été évaluées puis écartées (décision D07) au profit d’un chemin moins coûteux — étiquette liée à l’empreinte du commit et registre unique; motif et condition de réévaluation au § 2.6.3.

Pour les risques applicatifs, la référence est le classement de l’OWASP [25] : sa dernière édition place le contrôle d’accès défaillant en tête et la mauvaise configuration en deuxième position, contre la cinquième en 2021 — ce qui valide le constat du chapitre 1 —, et ajoute une catégorie pour la chaîne d’approvisionnement logicielle, faisant des contrôles du § 2.2.1 une exigence de référentiel. Pour la plateforme, c’est le **CIS GCP Foundation Benchmark** [8, 13] : plus de cent contrôles en sept domaines, mobilisés comme **grille de configuration** et non de certification. Le mémoire publie des écarts nommés, datés et justifiés plutôt qu’un taux de conformité, qui supposerait une grille figée et un audit exhaustif hors périmètre. C’est ce que le projet attend d’un référentiel : documenté et justifié, un écart est une décision d’ingénierie; non documenté, une négligence.

2.3 Supervision et ingénierie de la détection

2.3.1 Modèle de supervision et détection comme code

Un SIEM remplit historiquement quatre fonctions : collecter des journaux hétérogènes, les normaliser, y appliquer des règles, présenter les alertes. Son modèle économique facture le volume ingéré, ce qui **incite à collecter moins** — incitation qui contredit le septième principe du Zero Trust (§ 2.1.2) — et son coût reste inaccessible à un budget contraint. D’où le *SIEM sur entrepôt de données* : dissocier **stockage et interrogation** (entrepôt généraliste) de la **logique de détection** (code versionné). Il apporte un coût aligné au volume, un langage standard, une rétention longue et aucune dépendance à un éditeur; il ne fournit ni règle, ni interface, ni corrélation, ni support. Un compromis, non une supériorité.

Le format **Sigma** [30] est à la détection ce que SQL est aux bases : une manière neutre d’exprimer une règle, indépendante du moteur, en YAML lisible (source, condition, faux positifs, criticité, techniques associées), qui permet de traiter les règles comme du code source. Mais **aucun moteur pris en charge ne cible l’entrepôt retenu ici** : le format a été évalué puis écarté au titre du principe de justification (PR1), une dépendance de conversion pour sept règles coûtant davantage qu’elle ne rapporte. Le socle conserve la propriété recherchée — une règle est un objet versionné, revu et testé — et paie ce choix par l’absence de portabilité, l’impossibilité d’importer une règle du corpus communautaire et un plafond de couverture lié au volume traduisible à la main, mesuré au chapitre 6.

2.3.2 La matrice des techniques d’attaque

La matrice **MITRE ATT&CK** [21, 32] recense les comportements d’attaquants en tactiques (l’objectif) et techniques (le moyen) : vocabulaire commun conception-détection, grille de

couverture, cible de l'enrichissement (§ 2.4). Précaution méthodologique : la version 19 (28 avril 2026) a scindé la tactique d'évasion des défenses en deux, portant la matrice Entreprise à quinze tactiques, 222 techniques et 475 sous-techniques — **toute mesure de couverture sans version indiquée n'est donc pas comparable**, et la version employée est consignée en annexe A.3. Le mémoire publie l'**inventaire nominatif des techniques couvertes** plutôt qu'un taux : le dénominateur pertinent étant le référentiel intégral, un pourcentage serait exact et sans valeur comparative.

2.3.3 Étude comparative et solution retenue

Cinq options ont été comparées (tableau 5) : produit SIEM commercial, service SIEM cloud, pile de recherche libre auto-hébergée, solution libre intégrée, entrepôt de données couplé à une détection en code. Les cinq sont réellement accessibles au projet, les deux premières étant écartées par leur modèle économique et non par leur indisponibilité. La grille retient huit des neuf critères évalués : le neuvième, l'absence de dépendance à un éditeur, laisse les trois options restantes à égalité, et un critère qui ne discrimine pas n'a pas tranché.

TAB. 5. Comparaison des cinq options de supervision sur les huit critères discriminants. Légende : ● favorable, ◐ intermédiaire, ○ défavorable.

Critère	SIEM comm.	SIEM cloud	Pile libre	Libre intégrée	Entrepôt + code
Coût pour un faible volume	○	○	◐	●	●
Coût d'exploitation courante	●	●	○	◐	◐
Règles fournies au départ	●	●	◐	●	○
Interface d'analyste fournie	●	●	●	●	○
Détection versionnée et testable	◐	◐	◐	◐	●
Rétention longue maîtrisée	○	◐	○	◐	●
Analyse exécutée sur les données stockées	○	◐	◐	○	●
Maturité et support	●	●	●	◐	○

La contrainte budgétaire du chapitre 1 élimine les deux premières colonnes. Le **critère décisif** entre les trois restantes est **unique** : appliquer un rapprochement automatique aux alertes *là où elles sont stockées*, sans les exporter — seule la dernière option le permet. Son prix se lit sur les quatre lignes perdues : ni règles, ni interface d'analyste, ni support, et un coût d'exploitation à la charge du projet — trois chantiers du chapitre 5 et trois risques du chapitre 6. Le mode d'exécution des charges a fait l'objet d'une comparaison de même forme (§ A.2.1).

2.4 Enrichissement sémantique des alertes

Une règle de détection produit une alerte : horodatage, adresse, ressource, message. L'analyste doit répondre à trois questions qu'elle ne contient pas — *quel comportement d'attaquant ? est-ce grave ? que faire ?* —, premier poste de charge à disparaître quand l'équipe se réduit à une personne. L'automatiser, c'est associer chaque alerte à une technique ATT&CK et afficher la conduite à tenir.

2.4.1 Approches disponibles

Quatre familles permettent cette association ; le tableau 6 les oppose par leur *limite décisive* plutôt que par leurs mérites, car c'est la limite qui a tranché.

TAB. 6. Approches d’association alerte → technique ATT&CK

Approche	Principe	Limite décisive
Mots-clés / regex	Table écrite à la main	Ignore les reformulations ; maintenance manuelle
Similarité vectorielle (TF-IDF)	Statistique du texte	Ignore le sens ; formulations équivalentes éloignées
Modèles de langue spécialisés	Proximité vectorielle = proximité de sens	Déterministe, exécution locale ; pas d’explication en langue naturelle
Modèles génératifs	Le modèle rédige l’interprétation	Non déterministe, coût par appel, injection d’instructions

La troisième est retenue. Le dernier point de la quatrième ligne est un argument de **sécurité** et non de performance : les journaux portent par construction du texte de tiers non fiables, et les soumettre à un modèle génératif transmet une entrée contrôlée par l’attaquant à un composant qui suit des instructions, là où un modèle produisant un vecteur numérique n’en exécute aucune. C’est la seule décision de l’inventaire dont la condition de réévaluation est *aucune* (§ 2.6.3).

2.4.2 Modèles spécialisés et travail le plus proche

Les modèles généralistes fondés sur l’architecture Transformer [11] traitent mal le vocabulaire de la cybersécurité, d’où des modèles spécialisés comme **SecureBERT** [5] ; et rapprocher deux descriptions d’attaque exige une représentation par **phrase**, l’architecture Sentence-BERT [26]. **ATT&CK-BERT** combine les deux [1, 2] : un modèle de phrases entraîné pour que deux descriptions d’une même action soient proches dans l’espace vectoriel, exécutable localement et sans appel externe — essentiel vu le coût et la nature des données traitées.

Le travail le plus proche est **SMET** (*Semantic Mapping of CVE to ATT&CK*), IFIP DBSec 2023, étendu en 2024 [3] : il associe une vulnérabilité publiée à des techniques d’attaque via ATT&CK-BERT et une régression logistique. L’idée n’est donc pas nouvelle, et trois différences précises séparent SMET de ce projet. L’**entrée** : une description de vulnérabilité rédigée et structurée pour SMET, une alerte courte et bruitée ici. Le **régime** : hors ligne sur un corpus constitué pour SMET, périodique en recette et sous contrainte de latence et de coût ici. La **finalité** : SMET enrichit la connaissance d’une vulnérabilité, ce projet **prototype le réordonnancement des vulnérabilités détectées à la livraison selon les menaces observées**. Cette dernière différence est l’hypothèse d’apport du mémoire — **réintroduire l’observation d’exploitation dans la décision de développement** —, objet de la question Q6 du chapitre 1.

2.5 Choix de la plateforme d’hébergement

La plateforme qui héberge les méthodes et les outils comparés jusqu’ici appelle la même justification. L’application pilote tournait avant le projet sur un serveur unique loué chez un hébergeur européen : la migration vers un fournisseur de cloud est une décision, non un préalable, argumentée ici et enregistrée au chapitre 4 sous la référence D00.

Six options ont été examinées (tableau 7) : trois grands fournisseurs de cloud, un fournisseur européen généraliste, un hébergeur européen à forfait comparable à l’existant, et un hébergeur mauritanien. Les six sont réellement accessibles au projet, par le budget comme par les compétences déclarées par l’entreprise d’accueil : comparer une option hors de portée serait une comparaison de façade. Sur les dix critères évalués, la grille publiée en retient sept, un critère qui ne discrimine pas n’ayant pas participé à la décision — sont retirées la région unique

et documentée, la fédération d'identité sans secret permanent (reprise comme brique au § 2.6.2) et la maturité de l'infrastructure en code, sur lesquelles les grands fournisseurs sont à égalité.

TAB. 7. Comparaison des six options d'hébergement sur les sept critères discriminants
Légende : ● favorable, ◐ intermédiaire, ○ défavorable. « Forfait » désigne un serveur loué à prix fixe chez un hébergeur européen, comparable à l'existant ; « Local » un hébergeur mauritanien.

#	Critère	GCP	AWS	Azure	OVH	Forfait	Local
1	Palier gratuit couvrant l'entrepôt de supervision	●	◐	◐	○	○	○
2	Coût direct à périmètre de calcul comparable	○	○	○	◐	●	◐
3	Facturation nulle en l'absence de trafic	●	●	●	○	○	○
4	Proximité géographique de la Mauritanie	○	○	○	◐	◐	●
5	Briques de sécurité managées	●	●	●	○	○	○
6	Charge d'apprentissage pour une personne seule	◐	○	○	◐	●	●
7	Réversibilité et absence d'enfermement	○	○	○	◐	●	◐

Élimination. La contrainte humaine du chapitre 1 écarte les deux dernières colonnes (critère 5) : une personne seule ne peut exploiter et maintenir à jour en même temps un filtrage applicatif, un gestionnaire de clés, un annuaire d'identités par charge de travail et un entrepôt de journaux, briques dont dépend la faisabilité des vingt exigences du chapitre 3. La contrainte économique écarte les modèles facturés au forfait (critère 3) : le socle doit pouvoir ne rien coûter lorsqu'il ne sert pas. Deux réserves encadrent la lecture : le critère 6 est une appréciation et non une mesure, et le critère 2 est apprécié à partir des modèles de facturation — usage contre forfait — et non de prix relevés à une date unique, de sorte qu'aucun montant comparatif n'est publié. Sources et dates de consultation figurent en annexe A, § A.2.3.

Critère décisif. Entre les trois fournisseurs restants, il est **unique** et découle du § 2.3.3 : la recherche de similarité doit s'exécuter dans l'entrepôt de supervision plutôt que dans une base spécialisée. Un seul des trois réunit dans un même service le stockage, le langage de détection, la recherche vectorielle et un palier gratuit couvrant le volume du projet ; les deux autres imposeraient un composant supplémentaire, ce que le principe de justification (PR1) interdit. Google Cloud est retenu sur ce critère, et sur lui seul.

Prix payé. Trois critères sont perdus. Le **coût direct** (ligne 2) : un serveur à forfait chez un hébergeur européen reste moins cher, à périmètre de calcul comparable. La **réversibilité** (ligne 7) : l'architecture d'origine, faite de conteneurs et d'un fichier de composition, était portable d'un hébergeur à l'autre ; le socle retenu ne l'est plus. La **proximité géographique** (ligne 4) : aucun des fournisseurs examinés n'exploite de région en Afrique de l'Ouest, et l'hébergeur mauritanien serait le seul à satisfaire ce critère comme le seul à n'en satisfaire aucun des six autres. Conserver l'hébergeur à forfait aurait maintenu ce coût et cette portabilité, au prix d'exploiter à la main les quatre briques ci-dessus : c'est la contrainte d'une seule personne, non une préférence technique, qui a fermé cette voie. **Le projet échange de la réversibilité et du coût direct contre des briques de sécurité qu'une personne seule n'aurait pas pu exploiter** — le chapitre 6 en mesure la part vérifiable.

2.6 Inventaire technologique du socle

La plateforme étant choisie, cette section énonce ce qui a été construit dessus. Un inventaire technologique ne vaut que s'il résiste à deux dérives symétriques : la liste de dépendances, qui

noie la décision dans l’outillage, et la plaquette commerciale, qui énumère des avantages sans nommer de contrepartie. **L’état décrit est celui relevé le 28 août 2026** sur la branche principale du dépôt et l’environnement de recette, donc **postérieurement à la refonte du plan réseau** appliquée en douze étapes du 11 au 25 août 2026 au titre de la décision D15 (chapitre 4).

2.6.1 Le critère de sélection

Un mémoire d’ingénieur ne recense pas ses bibliothèques; il recense ses **décisions d’architecture matérialisées par un composant**. Un composant est une **brique structurante** s’il satisfait **au moins deux des trois critères** suivants; à défaut, il relève de la sous-technologie.

1. **Arbitrage** : au moins une alternative sérieuse a été évaluée puis écartée, et le motif du rejet est écrit.
2. **Portée architecturale** : son retrait modifierait l’**architecture** et non une seule implémentation — retirer l’entrepôt de supervision change le système, retirer une bibliothèque de graphiques change une page.
3. **Propriété portée** : elle porte une **propriété du système** — sécurité, coût, disponibilité, reproductibilité — que le mémoire revendique et devra démontrer.

Le tableau 8 l’applique à cinq technologies du dépôt : les deux rejets y sont plus instructifs que les deux admissions, et le cas frontière montre où passe la limite.

TAB. 8. Application du critère de sélection : deux admissions, deux rejets et un cas frontière

Technologie	Brique ?	Pourquoi
Entrepôt de données comme système de supervision	Oui	Arbitrage documenté (D04) sur cinq options; porte le coût <i>et</i> la capacité de détection. Trois critères sur trois
Fédération d’identité de la chaîne de livraison	Oui	Supprime une classe de risque entière plutôt que de la gérer (D08); son retrait réintroduirait une clé permanente dans le chemin de déploiement
Bibliothèque de graphiques du tableau de bord	Non	Aucune alternative évaluée, aucune propriété du système n’en dépend, aucune couche touchée par son remplacement. Très visible sur chaque capture, et pourtant zéro critère sur trois
Bibliothèque de génération de codes temporels	Non	Implémentation d’un standard ouvert : <i>le standard est la brique, pas la bibliothèque</i> . La substituer ne changerait ni le protocole d’authentification ni sa surface
Pilote d’accès à la base de données	Frontière	Sous-technologie : aucun arbitrage documenté, aucune couche modifiée par son remplacement. Mais son caractère synchrone <i>est</i> cité au chapitre 5, car il justifie un choix de conception de l’API

Ce critère est ce qui empêche l’inventaire de dériver : **trente-trois composants le franchissent, quand le dépôt en compte plusieurs centaines**.

2.6.2 Les trente-trois briques structurantes

Le tableau 9 les présente par couche, du socle vers la chaîne de livraison; le rôle de chacune est porté par son libellé, le produit étant nommé entre parenthèses à sa première occurrence. **L’inventaire nominatif des alternatives évaluées puis écartées, couche par couche**, est publié en annexe A, § A.2.2; les deux comparaisons formalisées y figurent également.

TAB. 9. Les trente-trois briques structurantes, par couche : critère décisif et prix payé

Brique et rôle	Critère décisif	Prix payé
N1a — Socle et infrastructure : huit briques		

Brique et rôle	Critère décisif	Prix payé
Fournisseur de cloud public unique (Google Cloud) : support de l'ensemble du socle, dans une région européenne unique	Seul à réunir dans un même service le stockage, le langage de détection et la recherche vectorielle (§ 2.5)	Réversibilité perdue, coût direct supérieur à un forfait, aucune région en Afrique de l'Ouest
Infrastructure décrite en code (Terraform, 16 modules) : provisionnement, reproductibilité, détection de dérive	Maturité de l'écosystème de modules et portabilité de la description	Langage déclaratif : toute logique conditionnelle passe par des compteurs, moins lisibles qu'un langage général. L'état est un actif à protéger que le code ne décrit pas, et un plan ciblé peut inclure des remplacements destructifs sans rapport
Exécution de conteneurs sans serveur (Cloud Run, D01) : support des cinq services et des trois tâches	Aucun système d'exploitation à durcir ni cluster à exploiter — décisif sous contrainte mono-opérateur	Démarrage à froid mesuré : environ deux secondes sur l'API, 94 s au centile 99 sur le service d'encodage, ce qui a imposé de recalibrer le budget de la sonde. Aucune charge à état, aucune tâche longue
Réseau privé virtuel en mode personnalisé : un sous-réseau par locataire, accès privé aux données, refus par défaut dans les deux sens	Contrôle explicite des plages et refus par défaut en entrée et en sortie , chaque autorisation étant nominative : aucune règle d'autorisation ne comporte de plage source, ce qui serait de la confiance de zone	Trois sous-réseaux et douze règles là où l'ancien plan en déclarait deux et quatre : les refus croisés croissent comme le carré du nombre de locataires, ce qui borne la conception à trois ou quatre. Et le sélecteur demeure l' étiquette réseau , la plateforme n'exposant pas le compte de service au niveau des interfaces de sortie : la frontière est opposable à une charge de travail compromise, non à un opérateur capable de déployer
Sortie réseau directe : interface réseau attachée à chaque instance dans le sous-réseau de son locataire, en remplacement du connecteur d'accès sans serveur (D15, bascule service par service du 12 au 15/08/2026)	C'est ce qui rend le pare-feu applicable aux charges de travail : sans adresse dans un sous-réseau, aucune règle ne peut les désigner, ni comme source ni comme cible, et un refus par défaut en sortie resterait une déclaration sans effet	Chaque instance active consomme une adresse du sous-réseau, là où le connecteur en immobilisait seize quel que fût le trafic : une montée en charge imprévue peut épuiser un /26. Le rattachement de l'interface intervient au démarrage de l'instance, donc dans le chemin du démarrage à froid. Enfin le socle perd un objet observable : les interfaces sont éphémères et ne se donnent à voir que par les journaux de flux
Accès privé aux services managés : connexion à la base sans adresse publique	Élimine structurellement l'exposition de la base	Plage allouée automatiquement par le fournisseur, non maîtrisée dans la description ; le module de base n'est pas réinstanciable en l'état, le pairage étant câblé à l'intérieur
Répartiteur de charge applicatif global : point d'entrée public unique, terminaison du chiffrement, routage par nom d'hôte vers quatre services	Point d'entrée unique = point de contrôle unique ; certificats gérés et renouvelés par le fournisseur	La gestion avancée du trafic — pondération, mise en miroir, politiques de réessai — n'est pas disponible dans la variante retenue. L'entrée des services étant restreinte à ce seul chemin, la garantie repose sur un contrôle unique, sans défense en profondeur
Filtrage applicatif managé au bord (Cloud Armor) : refus des charges d'attaque connues, limitation de débit, restriction géographique	Aucun composant à exploiter ; règles maintenues par le fournisseur ; application uniforme aux quatre points d'entrée, sans exception	Cinq familles de règles retenues sur onze disponibles, à la sensibilité la plus basse : arbitrage explicite entre faux positifs et évasions — quatre motifs sur cinq bloqués au test réel du 19/08/2026. Aucune protection adaptative : le seuil anti-saturation est fixe
N1b — Identité, secrets et chiffrement : six briques		
Gestion des identités et des accès du fournisseur : sept identités de service, droits au moindre privilège, aucun rôle primitif	Une identité par charge de travail : c'est ce qui remplace les pare-feux internes (PR2)	Plusieurs liaisons demeurent à l'échelle du projet là où une portée par ressource serait possible ; la granularité par instance n'existe pas pour la base ; et aucune politique d'organisation ne rend la règle préventive (É7) — elle est tenue par discipline, vérifiée par inventaire
Fédération d'identité pour la chaîne de livraison (D08) : authentification de la chaîne sans clé permanente, sous condition de dépôt et de branche	Supprime la classe de risque au lieu de la gérer : il n'y a pas de clé à faire fuir	Dépendance à la forge logicielle comme émetteur d'assertion : sa compromission devient un chemin d'accès. La restriction de branche tient par une condition d'attribut, non par la liaison elle-même
Coffre de secrets managé : neuf secrets, un par usage, injectés par référence dans les services	Chiffrement par clé gérée et liaison d'accès par secret , jamais au niveau du projet	Dépendance réseau à l'exécution pour un secret, là où le montage natif était disponible ; un secret subsiste hors clé gérée, vestige d'une interface antérieure dont le retrait est planifié

Brique et rôle	Critère décisif	Prix payé
Service de gestion de clés, chiffrement par clés gérées : entrepôt, secrets et espace média ; rotation à 90 jours	Contrôle de la rotation et de la révocation, exigé par la nature des données de l'application hébergée	Niveau de protection logiciel et non matériel ; le chiffrement de l'entrepôt n'est pas rétroactif ; il est structurellement inapplicable à la base, le champ étant immuable après création
Authentification applicative par jeton signé et rôles (D10) : contrôle d'accès à l'API de supervision, trois rôles, vérification route par route	Aucune dépendance externe ; le rôle devient visible dans la signature de chaque point d'entrée, donc auditable en lecture	Aucun mécanisme de révocation : un jeton reste valide jusqu'à son expiration après une déconnexion ou un changement de rôle, et l'état actif d'un compte n'est vérifié qu'à l'émission
Second facteur par code temporel à usage unique : renforcement de l'accès au tableau de bord ; secret chiffré au repos	Standard ouvert, vérifiable hors ligne, sans dépendance ni coût par usage	Pas de résistance à l'hameçonnage ; aucun code de secours, donc la perte du terminal exige une intervention en base ; le secret est protégé par un chiffrement applicatif dont la clé unique sans version interdit toute rotation
N1c — Exécution, conteneurisation et applications : six briques		
Conteneurisation multi-étage, utilisateur non privilégié, base épinglée par empreinte : format de livraison de tous les services	Surface réduite et image finale débarrassée des outils de construction, ce qui a permis d'éliminer une vulnérabilité critique en retirant le gestionnaire de paquets	Construction plus longue et fichiers de description plus complexes ; la mise à jour de la base épinglée redevient un geste manuel à chaque publication
Registre d'images privé du fournisseur (D07) : stockage des artefacts déployés	Un registre unique : deux registres constituent deux surfaces de chaîne d'approvisionnement et une ambiguïté sur la source de vérité	Aucune immuabilité d'étiquette déclarée, aucune politique de nettoyage, et l'analyse de vulnérabilité reste externe à la plateforme — l'image y est publiée avant d'être analysée
Cadre applicatif à validation typée pour l'API : vingt et un points d'entrée, unique accès aux données de sécurité	Validation déclarative en entrée et contrat de sortie forcé : le contrôle d'accès devient visible dans la signature de chaque point d'entrée	Aucun bénéfice de l'asynchronisme, les pilotes retenus étant synchrones. Aucune version portée par les points d'entrée ; la documentation d'interface demeure publique
Cadre web à rendu serveur pour le tableau de bord (D14) : douze vues, sept routes serveur	Le jeton d'authentification reste côté serveur et n'est jamais lisible par un script client — propriété de sécurité, pas de confort	Rendu dynamique à chaque requête, aucune mise en cache statique ; démarrage à froid au-delà de dix secondes, qui impose d'y maintenir une instance active ; couverture de tests de 3,00 % au 28/08/2026
Accès à la base par connecteur applicatif chiffré : liaison entre l'API et la base	Tunnel chiffré mutuellement authentifié vers l'adresse privée : c'est le plus strict des trois modes disponibles	Dépendance à une bibliothèque cliente supplémentaire et à un pilote purement interprété, donc synchrone — c'est ce pilote qui interdit l'asynchronisme de la ligne précédente
Outil de migration de schéma versionné : évolution du schéma relationnel de la plateforme	Le schéma devient reconstituible depuis le dépôt — réponse directe au constat bloquant B5 de l'audit	Aucune automatisation dans la chaîne : les migrations de la plateforme sont déclenchées à la main, là où l'application hébergée les exécute par une tâche avant déploiement
N1d — Données et entrepôt de supervision : cinq briques		
Base relationnelle managée, haute disponibilité régionale (D03, D13) : comptes, rôles, journal d'audit applicatif, données de l'application hébergée	Restauration à un instant donné et bascule régionale sans exploitation à charge — décisif sous contrainte mono-opérateur, et mesuré à 32 min 45 s pour zéro perte le 03/08/2026	Instance de gamme d'entrée facturée au tarif haute disponibilité ; chiffrement par clés gérées structurellement impossible ; une seule instance partagée entre les locataires
Entrepôt de données généraliste comme système de supervision (BigQuery, D04) : dix tables — journaux normalisés, détections, enrichissement, vulnérabilités, verdicts	Seule option offrant stockage, langage de détection et recherche vectorielle dans le même service, sans base spécialisée (D06)	Ni règles, ni interface, ni corrélation, ni support fournis : trois chantiers à construire. Plafond de règles maintenables par une personne. Poste de coût dominant, avec un minimum forfaitaire par table balayée. Aucun index vectoriel déployé : chaque recherche parcourt tout le référentiel
Requêtes planifiées de l'entrepôt comme ordonnanceur : douze exécutions, cinq normalisations et sept règles de détection	Aucun composant supplémentaire : l'ordonnancement vit là où vivent les données (PR1), et le moteur d'orchestration a été retiré après soixante exécutions en échec consécutives	Cadence plancher de cinq minutes imposée par le service ; aucune dépendance entre exécutions, donc aucune garantie d'ordre ; les seuils sont figés dans les requêtes
Stockage objet avec prévention d'accès public et clés gérées : espace média de l'application hébergée	L'application d'origine écrivait sur le disque local, ce qui interdisait toute mise à l'échelle et toute reprise : c'était le constat bloquant B6	Aucun versionnement d'objet, aucune règle de cycle de vie : une suppression accidentelle est irréversible

Brique et rôle	Critère décisif	Prix payé
Collecte de journaux et exports vers l'entrepôt : quatre exports déclarés en code, filtrage à la source	Filtrage au moment de la collecte et non après stockage : c'est le levier de coût principal (besoin BNF3)	Trois exports sur quatre filtrent réellement ; celui du répartiteur ingère la totalité du trafic et reste le poste de coût dominant. La liste des services collectés étant explicite, un service oublié disparaît de la supervision sans erreur visible. Les journaux d'accès aux données restent dans l'espace par défaut, à conservation modifiable
N1e — Détection et enrichissement sémantique : quatre briques		
Règles de détection versionnées, écrites dans le dialecte de l'entrepôt : sept règles R1 à R7, fenêtre glissante, déduplication, étiquetage par technique	Aucun moteur de conversion ne cible ce dialecte : la traduction manuelle évite une dépendance de conversion pour sept règles (verrou V2)	Aucune portabilité vers un autre système de supervision, aucun accès au corpus communautaire, et un plafond de couverture lié au volume maintenable par une personne — six techniques et cinq tactiques sur quinze
Référentiel de techniques d'attaque (MITRE ATT&CK) : vocabulaire commun conception-détection, grille de couverture, cible de l'enrichissement	Seul référentiel qui fournit à la fois un vocabulaire de détection et un catalogue textuel encodable	Le dénominateur est la matrice intégrale, qui couvre des systèmes absents du périmètre : tout taux rapporté à ce dénominateur est structurellement bas, ce qui conduit le mémoire à publier l'inventaire nominatif des techniques plutôt qu'un pourcentage
Modèle de représentation de phrases spécialisé en cybersécurité (D05) : encodage des détections et des techniques en vecteurs comparables	Représentation par phrase entraînée sur le vocabulaire du domaine ; et surtout , un modèle qui produit un vecteur n'exécute aucune instruction, là où soumettre des journaux à un modèle génératif transmettrait une entrée contrôlée par l'attaquant à un composant qui suit des instructions	Aucune explication en langue naturelle ; poids d'environ 440 mégaoctets embarqués dans l'image ; consommation mémoire au pic de l'ordre de 900 mégaoctets ; qualité non établie sur des alertes courtes et bruitées (verrou V3)
Moteur d'inférence embarqué, exécution sur processeur généraliste : service d'encodage interne, sans sortie publique et sans droit sur l'entrepôt	Exécution locale et déterministe, sans appel externe ni coût par appel, et sans transmission de données de sécurité à un tiers	Démarrage à froid de 94 s au pic, qui a imposé de recalibrer le budget de la sonde de disponibilité ; l'export quantifié a été testé puis rejeté sur mesure, donc les poids restent en précision flottante simple
N1f — Chaîne de livraison et chaîne de provisionnement : quatre briques		
Forge logicielle et son moteur d'exécution (GitHub Actions) : porte la chaîne de livraison applicative (F3) et la chaîne de provisionnement de l'infrastructure (F7)	Intégration native avec la fédération d'identité, qui supprime la clé permanente	Les actions réutilisées sont référencées par étiquette mobile : une redirection d'étiquette ferait exécuter un code différent sans qu'une ligne du dépôt change
Détection de secrets versionnés (Gitleaks, D09) : première porte bloquante de la chaîne	Coût quasi nul, gain élevé, et placement en tête de chaîne : un secret est compromis dès sa publication, le détecter tôt déclenche la rotation pendant qu'elle sert encore	Jeu de règles par défaut, non spécialisé au domaine ; résultats disponibles dans les journaux de la chaîne uniquement, sans format d'échange normalisé
Analyse statique du code (Semgrep) : deuxième porte bloquante	Exécutable localement, jeu de règles ouvert, exclusions justifiables ligne à ligne plutôt que globalement	Le jeu de règles distant évolue : le verdict pouvait varier à version d'outil identique, ce qui a imposé un verrouillage de version. Sept exclusions nominatives à maintenir
Analyse de vulnérabilité des images et de la configuration (Trivy) : troisième porte bloquante, sur les deux chaînes, avec restitution du rapport dans la supervision (F6)	Un seul outil couvre les images et la description d'infrastructure : un composant en moins, application directe de PR1	Aucune génération de nomenclature logicielle ni de signature d'artefact, alors que l'outil en est capable : deux familles de contrôle restent découvertes (décision D07). Les vulnérabilités sans correctif amont sont ignorées

Une brique a quitté l'inventaire sans successeur. La *traduction d'adresses de sortie* y figurait jusqu'à la refonte du réseau ; elle n'a pas été corrigée, elle est devenue **sans objet** — les interfaces de sortie directe n'ont pas d'adresse externe, l'accès privé leur donne tout ce qu'elles doivent joindre, et le refus par défaut en sortie interdit toute autre destination : **il ne reste aucun trafic qu'une passerelle de traduction aurait à traiter**. La suppression a été prononcée sur mesure : le critère posé avant l'observation était *aucune connexion enregistrée par*

la passerelle, la journalisation a été portée à ALL du 15 au 22 août 2026, elle n'en a relevé aucune, et la suppression a suivi le 24 août 2026. La distinction n'est pas de vocabulaire : **corriger un composant mal réglé le laisse dans l'inventaire** — avec son coût, sa charge d'exploitation et sa surface — **tandis qu'établir qu'il est sans objet l'en retire**, ce que demande le principe de justification (PR1). L'inventaire passe de trente-quatre à trente-trois briques, et la couche N1a de neuf à huit.

Le service de noms de domaine n'est pas une brique du socle, et son absence est délibérée. Les enregistrements qui font pointer les trois domaines vers le point d'entrée sont créés à la main chez le bureau d'enregistrement, sans ressource correspondante dans la description en code : c'est le **seul maillon de la chaîne d'exposition qui échappe au principe de description en code** (PR4), écart enregistré sous la référence **É10**. Sa conséquence est opérationnelle et vérifiée : une bascule de nom faite à la main a rompu une porte de la chaîne de livraison, sans qu'aucun contrôle ne la signale.

2.6.3 Les sept composants évalués puis écartés

Un inventaire qui n'énumère que ce qu'il contient laisse penser que tout ce qui n'y figure pas a été oublié. Sept composants de l'état de l'art ont été évalués puis écartés au titre du principe de justification (PR1), et **six le sont par arbitrage de coût**. Le *périmètre de service anti-exfiltration* : disproportionné pour un projet unique, et sa pose exige un périmètre administratif indisponible. L'*orchestrateur de conteneurs et maillage de services* : une souplesse inutile ici, au prix d'un cluster à exploiter, la plateforme fournissant déjà le chiffrement interne et l'identité par service. Le *cache distribué* : utile aux seules limitations de débit distribuées, mise à l'échelle hors objectif (BNF7). Le *déploiement multi-région* : hors périmètre déclaré au chapitre 1, coût doublé, perte de données déjà couverte par les sauvegardes. La *signature d'artefacts et la nomenclature logicielle* : remplacées par l'étiquette liée à l'empreinte du commit et le registre unique. La *passerelle d'authentification du fournisseur* : elle exige un annuaire d'entreprise indisponible, le besoin étant couvert par l'autorisation applicative par rôles.

Le septième est le **modèle de langue génératif pour l'enrichissement, seul rejet motivé par la sécurité** : sortie non déterministe et surface d'injection par instruction, toutes deux rédhibitoires pour une chaîne de preuve. La **condition de réévaluation** de chacun est enregistrée, avec le motif complet, en annexe D, section D.2 : datable pour les six premiers, **aucune pour le septième**. Les deux natures ne se confondent pas — un arbitrage de coût se rouvre avec le contexte, un principe non — et **un socle qui les traite de la même façon ne sait plus laquelle de ses décisions est négociable**.

2.6.4 Deux lectures transverses de l'inventaire

Première lecture : le fil conducteur. Les trente-trois briques ne résultent pas de trente-trois décisions indépendantes : **deux contraintes** du chapitre 1 — une personne, quelques dizaines d'euros par mois — et **un principe**, celui de justification (PR1), agissent comme trois filtres successifs. L'*humaine* écarte ce qui demande une exploitation permanente : orchestrateur, maillage de services, filtrage, coffre de secrets et pile de recherche auto-hébergés. L'*économique* écarte les modèles au forfait et la supervision commerciale. Le *principe* écarte les doublons : base

vectorielle séparée, second registre d'images, ordonnanceur externe, analyseur de configuration distinct de l'analyseur d'images. **Trois filtres, et il reste trente-trois briques : c'est peu pour un système qui couvre le bord, l'identité, l'exécution, le réseau, les données, la détection, l'enrichissement, l'observabilité et deux chaînes de livraison.**

Seconde lecture : ce qu'enseigne la colonne « prix payé ». Lue verticalement, elle se répartit en trois natures, et la distinction n'est pas cosmétique.

- **Des prix de performance, tous mesurés** et reportés au chapitre 6 : démarrage à froid, cadence plancher d'ordonnancement, délai de détection, durée de reconstruction de la base. Ils sont acceptés *parce qu'ils sont connus* : un coût mesuré est gouvernable, un coût supposé ne l'est jamais.
- **Des prix de couverture, tous nommés** : cinq familles de règles de filtrage sur onze, aucune signature d'artefact, aucune nomenclature logicielle, aucune protection adaptative, aucun index vectoriel. Ce ne sont pas des aveux : ils délimitent *ce que le socle ne prétend pas faire*, et c'est ce qui rend crédible ce qu'il prétend faire.
- **Un prix structurel, et il est unique** : la **réversibilité**. Le socle n'est plus portable d'un fournisseur à l'autre, et sa reconstruction ailleurs demanderait de remplacer le filtrage, l'entrepôt, la gestion des clés et la fédération d'identité.

Le troisième est **le seul prix que le projet ne peut pas réduire par un travail supplémentaire** : les deux premières familles se referment avec du temps d'ingénieur — on calibre un démarrage, on écrit des règles — là où la réversibilité *augmente* avec chaque brique ajoutée.

Un fait que ces trois natures ne classent pas. La refonte du plan réseau (D15) a **retiré deux briques du socle — le connecteur d'accès sans serveur et la passerelle de traduction d'adresses avec son routeur — sans en ajouter aucune** : la sortie réseau directe n'est pas un composant à exploiter, c'est un mode de rattachement d'instances existantes. Dans le même geste, le socle a gagné un refus par défaut en sortie, un sous-réseau par locataire et huit règles de pare-feu de plus, toutes ciblées par identité et par port : **une architecture qui se simplifie et se durcit dans le même mouvement est assez rare pour être relevée**. Le solde financier va dans le même sens : la suppression du connecteur retire un coût fixe permanent et indépendant du trafic, que la tarification publique situe autour de treize euros par mois, contre un supplément d'ingestion de journaux de flux d'un à deux euros. **Ce solde est un ordre de grandeur de tarification publique et non une facture relevée** ; le vérifier suppose de comparer les postes de facturation des mois encadrant la bascule, comparaison qui n'a pas été faite et dont le mode opératoire est publié ici pour qu'un tiers puisse l'exécuter.

2.7 Référentiels et méthodes mobilisés

Les référentiels ne sont pas des ornements bibliographiques : ils subissent le même traitement que les briques techniques, avec alternatives évaluées, critère décisif et limite assumée. Sept sont mobilisés. Cinq l'ont déjà été là où ils servent — référentiel normatif Zero Trust et modèle

de maturité au § 2.1, classement des risques applicatifs et référentiel de configuration de la plateforme au § 2.2.2 —, et le sixième est le **règlement européen sur la protection des données**, applicable au moins par le lieu du traitement, dont la limite est que base légale, durées de conservation et droit d’effacement relèvent du responsable de traitement, hors périmètre du socle.

Le septième — la méthode d’analyse de risque — appelle une justification propre, parce qu’il structure le chapitre suivant. **STRIDE** [29] applique six catégories de menaces à chaque flux et à chaque composant : l’analyse technique est fine, mais ne traite ni les enjeux métier ni les sources de risque. **EBIOS Risk Manager** [4] déroule cinq ateliers, des valeurs métier au traitement du risque : il relie le risque technique à l’enjeu métier, au prix d’une mise en œuvre plus lourde, et ses cinq ateliers ne sont pas tous menés ici au même niveau de détail. **ISO/IEC 27005 :2022** [19] fournit un cadre général, sans méthode opératoire directement applicable. **Le choix retenu combine les deux premières**, sur un critère décisif unique : *aucune des deux, seule, ne produit à la fois le lien au métier et le détail par flux* ; la matrice *menace* → *exigence* → *contrôle* → *test* qui en résulte relève du chapitre 3.

Conclusion du chapitre

Les réponses aux carences du chapitre 1 existent, mais aucune ne s’applique telle quelle : le référentiel Zero Trust suppose des moyens que le projet n’a pas ; la détection comme code fournit un format neutre mais aucun moteur de conversion vers l’entrepôt retenu ; les modèles de rapprochement sémantique n’ont pas été éprouvés sur des alertes courtes et bruitées. L’inventaire des trente-trois briques a converti cet état de l’art en décisions, chacune avec son critère décisif et son prix. Quatre **verrous** en résultent.

- **V1** (origine § 2.1.3 ; traité aux ch. 4 et 5). Les architectures Zero Trust de référence supposent une équipe de sécurité ; aucune n’est dimensionnée pour une exploitation par une seule personne.
- **V2** (origine § 2.3.1 ; ch. 5 et 6). La détection comme code ne dispose pas de moteur de conversion vers l’entrepôt retenu : traduction manuelle, couverture plafonnée.
- **V3** (origine § 2.4.2 ; ch. 6). Les modèles de rapprochement sémantique sont évalués sur des textes bien formés, non sur des alertes courtes et bruitées issues d’un système en exploitation.
- **V4** (origine § 2.4.2 ; ch. 5 et 6). Aucun travail examiné ne traite la boucle entre vulnérabilités détectées à la livraison et menaces observées en exploitation.

La contribution est d’ingénierie, un point par verrou : une **architecture Zero Trust dimensionnée pour la contrainte réelle** d’une entreprise émergente (V1) ; une **chaîne de détection versionnée** sur un entrepôt généraliste, limites publiées (V2) ; un **protocole d’évaluation** face à deux références simples (V3) ; un **prototype de boucle** entre livraison et détection (V4) — les deux derniers restant à l’état de protocole publié, leurs conditions de publication, énoncées avant tout relevé, n’étant pas réunies à la date de remise. Le chapitre suivant construit la matrice qui relie chaque menace à un contrôle et au test qui en démontre l’efficacité.

Chapitre 3 Analyse des besoins et modélisation des menaces

De la valeur métier à l'exigence de sécurité vérifiable

Une architecture de sécurité ne se conçoit pas à partir d'une liste de bonnes pratiques, mais à partir d'une réponse à trois questions : qu'est-ce qui a de la valeur, qui voudrait s'y attaquer, et par quel chemin ? Ce chapitre y répond, puis en dérive vingt exigences de sécurité et la matrice qui relie le risque analysé ici, l'architecture du chapitre 4, la réalisation du chapitre 5 et les mesures du chapitre 6.

Pourquoi deux méthodes plutôt qu'une. Aucune des deux méthodes retenues au chapitre 2 ne suffit seule : EBIOS Risk Manager hiérarchise et fixe la gravité, mais laisserait des scénarios trop abstraits pour en dériver un test ; STRIDE énumère systématiquement, mais produirait un inventaire sans hiérarchie de valeur, où le balayage automatisé pèserait autant que la perte du corpus. Leur combinaison sépare le niveau métier, qui décide de ce qui compte, du niveau technique, qui décide d'où cela peut être atteint.

3.1 Acteurs et cas d'utilisation

3.1.1 Acteurs légitimes et acteurs hostiles

L'analyse distingue les acteurs **légitimes**, dont les besoins définissent les fonctionnalités, des acteurs **hostiles**, dont les objectifs définissent les menaces. La distinction n'est pas étanche — un compte légitime détourné devient un acteur hostile disposant de droits légitimes — d'où une série unique A1 à A11 dont une colonne indique la nature (tableau 10), plutôt qu'une numérotation séparée qui suggérerait deux populations disjointes.

TAB. 10. Acteurs du modèle : série unique, nature indiquée en colonne

Acteur	Nature	Rôle ou motivation	Interaction ou moyens
A1 — Utilisateur	Légitime	Contribue à l'application hébergée	Point d'entrée public (F1)
A2 — Analyste	Légitime	Consulte, qualifie et documente les incidents	Tableau de bord, lecture et verdict
A3 — Administrateur	Légitime	Administre la plateforme	Consoles d'administration et dépôts
A4 — Développeur	Légitime	Modifie le code ou l'infrastructure	Chaînes F3 et F7
A5 — Identité de déploiement	Légitime	Identité automatisée à privilèges	Fédération sans secret permanent, F3 et F7
A6 — Tâches internes	Légitime	Détectent et enrichissent	Requêtes et tâches planifiées, F5
A7 — Opportuniste	Hostile	Gain rapide, cible non choisie	Outils automatisés, vulnérabilités connues
A8 — Acteur intéressé par le corpus	Hostile	Valeur du corpus linguistique constitué	Ciblage délibéré, patience
A9 — Participant fraudeur	Hostile	Gain financier lié aux prix de la compétition	Comptes multiples, manipulation applicative
A10 — Chaîne d'approvisionnement	Hostile	Exécution de code chez la victime	Dépendance ou image de base compromise
A11 — Interne ou prestataire	Hostile	Négligence, curiosité ou malveillance	Accès légitime initial, connaissance du système

Deux acteurs appellent une vigilance particulière. L'identité de déploiement (A5) possède des droits de modification sur l'ensemble du socle et doit être traitée comme une identité à privilèges, non comme un outil. Le participant fraudeur (A9) dispose d'un accès parfaitement légitime et d'une incitation financière : aucun contrôle de périmètre ne le distingue d'un contributeur ordinaire, et c'est le comportement applicatif, non le réseau, qui le révèle.

3.1.2 Cas d'utilisation du socle

Huit cas d'utilisation structurent le socle, formulés du point de vue de l'acteur et non du composant technique (figure 6), chacun rattaché à un flux : F1 pour UC1 à UC3, F3 pour UC4, F7 pour UC5, F4 et F5 pour UC6, F5 pour UC7, F6 pour UC8. Deux commandent la conception : **UC3** impose que le verdict de l'analyste soit enregistré sans pouvoir altérer les preuves sur lesquelles il porte, d'où la séparation, au chapitre 4, entre tables de preuve en écriture interdite et table de verdict humain ; **UC8**, qui correspond à la question Q6 et au verrou V4, constitue l'apport propre du mémoire.

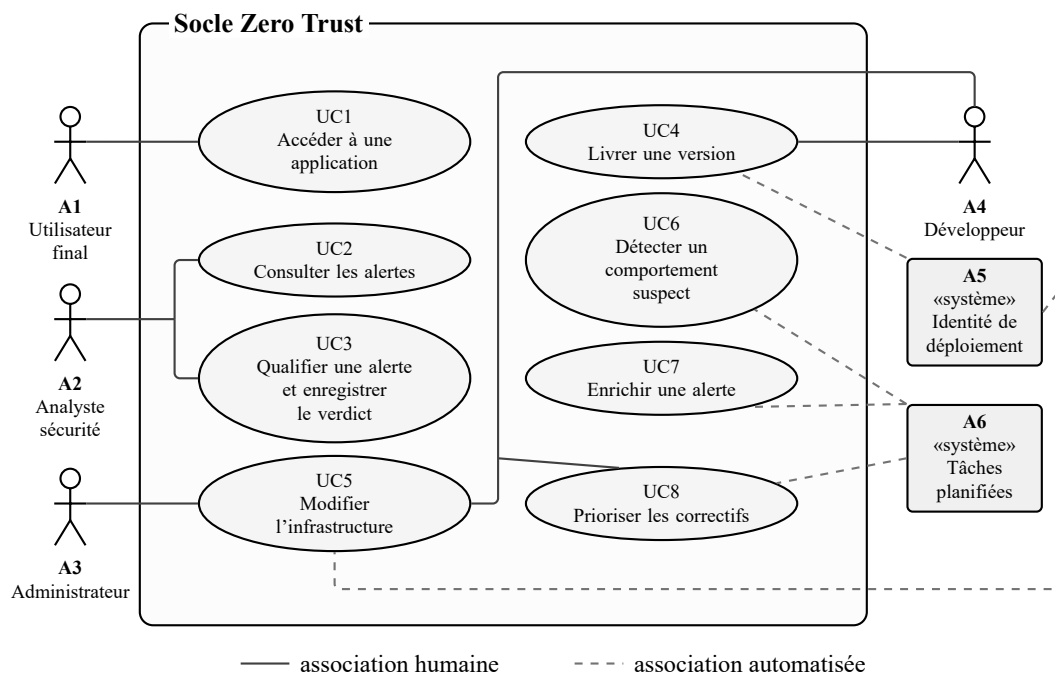


FIG. 6. Diagramme de cas d'utilisation du socle

3.2 Spécification des besoins

3.2.1 Besoins fonctionnels

Les besoins fonctionnels traduisent les carences C1 à C4 identifiées par l'audit du chapitre 1 (tableau 11).

TAB. 11. Besoins fonctionnels

#	Besoin	Segment	Origine
BF1	Exposer les applications derrière un point d'entrée unique, filtré et journalisé	Sécurité	C1
BF2	Attribuer une identité distincte à chaque charge de travail, droits minimaux	Sécurité	C1

TAB. 11. Besoins fonctionnels (suite)

#	Besoin	Segment	Origine
BF3	Rendre les données inaccessibles depuis Internet, accès privé uniquement	Sécurité	C1
BF4	Décrire l'intégralité du socle sous forme de code versionné	Ops	C2
BF5	Contrôler automatiquement chaque livraison avant mise en production	Dev	C3
BF6	Authentifier l'identité de déploiement sans secret permanent	Dev	C3
BF7	Centraliser les journaux de toutes les couches dans un entrepôt unique	Détection	C4
BF8	Exécuter des règles de détection versionnées sur ces journaux	Détection	C4
BF9	Garantir qu'aucun composant d'analyse ne modifie les preuves qu'il analyse	Sécurité	(propre)
BF10	Associer automatiquement chaque alerte à une technique d'attaque connue	Données	V3
BF11	Présenter à l'analyste incidents, contexte et conduite à tenir	Métier	C4
BF12	Réordonner les vulnérabilités détectées à la livraison selon les menaces observées	Données	V4
BF13	Permettre l'accueil d'une nouvelle application sans reconception du socle	Métier	(entreprise)

BF9 est volontairement absolu : *un moteur de détection ne doit jamais modifier les preuves qu'il analyse*. **BF13** traduit l'objectif d'entreprise du chapitre 1 : aucun composant du socle ne doit contenir de logique spécifique à une application.

3.2.2 Besoins non fonctionnels

Le tableau 12 recense les sept besoins non fonctionnels, avec pour chacun la cible visée et le moyen de vérification retenu.

TAB. 12. Besoins non fonctionnels

#	Besoin	Cible	Vérification
BNF1	Disponibilité	Objectif de niveau de service instrumenté, mesuré en continu	Supervision, ch.6
BNF2	Latence	Objectif défini et mesuré ; tout dépassement documenté	Supervision, ch.6
BNF3	Coût mensuel	Quelques dizaines d'euros ; poste dominant identifié	Facturation, ch.6
BNF4	Exploitabilité par une seule personne	Procédures écrites et exécutées au moins une fois	Exécution réelle, ch.6
BNF5	Reproductibilité	Reconstruction complète d'un environnement, chronométrée	Reconstruction complète
BNF6	Auditabilité	Chaque décision automatisée journalisée, entrées et version	Inspection des journaux
BNF7	Scalabilité	Volontairement limitée ; limites mesurées et documentées	Déclaration explicite, ch.6

BNF3 : le poste de coût dominant d'une supervision de sécurité n'est pas le calcul mais l'**ingestion des journaux**, d'où le choix de filtrer à la source (chapitre 4). **BNF7** est une limite assumée : déclarée sans mesure, elle resterait une affirmation, d'où son inscription au programme de validation du chapitre 6.

3.3 Flux de données et frontières de confiance

STRIDE ne s'applique pas à une architecture en général mais à un objet précis : un **diagramme de flux de données** portant ses **frontières de confiance** — les lieux où une donnée passe sous le contrôle d'une entité de confiance différente. C'est là, et seulement là, que la méthode énumère ses six catégories : poser ce diagramme est la condition de validité des scénarios opérationnels qui en sont dérivés.

3.3.1 Le diagramme de flux de données du socle

La figure 7 représente le socle dans la notation usuelle de la modélisation de menaces. Les composants y portent exactement les noms de la vue de déploiement du chapitre 4 (figure 10),

afin que les deux figures se lisent l'une sur l'autre ; les arcs portent les identifiants des sept flux F1 à F7 (tableau 21).

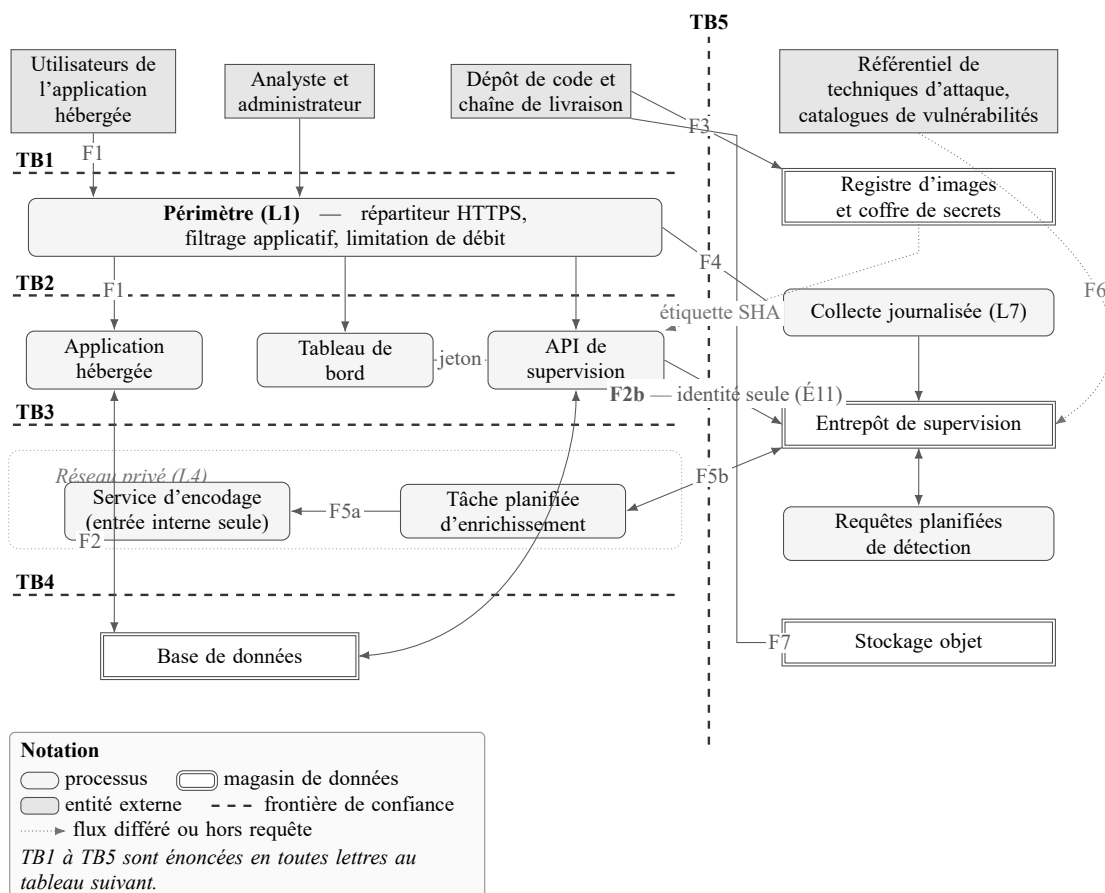


FIG. 7. Diagramme de flux de données du socle et ses cinq frontières de confiance. Les frontières TB1 à TB4 sont empilées et franchies par le réseau ; TB5 leur est orthogonale et n'est franchie que par l'identité. C'est cette frontière, sur laquelle aucun dispositif réseau ne peut s'interposer, que traversent douze des vingt-quatre scénarios opérationnels, dont six des huit scénarios de gravité critique.

TAB. 13. Les cinq frontières de confiance : ce que chacune porte, et les scénarios opérationnels qui la franchissent

#	Frontière	Franchie par	Menaces dominantes	Nature du contrôle qui s'y interpose	Scénarios rattachés (nombre, dont critiques)
TB1	Internet → périmètre	Requête HTTPS (F1)	Déni de service, divulgation par reconnaissance, usurpation	Réseau et applicatif : filtrage applicatif, limitation de débit, terminaison TLS	SO2 à SO5 — 4, aucun critique
TB2	Périmètre → charges de travail	Trafic déjà filtré (F1)	Altération, élévation de privilège	Réseau : entrée des services restreinte au répartiteur ; jeton d'identité vérifié	SO1 — 1, aucun critique
TB3	Charges de travail → réseau privé	Interface de sortie directe de la charge (F2, F5)	Divulgence par canal sortant, élévation par rebond	Réseau : refus par défaut en sortie, autorisations nommées par identité et par port, refus journalisés	SO17, SO18, SO24 — 3, aucun critique
TB4	Réseau privé → données	Adresse privée (F2)	Divulgence d'information	Réseau : absence d'adresse publique, chiffrement obligatoire du transport	SO6, SO8 — 2, les deux critiques

TAB. 13. Les cinq frontières de confiance (suite)

#	Frontière	Franchie par	Menaces dominantes	Nature du contrôle qui s'y interpose	Scénarios rattachés (nombre, dont critiques)
TB5	Charges de travail → plan managé du fournisseur	Identité seule , hors du réseau privé (F3, F4, F5b, F7)	Usurpation, altération des preuves, élévation de privilège	Identité exclusivement : autorisations, jetons de courte durée, fédération	SO7, SO9 à SO14, SO16, SO20 à SO23 — 12 , dont 6 critiques : SO9, SO10, SO12, SO20, SO21, SO22

3.3.2 TB5, frontière sans contrôle réseau

Les quatre premières frontières se comportent comme celles d'une architecture classique : chacune sépare deux zones que le trafic relie par un chemin réseau, sur lequel un dispositif peut être posé — filtre, refus par défaut, absence d'adresse publique. Un lecteur habitué au modèle périmétrique les reconnaît, et c'est ce qui rend TB5 difficile à voir.

TB5 n'est pas un chemin réseau. Lorsqu'une charge de travail écrit dans l'entrepôt de supervision, lit un secret dans le coffre, tire une image du registre ou modifie l'état de l'infrastructure, elle s'adresse aux interfaces du fournisseur : aucun dispositif réseau n'arbitre cet appel. Depuis la refonte du plan réseau (section 4.2.5), il emprunte bien l'interface de sortie de la charge et se heurte au refus par défaut ; mais la règle qui le laisse passer ne désigne qu'une plage de destination du fournisseur, la même pour l'entrepôt du socle et pour tout autre entrepôt du même fournisseur. Il est autorisé, ou refusé, par la seule vérification de l'identité qui le présente. Le chapitre 4 relève ce point comme l'écart É11 : la vue de déploiement, qui aligne les composants sur un plan réseau, laisse croire l'inverse.

Deux conséquences en découlent. Aucun contrôle réseau ne réduit un risque porté par TB5 : aucun ne sépare l'interface du fournisseur que le socle emploie de celle qu'un attaquant contrôlerait chez le même fournisseur, et les distinguer supposerait un périmètre de service, donc une organisation dont le projet ne dispose pas. Et TB5 est la frontière que franchissent les chemins d'administration et de livraison — précisément ceux que le modèle périmétrique du chapitre 1 laissait sans contrôle parce qu'il ne les voyait pas comme des chemins.

Sur TB5, l'identité n'est pas un contrôle parmi d'autres : elle est le seul. C'est la traduction opérationnelle du principe d'identité (PR2) et la raison pour laquelle le chapitre 4 traite le plan d'identité comme la segmentation réelle de l'architecture.

3.4 Analyse de risque

3.4.1 Valeurs métier, sources de risque et scénarios stratégiques

Une **valeur métier** est ce dont la perte, l'altération ou la divulgation nuit à l'organisation ; un **bien support** est un élément technique dont une valeur métier dépend. Six valeurs métier ont été retenues : le corpus linguistique constitué, premier actif de l'entreprise ; les identités et les voix des contributeurs ; l'intégrité de la compétition, dont dépend la crédibilité du dispositif d'incitation ; la disponibilité du service ; l'intégrité des preuves de supervision ; la crédibilité technique de MENAL, atteinte transverse des cinq précédentes. La cinquième est propre au

socle : protéger les données sans protéger les traces de l'attaque rend la supervision contestable, et c'est elle qui justifie l'interdiction d'écriture faite aux composants d'analyse (BF9).

Neuf biens supports les portent, de la base applicative au point d'entrée public, et les cinq sources de risque sont les acteurs hostiles A7 à A11 du tableau 10. Une sixième, l'acteur étatique organisé, est **écartée par décision explicite** : la traiter supposerait des moyens de détection et de réponse sans commune mesure avec le périmètre du projet, et l'inclure sans ces moyens produirait une analyse dont aucune exigence ne découlerait ; l'exclusion est datée et révisable si le corpus change de statut. La codification des ateliers figure en annexe C.

Sept scénarios stratégiques relient chacun une source de risque à une valeur métier atteinte, par un chemin de haut niveau ; l'annexe C les énonce avec leur codification et leur gravité. **Quatre sont de gravité critique** : accès direct à la base de données puis copie du corpus et des identités, obtention du jeton d'export du corpus, détournement de l'identité de déploiement suivi d'un déploiement non revu, divulgation d'un secret permettant de reconstituer des accès légitimes. Les trois autres, graves ou significatifs, portent sur l'altération des journaux et des détections, sur le classement de la compétition et sur la disponibilité d'un service exposé. Trois des quatre critiques — accès direct à la base, jeton d'export, divulgation d'un secret — correspondent à des points bloquants de l'audit du chapitre 1 : l'audit a fourni la matière factuelle de cette analyse, non une liste théorique.

3.4.2 Scénarios opérationnels

Les scénarios stratégiques sont traduits en chemins techniques par application systématique des six catégories STRIDE aux sept flux F1 à F7, en chacun des points où ils franchissent une des cinq frontières de la section 3.3. L'opération produit **vingt-quatre scénarios opérationnels SO1 à SO24**, dont huit au niveau de risque le plus élevé ; le tableau détaillé de l'annexe C rattache chacun à sa frontière et à sa catégorie STRIDE, et la dernière colonne du tableau 13 en donne la répartition.

Lecture. Douze scénarios sur vingt-quatre, et **six des huit de gravité critique**, franchissent TB5 : ce résultat n'était pas un objectif de la modélisation, il en sort. Les deux scénarios de TB4 sont eux aussi de gravité critique, mais un contrôle réseau simple et vérifiable les adresse — l'absence d'adresse publique.

Trois rattachements méritent d'être justifiés, aucun n'ayant été forcé. **SO15**, l'absence de trace permettant d'attribuer une action, et **SO19**, la falsification du rattachement d'une vulnérabilité pour la déclasser, ne franchissent aucune frontière et ne figurent donc dans aucune ligne du tableau ; ce sont aussi les seuls auxquels la matrice des techniques d'attaque ne fait correspondre aucune technique, pour la même raison — un défaut de traçabilité et un abus de droit interne ne sont pas des chemins d'attaque, ce sont les conditions qui les rendent indétectables. **SO1** est rattaché à TB2, la frontière qu'une charge utile franchit effectivement, alors que le contrôle qui le traite est posé une frontière en amont, sur TB1 : seul endroit du socle où la défense est placée avant la frontière menacée plutôt que sur elle.

3.4.3 Appréciation et traitement du risque

Le croisement gravité × vraisemblance, détaillé en annexe C, place la zone de risque la plus élevée sur les chaînes de livraison applicative et de provisionnement (F3, F7) et sur l'accès direct aux données (F2) — la répartition qui précède en donne l'explication structurelle. Le scénario le plus critique de vraisemblance forte correspond exactement au point bloquant B2 de l'audit.

Les décisions de traitement sont, pour l'essentiel, la **réduction** par des contrôles d'architecture, complétée par deux **acceptations explicites**, datées et révisables ; aucun transfert n'est appliqué, faute d'assurance ou de sous-traitance de sécurité dans le périmètre.

3.5 Exigences de sécurité et traçabilité

3.5.1 Les vingt exigences de sécurité

L'analyse de risque est traduite en vingt exigences de sécurité EX1 à EX20 (tableau 14). Chacune est formulée comme une **propriété vérifiable du système** et non comme une intention, ce qui rend possible l'écriture d'un test au chapitre 6 : « les accès doivent être maîtrisés » ne se teste pas ; « une connexion directe depuis Internet est refusée » se teste par une connexion directe depuis Internet.

TAB. 14. Formulation complète des vingt exigences de sécurité

#	Exigence de sécurité
EX1	Toute requête empruntant le point d'entrée public est soumise aux règles de filtrage configurées
EX2	Les tentatives d'authentification anormales sont limitées et détectées
EX3	Le service reste disponible sous charge anormale et le balayage est tracé
EX4	La base applicative n'expose pas d'adresse publique et une connexion directe depuis Internet est refusée
EX5	Une identité applicative ne peut accéder qu'aux données de son périmètre
EX6	Tout accès aux données est lié à une identité vérifiée, sans jeton transmissible
EX7	Les comptes de service du périmètre n'utilisent pas de clé statique inventoriée ; toute exception est tracée
EX8	Un artefact présentant une vulnérabilité critique corrigable détectée par la porte configurée est bloqué
EX9	Le déploiement ne peut tirer que du registre de confiance unique
EX10	Un secret reconnu par les règles du détecteur configuré bloque la chaîne avant livraison
EX11	Les identités d'exécution des composants d'analyse n'ont aucun droit d'écriture sur les tables de preuve
EX12	Toute interruption de la collecte de journaux est détectable
EX13	Toute action privilégiée est attribuable à un acteur identifié
EX14	Le service d'encodage n'accepte que des appels internes, et sa sortie réseau est restreinte aux destinations nécessaires à son fonctionnement
EX15	Une charge anormale d'alertes ne compromet pas la chaîne d'enrichissement
EX16	Une modification hors code d'une ressource déjà gérée est détectée par rafraîchissement ; les ressources non gérées sont contrôlées par inventaire
EX17	L'état de l'infrastructure est privé, versionné et chiffré
EX18	Toute modification de droits est revue avant application
EX19	Une consommation de ressources anormale est détectée
EX20	Les sorties réseau sont limitées à des destinations connues, et les refus du pare-feu sont journalisés

Deux exigences appellent une précision d'état à la date de 25/08/2026, postérieure à la refonte du plan réseau (décision D15, section 4.2.5, qui en établit le détail et les dates). **EX20** est portée par un contrôle et non plus par l'autorisation implicite du fournisseur : la totalité du trafic sortant des charges porteuses de données emprunte le réseau virtuel, cinq autorisations nommées par identité et par port y sont posées, et le refus par défaut en sortie rejette tout le reste ; les destinations autorisées sont celles inventoriées pendant la fenêtre du 15 au 22/08/2026, non celles supposées, et les refus sont journalisés depuis le 19/08/2026 (écart É1, clos). Le critère

se vérifie en deux points : aucune règle d'autorisation ne comporte de plage source, et une destination hors inventaire est refusée puis retrouvée dans l'entrepôt — objet du protocole T20.

EX14 est portée en entrée par la restriction du service d'encodage aux appels internes, et contre le rebond par son retrait du réseau privé : le composant ne porte plus d'interface dans un sous-réseau, et son identité dédiée — écart É3, corrigé le 19/08/2026 — ne détient que le droit d'écrire des journaux. Sa sortie emprunte en revanche le chemin managé de la plateforme d'exécution, qu'aucune règle de pare-feu ne gouverne; le relevé du 25/08/2026 l'établit, et l'exigence reste ouverte à ce titre (protocole T14, non conforme).

Deux réserves accompagnent ces états, toutes deux établies en section 4.2.5 : l'exfiltration par les interfaces du fournisseur n'est pas fermée, et le sélecteur des règles est l'étiquette réseau et non le compte de service — la frontière est donc opposable à une charge de travail compromise, non à un opérateur capable de déployer. La distinction entre la propriété exigée et le degré de garantie atteint est portée par le chapitre 6, jamais dissimulée dans la formulation de l'exigence.

3.5.2 Matrice de traçabilité

Cette matrice (tableau 15) relie les quatre niveaux d'analyse : pour chaque scénario opérationnel, elle établit la chaîne complète du risque analysé jusqu'à sa démonstration. Chaque ligne se lit ainsi : *ce scénario impose cette exigence, réalisée par ce contrôle, dont l'efficacité est démontrée par ce test*. L'exigence y est appelée par son identifiant ; sa formulation complète est celle du tableau 14 ci-dessus.

TAB. 15. Matrice de traçabilité menace → exigence → contrôle → test

Menace	Exig.	Contrôle (couche)	Test de validation
SO1	EX1	Filtrage applicatif au point d'entrée unique (L1)	T1 — Charges d'attaque connues; vérification du blocage
SO2, SO3	EX2	Limitation de débit (L1); règle de détection sur échecs répétés (L5)	T2 — Échecs répétés; blocage et alerte
SO4, SO5	EX3	Limitation de débit, restriction géographique (L1); journalisation (L7)	T3 — Test de charge; limitation et trace
SO6	EX4	Base sans adresse publique, accès privé uniquement (L4, L5)	T4 — Connexion directe externe; échec attendu
SO7	EX5	Une identité de service par charge de travail (L2)	T5 — Lecture de l'entrepôt de supervision; refus attendu
SO8	EX6	Authentification requise entre services (L2, L3)	T6 — Appel sans jeton; refus attendu
SO9	EX7	Identité fédérée, jetons courts, création de clés interdite (L2)	T7 — Inventaire des clés; tentative de création; refus attendu
SO10	EX8	Contrôle de vulnérabilité bloquant (F3)	T8 — Artefact vulnérable; blocage attendu
SO11	EX9	Registre unique autorisé, droits limités (L2, F3)	T9 — Déploiement depuis source externe; refus attendu
SO12	EX10	Détection de secrets bloquante (F3); gestionnaire dédié (L2)	T10 — Secret factice; blocage attendu
SO13, SO16	EX11	Droits d'écriture réservés à la collecte (L2, L5)	T11 — Écriture avec l'identité d'enrichissement; refus attendu
SO14	EX12	Supervision de la continuité du flux (L7)	T12 — Interruption volontaire; alerte attendue
SO15	EX13	Journaux d'audit du fournisseur activés (L7)	T13 — Action privilégiée; attribution vérifiée
SO17	EX14	Entrée interne (L6); composant retiré du réseau privé, sans interface ni chemin vers une ressource privée; identité dédiée limitée à l'écriture de journaux (L2, L4)	T14 — Connexion sortante émise depuis le composant; refus et trace attendus
SO18	EX15	Traitement par lots à cadence fixe (L6)	T15 — Volume anormal; comportement et coût observés
SO20	EX16	Infrastructure en code exclusive, détection de dérive (F7)	T16 — Ressource manuelle; détection comme dérive

Menace	Exig.	Contrôle (couche)	Test de validation
SO21	EX17	Stockage d'état distant, accès restreint (F7)	T17 — Accès non autorisé ; refus attendu
SO22	EX18	Approbation manuelle obligatoire (F7)	T18 — Changement élargissant des droits ; blocage en attente
SO23	EX19	Supervision de consommation, alerte de budget (L7)	T19 — Consommation simulée ; alerte attendue
SO24	EX20	Refus par défaut en sortie ; cinq autorisations nommées par identité et par port ; refus journalisés et versés à l'entrepôt (L4, É1)	T20 — Destination hors inventaire ; refus attendu et ligne de refus retrouvée dans l'entrepôt

Vingt exigences, vingt tests. Ces tests constituent le programme de validation du chapitre 6, qu'ils fixent *avant* que celui-ci ne soit écrit ; aucun n'est optionnel, une exigence ne devenant une propriété établie qu'au passage de son test. La matrice se lit dans les deux sens : de gauche à droite elle justifie chaque exigence par le scénario qui la motive, de droite à gauche elle vérifie que chacune porte son test. Elle compte une ligne par exigence et nomme donc vingt des vingt-quatre scénarios ; le traitement des quatre autres — SO3, SO5, SO16 et SO19 — est arrêté par la table de décision de risque de l'chapitre C, qui les couvre tous. Elle établit enfin que les douze scénarios de TB5 sont adressés par des contrôles d'identité (EX5 à EX11, EX16 à EX19) et non par des contrôles réseau qui ne s'y appliqueraient pas.

3.6 Rattachement aux référentiels

Les vingt exigences sont rattachées aux référentiels du chapitre 2 (tableau 16), pour exprimer la conformité en termes reconnus et identifier les écarts assumés ; le chapitre 6 en donne le détail, lacunes comprises.

TAB. 16. Rattachement des exigences aux référentiels

Référentiel	Exigences concernées	Écarts assumés
Zero Trust ([27])	EX4-EX7, EX11, EX13, EX14, EX20	Aucun principe non traité ; degré mesuré au ch.6
Applicatif ([25])	EX1, EX8-EX10	Code hébergé hors périmètre
Infrastructure (CIS)	EX4, EX5, EX7, EX13, EX16, EX17, EX20	Journalisation des flux échantillonnée en régime permanent, justifiée par le coût
Techniques d'attaque ([21])	Couverture des scénarios opérationnels	Partielle par construction ; plafond et lacunes publiés au ch.6

Conclusion du chapitre

Ce chapitre a transformé les carences du chapitre 1 et l'état de l'art du chapitre 2 en exigences vérifiables : six valeurs métier, dont l'intégrité de la chaîne de preuve, propre au socle ; cinq sources de risque, la sixième écartée par décision datée ; sept scénarios stratégiques, que l'application systématique de STRIDE au diagramme de flux et à ses cinq frontières a traduits en vingt-quatre scénarios opérationnels, puis en vingt exigences associées chacune à un contrôle et à un test. Le principal enseignement est double : les scénarios les plus graves ne concernent pas l'application exposée sur Internet mais les chemins d'administration, de livraison et d'accès aux données, et ces chemins se distinguent par le fait qu'ils franchissent TB5, la seule frontière du socle qu'aucun contrôle réseau ne peut garder. Le chapitre suivant présente l'architecture qui réalise ces vingt contrôles, et son plan d'identité — réponse directe à TB5.

Chapitre 4 Conception de l'architecture

Vues d'architecture, plan d'identité et registre des décisions

Ce chapitre présente l'architecture qui réalise les vingt exigences du chapitre 3, chaque affirmation étant adossée à une vue qui la rend vérifiable : une architecture qui ne documente que ce qu'elle contient laisse penser que ce qui n'y figure pas a été oublié.

4.1 Principes directeurs de conception

Quatre principes ont guidé l'ensemble des décisions ; ils rendent chaque choix contestable.

PR1 — tout composant doit justifier son existence. Un composant ajouté est à configurer, mettre à jour, surveiller et payer : exploité par une seule personne, il dégrade la sécurité réelle même s'il améliore la sécurité théorique. Règle appliquée : **un composant n'est retenu que s'il couvre une menace du chapitre 3 qu'aucun composant existant ne couvre déjà** — sept ont été écartés (section 4.7.2).

PR2 — l'identité est le plan de contrôle, pas une couche. Le modèle périmétrique segmente par le réseau ; le modèle retenu segmente par l'identité, chaque charge de travail ayant la sienne. La représenter comme une couche latérale reviendrait à admettre des chemins où elle n'est pas consultée, soit la confiance implicite même (section 4.2.2).

PR3 — un moteur de détection ne modifie jamais les preuves qu'il analyse. Traduction de la valeur métier VM5 et de l'exigence EX11, étendue au tableau de bord ; seule exception explicite, l'enregistrement du verdict humain, donnée nouvelle et non modification.

PR4 — rien n'existe dans l'infrastructure qui n'existe d'abord dans le code. Réponse à la carence C2 et au point bloquant B5 de l'audit du chapitre 1, pour trois effets : reproductibilité, contrôle avant existence, détection de dérive. Les commandes interactives restent réservées à l'exploitation ponctuelle.

4.2 Vues d'architecture

Cinq vues statiques décrivent le socle, le réseau étant donné dans ses deux états, avant et après la refonte. Aucune ne peut afficher un composant qui n'est pas déclaré en code.

4.2.1 Vue de contexte

La figure 8 fixe la frontière du système et nomme ce dont le socle dépend sans le maîtriser : six systèmes tiers, dont trois imports de données qui portent le risque de chaîne d'approvisionnement — dépendance ou image de base compromise, acteur A10 du chapitre 3. Ces trois imports sont différés, hors du chemin de la requête : une indisponibilité y dégrade l'enrichissement ou la priorisation, jamais le service rendu. Le sixième, la zone de noms de domaine tenue chez le bureau d'enregistrement, figure en dépendance externe et non en composant de la couche de

périmètre — écart É10 : elle est consultée *avant* tout contact avec le socle, de sorte qu’une dérive y rend le socle injoignable sans qu’aucun contrôle interne ne s’en aperçoive.

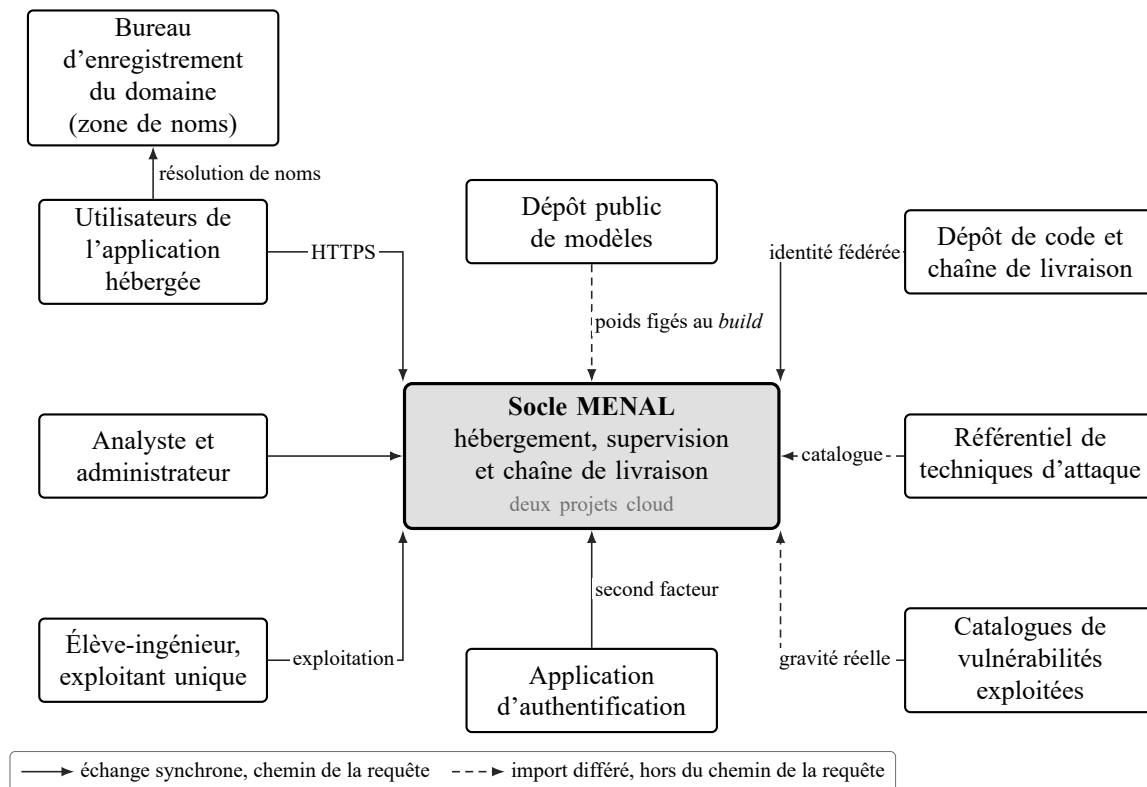


FIG. 8. Vue de contexte : le socle, ses acteurs et les six systèmes extérieurs dont il dépend — trois imports différés portent le risque de chaîne d’approvisionnement, la zone de noms échappe seule à la description en code (É10)

4.2.2 Modèle en couches et justification des deux plans transversaux

L’architecture s’organise en sept niveaux numérotés (figure 9), dont deux plans transversaux plutôt que des couches ordinaires, suivant l’approche recommandée pour les architectures cloud sécurisées [14]. La conception initiale comportait deux couches de même numéro et omettait l’enrichissement (L6) : la numérotation a été révisée, un modèle en couches n’ayant de valeur que si documentation, code et tests désignent la même chose.

L2 est un plan parce que l’identité est vérifiée à *chaque* saut — du périmètre aux charges de travail, de celles-ci aux données, de la chaîne de livraison au registre [27] — portée dont un bloc latéral ne rendrait pas compte ; **L7 en est un** parce que la collecte part de *toutes* les couches pour alimenter l’entrepôt de supervision (L5), sans source de données autrement.

4.2.3 Vue de déploiement et chemins réseau effectifs

La figure 10 situe les mêmes éléments comme composants réels reliés par des liens réseau, dont le *style* porte l’information la plus contre-intuitive du socle : tous les chemins internes ne traversent pas le réseau privé, l’accès à l’entrepôt empruntant le chemin managé du fournisseur, autorisé par l’identité seule et non par une règle réseau (É11). Le tableau de bord, lui, ne rejoint pas l’API par un lien direct : son appel ressort par le répartiteur et subit un **second passage du**

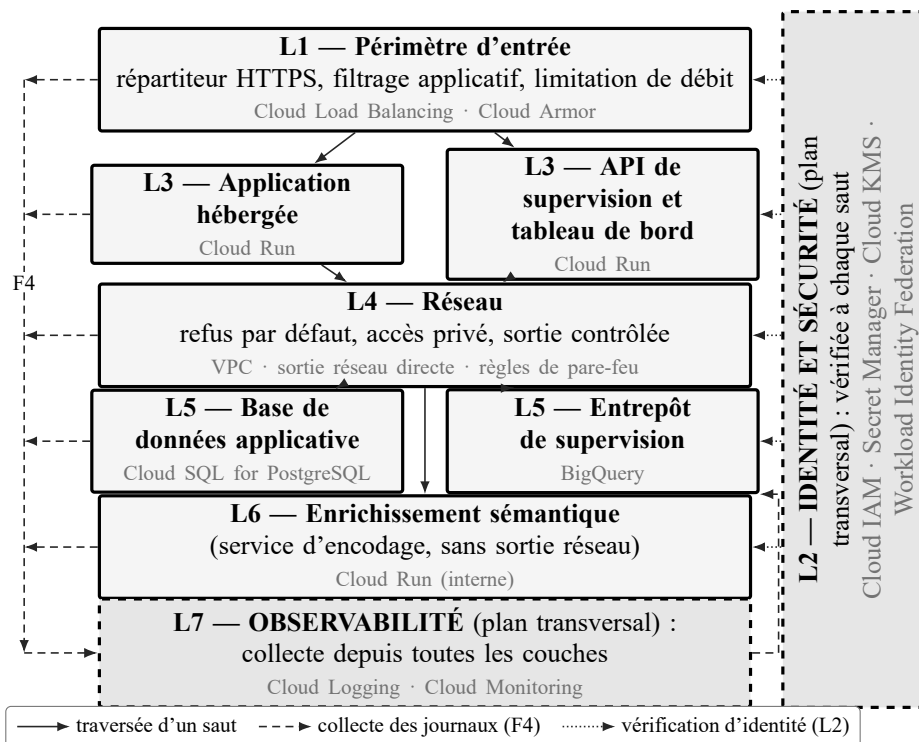


FIG. 9. Modèle en couches : cinq couches empilées (L1, L3, L4, L5, L6) et deux plans transversaux (L2, L7), dont la bordure en tirets marque la portée. La résolution de noms ne figure pas en L1 : elle est une dépendance externe (figure 8).

filtrage applicatif, ce qui explique le comportement observé de la limitation de débit sur les chemins d'authentification (section 5.8.1).

4.2.4 Topologie réseau avant la refonte

Les deux vues précédentes nomment le réseau sans le décrire ; la figure 11 le décrit plage par plage et règle par règle, tel qu'il se lisait dans le dépôt **avant la refonte du 11 au 25/08/2026** — chaque affirmation reste recoupable avec le code de cette période. Cette vue n'est pas un état des lieux mais le dossier d'instruction de D15. Une question le résumait : *par où sortait le trafic de la tâche d'enrichissement ?* Il sortait *intégralement* par le connecteur, y compris vers les interfaces publiques du fournisseur — seul réglage permettant à l'appel d'atteindre un service à entrée interne ; le refus général en entrée, journalisé à la priorité la plus basse, alimentait la détection de mouvement latéral.

4.2.5 Refonte du plan réseau appliquée (D15)

La topologie qui précède décrit l'état antérieur ; celle-ci décrit la refonte qui l'a remplacé — décision D15, conduite en douze étapes **du 11 au 25/08/2026**. La date de référence du mémoire lui étant postérieure, **le réseau décrit ici est celui qui est en service à 25/08/2026**.

Le verrou que la refonte a levé. Six des sept charges desservies par le connecteur portaient le réglage de sortie *plages privées seulement* : seul le trafic destiné aux plages privées normalisées entraînait dans le réseau virtuel. Tout le reste — appels aux interfaces du fournisseur, appel du tableau de bord vers le répartiteur — empruntait le chemin managé de la plateforme d'exécution, **hors du réseau virtuel, donc hors de portée de toute règle de pare-feu**. Poser alors un refus

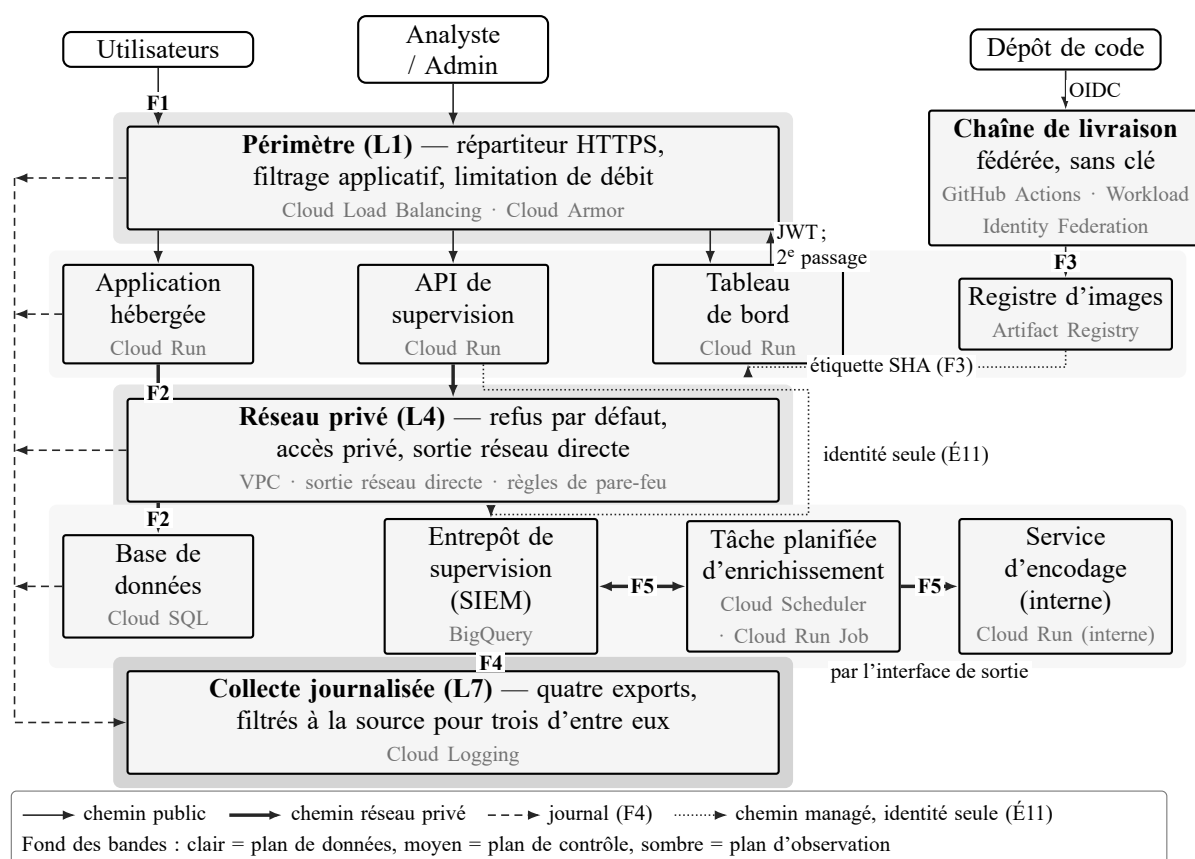


FIG. 10. Vue de déploiement : composants, liens réseau et flux F1 à F5. Le tableau de bord n'atteint les données que par l'API, et son appel ressort par le répartiteur : il subit un second passage du filtrage applicatif.

par défaut en sortie n'aurait rien bloqué : **le défaut n'était pas l'absence d'une règle, c'était que le trafic ne passait pas là où elle se serait appliquée** — ce qui explique aussi que la passerelle de traduction d'adresses ne manquait à personne. La migration a donc d'abord déplacé le trafic, et seulement ensuite l'a contrôlé.

La *sortie réseau directe*, disponible en version générale sur la plateforme retenue, fait les deux : elle place les interfaces de sortie des charges de travail *dans* un sous-réseau, ce qui rend le pare-feu applicable à elles, et elle supprime le connecteur d'accès sans serveur — son coût plancher permanent et le point de défaillance unique qu'il constituait pour les sept charges qu'il desservait. Le schéma du fournisseur d'infrastructure, dans la version verrouillée par le dépôt, expose le mécanisme sur le service comme sur la tâche : relevé du 29/08/2026.

Principe directeur et plan d'adressage. Le principe est la traduction directe du principe d'identité (PR2) au plan réseau : **l'identité, plan de contrôle du socle, devient le sélecteur du pare-feu lui-même**. Le critère d'acceptation qui en découle est vérifiable en une commande : *aucune règle d'autorisation ne comporte de plage source*.

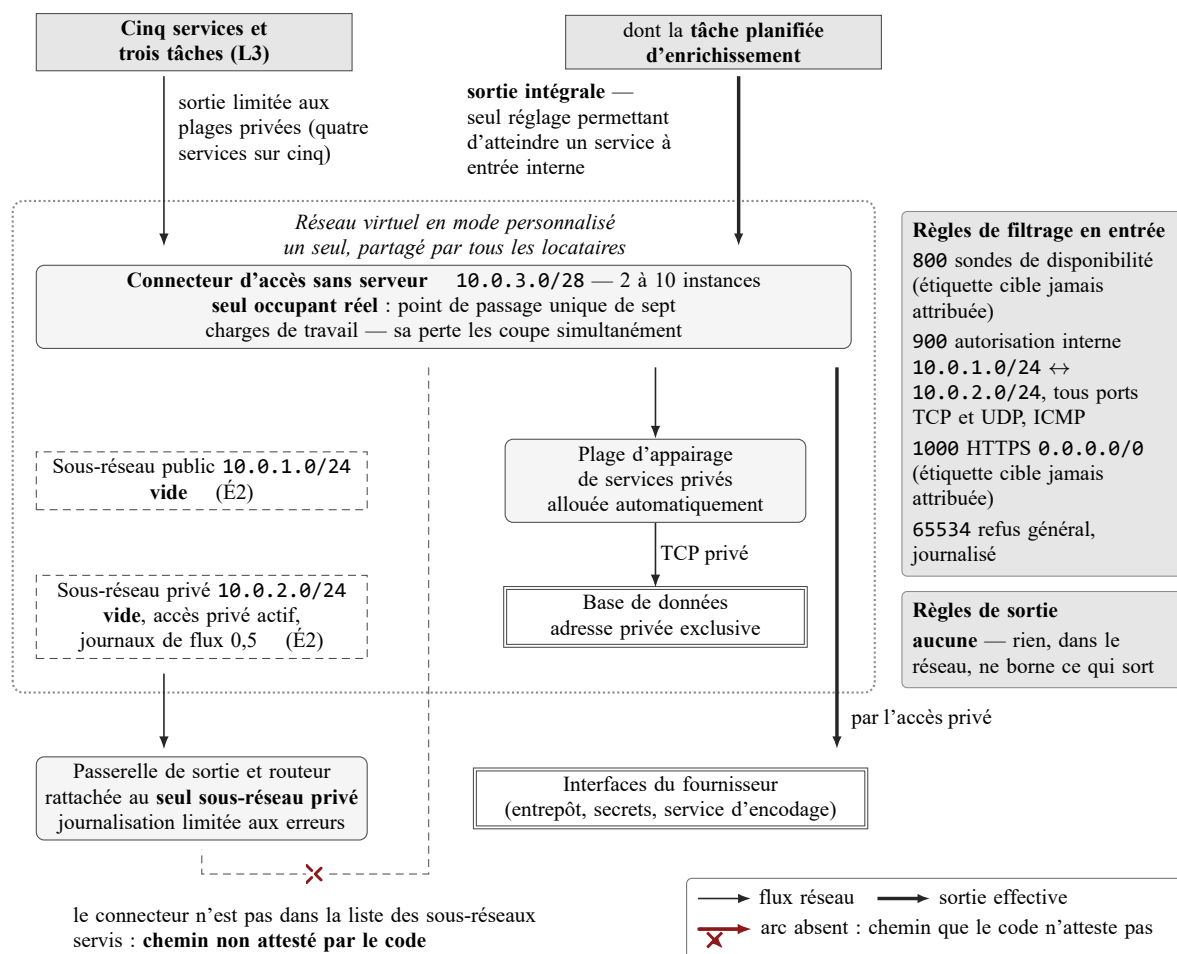


FIG. 11. Topologie réseau **avant la refonte** — état du dépôt jusqu'au 11/08/2026. La sortie des charges de travail n'y était pas gouvernée par le réseau mais par le paramètre de la plateforme d'exécution : la passerelle ne desservait que le sous-réseau privé, lequel était vide, et la plage qui portait la totalité de la sortie ne lui était pas rattachée. Aucune règle de sortie n'existait : c'est le diagnostic qui a motivé D15.

TAB. 17. Plan d'adressage du réseau du socle, en service depuis le 11/08/2026. Chaque longueur de préfixe est justifiée par le plafond d'instances déclaré et sa marge : un préfixe posé sans raison est une dette d'adressage.

Sous-réseau	Plage	Ce qui l'occupe	Justification du préfixe
Locataire plateforme	10.0.8.0/26	Interfaces de sortie de l'API de supervision, du tableau de bord et de la tâche d'enrichissement	60 adresses pour un plafond déclaré de six instances, soit dix fois la marge ; c'est aussi le préfixe minimal recommandé pour la sortie réseau directe
Locataire hébergé	10.0.8.64/26	Interfaces de sortie de l'application hébergée et de ses deux tâches	Même préfixe : un locataire ne doit pas hériter d'un plafond de croissance inférieur par accident de plan
Troisième locataire	10.0.8.128/26	Créé vide, réservé	Un sous-réseau sans ressource ne coûte rien : l'accueil du troisième locataire, seuil de bascule déclaré du projet, devient une ligne de configuration et non une décision d'adressage prise dans l'urgence
Réserve	10.0.8.192/26	—	Ferme le bloc /24 : un /24 vaut quatre locataires, l'extension suivante se fait sur le /24 voisin selon la même règle
Appairage de services privés	/16 en service, /20 pour une reconstruction	Adresse privée de la base de données	Le /16 en place est seize fois surdimensionné et immuable sans recréer l'appairage ; un /20 suffit à une instance par locataire et ne vaut donc que pour un provisionnement neuf. Séparé du bloc des locataires : une erreur de plan ne peut pas les faire se chevaucher

TAB. 17. Plan d'adressage cible (suite)

Sous-réseau	Plage	Ce qui l'occupe	Justification du préfixe
Supprimés au cours de la migration : la plage 10.0.3.0/28 et le connecteur, le 15/08/2026; les deux sous-réseaux 10.0.1.0/24 et 10.0.2.0/24, qu'aucune ressource n'occupait et qu'aucun module ne consommait, le 24/08/2026 — ce qui ferme l'écart É2.			

Les règles de pare-feu en service. Douze règles — **cinq autorisations et sept refus** — ont remplacé les quatre antérieures, dont une ouvrait tous les ports TCP et UDP ainsi qu'ICMP entre deux plages, sans aucune cible. Elles ont été posées du 22 au 23/08/2026, autorisations d'abord, refus nommés ensuite, refus par défaut en dernier; **chaque autorisation porte une identité nommée et un port nommé**. La journalisation suit la convention du projet — *les refus sont journalisés, les autorisations ne le sont pas* — pour ne pas payer un volume d'ingestion sans valeur de détection (BNF3); chaque refus journalisé alimente l'export existant vers l'entrepôt, sans modifier la chaîne de détection.

TAB. 18. Règles de pare-feu en service depuis le 23/08/2026. Aucune autorisation ne comporte de plage source : c'est le critère d'acceptation de la conception.

Réf.	Sens	Cible — identité de service	Destination ou source	Ports	Action
E1–E2	Sortie	API de supervision; application hébergée	Adresse privée de la base	5432	Autoriser
E3	Sortie	Tableau de bord; tâche d'enrichissement	Adresse privée de la base	tous	Refuser, journalisé
E4	Sortie	API de supervision; application hébergée; tâche d'enrichissement	Interfaces privées du fournisseur	443	Autoriser
E5	Sortie	Tableau de bord	Adresse du répartiteur, et elle seule	443	Autoriser
E6	Sortie	Tâche d'enrichissement	Service d'encodage	443	Autoriser
E7–E8	Sortie	Identités d'un locataire	Plage de l'autre locataire	tous	Refuser, journalisé
E9	Sortie	<i>tout le réseau</i>	0.0.0.0/0	tous	Refuser par défaut, journalisé
I1–I2	Entrée	Identités d'un locataire	Plage de l'autre locataire	tous	Refuser, journalisé
I3	Entrée	<i>tout le réseau</i>	0.0.0.0/0	tous	Refuser par défaut, journalisé

Trois lectures méritent la soutenance. **Les refus nommés E3, E7, E8, I1 et I2 ne changent aucun verdict** — E9 les rendrait redondants : ils existent pour *produire un signal*, une tentative du tableau de bord vers la base étant alors journalisée sous un nom de règle qui dit exactement ce qui s'est passé, directement exploitable par la chaîne de détection. **Aucune autorisation en entrée ne subsiste** : le pare-feu est à états, rien n'initie de connexion vers une charge de travail par le réseau, et les trois règles antérieures ont été supprimées le 24/08/2026 sans successeur — l'inventaire des instances de calcul, vide, établit qu'elles ne protégeaient rien. Enfin **la règle E5 borne le tableau de bord à une seule adresse au monde**, celle du répartiteur : le réseau referme un écart que le plan d'identité laisse ouvert (É9).

La figure 12 rassemble le plan d'adressage et ces règles en une vue unique, à mettre en regard de la figure 11 : les charges de travail y figurent à *l'intérieur* des sous-réseaux, et le bloc des règles ne comporte plus une seule plage source.

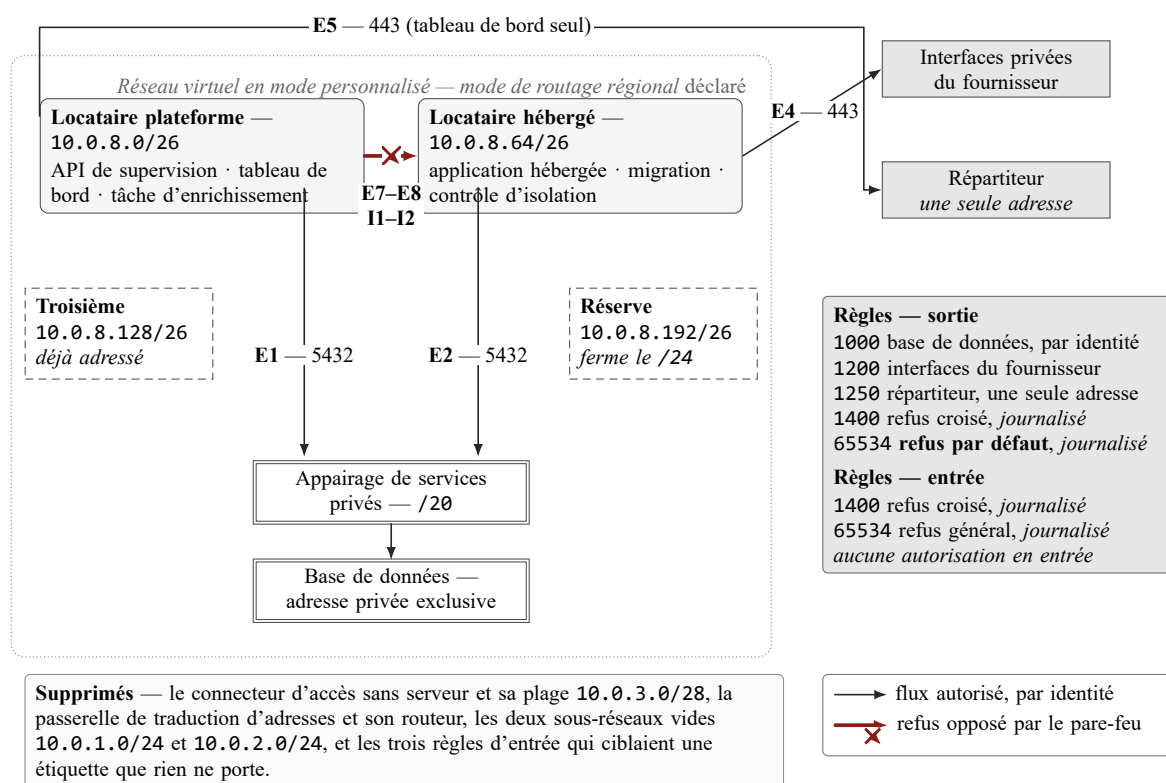


FIG. 12. Topologie réseau **après la refonte appliquée du 11 au 25/08/2026** — le réseau en service à 25/08/2026, à comparer à la figure 11. Les charges de travail émettent *depuis* un sous-réseau : le pare-feu leur est applicable, et aucune autorisation ne comporte de plage source.

Une limite du mécanisme, dite avant qu'un jury la trouve

Le sélecteur par compte de service est une fonctionnalité réelle du pare-feu du fournisseur, mais **son application aux interfaces de sortie directe n'est pas établie** : à 25/08/2026, le schéma du fournisseur d'infrastructure n'expose que les étiquettes à ce niveau. La refonte applique donc une convention — *une étiquette par compte de service, l'une et l'autre déclarées dans le même bloc* — et un commutateur qui bascule vers le sélecteur par identité une fois la vérification passée : la propriété revendiquée ne change pas, c'est le mécanisme qui l'exprime qui attend sa preuve. La conséquence porte sur la ségrégation entre locataires et vaut pour le réseau en service : une étiquette se pose dans la définition de la révision, de sorte que **la frontière entre locataires est opposable à une charge de travail compromise, mais non à un opérateur capable de déployer** — lequel poserait l'étiquette de l'autre locataire. Ce second cas relève du resserrement du droit de déploiement (section 4.6.2). La vérification qui lève la réserve est la première du protocole et tient en une règle de test et un appel.

Ce que la refonte a fermé, ce qu'elle coûte, et dans quel ordre. Trois défauts sont tombés ensemble parce que **la passerelle de traduction d'adresses n'a pas été mieux configurée : elle est devenue sans objet** au sens de PR1 (section 2.6.2). Sa suppression, le 24/08/2026, a emporté son rattachement au mauvais sous-réseau, sa journalisation limitée aux erreurs — qui

laissait toute connexion sortante réussie sans signal — et son allocation d'adresses automatique, qui interdisait toute liste d'autorisation chez un tiers.

Les montants qui suivent sont des ordres de grandeur de tarification publique, non des montants relevés sur facture. La suppression du connecteur, facturé au plancher de deux instances permanentes, libère de l'ordre de **onze à treize euros par mois** ; sous-réseaux, routes et règles ne sont pas facturés ; seuls les journaux de flux deviennent un poste de un à deux euros. S'y ajoute un coût évité qui ne figure dans aucun tableau, la montée en charge du connecteur, qui disparaît *en tant que risque*. La conséquence est structurante : **le coût marginal réseau d'un locataire supplémentaire passe d'une douzaine d'euros par mois à zéro** — un sous-réseau et deux règles de refus croisé ne sont pas facturés, et le troisième sous-réseau est déjà créé — de sorte que **la ségrégation réseau entre locataires a cessé d'être un arbitrage entre coût et sécurité** et que le troisième seuil du chapitre 6 devient franchissable sans renégocier le budget. *Le rapprochement de ces ordres de grandeur avec la facture appartient au mois suivant la migration, sur les postes d'accès réseau, de traduction d'adresses et de télémétrie.*

Les douze étapes ont obéi à une règle unique — *on n'interdit jamais avant d'avoir observé, et on n'observe qu'après avoir fait passer le trafic par l'endroit où on l'observe* — qui commande le calendrier du 11 au 25/08/2026 ; la conduite de l'opération, la fenêtre d'observation de sept jours et le traitement de la seule étape réellement dangereuse, le refus par défaut en sortie, sont rapportés en section 5.3.3. Deux propriétés sont ici établies par contrôle direct — l'exposition de la sortie réseau directe dans la version verrouillée du fournisseur, relevée le 29/08/2026, et le fait que les trois règles d'entrée supprimées ne protégeaient rien, l'inventaire des instances de calcul étant vide ; les deux autres, applicabilité du sélecteur par identité et démonstration que le tableau de bord ne joint plus qu'une adresse, portent leur commande et leur critère au plan de validation continue (section 6.2.3). Enfin, une architecture de pare-feu à douze règles exploitée par une seule personne se dégrade au premier incident où une autorisation large débloque une urgence : le critère d'acceptation — *aucune règle d'autorisation ne comporte de plage source* — est donc porté en porte bloquante par l'analyse de configuration de la chaîne de provisionnement (chapitre 5). **L'architecture refuse elle-même sa propre dégradation.**

Ce que la refonte ne ferme pas. Cinq limites sont assumées. La plage d'appairage de services privés est immuable sur l'instance existante : la cible /20 ne vaut que pour un provisionnement neuf. La base de données et l'entrepôt restent partagés — **la ségrégation réseau n'empêche pas deux identités d'atteindre le même serveur**, elle empêche l'une d'atteindre l'interface de l'autre. Le refus par défaut en sortie supprime le canal de commande vers un hôte arbitraire mais **non l'exfiltration par les interfaces du fournisseur lui-même** : l'autorisation qui rend l'entrepôt joignable rend joignable tout entrepôt du même fournisseur, et fermer ce chemin exigerait un périmètre de service, donc une organisation cloud dont le projet ne dispose pas. Le détachement des deux charges qui n'ont aucune dépendance privée leur laisse une **sortie managée non gouvernée**, arbitrage dont le prix est mesuré par T14. Enfin la conception ne tient pas au-delà de trois ou quatre locataires, le nombre de refus croisés croissant comme le carré de leur nombre : au-delà, la réponse est **un projet cloud par locataire**, qui règle du même coup la base et l'entrepôt partagés.

4.2.6 Isolation des données entre locataires (D16)

La ségrégation réseau appliquée en section 4.2.5 empêche une charge de travail d'atteindre l'interface d'une autre; elle ne peut rien sur le fait que les deux atteignent *le même serveur* de base de données. La frontière de donnée reste donc portée par les droits du moteur, appliqués à l'exécution : cette sous-section établit contre qui elle tient, puis expose la conception qui la remplacerait — décision D16, arrêtée le 29/08/2026 et **non appliquée**. Ce statut est un choix : **deux migrations d'infrastructure dans la même quinzaine, conduites par un opérateur unique, ne seraient pas soutenables** — la contrainte humaine du chapitre 1 appliquée à l'ordonnancement du projet lui-même.

Ce que la frontière actuelle garantit, et contre qui elle cède. Dix ordres, dont six révocations, retirent aux comptes applicatifs l'appartenance au rôle privilégié de l'instance et referment les connexions croisées. Le tableau 19 confronte cette frontière à chaque adversaire plutôt qu'à une échelle de maturité : c'est la seule façon de dire ce qu'elle vaut.

TAB. 19. Ce que la frontière d'isolation des données arrête, et ce qu'elle n'arrête pas. Les trois défaillances sont des *circonstances d'exploitation*, non des attaques — c'est précisément pourquoi une frontière portée par un geste ne suffit pas.

Adversaire	La frontière tient-elle ?	Ce qui la tient réellement
Charge applicative compromise, dans l'un ou l'autre sens	Oui — établi le 19/08/2026 par six vérifications sur six, par tentative de connexion réelle et non par lecture de configuration	Le retrait de l'appartenance privilégiée et la révocation de connexion. Rien d'autre
Fuite du mot de passe applicatif	Oui	La même révocation : le mot de passe n'ouvre que sa propre base
Identité de la chaîne de livraison compromise	Partiellement : elle déploie sous l'identité d'un locataire et lit ses secrets, jamais ceux de l'autre	La liaison secret par secret du coffre — la frontière la plus solide du socle est dans le plan d'identité, non dans le moteur de base
Opérateur détenteur d'un rôle d'administration de l'instance	Non, et aucune conception de droits ne peut y répondre : l'export lit n'importe quelle base sans traverser le moteur d'autorisation	Rien. <i>Un octroi n'est pas une défense contre le plan de contrôle qui l'héberge</i>
Réconciliation de l'infrastructure après un clonage	Non, et sans borne temporelle : le clone porte un nom neuf, la déclaration des comptes y est ancrée, l'application suivante les recrée privilégiés	Rien
Accueil d'un nouveau locataire	Non, et sans aucune détection : le contrôle quotidien ne connaît que deux comptes écrits en dur	Rien

TAB. 19. Ce que la frontière d'isolation des données arrête (suite)

Adversaire	La frontière tient-elle ?	Ce qui la tient réellement
Restauration d'un locataire	Sans objet — et c'est le problème : l'unité de reprise est l'instance, restaurer l'un fait reculer l'autre	Rien. Défaut de rayon d'action, non de droits

Deux enseignements commandent la conception. La frontière **cède dans trois circonstances d'exploitation nommées** — l'accueil d'un locataire, la réconciliation d'une infrastructure décrite avec une infrastructure restaurée, et sa propre disparition silencieuse : ce ne sont pas des attaques. Et elle est **asymétrique** : franchie depuis le locataire hébergé, elle livre des empreintes de mots de passe et un secret de second facteur chiffré ; franchie depuis la plateforme, elle livre **un identifiant national en clair**. La direction qui coûte part donc de l'hébergeur, et l'actif qu'elle protège ne l'est par rien d'autre que la révocation.

La conception retenue : une isolation proportionnée à la sensibilité. Quatre niveaux ont été évalués — durcissement logique remis sous code, séparation par schéma, instance dédiée par locataire, projet cloud dédié par locataire. D16 retient le troisième *pour le seul locataire qui porte une donnée irréparable* et le premier partout ailleurs, pour deux raisons. **La frontière doit d'abord changer de nature, pas de qualité** : remettre les dix ordres sous contrôle du code les rend versionnés, rejoués et surveillés, mais ils restent un geste — à la question « que se passe-t-il si quelqu'un accorde le rôle privilégié ? », la réponse demeure *on le voit sous vingt-quatre heures*, quand avec une instance dédiée la question n'a plus de sens. **La sensibilité commande ensuite la proportion, non l'égalité de traitement** : le chapitre 1 fonde le niveau d'exigence du socle sur la biométrie vocale et l'identifiant national, et traiter les deux locataires à l'identique reviendrait à surpayer pour la plateforme ou à sous-protéger l'application hébergée.

Le **test d'admission d'un locataire** énonce cette proportion en critère opposable, en trois questions : **(i)** la donnée traitée est-elle **irréversible** en cas de fuite — identifiant officiel, biométrie, donnée de santé, moyen de paiement ? **(ii)** l'éditeur est-il un **tiers** de l'exploitant du socle ? **(iii)** un engagement **contractuel** d'hébergement est-il pris ? **Une seule réponse affirmative impose une instance dédiée** ; aucune, une base dédiée sur l'instance mutualisée, derrière la tâche de durcissement idempotente. L'application hébergée répond oui à la première ; un troisième locataire répondrait très probablement oui à la deuxième.

Le coût, et l'avertissement qui va avec. Une instance dédiée zonale, sauvegardes et restauration à un instant donné identiques, coûte de l'ordre de dix à douze euros par mois, quand la refonte réseau en a libéré onze à treize — deux ordres de grandeur de tarification publique, le second attendant son rapprochement avec la facture. **L'économie du réseau finance exactement l'isolation des données, et une seule fois** : le solde commun des deux décisions est proche de zéro, et c'est cette neutralité qui rend D16 tenable sous la contrainte économique du chapitre 1. Le prix payé doit être dit : le locataire hébergé perdrait la bascule régionale automatique, acquise le 08/08/2026 et **jamais éprouvée par un test** — la seule reprise mesurée du projet est un clonage, qui fonctionne identiquement sur une instance zonale — et **la mesure de 32 min 45 s**

ne se transporte pas, ayant été relevée sur une instance donnée. En contrepartie, la nouvelle instance naîtrait avec le chiffrement par clé gérée, à coût nul : possibilité que l'instance existante a perdue définitivement, le champ n'étant modifiable qu'à la création.

Le piège de la reprise, et pourquoi le contrôle ne doit pas réparer. Puisque la frontière ne survit pas à la réconciliation qui suit un clonage, elle doit être déplacée dans la définition même de *reprise terminée* : le mode opératoire de restauration ne s'achève pas au retour du service, mais au rejeu de la tâche de durcissement puis du contrôle d'isolation — motif déjà éprouvé par la tâche de migration du locataire. S'y ajoutent une alerte de fraîcheur, l'absence du contrôle étant aujourd'hui silencieuse, et l'énumération des comptes plutôt que leur inscription en dur. Une réparation automatique est en revanche **écartée par un argument dirimant** : réparer exige précisément les privilèges que la frontière retire, et un réparateur permanent supposerait de **créer une identité inter-bases à demeure pour défendre une frontière inter-bases**. La remise sous code passe pour la même raison par une tâche idempotente et non par un fournisseur de description supplémentaire, l'instance n'ayant aucune adresse publique et la chaîne de provisionnement ne contenant ni planification ni application. Son gain réel n'est d'ailleurs pas l'écriture des ordres, c'est que **la source de vérité qui crée la base devienne celle qui en referme la porte**.

Ce que la conception ne couvre pas. Elle ne prétend rien contre le plan de contrôle du fournisseur : un opérateur détenteur d'un rôle d'administration exporte n'importe quelle base sans traverser le moteur d'autorisation, et seule une séparation de projets y répondrait — réponse terminale déjà nommée en section 4.2.5. Elle ne referme pas le chiffrement applicatif de l'identifiant national, chantier propre à l'éditeur. Enfin elle suppose établie une propriété qui ne l'est pas : la version de moteur en service autorise un compte portant le droit de création de rôles à s'accorder lui-même n'importe quelle appartenance, comportement durci seulement à la version suivante. **Tant que l'énumération des attributs de rôle n'a pas été relevée, la garantie établie le 19/08/2026 porte une réserve** — et c'est la première vérification du protocole, celle qui conditionne les autres.

Critères de validation de l'état final. Une vue d'architecture ne vaut que si un tiers peut dire à quoi elle sert et comment il en prononce la recette. Le tableau 20 le fait pour les **six vues qui portent une décision opposable** : les quatre de cette section, le plan d'identité (section 4.6) et les frontières de confiance du chapitre 3. Les autres figures du mémoire n'y sont pas inscrites, et le motif est toujours le même : on ne prononce pas la recette d'un état qu'on a supprimé (figure 11) ; une vue de latence ou de schéma se valide par une mesure ou par une propriété du schéma, non par une revue d'architecture (figure 13, figure 14) ; les vues de comportement illustrent un protocole sans le remplacer (figure 15, figure 18) ; et la chaîne de délégation (figure 17) **n'est pas recettable par construction**, puisqu'elle décrit ce qui serait atteignable et non ce qui est vérifié — sa réserve est son objet entier.

TAB. 20. Critères de recette des vues d'architecture : le point de vue servi, les critères datés avec leur protocole, et la réserve de chaque vue.

Vue	Point de vue — décision servie	Critères de recette, datés, et protocole	Réserve — ce que la vue ne démontre pas
Contexte	Architecte — arbitre les dépendances non maîtrisées	Les trois imports différés ne sont sur aucun chemin de requête (conception, 25/08/2026); la zone de noms reste hors code — écart É10	Ni volumétrie, ni disponibilité des tiers
Couches	Architecte — vérifie qu'aucune couche n'est traversée sans identité	L2 vérifiée à chaque saut : T5 conforme 23/08/2026; T6 partiel au 25/08/2026	Ne montre pas les chemins réseau; voir la vue de déploiement
Déploiement	Exploitant — décide si le chemin privé est le seul chemin de données	Sorties refusées : T20 conforme 24/08/2026; données inaccessibles depuis Internet : T4 partiel	Ni volumes, ni latences, ni perte du connecteur (T15 , validation continue)
Topologie cible	Architecte réseau — prononce la recette de la refonte	Émission depuis un sous-réseau, pare-feu applicable : T20 conforme 24/08/2026; isolation : T5 conforme 23/08/2026	Ne couvre pas le trafic entrant; T1 reste non conforme
Plan d'identité	Responsable sécurité — décide si une identité peut altérer une preuve	Inventaire de clés vide : T7 conforme 19/08/2026; intégrité de la preuve : T11 conforme, test automatisé	Décrit les droits déclarés, non leur composition (voir la vue de délégation)
Frontières de confiance	Analyste de la menace — décide où poser un contrôle	TB1–TB4 franchises par le réseau, TB5 par l'identité seule : T5 et T11 conformes; T14 non conforme au 25/08/2026	Ne hiérarchise pas les scénarios; la gravité est portée par l'annexe C

4.3 Vue dynamique : les sept flux et le cycle de la donnée

La vue en couches décrit ce qui existe; la vue en flux décrit ce qui se passe. Les sept flux F1 à F7 forment le vocabulaire commun du projet, employé pour l'analyse de menace du chapitre 3, la réalisation et les tests (tableau 21).

TAB. 21. Les sept flux de l'architecture.

Flux	Chemin	Exigences
F1	Utilisateur → périmètre → filtrage → charge de travail	EX1–EX3
F2	Charge de travail → réseau privé → base de données	EX4–EX6
F3	Dépôt → chaîne de livraison → registre → déploiement	EX7–EX10
F4	Toutes les couches → collecte → entrepôt de supervision	EX11–EX13
F5	Planificateur → enrichissement → modèle → recherche vectorielle	EX11, EX14, EX15
F6	Vulnérabilités de livraison → encodage → rapprochement → priorisation	apport, aucune exigence
F7	Dépôt → plan → contrôle → approbation → application	EX16–EX18

Le flux F6 est l'hypothèse d'apport de l'architecture. Il relie deux ensembles habituellement disjoints : la chaîne de livraison, qui classe les vulnérabilités par gravité théorique, et la chaîne de détection, qui observe les techniques réellement dirigées contre le système. Le rapprochement réordonne les correctifs — une vulnérabilité moyenne liée à une technique observée cette semaine passe devant une vulnérabilité élevée sans rapport avec l'activité constatée. F6 ne couvre aucune exigence et ne réduit aucun risque par lui-même : c'est une *hypothèse*, publiée avec le protocole qui permettrait de la réfuter — la comparaison

des ordres de correction obtenus avec et sans rapprochement. Ce protocole ne figure pas parmi les six du plan de validation continue; il est écrit pour qu'un tiers l'exécute et contredise l'hypothèse.

4.3.1 Cycle de vie de la donnée de sécurité

Les flux disent qui parle à qui, non ce que devient la donnée. Six étapes séparent l'événement de son affichage, et ce sont les *cadences portées sur les transitions* qu'il faut lire dans la figure 13 : cinq minutes pour la normalisation, cinq pour la détection, quinze pour l'enrichissement sont des attentes d'ordonnanceur et non des temps de traitement, qui s'additionnent avec la position de l'événement dans la fenêtre et bornent le délai bien plus sûrement que la puissance de calcul. Deux propriétés s'y lisent aussi : le score est recalculé à chaque consultation et jamais persisté; et la branche d'enrichissement est *informationnelle*, la figure 14 en donnant la raison, de modèle de données et non d'algorithme.

4.3.2 Modèle de données des deux systèmes de stockage

Le socle stocke dans deux systèmes de nature opposée : une base relationnelle pour l'exploitation du tableau de bord, un entrepôt analytique pour les preuves de sécurité. Dans le modèle entité-association de la figure 14, deux absences comptent plus que les présences. La table d'enrichissement porte l'identifiant de la détection dont elle est issue, mais pas l'entité que cette détection désigne, or le score d'incident regroupe les détections *par entité* : la jointure du rattachement sémantique au score est structurellement impossible, conséquence du schéma et non choix d'algorithme. Et aucun lien n'existe entre les deux systèmes, la chaîne de preuve étant cloisonnée de la base des comptes — propriété voulue dont le prix est qu'un verdict ne se résout pas en un nom sans franchir volontairement ce cloisonnement. Le détail des dix tables, avec leur écrivain unique, figure au chapitre 5 (tableau 27).

4.4 De l'attaque à l'incident : fonctionnement de bout en bout

Entre la requête malveillante qui atteint le périmètre et l'incident qualifié que voit l'analyste, deux registres se partagent le récit sans se recouvrir : la figure 15 dit *qui agit* et *par quelle règle*, la figure 13 dit *quand*, sa colonne d'horodatage relatif situant chaque étape par rapport au refus opposé au périmètre.

La séquence porte une propriété du périmètre qu'aucune autre vue ne rend : l'évaluation de la politique de filtrage est **premier-match-gagne** — les règles sont ordonnées par priorité, la première qui correspond décide, les suivantes ne sont pas évaluées. L'ordre est donc une propriété de sécurité et non un détail de configuration : une règle de régulation de débit placée avant les règles applicatives les rend inertes, puisqu'elle laisse passer de manière terminale le trafic conforme au seuil — c'est l'incident corrigé pendant la réalisation (section 5.8.1), et la raison pour laquelle la restriction géographique est écrite comme un refus dont les exemptions d'administration sont repliées à l'intérieur.

Deux définitions commandent leur lecture : une **requête planifiée** est une requête enregistrée dans l'entrepôt et exécutée à intervalle fixe sans intervention humaine, et la **fenêtre glissante** est l'intervalle immédiatement passé sur lequel porte chaque exécution. S'y ajoute le **démarrage**

Notation patte-d'oie —+ un —< plusieurs ——— rattachement sans clé ———X jointure impossible
 [grisé] table grisée : déclarée, jamais utilisée — le grisé est toujours doublé par l'étiquette écrite dans la table

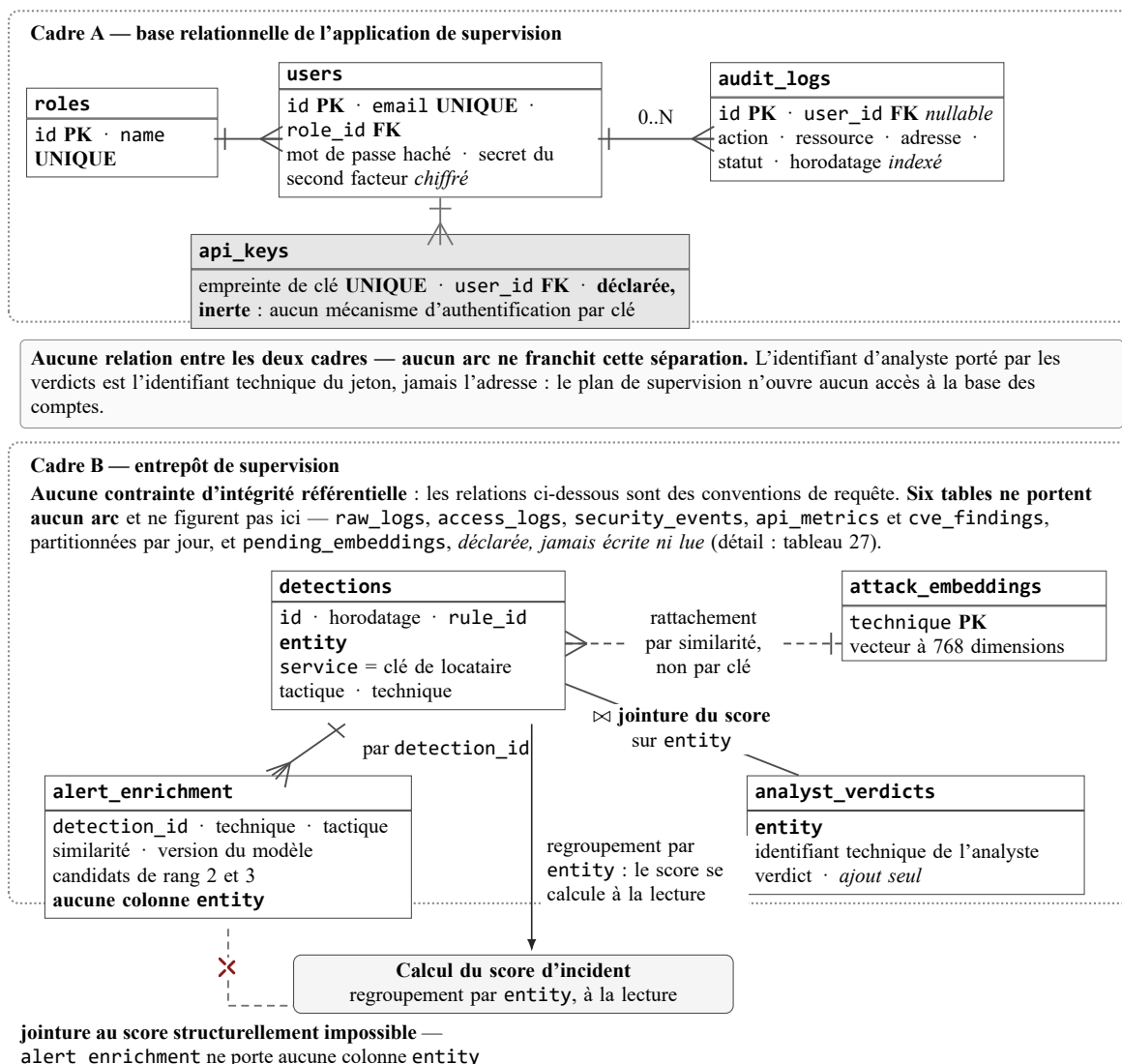


FIG. 14. Modèle de données des deux systèmes de stockage : ce que les clés permettent, et la jointure que leur absence interdit. L'impossibilité de corréler le rattachement sémantique au score d'incident est une propriété *du schéma* et non un choix d'algorithme — une colonne manquante suffit à l'expliquer — et les deux systèmes de stockage sont volontairement disjoints.

mesure pas la criticité d'une couche : L5 est la moins chargée et porte pourtant toute la chaîne de preuve, des journaux au score.

TAB. 22. Conception détaillée des sept niveaux : composants, produits, contrôles et exigences

Niveau	Composants et produits employés	Contrôles apportés	Exigences
L1 Périmètre d'entrée	Répartiteur global HTTPS, trois certificats gérés, moteur de filtrage applicatif, limitation de débit, restriction géographique. <i>Cloud Load Balancing</i> , <i>Cloud Armor</i> — politique unique attachée à tous les services publiés. La zone de noms est une dépendance externe (É10)	HTTPS exclusivement (port 80 redirigé, TLS 1.2 au minimum). Cinq familles de règles préconfigurées en blocage direct , non en observation. Restriction géographique écrite comme un <i>refus</i> dont les exemptions — sondes, administration — sont repliées à l'intérieur, une autorisation prioritaire étant terminale. Limitation de débit à deux niveaux : seuil strict avec bannissement sur les chemins d'authentification, seuil global élevé contre la saturation	EX1, EX2, EX3

TAB. 22. Conception détaillée des sept niveaux (suite)

Niveau	Composants et produits employés	Contrôles apportés	Exigences
L2 Identité et sécurité (<i>plan transversal</i>)	<i>Cloud IAM</i> (sept identités de service), <i>Secret Manager</i> (neuf secrets, dont huit chiffrés par une clé gérée par le projet), <i>Cloud KMS</i> (deux trousseaux, deux clés, rotation de quatre-vingt-dix jours), <i>Workload Identity Federation</i>	Plan interrogé à chaque appel, quel que soit le niveau (PR2). Un secret par usage, jamais dérivé d'un autre ; le code d'infrastructure crée les conteneurs de secrets, jamais leurs valeurs. Les deux trousseaux sont une contrainte de plateforme, non une redondance : la réplication du coffre n'accepte qu'une clé globale, le chiffrement de l'entrepôt exige une clé régionale. Le neuvième secret, mot de passe du tableau de bord antérieur (D14), n'est lu par aucun code	EX5, EX6, EX7, EX10, EX11
L3 Charges de travail	Cinq services et trois tâches : API de supervision, tableau de bord, service d'encodage, interface web et interface de programmation de l'application hébergée ; enrichissement, migration du schéma, vérification quotidienne de l'isolation des bases. <i>Cloud Run</i> , <i>Cloud Scheduler</i> pour deux déclencheurs, la chaîne de livraison pour le troisième	Entrée restreinte au répartiteur pour les quatre services publiés, adresses directes du fournisseur neutralisées ; entrée strictement interne pour le service d'encodage, invocable par la seule identité de la tâche d'enrichissement. Une identité de service par charge de travail. Sortie gouvernée par le pare-feu et non plus par un paramètre de plateforme depuis la refonte du 23/08/2026. Déploiement par une étiquette égale à l'empreinte du commit, qui ne vaut pas empreinte d'image immuable (É8)	EX6, EX9
L4 Réseau	Un réseau virtuel en mode personnalisé, un sous-réseau par locataire dont un réservé au troisième, un appairage de services privés vers la base, et douze règles de filtrage dont cinq autorisations . <i>VPC</i> , <i>sortie réseau directe</i> et <i>Private Service Access</i>	Refus par défaut en entrée et en sortie , l'un et l'autre journalisés ; cinq autorisations ciblées par identité de service et par port ; refus croisés entre locataires journalisés, qui alimentent la chaîne de détection sans la modifier ; base joignable par une adresse privée exclusive. Principe de la couche : le réseau n'autorise jamais par la position, il filtre par l'identité — être à l'intérieur du réseau privé ne confère aucun droit	EX4, EX20
L5 Données	Base applicative (comptes, rôles, journal d'audit) et entrepôt de supervision , cœur du dispositif de détection (figure 13, figure 14). <i>Cloud SQL for PostgreSQL 15</i> (adresse privée seule, haute disponibilité régionale, restauration à un instant donné sur sept jours), <i>BigQuery</i> (dix tables), <i>Cloud Storage</i> (clé gérée, prévention d'accès public)	Intégrité des preuves : l'écriture sur les journaux bruts et les détections est réservée à la collecte et aux règles, aucune identité applicative ou d'analyse n'y accédant (EX11). Coût : partition par jour, expiration à quatre-vingt-dix jours sur les seules tables de journaux, filtre restrictif à la source sur trois exports sur quatre. Seuil de rattachement déclaré en tête de requête, donc auditable et modifiable sans redéploiement (BNF6)	EX2, EX4, EX11
L6 Enrichissement sémantique	Un service d'encodage sans état, une tâche d'enrichissement par lots, un référentiel de techniques d'attaque vectorisé. <i>Cloud Run</i> en entrée interne seule, modèle de représentation de phrases spécialisé en cybersécurité embarqué dans l'image et exécuté hors ligne, recherche vectorielle native de l'entrepôt — ce qui supprime la base vectorielle séparée qu'imposerait un autre fournisseur (D05, D06)	Poids du modèle traités comme un artefact tiers non fiable : révision figée, format refusant l'exécution de code à la désérialisation, empreintes consignées, mêmes contrôles de vulnérabilité que le code. Embarqués dans l'image plutôt que téléchargés à l'exécution, ce qui retire du chemin critique une dépendance externe et un point d'injection. Appel authentifié par jeton d'identité. Un export quantifié a été rejeté par une porte d'acceptation <i>codée</i> — plancher de similarité et accord de premier rang — dont l'échec interrompt la construction de l'image	EX14, EX15
L7 Observabilité (<i>plan transversal</i>)	Quatre exports de journaux, politiques d'alerte, objectifs de service, sondes de disponibilité, lien entre une alerte affichée et sa procédure d'incident. <i>Cloud Logging</i> , <i>Cloud Monitoring</i>	Sources collectées : journaux d'audit du fournisseur, journaux des charges de travail, verdicts du filtrage applicatif, journaux réseau (EX13) ; trois exports sur quatre portent un filtre restrictif à la source (EX12, BNF3). Sondes sur les points de santé (BNF1). Une procédure d'incident par famille de technique, accessible depuis le tableau de bord : une alerte sans conduite à tenir transfère toute la charge d'interprétation à l'analyste (BNF4). Indicateurs publiés : délai de détection, part des détections issues du rattachement, taux d'alertes non rattachées, latence, version du modèle (BNF6)	EX12, EX13, EX19

Points de vigilance. Chaque niveau nomme ce qu'il ne garantit pas lui-même, et quatre des sept — L1, L3, L4 et L6 — y désignent une **confiance résiduelle** : un contrôle qu'ils n'exercent

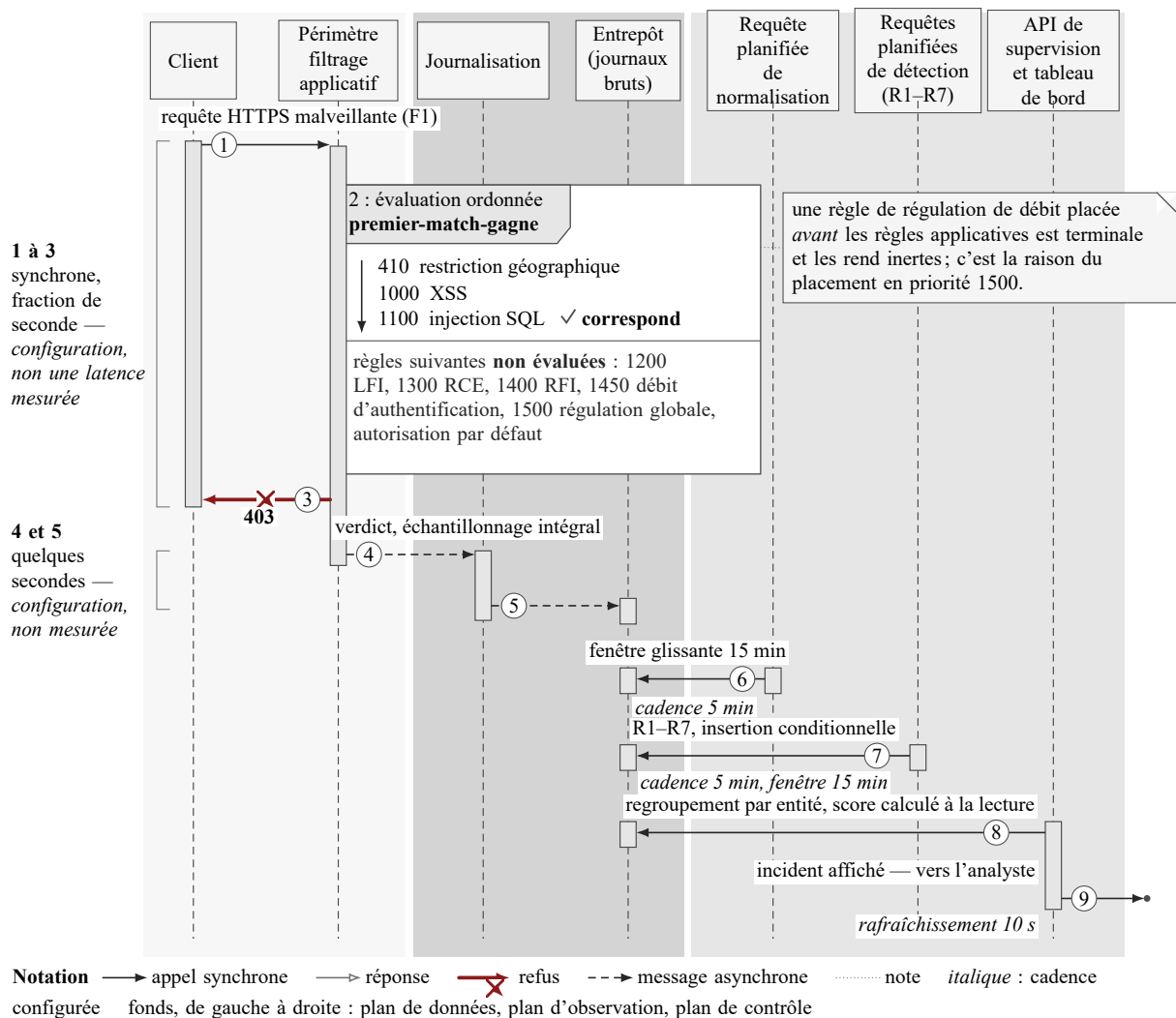


FIG. 15. Requête malveillante refusée au périmètre : ordre d'évaluation des règles et trajet de la preuve jusqu'à l'analyste. L'ordre est une propriété de sécurité — la première correspondance est terminale et les six règles suivantes ne sont jamais évaluées — et la preuve du refus met beaucoup plus de temps à atteindre l'analyste que le refus lui-même à être prononcé.

pas et qu'un contrôle voisin doit reprendre. Les deux contrôles dynamiques qui les établissent en propre, T14 et T20, portent leur relevé daté et figurent au **plan de validation continue** (section 6.2.3).

L1 charge les règles préconfigurées à leur niveau de sensibilité le plus bas : arbitrage assumé entre un taux de faux positifs intenable pour un exploitant unique et la résistance aux techniques d'évasion, mesurée au chapitre 6.

L2 ne peut interdire structurellement la création d'une clé d'identité de longue durée — cela relève d'une politique d'organisation, dont la pose exige un périmètre administratif dont le projet ne dispose pas (É7) : le contrôle est porté par la fédération, qui rend la clé inutile, et vérifié par inventaire. Seconde réserve, de conception : la clé qui chiffre les secrets du second facteur ne porte pas d'identifiant de version, de sorte qu'une rotation les rendrait illisibles d'un seul coup ; son versionnement est la première évolution prévue de ce plan.

L3 accorde le droit d'invocation à tous sur les services publiés : leur protection tient entièrement au paramètre d'entrée restreinte au répartiteur, contrôle unique dont une

régression les exposerait publiquement. Le choix est assumé dans le code, faute d'un service d'authentification en amont disponible hors organisation cloud ; le contrôle compensatoire est la vérification de ce champ à chaque plan d'infrastructure, le seuil de bascule l'acquisition d'une organisation. La limite de requêtes simultanées par instance n'est déclarée nulle part : seule valeur du modèle d'exécution qui échappe à PR4.

L4 ne porte plus la réserve qu'enregistrait D11 : depuis la refonte appliquée du 11 au 25/08/2026 (section 4.2.5), la sortie est gouvernée par le pare-feu et non par un paramètre de plateforme, la règle interne de priorité 900 a été supprimée le 24/08/2026 avec les deux sous-réseaux vides qu'elle reliait (É2), et le canal de détection des refus réseau n'est plus muet — la journalisation des refus, acquise le 19/08/2026 (É1), a porté le 24/08/2026 trois refus de sortie réellement opposés et retrouvés dans l'entrepôt (T20). **La confiance résiduelle de la couche a changé de nature, et elle est mesurée** : le service d'encodage et l'interface web de l'application hébergée ont été détachés du sous-réseau au motif, exact, qu'ils n'ont aucune dépendance privée, de sorte que leur **sortie managée échappe au pare-feu**. Le 25/08/2026, une sonde portant la configuration réseau de la révision déployée du service d'encodage a atteint une destination externe en 412 ms : c'est la non-conformité T14, qui reste ouverte, le motif du détachement valant pour la sortie *nécessaire* et non pour la sortie *possible*.

L5 n'applique pas rétroactivement le chiffrement par clé gérée : deux tables seulement portent une configuration explicite, les tables de preuves antérieures restant chiffrées par la clé du fournisseur, et généraliser supposerait de les recréer donc d'interrompre la chaîne de preuve — arbitrage tranché en faveur de la continuité. Point de méthode : abaisser le seuil de rattachement jusqu'à ce que toute alerte en reçoive un aurait produit un tableau de bord entièrement rempli et entièrement faux ; le choix inverse a été fait, afficher le taux d'alertes non rattachées comme indicateur de qualité.

L6 porte au premier chef la sortie non gouvernée du service d'encodage, énoncée en L4. Second point, dimensionnant : la recherche vectorielle s'exécute sans index déclaré, chaque appariement balayant l'intégralité du référentiel — acceptable à la volumétrie d'ATT&CK et à la cadence de quinze minutes, c'est la première limite qu'une montée en charge rencontrerait.

L7 laisse sans filtre le quatrième export, poste de coût dominant de l'entrepôt, parce que c'est lui qui rend la détection possible : les verdicts du filtrage applicatif n'existent que dans ce journal, et tout échantillonnage y créerait un angle mort statistique sur la source de preuve la plus dense. La condition de réévaluation est le franchissement du budget d'ingestion mensuel.

4.5.1 Couverture des exigences de sécurité

Les vingt exigences du chapitre 3 sont toutes prises en charge par au moins une couche ou un flux, le détail figurant en annexe D ; cette prise en charge n'est pas une preuve de conformité, implémentation et niveau de test étant évalués au chapitre 6. Trois réserves, portant sur quatre exigences, sont nommées : **EX7**, politique d'organisation inapplicable faute d'organisation cloud (É7), compensée par les autorisations et l'infrastructure en code ; **EX9**, déploiement par étiquette égale au SHA du commit et non par empreinte d'image stricte (É8) ; **EX16 et EX18**, portée bornée aux ressources déjà décrites en code et revue d'approbation manuelle. La

correspondance avec les sept principes Zero Trust du chapitre 2 a été vérifiée point par point : l'identité comme plan de contrôle et la mesure continue de l'état y sont les mieux représentés.

4.6 Le plan d'identité : la segmentation réelle

Cette section traduit le principe d'identité (PR2) : ce qui, dans cette architecture, remplace les pare-feux internes.

4.6.1 Matrice des identités et des droits

Le tableau 23 recense les identités du socle et leurs droits ; la figure 16 en projette les cinq porteuses d'un droit direct sur une ressource, et rend visible ce qu'un tableau montre mal : les interdictions.

TAB. 23. Matrice des identités et des droits.

Identité	Droits accordés	Interdiction structurante
Identité applicative (une par application)	Accès à la base de données ; accès aux secrets de cette application uniquement	Aucun accès à l'entrepôt de supervision
Identité de l'API de supervision	Lecture seule sur l'entrepôt ; accès à la base ; secrets de la plateforme	Aucune écriture sur les preuves — exception unique : la table des verdicts d'analyste
Identité du tableau de bord	Appel de l'API de supervision ; lecture du jeu de données de supervision	Aucun accès à la base de données applicative ; séparation vis-à-vis de l'entrepôt appliquée par le code et non par les autorisations (écart É9)
Identité de la tâche d'enrichissement	Lecture des détections ; écriture uniquement sur la table d'enrichissement ; appel du service d'encodage	Écriture interdite sur les journaux bruts et les détections
Identité de déploiement	Écriture dans le registre ; déploiement ; usurpation contrôlée des identités d'exécution	Aucune clé exportée ; portée limitée au projet de son environnement

La plus significative est celle de la tâche d'enrichissement : l'interdiction d'écriture sur les détections empêche un attaquant qui l'aurait compromise d'effacer la trace de son passage (scénario SO16, test T11 du chapitre 6).

4.6.2 Chaînes de délégation d'identité

Une matrice de droits dit ce que chaque identité peut faire, non ce qu'un attaquant obtient en *enchaînant* les délégations : c'est l'objet de la figure 17, dont il faut regarder le *dernier* segment. **L'identité de déploiement porte un droit de déploiement à l'échelle du projet, et non ressource par ressource** : combinée à l'usurpation de l'identité de l'API de supervision — qui accède à la clé de signature des jetons de session — elle ouvre un chemin allant de la branche principale du dépôt à un jeton portant le rôle d'administration. Le code a fermé la porte adjacente, en refusant à cette identité d'API tout accès aux secrets à l'échelle du projet et en le limitant à trois secrets nommés ; la chaîne subsiste par le droit de déploiement. La réduction retenue — restreindre ce droit aux seuls services réellement déployés par la chaîne, ressource par ressource — est portée au plan de remédiation et conditionne l'accueil d'un troisième locataire. Ce chemin est nommé ici parce qu'un modèle de menace qui ne considère que les droits directs manque systématiquement les chemins composés.

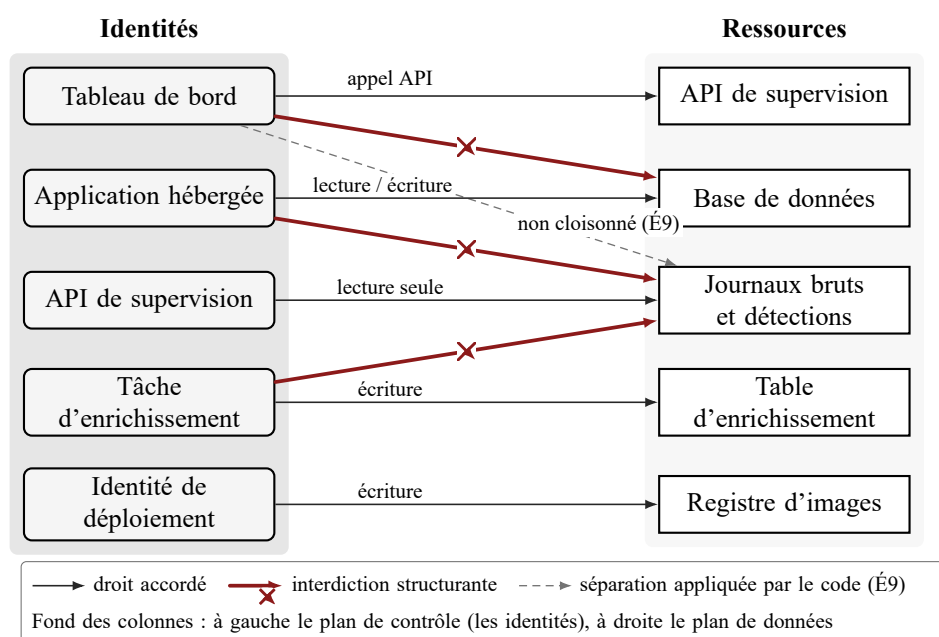


FIG. 16. Plan d'identité : droits accordés et interdictions structurantes (cinq identités). Ni l'application hébergée ni la tâche d'enrichissement ne peuvent écrire sur les preuves (scénario SO16, test T11); le tableau de bord passe par l'API de supervision, mais son identité conserve un droit de lecture sur l'entrepôt — c'est l'écart É9.

Trois chaînes secondaires de délégation suivent le même motif — un agent managé du fournisseur obtient le droit de créateur de jeton sur une identité d'exécution : l'agent de transfert des requêtes planifiées et celui de l'ordonnanceur vers l'identité des règles de détection, et l'opérateur humain vers l'identité de la tâche d'enrichissement lors du rejeu des tests de bout en bout. Cette dernière liaison est nominative et **posée hors du code** : c'est la seule des trois qu'aucun plan d'infrastructure ne rejouerait.

4.6.3 Fédération de la chaîne de livraison, secrets et chiffrement

Le point bloquant B2 concernait un secret unique gouvernant sept mécanismes ; le scénario SO9, une clé d'identité de longue durée détenue par la chaîne de livraison. La réponse aux deux est de même nature : **supprimer la classe de risque plutôt que la gérer**. La chaîne de livraison s'authentifie par fédération d'identité — une assertion signée par la forge, vérifiée par le fournisseur cloud, contre un jeton de courte durée — sous une condition d'attribut restreignant la fédération à un dépôt et une branche précis (section 5.2.3). La politique interdisant la création de clés de compte de service étant inapplicable faute d'organisation cloud (É7), l'absence de clé est vérifiée par inventaire, non garantie par une contrainte structurelle. Deux règles de secrets complètent ce plan, sans exception : **un secret par usage, jamais de secret dérivé d'un autre** — B2 en démontrait le coût, la fuite d'une valeur unique compromettant l'authentification, l'anonymat et l'actif principal — et **l'infrastructure en code crée les conteneurs de secrets, jamais leurs valeurs**, injectées hors du code, pour que le fichier d'état ne devienne jamais un coffre.

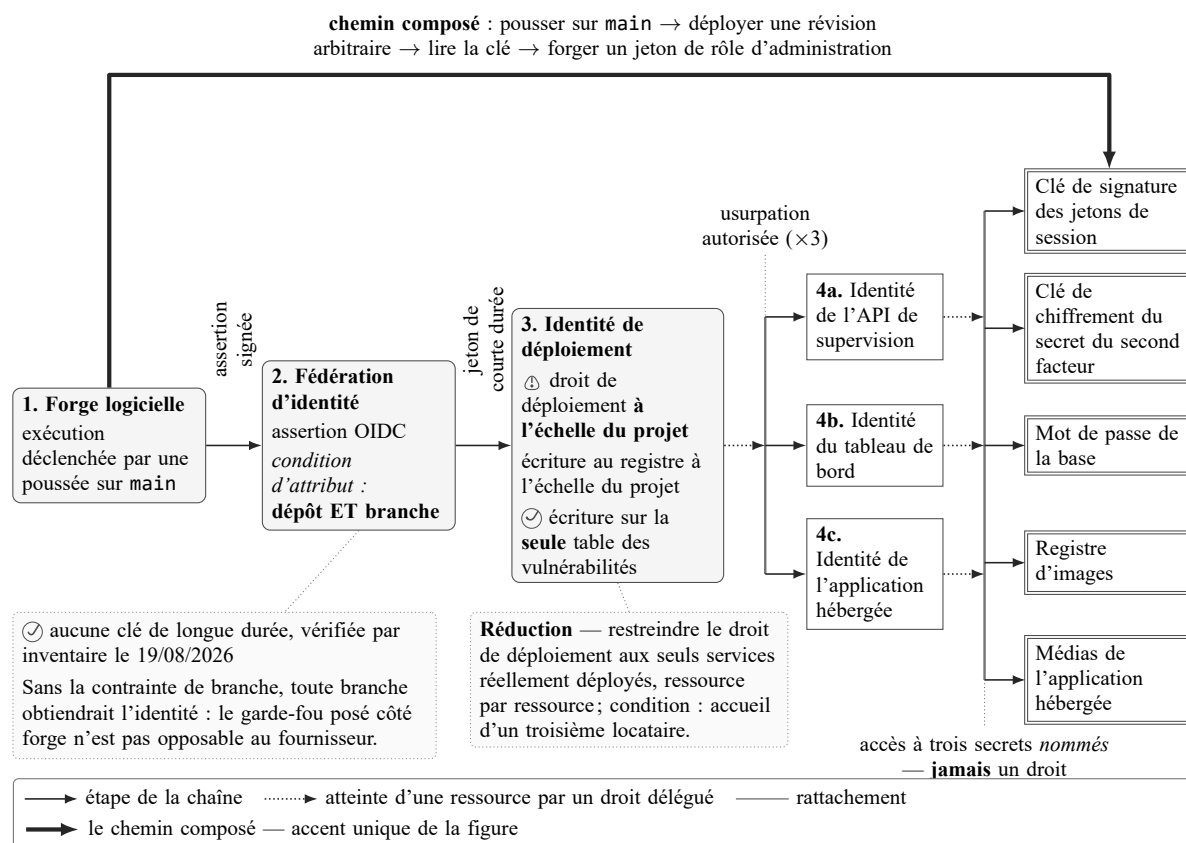


FIG. 17. Chaînes de délégation d'identité : ce qu'un droit de déploiement à l'échelle du projet rend atteignable. Aucun droit pris isolément n'est anormal — la fédération est durcie par une condition d'attribut portant sur le dépôt *et* sur la branche, sans clé de longue durée, et l'écriture à l'entrepôt est bornée à une seule table. Le risque naît de la **composition** : c'est la portée du droit de déploiement, en aval, qui porte le risque résiduel, non la fédération, en amont.

4.6.4 Authentification à deux facteurs et cycle de la session

L'accès humain au tableau de bord est le seul point du socle où une personne, et non une charge de travail, présente une identité. Ce qu'il faut regarder dans la figure 18 est le **jeton intermédiaire** : entre la vérification du mot de passe et celle du code à usage unique, la session est authentifiée sans être autorisée. Ce jeton ne porte *aucune revendication de rôle*, vit cinq minutes et est refusé par toutes les routes métier ; symétriquement, un jeton d'accès est refusé par la route de vérification du second facteur, et le rôle n'apparaît qu'au cinquième état, *relu en base* plutôt que recopié. C'est cette séparation des types de jeton, plus que le second facteur, qui constitue le contrôle.

Deux conséquences de conception en découlent. **La limitation de débit est à deux niveaux** : au périmètre, dix requêtes par 60 s et par adresse avec bannissement de 300 s ; en applicatif, un compteur indexé sur le *défi* en cours et non sur l'adresse source, parce que l'appel relayé présente l'adresse de sortie partagée du tableau de bord. Les deux couches ne mesurent donc pas la même chose, et le raisonnement qui conduit à ce choix, mesure à l'appui, est exposé au section 5.6.3. La session est par ailleurs un jeton signé sans état serveur, donc non révocable avant son échéance d'une heure : arbitrage assumé — l'état serveur qu'exigerait la révocation ajouterait un composant à exploiter, ce que PR1 écarte à ce périmètre — dont la condition de

réévaluation est l'ouverture du tableau de bord à des comptes autres que ceux de l'exploitant unique.

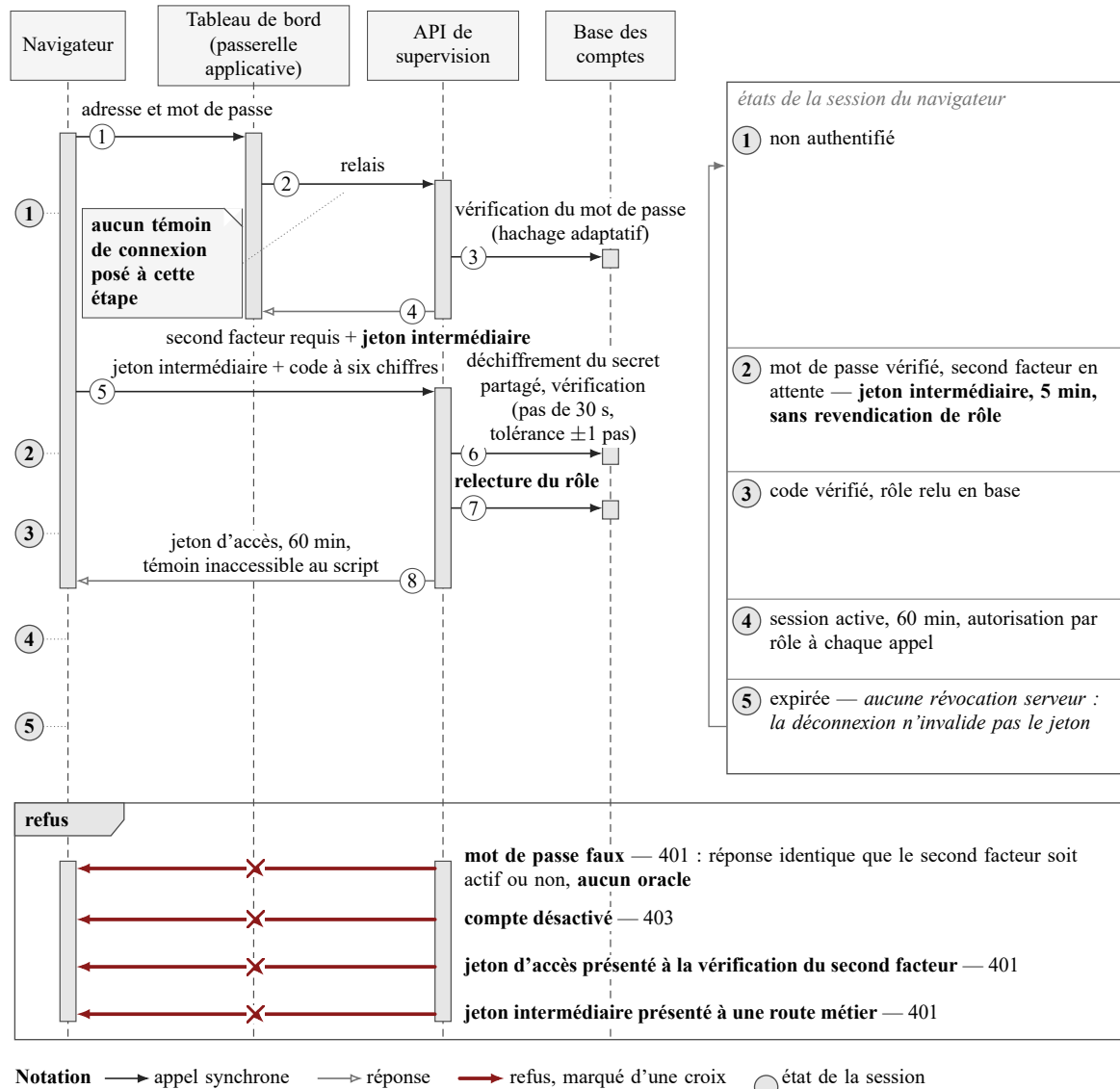


FIG. 18. Authentification à deux facteurs : cinq états de la session et le jeton intermédiaire qui ne porte aucun rôle. Entre le mot de passe et le code à usage unique, la session existe **authentifiée mais non autorisée** ; c'est la séparation des types de jeton — non le second facteur — qui interdit d'utiliser ce demi-passage.

4.7 Décisions d'architecture et écarts d'implémentation

4.7.1 Registre des décisions

Le registre prouve qu'une architecture est délibérée : chaque décision y figure avec son statut (tableau 24), sa justification complète étant reportée en annexe D. Il en compte dix-sept, de D00 à D16 ; la première, le choix d'un fournisseur unique, conditionne toutes les suivantes.

La décision D13 illustre la fonction du registre : elle contredit D03, contradiction enregistrée telle quelle plutôt que masquée par une réécriture rétroactive. Un second registre,

TAB. 24. Registre synthétique des décisions d'architecture (justification complète en annexe D).

#	Décision	Statut
D00	Google Cloud comme fournisseur unique du socle	Validée
D01	Exécution de conteneurs sans serveur comme unique plateforme	Validée
D02	Point d'entrée unique avec filtrage applicatif	Validée
D03	Base de données managée, adresse privée, restauration à un instant donné	Validée
D04	Entrepôt de données généraliste comme système de supervision	Validée
D05	Modèle de représentation non génératif pour l'enrichissement	Validée
D06	Recherche vectorielle déportée dans l'entrepôt	Validée
D07	Registre d'images unique, retrait du second registre	Retouchée
D08	Fédération d'identité pour la chaîne de livraison	Ajoutée
D09	Détection de secrets en tête de chaîne	Ajoutée
D10	Autorisation applicative par rôles conservée	Validée
D11	Sortie réseau : route par défaut, aucune règle de sortie déclarée	Réserve, levée par D15
D12	Infrastructure en code comme standard unique de provisionnement	Validée, renforcée
D13	Passage de la base de données en haute disponibilité régionale	Révision de D03 (08/08/2026)
D14	Réécriture du tableau de bord sur cadre à rendu serveur avec passerelle applicative	Validée
D15	Sortie réseau directe, refus par défaut en sortie et pare-feu ciblé par identité	Appliquée du 11 au 25/08/2026 (section 4.2.5)
D16	Isolation des données proportionnée à la sensibilité : instance dédiée au locataire porteur de donnée irréparable	Arrêtée le 29/08/2026, non appliquée (section 4.2.6)

tenu au fil de la réalisation, compte quinze entrées du 30/07/2026 au 19/08/2026 ; les deux sont complémentaires (détail en annexe D).

4.7.2 Composants évalués puis écartés

Sept éléments ont été évalués puis écartés en application de PR1. Un seul l'a été pour un motif de sécurité : le **modèle de langue génératif**, dont la sortie non déterministe et la surface d'injection sont rédhibitoires pour une chaîne de preuve — **ce refus ne sera pas révisé si le contexte change**. Les six autres — périmètre anti-exfiltration, orchestrateur et maillage de services, cache distribué, déploiement multi-région, signature des images au déploiement, passerelle d'authentification — relèvent d'un arbitrage de coût ou d'une redondance avec un contrôle déjà présent (section D.2).

4.7.3 Écarts entre la conception et l'implémentation

Tout projet d'infrastructure produit des écarts entre l'architecture décrite et le système déployé. La question n'est pas de savoir s'il y en a, mais s'ils sont connus, justifiés, datés lorsqu'ils sont clos et mesurés dans leurs conséquences ; ceux encore ouverts portent, à la place d'une date, leur état d'avancement, et ils figurent ici plutôt qu'en annexe (tableau 25). Deux d'entre eux, É10 et É11, portaient sur ce que les vues laissaient croire : les vues ont été corrigées, les écarts subsistent parce qu'ils décrivent une propriété du système et non un défaut de dessin.

L'écart É3 a été le plus significatif, entorse au principe d'identité dans la couche même qui l'illustre : l'identité dédiée a été déployée et vérifiée le 19/08/2026. La séparation est établie par la description en code et par la revue, non par une épreuve dynamique — le contrôle d'usurpation

TAB. 25. Écarts entre conception et implémentation.

#	Écart et cause	Date ou état	Exigence	Statut
É1	Journalisation des refus du pare-feu et de la passerelle de sortie initialement absente	19/08/2026	EX20	Corrigé, déployé et vérifié
É2	Les deux sous-réseaux prévus, public <i>et</i> privé, sont inutilisés : aucune ressource ne les occupait, aucune machine virtuelle n'existait dans le dépôt et les sorties du module réseau n'étaient consommées par aucun autre module ; les deux sous-réseaux ont été supprimés au titre de D15	24/08/2026	—	Corrigé, appliqué et vérifié
É3	Service d'encodage partage l'identité de la tâche de détection planifiée, faute d'identité dédiée	19/08/2026	EX5, EX14	Corrigé le 19/08/2026, vérifié
É4	Mécanisme de connexion au réseau privé différent de celui prévu (confort d'un composant managé) : le connecteur d'accès sans serveur a été supprimé et remplacé par la sortie réseau directe au titre de D15	15/08/2026	—	Corrigé, appliqué et vérifié
É5	Cadence de la tâche d'enrichissement plus lente que prévu (arbitrage coût/latence)	mise en œuvre	—	Assumé
É6	Cache d'encodage instrumenté mais non utilisé (non terminé)	mise en œuvre	—	À terminer
É7	Politiques d'organisation décrites en code mais inapplicables sans organisation GCP	19/08/2026	EX7	Ouvert, contrôle compensatoire par IAM et IaC
É8	Déploiement applicatif référencé par une étiquette égale au SHA du commit, et non par une empreinte d'image stricte	19/08/2026	EX9	Assumé, provenance à renforcer
É9	Cloisonnement du tableau de bord non appliqué par les autorisations : l'interface passe par l'API de supervision dans son code, mais son identité de service conserve un droit de lecture sur le jeu de données de supervision et le droit d'exécuter des requêtes ; la séparation est applicative et non structurelle	27/08/2026	EX5	Ouvert
É10	Zone de noms de domaine hors du périmètre décrit en code : aucune ressource de zone n'est déclarée, les enregistrements sont créés à la main chez le bureau d'enregistrement, par exception au principe de description en code (PR4) ; les vues la portent en dépendance externe, jamais en composant de la couche de périmètre	27/08/2026	—	Ouvert
É11	L'accès à l'entrepôt de supervision ne traverse pas le réseau privé : depuis la refonte, les appels sortent bien par l'interface de la charge, mais la règle qui les admet (E4) désigne la plage des interfaces du fournisseur et non l'entrepôt du socle — l'autorisation reste portée par l'identité seule ; la vue de déploiement distingue ce chemin par le style du lien	27/08/2026	EX5	Assumé, documenté

qui l'établirait en propre ne figure pas parmi les six protocoles du plan de validation continue, et la réserve est portée comme telle. La refonte réseau en a clos deux autres, É2 et É4 ; les trois derniers, relevés le 27/08/2026, laissent É9 et É10 ouverts et É11 assumé.

Conclusion du chapitre

Quatre principes ont guidé l'architecture qui prend en charge les vingt exigences du chapitre 3 : justification de chaque composant, identité comme plan de contrôle plutôt que comme couche, intégrité de la chaîne de preuve, description exclusive de l'infrastructure en code. Le modèle comporte sept niveaux L1–L7, cinq couches et deux plans transversaux, chacun décrit jusqu'à son point de vigilance. Huit vues d'architecture et trois diagrammes de comportement rendent ces choix vérifiables plutôt que déclaratifs — dont la topologie réseau, qui répond à la question de la sortie, et le modèle entité-association, qui *montre* pourquoi le rattachement sémantique ne rejoint pas le calcul de score — et le tableau 20 énonce, pour les six vues qui portent une décision opposable, le point de vue servi, les critères de recette datés avec leur protocole, et la réserve. Sept flux structurent la vue dynamique; le sixième, hypothèse assortie de son protocole de réfutation, relie les vulnérabilités détectées à la livraison aux techniques d'attaque observées en recette. Dix-sept décisions ont été enregistrées, de D00 à D16, dont une révision explicite d'une décision antérieure, et sept composants écartés. Les onze écarts recensés sont datés lorsqu'ils sont clos et rattachés aux exigences qu'ils affectent; quatre sont clos et vérifiés, deux le 19/08/2026 et deux par la refonte réseau, les 15 et 24/08/2026.

Chapitre 5 Réalisation et industrialisation

Description en code, chaînes de livraison et de provisionnement, supervision et accueil d'un locataire

Le chapitre précédent décrivait une architecture cible; celui-ci rend compte de ce qui a été construit, en distinguant partout **réalisé et vérifié, réalisé et rattaché à une vérification planifiée et écarté par une décision motivée**. Deux chaînes structurent l'exposé : la livraison applicative et le provisionnement de l'infrastructure.

5.1 Environnement de travail et description en code

Deux environnements réels correspondent à deux projets cloud distincts : le développement, dimensionné au minimum, et la recette, de topologie identique à la cible; la production est une cible documentée, non provisionnée. Séparer par projet plutôt que par étiquette rend l'isolation **structurelle** — les ressources d'un environnement ne sont pas adressables depuis l'autre — sous réserve des liaisons d'autorisation accordées à l'identité de déploiement, qu'aucun test dédié n'a éprouvées. Le développement n'est pas un miroir fidèle de la recette : la configuration du second locataire et huit variables d'accueil de plusieurs applications n'existent qu'en recette, et la chaîne de promotion n'a pas été déroulée de bout en bout. Une règle vaut cependant sans exception — *les mêmes modules servent partout, seules les variables de dimensionnement changent* — de sorte qu'aucune configuration « sans authentification en développement » ne risque d'être promue par inadvertance. Le quatrième projet d'amorçage prévu à la conception n'a pas été créé, ses éléments étant replacés dans chaque projet d'environnement : simplification cohérente avec le principe de justification (PR1), enregistrée comme écart.

Le dépôt d'infrastructure transpose le modèle en couches du chapitre 4 en un module par couche (annexe B). Les trois politiques d'organisation prévues — pas d'adresse publique de base de données, pas de clé d'identité de service, pas d'espace de stockage public — se sont révélées inapplicables dans le périmètre administratif disponible (écart É7) : ces interdictions sont donc recherchées par la configuration des modules, les contrôles de la chaîne d'infrastructure et la revue du *plan*.

5.1.1 Frontière entre le code et l'exploitation

Le principe de description en code (PR4) s'applique à toutes les ressources durables du socle, **à six exceptions que ce mémoire nomme et justifie** : trois tiennent à la nature de l'objet, trois à une limite du dispositif et sont traitées comme des écarts, avec leur contrôle compensatoire. Les énoncer vaut mieux que revendiquer une couverture totale, car **un principe dont on ne sait pas dire la frontière n'est pas appliqué, il est proclamé**.

1. **Les valeurs des secrets et les données applicatives.** Le code crée les conteneurs, les clés de chiffrement et les droits d'accès ; jamais le contenu, qu'une description en code ferait mécaniquement apparaître en clair dans le fichier d'état.
2. **Les comptes du tableau de bord et leurs secrets de second facteur**, nés d'un appel authentifié à l'API de supervision à l'exécution ; le premier compte d'administration est créé par une tâche éphémère plutôt que par une ressource déclarée.
3. **Les enregistrements de noms de domaine**, tenus chez le bureau d'enregistrement, hors du périmètre d'administration du fournisseur cloud : dépendance externe au chapitre 4, non composant de la couche de périmètre.
4. **Le versionnement de l'espace de stockage de l'état d'infrastructure**, activé à la main. Contrôle compensatoire : la revue d'inventaire de cet espace ; condition de clôture : sa déclaration dans un module d'amorçage distinct de l'état qu'il héberge.
5. **Les ordres de révocation SQL qui séparent les locataires** sur l'instance partagée (annexe B) : gestes d'exploitation réversibles par une restauration à un instant donné, qu'un contrôle quotidien *détecte* sans les *prévenir* (section 5.7).
6. **La liaison d'usurpation d'identité accordée à l'opérateur humain** sur l'identité de la tâche d'enrichissement, posée à la main pour rejouer les tests de bout en bout. Contrôle compensatoire : elle est nominative et figure à l'inventaire des chaînes de délégation du chapitre 4.

S'y ajoute une zone qui n'est pas une exception mais un *partage*, couture la plus délicate entre les deux chaînes et commune à toute équipe combinant infrastructure en code [22] et livraison continue : la chaîne d'infrastructure (F7) crée le service d'exécution et en possède la définition, la chaîne applicative (F3) met à jour l'image à chaque livraison, et si les deux prétendent posséder le champ « image », chaque exécution de l'une annule le travail de l'autre. **Résolution retenue :** l'infrastructure possède le service, l'applicatif possède l'image, le code d'infrastructure ignorant explicitement ce champ. Le fichier de variables de la recette n'est par ailleurs pas versionné alors qu'il porte des décisions de sécurité — chemins protégés par le filtrage applicatif, services ingérés dans l'entrepôt — ce qui limite la reproductibilité d'un provisionnement depuis un poste neuf : c'est le correctif de reproductibilité le plus rentable identifié.

5.1.2 État d'infrastructure : sécurité et détection de dérive

Le fichier d'état décrit la topologie complète du système : donnée sensible, traitée comme telle par cinq mesures détaillées en annexe B. C'est la règle des secrets ci-dessus qui l'empêche de devenir un coffre : aucune valeur sensible n'y a été relevée lors des revues du 19/08/2026, et son inspection exhaustive sous une identité non autorisée est l'objet du protocole T17, **conforme** le 20/08/2026 sur quatre refus opposés à trois identités de service (section 6.2). La détection de dérive [17] repose sur une planification régulière : pour une *ressource déjà gérée dans l'état*, un écart entre la configuration déclarée et la valeur observée produit un plan non vide ; une ressource nouvelle, absente de l'état, y échappe et exige un contrôle d'inventaire complémentaire. Le protocole T16 modifie hors code un attribut réversible d'une ressource

gérée, planifie avec rafraîchissement, puis rapproche le résultat des journaux d'audit : il est porté comme partiellement conforme au chapitre 6.

Point de vigilance

Deux limites sont rapportées bien que défavorables. **Le verrouillage des versions a dû être corrigé** : le fichier de verrouillage et l'initialisation complète de la validation ont été ajoutés le 19/08/2026 après constat d'un défaut de reproductibilité. **Le plan ne prédit pas toujours l'effet réel de l'application** : la planification ne capture pas certaines validations effectuées par le fournisseur au moment de l'application, comme le montre l'incident détaillé en section 5.8.1 ; la procédure a été amendée en conséquence.

Une fois ces correctifs appliqués, la planification du 19/08/2026 sur la recette ne renvoie **aucune différence** : la configuration déclarée dans le dépôt correspond exactement à l'état réellement provisionné.

5.2 Chaîne de livraison applicative

5.2.1 Déclenchement, permissions, graphe des tâches et portes bloquantes

La chaîne applicative se déclenche sur la poussée sur la branche principale et sur l'ouverture d'une demande de fusion vers cette branche, **filtrée par chemins** (annexe B). Le filtre n'est pas un confort : avant sa pose, **toute poussée sur la branche principale reconstruisait et redéployait la plateforme**, y compris une correction de documentation — un déclencheur non filtré dilue la signification d'un déploiement et rend illisible le lien entre un changement et son effet. Les permissions du jeton de la forge sont, elles, **déclarées au niveau du flux** — lecture du dépôt, émission d'un jeton d'identité — donc héritées par les six tâches, y compris celles d'analyse et de test qui ne s'authentifient jamais auprès du fournisseur cloud : la lisibilité d'un fichier unique l'emporte ici sur la granularité du moindre privilège. Le périmètre reste borné, aucun droit d'écriture sur le dépôt, mais l'écart est réel ; sa condition de clôture est la factorisation des deux chaînes en un flux appellable commun, sur le modèle de la chaîne dédiée à l'application pilote, qui applique déjà le réglage fin.

Les six tâches ne s'exécutent pas en séquence : elles forment un graphe orienté à **deux chemins parallèles** qui se rejoignent, celui de l'API et celui du tableau de bord, aux dépendances *bloquantes*. Vue par étapes, la chaîne de l'API en compte huit, dont trois **portes bloquantes** [24] ; les tests de l'API en forment une quatrième, parallèle à l'analyse, et le chemin du tableau de bord porte la sienne (figure 19). Deux réglages absents complètent ce portrait, assumés plutôt que tus : la chaîne ne déclare ni contrôle de concurrence — deux poussées rapprochées se déploient en parallèle, sans garantie d'ordre — ni environnement protégé, donc aucune approbation manuelle avant le déploiement. Les deux relèvent du même arbitrage, une chaîne à un seul opérateur sur un environnement de recette, et de la même condition de bascule : l'ouverture de la branche principale à un second contributeur.

L'ordre des portes n'est pas arbitraire : la recherche de secrets [12] précède l'analyse statique pour une raison économique, un secret étant compromis dès sa publication et sa détection à la première étape déclenchant immédiatement la rotation. Le déploiement à l'étape 7 s'effectue

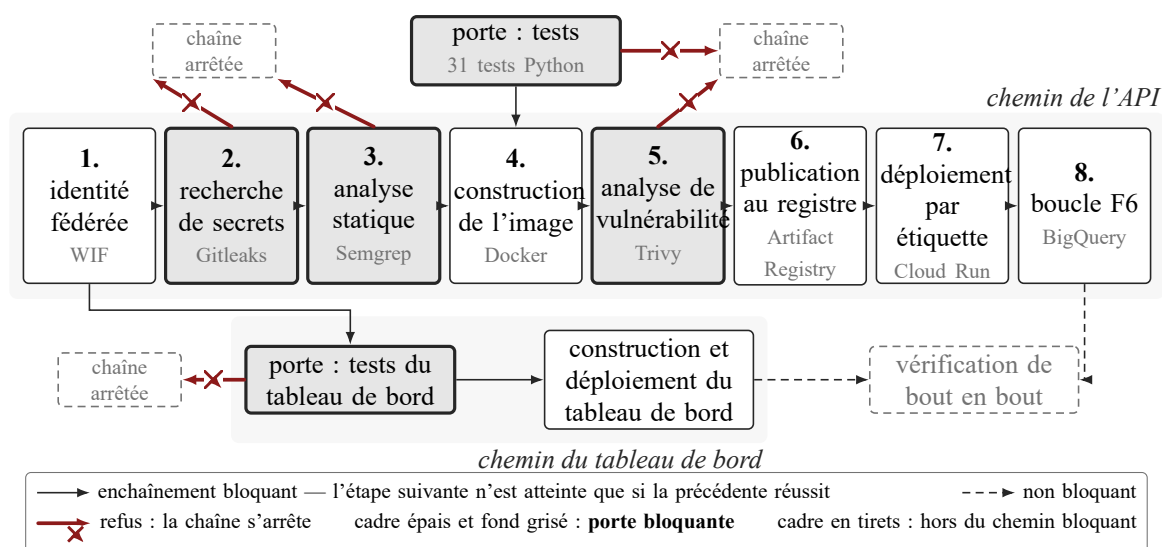


FIG. 19. Chaîne de livraison applicative. Chemin de l'API : huit étapes, dont trois portes bloquantes, plus la porte de tests qui conditionne la construction ; chemin du tableau de bord : sa propre porte. La vérification de bout en bout suit le déploiement et ne le défait pas — c'est une vérification, non une porte. Les cas de refus sont décrits en section 5.2.6 ; deux d'entre eux portent un protocole numéroté, T8 et T10, dont le chapitre 6 donne le verdict daté.

par **étiquette SHA** plutôt que par tag mutable, dans l'esprit des cadres de provenance [23], et l'étape 5 s'appuie sur une analyse d'image alignée sur les pratiques recommandées pour les conteneurs [13].

5.2.2 Les huit familles de contrôles

Décrire une chaîne par ses étapes ne dit pas ce qu'elle contrôle. Le tableau 26 la décrit par *familles de contrôles* ; sa dernière colonne est celle qu'il faut lire, car la destination du résultat détermine si un constat est exploitable ou seulement affiché.

TAB. 26. Les huit familles de contrôles de la chaîne de livraison applicative, dépôt vérifié le 25/08/2026.

Famille	État, outil et caractère bloquant	Destination du résultat
Recherche de secrets versionnés	Réalisée — détecteur de secrets, jeu de règles par défaut, bloquant	Journaux d'exécution de la chaîne
Analyse statique du code	Réalisée — analyseur statique, version épinglée, sept exclusions nominatives, bloquant	Journaux d'exécution de la chaîne
Analyse de la description d'infrastructure	Réalisée — analyseur de configuration, bloquant sur gravité critique	Journaux d'exécution de la chaîne
Analyse de vulnérabilité des images	Réalisée — analyseur d'image, quatre images, bloquant sur gravité critique corrigeable	Journaux et entrepôt de supervision (table des vulnérabilités) — seule famille dont le résultat quitte la chaîne
Tests automatisés	Réalisée — cadre Python (31 tests) et cadre JavaScript, bloquant sur échec, non bloquant sur couverture	Rapport de test conservé 7 jours
Analyse de composition logicielle (dépendances)	Arbitrée	Risque capté en aval par l'analyse d'image, qui inventorie les paquets de l'artefact livré ; ce chemin ne couvre ni les dépendances de développement, ni les avis sans correctif amont, écartés par configuration. Réévaluation : la première dépendance directe hors image

TAB. 26. Les huit familles de contrôles de la chaîne de livraison applicative (suite)

Famille	État, outil et caractère bloquant	Destination du résultat
Test dynamique du service déployé	Arbitrée	La vérification post-déploiement établit la disponibilité par le domaine public, jamais l'absence de vulnérabilité ; la validation dynamique du filtrage applicatif est portée par les protocoles du chapitre 6. Réévaluation : une homologation par un tiers
Signature d'artefact, provenance et nomenclature logicielle	Arbitrée (décision D07)	Traçabilité atteinte par un chemin moins coûteux — étiquette liée à l'empreinte du commit, registre unique — qui ne prouve pas que l'artefact déployé vient de la chaîne attendue. Réévaluation : l'ouverture du socle à un éditeur tiers

La boucle qui ferme le circuit. La plupart des chaînes de ce niveau s'arrêtent au constat, et le rapport meurt dans un journal que personne ne relit ; ici, le résultat de l'analyse d'image devient une donnée de supervision, interrogeable avec les mêmes outils que les détections, ce qui rend possible le flux F6 (section 5.2.5). La contrepartie doit être dite : aucun constat des autres familles n'est publié au format d'échange normalisé qu'attend l'onglet de sécurité de la forge, et les vulnérabilités du tableau de bord ne sont pas exportées — la chaîne ferme *une* boucle, pas toutes.

La discipline des exclusions d'analyse statique. Chacune des sept exclusions porte une justification écrite ancrée sur un fichier et une ligne (annexe B). Le point remarquable est ailleurs : la règle qui détecte une vérification de certificat désactivée est **volontairement non écartée**, son constat étant neutralisé par des annotations nominatives posées là où le comportement est assumé, de sorte que **toute nouvelle occurrence ailleurs dans le dépôt fasse échouer la chaîne** — une exclusion globale aurait supprimé le constat existant et, du même geste, la capacité à détecter le suivant.

Point de vigilance

Une limite de cet épinglage est reconnue et mesurée : la version de l'analyseur est figée, mais le *jeu de règles* qu'il télécharge est distant et mutable. Deux exécutions à version d'outil identique ont dénombré 612 règles le 20/08/2026 et 606 le 24/08/2026. Le verdict de la chaîne dépend donc en partie d'un référentiel que le dépôt ne contrôle pas ; la clôture de cet écart suppose de figer aussi le jeu de règles.

5.2.3 Authentification sans secret permanent

L'étape 1 réalise l'exigence EX7 par la fédération d'identité décrite au chapitre 4 : la chaîne ne détient aucune clé, et cette absence n'est pas une intention — la recherche exhaustive des ressources de clé de compte de service, des fichiers d'identifiants et de la variable d'environnement qui les désigne ne relève aucune occurrence dans le dépôt. Le point à valoriser est la forme de la condition d'attribut qui restreint cette fédération : elle porte **à la fois** sur le dépôt d'origine **et** sur la référence de branche (annexe B). Sans la contrainte de branche, n'importe quelle branche du dépôt obtenait l'identité de déploiement et, avec elle, le droit de déployer une révision arbitraire des services. Le garde-fou qui semble couvrir ce cas, la condition de branche posée sur l'étape de construction, se trouve **côté forge** : déclaré dans le même fichier que ce qu'il

protège, un contributeur capable de modifier ce fichier le lève en même temps qu’il l’exploite. **Seul le filtre du fournisseur cloud fait autorité**, parce qu’il est déclaré ailleurs, appliqué par une autre partie et non modifiable depuis le dépôt — application directe du principe d’identité (PR2) : la décision d’autorisation appartient au vérificateur, jamais à l’émetteur.

Trois réserves complètent ce constat sans l’annuler : la liaison d’usurpation est posée sur l’attribut de dépôt et non sur celui de référence, de sorte que la restriction de branche ne tient que par la condition d’attribut ; la référence autorisée a une valeur par défaut commune aux deux environnements ; et les trois paliers d’identité prévus à l’origine ont été remplacés par une fédération et une identité de déploiement uniques par projet — le chemin d’autorisation y gagne en lisibilité, sans que l’impossibilité d’un accès croisé soit prouvée.

5.2.4 Déploiement, retour arrière et frontière avec l’infrastructure

Le déploiement de l’étape 7 remplace intégralement le trafic du service par la nouvelle révision, sans répartition progressive ; le bloc de répartition a été rendu explicite dans le code et placé hors du champ comparé par la chaîne d’infrastructure pour préparer un déploiement graduel, capacité non exploitée à ce jour. Le retour arrière est donc un geste manuel documenté — remplacer la totalité du trafic sur la révision précédente, restée disponible — dont la condition de bascule est la première mise en production, où il devient un délai de rétablissement non maîtrisé. La vérification de disponibilité qui suit interroge le service par son domaine public, donc à travers le filtrage applicatif : elle éprouve la chaîne d’accès complète, non le seul conteneur.

Point de vigilance

Un défaut d’ordonnancement est rapporté ici plutôt que tu. L’image est publiée au registre *avant* l’analyse de vulnérabilité : une image porteuse d’une faille critique corrigeable entre donc dans le registre de confiance, seul son déploiement étant refusé. La chaîne écrite plus tard pour l’application hébergée construit localement, analyse, puis ne publie que si l’analyse passe — c’est l’ordre correct, et il sert de cible d’alignement.

Une réserve reste ouverte sur le schéma de données : la chaîne du socle n’automatise aucune migration, alors que celle de l’application hébergée l’exécute comme une tâche distincte, attendue jusqu’à son terme avant tout déploiement, et interdit à chaque instance de la déclencher elle-même — le bon motif, puisque N instances qui migrent sans verrou de schéma produisent une corruption silencieuse.

5.2.5 Boucle entre livraison et détection : la huitième étape

L’étape 8 réalise le flux F6, hypothèse d’apport exposée au chapitre 4 et rattachée à la question Q6 du chapitre 1 comme au verrou V4 du chapitre 2 : elle exporte le résultat de l’analyse de vulnérabilité vers une table dédiée, avec un droit d’écriture limité à cette seule table, de sorte que gravité théorique et techniques observées coexistent enfin dans un entrepôt où elles peuvent se parler. La chaîne est linéaire — analyse de vulnérabilité, service d’encodage, table des vulnérabilités, rapprochement avec les détections R1–R7 par technique ATT&CK, ordre de correction — et son apport se dit sans emphase : **F6 ne couvre aucune exigence de sécurité, il**

produit un ordre de traitement et non une réduction de risque ; sa chaîne de données existe, son utilité reste non validée (section 6.3.3) tant que l'ordre produit n'est pas comparé à l'ordre par gravité seule. Une limite s'y ajoute : le chargement inscrit une technique nulle pour chaque vulnérabilité, si bien que le croisement fonctionne sur la chaîne de données et non sur les valeurs. La condition de clôture est le renseignement de cette colonne à la source.

5.2.6 Refus vérifiés

Une chaîne de livraison doit être éprouvée par des cas de refus, faute de quoi rien ne distingue une porte qui laisse passer de bons artefacts d'une porte qui ne fonctionne pas — l'incident d'analyse statique de la section 5.8.1 montre que la distinction n'est pas théorique. Trois protocoles définissent ces cas : un secret factice doit arrêter la chaîne à la deuxième étape (T10), une image de base porteuse d'une faille critique connue à la cinquième (T8), et un espace de stockage volontairement exposé doit être refusé avant toute création (section 5.3). La campagne du chapitre 6 les a départagés (section 6.2) : **T8 est conforme**, sur un refus qui n'a pas été provoqué — la porte a réellement arrêté une livraison sur une vulnérabilité critique — tandis que **T10 reste partiellement conforme**, la porte étant bloquante à chaque livraison et sur l'historique complet, mais aucun refus n'ayant été opposé. Un quatrième cas, le défaut de code détecté par analyse statique, est établi autrement et mieux : par la remise en service de la porte le 19/08/2026 et sa première exécution réelle (section 5.8.1).

Un cinquième refus, non planifié, est **réellement survenu sur le code écrit pour ce projet** : la porte d'analyse de vulnérabilité a bloqué une livraison sur une faille critique embarquée par le *gestionnaire de paquets* de l'image de base, composant dont l'artefact final n'a aucun usage à l'exécution (T8, section 6.2.2). Entre inscrire la vulnérabilité sur une liste d'exception et retirer la cause, c'est la seconde voie qui a été retenue, la surface d'attaque disparaissant avec l'outil qui la portait : une porte a trouvé, dans le socle lui-même, un défaut que sa conception n'avait pas anticipé.

5.3 Chaîne de provisionnement de l'infrastructure

La seconde chaîne obéit à une logique différente, et cette différence est une décision d'architecture plutôt qu'un degré d'achèvement : elle est **automatisée jusqu'au contrôle et humaine au-delà**. Son intitulé l'annonce — le fichier qui la décrit s'appelle « contrôles d'infrastructure », non « déploiement d'infrastructure ». Le déclenchement est filtré sur le répertoire d'infrastructure, selon la même règle que la chaîne applicative, puis trois étapes s'exécutent (annexe B, figure 20).

La vérification de format est récursive et bloquante. Rendre bloquant un contrôle de forme peut surprendre ; c'est la condition d'une revue de plan utile, car une différence de mise en forme et une différence de sens se présentent à l'identique dans un écart calculé.

La validation syntaxique s'exécute sur les deux environnements, en initialisation sans accès distant : elle ne contacte ni le stockage de l'état ni le fournisseur cloud, et valide la cohérence interne de la description — références, types, arguments obligatoires, versions de fournisseurs — sans aucune autorisation sur l'infrastructure réelle. C'est ce qui permet à ce flux de ne déclarer aucune permission d'émission de jeton : il ne peut structurellement

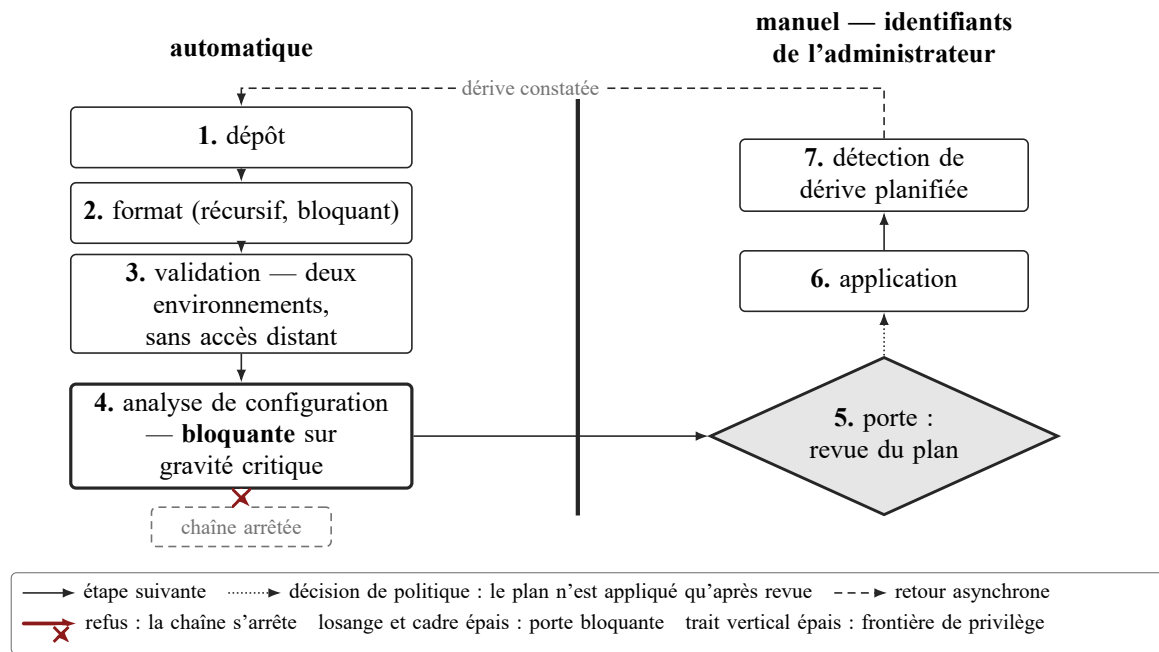


FIG. 20. Chaîne de provisionnement de l'infrastructure : la frontière automatique/manuel est un *choix de privilège*, non un degré d'achèvement — la partie automatisée n'a, par construction, aucun accès au fournisseur cloud.

pas s'authentifier auprès du fournisseur cloud, et cette impossibilité est une propriété, pas un manque.

L'analyse de sécurité de la description est une porte bloquante sur gravité critique, sur des motifs qui recoupent les trois interdictions que les politiques d'organisation auraient dû porter (section 5.1) ; un second passage, informatif, remonte les gravités inférieures sans arrêter la chaîne, de sorte que la porte n'accumule pas de dette silencieuse. **Aucun composant n'a été ajouté pour cette analyse** : c'est l'outil qui analyse les images, employé dans un autre mode — application du principe de justification (PR1).

5.3.1 La revue du plan comme porte humaine

Le plan de modification est produit puis appliqué par l'administrateur, hors de la chaîne, avec ses propres identifiants. Automatiser l'application supposerait d'accorder à l'identité de déploiement des droits de *lecture et d'écriture étendus sur tout le projet* — un plan complet lit toutes les ressources gérées, une application complète les modifie — soit la concentration de privilège que le chapitre 4 refuse.

Décision retenue. La revue humaine du plan est la porte de cette chaîne. **Condition de bascule** : l'automatisation devient rentable lorsque le périmètre justifie une *identité de déploiement d'infrastructure séparée* de l'identité de livraison applicative — c'est-à-dire à partir du troisième environnement, où la fréquence des modifications et le nombre d'opérateurs rendent le geste manuel plus risqué que le privilège qu'il évite.

Deux principes gouvernent l'ensemble. **Le plan est revu comme du code**, et se lit intégralement, jamais par sa fin : l'incident rapporté en section 5.8.1 montre qu'un plan à

périmètre restreint peut contenir un remplacement destructif sans rapport. **L'application est la seule voie d'écriture** : toute modification venue d'un autre chemin devient une dérive, détectée à la planification suivante (section 5.1.2). D'où le verdict de T18, partiellement conforme au chapitre 6 : la revue a lieu, l'approbation n'est pas outillée.

5.3.2 Protection contre les destructions

Une chaîne de provisionnement peut détruire aussi vite qu'elle construit. Deux ressources seulement portent le verrou de destruction du langage de description : les deux clés de chiffrement. Les services d'exécution, les tâches et les modules applicatifs portent explicitement le verrou ouvert, cohérent avec leur caractère reconstructible. L'instance de base de données et les tables de l'entrepôt — *y compris celles qui portent les preuves* — ne portent en revanche pas la protection de suppression du fournisseur, le seul garde-fou de l'ensemble de données étant son refus de disparaître tant qu'il contient des tables.

Point de vigilance

Cet écart est classé au premier rang du plan de correction pour un motif de proportion : le coût est de quelques minutes, et l'effacement de la table des détections par une commande d'administration les 24 et 25/08/2026 a établi que le risque n'est pas théorique. La correction pose la protection de suppression du fournisseur sur l'instance de base de données et sur les trois tables de preuve — détections, verdicts d'analyste, événements de sécurité — et sert le principe d'intégrité de la preuve (PR3), qui perd son sens si la preuve peut être détruite d'un geste.

Le quatrième scénario de refus porte sur une ressource volontairement mal configurée, dont le blocage doit être constaté avant toute création plutôt que lors d'un audit a posteriori. Sa définition est complète — ressource, politique attendue, critère d'acceptation — mais elle ne porte pas de protocole numéroté : à la différence de T8 et de T10, elle n'entre pas dans la campagne du chapitre 6, et son premier passage est porté par le plan de correction.

5.3.3 Conduite d'une migration sur un système en service

La refonte réseau arrêtée sous la décision D15 (section 4.2.5) a été appliquée par cette chaîne — un plan lu intégralement puis appliqué à la main à chaque étape — en douze étapes, entre le 11 et le 25/08/2026. Elle est rapportée ici parce qu'elle est la seule opération du projet à avoir déplacé le chemin du trafic d'un système déjà en service : l'ordre y compte davantage que le contenu.

Cet ordre obéit à une règle unique — *on n'interdit jamais avant d'avoir observé, et on n'observe qu'après avoir fait passer le trafic par l'endroit où on l'observe*. Les trois sous-réseaux par locataire ont donc été créés d'abord (11/08) : ajout pur, qu'aucune ressource ne référençait encore. Les charges de travail ont ensuite basculé une par une en sortie réseau directe (12 au 14/08), en commençant par la tâche planifiée d'enrichissement — dont l'échec eût été visible et sans effet sur un utilisateur — et en gardant pour la fin le service le plus exposé ; chaque bascule produit une révision, et une révision qui ne démarre pas laisse la précédente servir, de sorte que le retour arrière est un redéploiement et non une reconstruction. Le connecteur d'accès

sans serveur n'a été supprimé qu'ensuite (15/08), une fois qu'aucune ressource ne le référençait et que le plan ne présentait qu'une seule destruction.

Sept jours d'observation ont remplacé le pari par la mesure (15 au 22/08) : échantillonnage des journaux de flux porté à un paquet sur deux, journalisation de la passerelle de traduction d'adresses portée à toutes ses connexions, et construction depuis l'entrepôt de l'inventaire exhaustif des destinations réellement jointes. C'est cet inventaire, et non une hypothèse sur les besoins des charges, qui a dicté les six autorisations posées le 22/08; c'est la même fenêtre qui a établi que la passerelle ne traitait aucun trafic, et justifié sa suppression par une mesure.

Une seule étape était réellement dangereuse, et elle a été traitée comme telle : la pose du refus par défaut en sortie, le 23/08, qui coupe tout ce que les cinq autorisations n'ont pas nommé. Elle a été jouée hors heures ouvrées, la commande de retour arrière préparée avant l'application, et n'a été déclarée réussie qu'au terme de trente minutes d'observation. Le risque résiduel avait été nommé avant d'être couru : un flux légitime qui ne survient pas pendant la fenêtre de sept jours — une tâche mensuelle, un chemin d'erreur — n'entre dans aucun inventaire. C'est la raison d'être des refus nommés posés juste avant lui : ils font apparaître un tel flux dans les journaux sous un nom de règle lisible, au lieu de le laisser disparaître dans un refus général qui n'explique rien. La passerelle, son routeur, les deux anciens sous-réseaux vides et les trois règles d'entrée qui ciblaient une étiquette que rien ne portait ont été retirés le lendemain; le régime permanent — échantillonnage ramené à un paquet sur dix, métadonnées exclues — a été posé le 25/08/2026.

5.4 Chaîne de détection

La collecte (flux F4) rassemble vers l'entrepôt de supervision les journaux d'audit du fournisseur, ceux des services d'exécution et les verdicts du filtrage applicatif, avec un filtrage appliqué à **la source** et non après stockage (BNF3). Une réserve porte sur les journaux d'audit : ceux d'activité d'administration sont collectés avec les autres sources, tandis que ceux d'accès aux données — entrepôt, secrets, clés, base applicative — restent dans l'espace par défaut du fournisseur, en conservation de trente jours, modifiable. L'attribution d'une action privilégiée visée par EX13 n'est donc établie que pour le plan d'administration, d'où l'exécution du protocole T13 sur les deux plans.

L'entrepôt compte dix tables (tableau 27), dont six voient leur identité d'écriture restreinte à une table unique par une liaison de droits : cette séparation vise l'exigence EX11 sans rendre les preuves immuables — une identité d'administration ou une liaison IAM excessive peut encore les modifier, ce qui doit être contrôlé séparément. Le score d'incident, recalculé à la lecture et jamais persisté (chapitre 4), est une **heuristique de tri** et non un verdict : il additionne un poids par gravité et une prime fixe lorsque les détections d'une même entité relèvent d'au moins deux tactiques distinctes, signe d'une chaîne d'attaque probable. L'asymétrie est voulue : le score est recalculé à chaque consultation et jamais conservé, le verdict de l'analyste est conservé et jamais modifié — traduction du principe d'intégrité de la preuve (PR3), **ce que la machine ordonne**

est révisable, ce que l’humain juge est définitif ; la colonne « verdict » reste vide tant que l’analyste n’a pas tranché.

TAB. 27. Modèle de données de l’entrepôt de supervision : dix tables, un écrivain chacune

Table	Contenu	Partition et rétention	Écrivain autorisé	Clé d’application
Journaux d’accès access_logs	Une ligne par requête HTTP applicative	Jour · 90 j	Normalisation F4 (identité de déploiement)	service
Journaux bruts raw_logs	Charge JSON des quatre sources collectées	Jour · 90 j	Normalisation F4	resource_name
Détections detections	Alertes R1–R7, tactique et technique ATT&CK	Jour · sans expiration	Requêtes planifiées R1–R7	service
Événements de sécurité security_events	Blocages du filtrage applicatif, déjà mitigés	Jour · sans expiration	Normalisation F4	absente
Enrichissement alert_enrichment	Technique rattachée, similarité, candidats de rang 2–3	Jour · sans expiration	Tâche F5 — droit limité à cette seule table	absente
Métriques api_metrics	Agrégat horaire : volume, erreurs, latence, blocages	Jour · sans expiration	Normalisation F4	absente
Verdicts analyst_verdicts	Jugement humain, ajout seul, jamais de mise à jour	Jour · sans expiration	API de supervision — cette seule table, rôle administrateur	absente
Vulnérabilités cve_findings	CVE du dernier scan, catalogue d’exploitation, score EPSS	Jour · sans expiration	Chaîne d’intégration — cette seule table, réécriture totale	sans objet
Vecteurs de référence attack_embeddings	872 vecteurs de 768 dimensions, catalogue ATT&CK	Aucune	Chargement hors ligne, identité d’opérateur	sans objet
File d’attente ML pending_embeddings	Déclarée, jamais écrite ni lue : vestige de F5 ; retrait décidé le 25/08/2026, non appliqué	Aucune	Aucun	sans objet

Trois colonnes portent des données à caractère personnel : l’adresse source et l’identifiant d’utilisateur des journaux d’accès, et l’entité des détections, le plus souvent une adresse. Les journaux expirent à quatre-vingt-dix jours ; les détections, qui portent la même adresse, n’expirent pas — écart assumé au titre de la valeur probante, à trancher par le responsable de traitement. Les 872 vecteurs de référence couvrent 697 techniques et sous-techniques du référentiel ATT&CK Entreprise [21]. Chaque locataire dispose en outre d’un espace de stockage objet dédié, chiffré par clé gérée, protégé contre tout accès public et administrable en écriture par la seule identité de l’application concernée : il porte les **enregistrements vocaux** de l’application pilote, données biométriques qui fondent la contrainte réglementaire du chapitre 1.

Point de vigilance

La journalisation des refus du pare-feu a été activée et vérifiée le 19/08/2026, ce qui clôt l’écart É1 et rend la source de signal disponible ; elle porte, depuis la migration rapportée en section 5.3.3, sur les six règles de refus du réseau — dont les quatre refus croisés entre locataires — que le puits existant collecte sans modification. Le trajet complet d’un refus jusqu’à l’entrepôt a été mesuré depuis : le 24/08/2026, trois sorties refusées — externe, croisée entre locataires et vers la base — ont été retrouvées dans l’entrepôt en 2 min 55 s à 4 min 12 s, ce qui rend le protocole T20 **conforme** (section 6.2) ; sa cadence de jeu est trimestrielle.

Il n’existe pas de convertisseur automatique depuis le format neutre de règles de détection vers le dialecte de l’entrepôt retenu (chapitre 2). La traduction des sept règles R1–R7 a donc été réalisée manuellement, selon un gabarit systématique — source, condition de sélection, fenêtre temporelle, agrégation, identifiants, faux positifs connus — dont l’annexe B donne un exemple.

La chaîne complète, de la collecte à l’affichage, est celle conçue au chapitre 4 (figure 13) et la réalisation n’en a pas déplacé une étape : les journaux bruts alimentent les sept requêtes planifiées R1–R7 sur une fenêtre de 15 min, les détections qu’elles écrivent sont lues par l’API qui calcule le score à la requête, et la tâche d’enrichissement forme un **second cycle indépendant** — encodage puis recherche vectorielle à trois candidats — dont le résultat n’est joint à aucun score. Les deux cycles étant indépendants, une détection est affichée dès qu’elle est écrite et son enrichissement arrive au cycle suivant.

Le plafond que cette traduction manuelle impose à la couverture est établi en section 2.3.1 (verrou V2) et mesuré au chapitre 6 ; la contrepartie est que les règles sont du code, versionnées, revues et déployées par la chaîne d’infrastructure.

5.5 Couche d’enrichissement sémantique

Les contrôles appliqués aux poids du modèle de représentation de phrases retenu [5, 2], traités comme un artefact tiers non fiable, sont ceux du chapitre 4. Ce que la réalisation ajoute est une mesure : **la fidélité est vérifiée, pas supposée**. La quantification en entiers, testée puis rejetée par la porte d’acceptation codée, dégradait les représentations au point de ne produire **aucune correspondance correcte de premier rang sur cinq cas** ; le modèle livré est donc en précision flottante simple. La tâche d’enrichissement retient trois candidats plutôt qu’un, afin que l’analyste compare des alternatives au lieu de recevoir une affirmation unique.

Posture de sortie réseau obtenue. Depuis la migration rapportée en section 5.3.3, les charges portent leurs interfaces de sortie *dans* un sous-réseau : tout leur trafic sortant traverse le pare-feu, le refus par défaut en sortie est posé, et cinq autorisations seulement le percent, chacune ciblée par une identité de service et par un port. Le plan d’adressage, les douze règles et les trois lectures qu’elles appellent sont établis en section 4.2.5 ; ce que la réalisation ajoute est que **le pare-feu est devenu une source de journal nommée** — les refus croisés entre locataires et l’interdiction faite au tableau de bord de joindre la base portent chacun un nom de règle qui dit ce qui a été tenté, et rejoignent l’entrepôt par le puits déjà en place, **sans qu’aucune modification de la chaîne de détection ait été nécessaire** (annexe B).

Cette posture n’établit pas l’impossibilité d’une exfiltration : elle en ferme la voie directe et en laisse deux ouvertes, énoncées en section 4.2.5 — les interfaces du fournisseur, et les deux charges détachées du réseau. La seconde n’est pas une hypothèse : le 25/08/2026, une sonde empruntant le chemin de la révision réellement déployée du service d’encodage a atteint une destination externe en 412 ms, quand la même sonde passant par le sous-réseau était refusée deux fois. **Le protocole T14 est donc non conforme** ; le correctif — réintégrer les deux charges au sous-réseau sous une étiquette qu’aucune autorisation de sortie ne couvre — coûte une révision sans changement applicatif. Le trajet d’un refus jusqu’à l’entrepôt est, lui, mesuré et **conforme** par T20 (24/08/2026, section 6.2).

5.5.1 État d’avancement réel de la couche

L’écart entre conception et réalisation est ici le plus important (tableau 28).

TAB. 28. État d'avancement de la couche d'enrichissement sémantique

Composant	Réalisé	Statut
Préparation et figement du modèle	Oui	Vérifié
Chemin public direct absent dans la configuration	Oui — mais la sortie <i>managée</i> de la révision déployée reste hors du pare-feu	T14 non conforme (25/08/2026)
Table de vecteurs de référence et index	Oui	Vérifié
Tâche d'enrichissement, recherche vectorielle	Oui	Réalisé
Cadence prévue (5 min)	Non — 15 min	Écart assumé (coût)
Cache par étiquette SHA d'entrée	Calculé, jamais exploité	Non réalisé
Vue de corrélation entre alertes	Non	Non réalisé
Enrichissement dans le score d'incident	Non	Écart majeur

Point de vigilance

La couche d'enrichissement produit ses résultats, mais ceux-ci n'alimentent pas le score d'incident présenté à l'analyste. Cet écart ne remet pas en cause la démonstration technique — la chaîne complète fonctionne et le chapitre 6 la mesure — mais il borne l'affirmation possible : le rattachement automatique produit des candidats consultables sans preuve suffisante de précision, de coût stabilisé ni d'amélioration de la priorisation. **Décision du 25/08/2026** : le positionnement informationnel est assumé comme état livré, et la jointure au score est reportée en perspective. Elle ne se réduit pas à une jointure technique : elle suppose une règle de décision évaluée et surtout l'ajout d'une clé d'entité à la table d'enrichissement, dont le chapitre 4 montre qu'elle est absente du schéma.

5.6 Tableau de bord et API de supervision

La supervision repose sur deux logiciels écrits pour ce projet : le tableau de bord, application web à rendu serveur, et l'API de supervision qui l'alimente (figure 21). Tout passe par l'API, qui applique le contrôle d'autorisation ; cette séparation réalise les exigences EX5 et EX6 et évite l'erreur fréquente donnant à une interface web les droits de lecture d'un entrepôt. Les vues se rafraîchissent en continu et signalent la fraîcheur de leurs données, mais cette actualisation porte sur des résultats *déjà calculés* : l'interface est vive, la détection ne l'est pas au même degré.

5.6.1 La chaîne de données d'une vue

Le point le plus solide de cette architecture n'est pas visible à l'écran : **aucune vue du tableau de bord n'interroge directement l'entrepôt de supervision ni la base applicative.** Toutes empruntent les cinq mêmes sauts, sans exception vérifiée ligne à ligne (figure 22, extrait en annexe B) : cette uniformité est ce qui rend la chaîne auditable.

Aucun script exécuté dans le navigateur ne peut donc lire le jeton, ni l'exfiltrer, y compris en cas d'injection de script réussie dans une vue : **le tableau de bord n'est pas un client privilégié, c'est un client comme un autre, qui n'a de pouvoir que celui du jeton qu'on lui a confié.** Les sept routes serveur ne dérogent pas à ce motif : ce sont des relais d'authentification, qui lisent le témoin, en font un en-tête d'autorisation, transmettent et rendent la réponse. L'une d'elles porte une décision : le relais de connexion *préserve* le code de refus pour dépassement de seuil au lieu de le réécrire en refus d'authentification, ce qui aurait fait croire à l'analyste qu'il s'était trompé de mot de passe et privé le centre d'opérations du signal d'attaque. Le garde de session vérifie la présence du témoin et sa non-expiration par simple décodage de la date d'échéance, **sans**

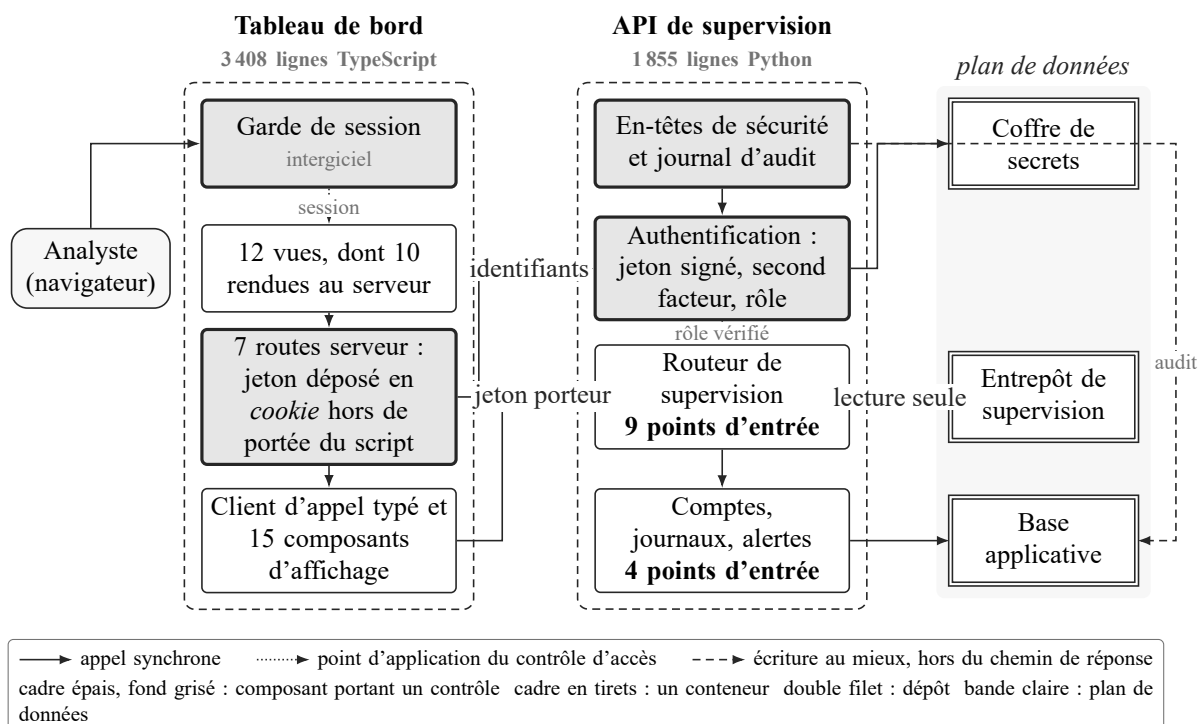


FIG. 21. Architecture interne des deux logiciels écrits : composants, frontières de déploiement et points d'application du contrôle d'accès. Le rôle est vérifié sur les treize points d'entrée de données de l'API — neuf de supervision et quatre de gestion — et jamais dans le tableau de bord, qui ne détient aucune autorisation propre ; l'échec de l'écriture d'audit est absorbé et ne fait jamais échouer la requête de l'analyste.

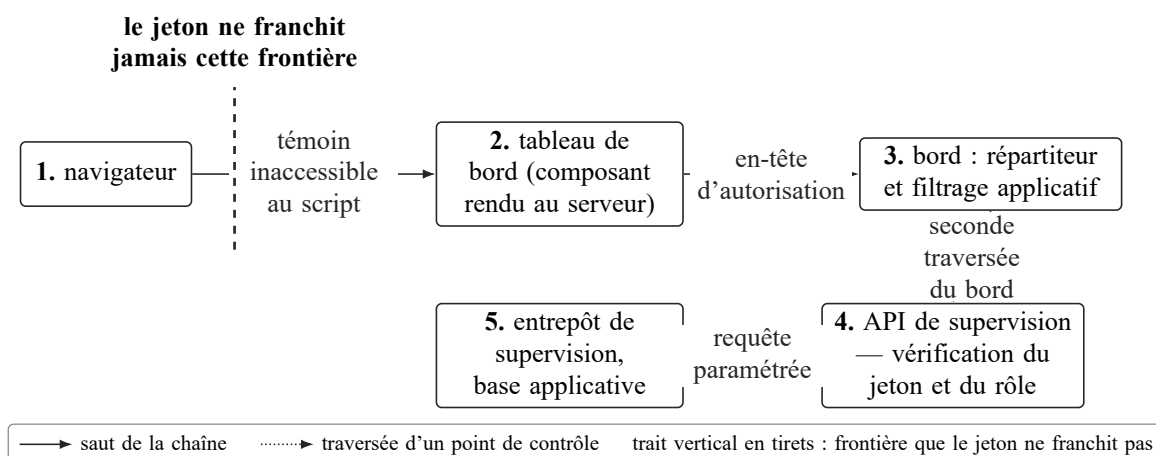


FIG. 22. Chaîne de données d'une vue du tableau de bord : les cinq sauts, et la frontière que le jeton ne franchit pas. L'autorité d'autorisation est l'API de supervision, qui vérifie le jeton et le rôle ; l'identité du tableau de bord ne détient aucune autorisation sur les données.

vérification de signature — le tableau de bord ne connaît pas la clé et ne doit pas la connaître ; ce contrôle est *documenté dans le code comme un contrôle d’ergonomie et non d’autorisation*, la seule source de vérité restant l’API.

5.6.2 Cartographie des vues

Le tableau 29 met en regard, pour chaque vue, ce qu’elle apporte à l’analyste avec le point d’entrée qu’elle appelle, et sa capacité à être filtrée par locataire.

TAB. 29. Cartographie des vues du tableau de bord : douze éléments rendus, dont dix au serveur, dépôt vérifié le 25/08/2026.

Vue	Apport à l’analyste et point d’entrée appelé	Filtre locataire
Vue d’ensemble	Cinq indicateurs, répartition par gravité, courbe des requêtes, dix dernières requêtes — journaux, alertes et synthèse en parallèle	Partiel — synthèse seule
Journal d’audit	Cent dernières requêtes reçues par l’API — journaux	Non
Alertes	Requêtes en erreur, gravité dérivée du code de retour — alertes, filtrées	Non
Détections	Deux cents détections des règles R1–R7 sur vingt-quatre heures — détections	Oui
Incidents	Entités agrégées, score de tri, verdict posé — incidents	Oui
Fiche d’incident	Jauge de score, tactiques rattachées, chronologie — incident par entité, 200 lignes	Oui
Couverture ATT&CK	Matrice de couverture par tactique — couverture	Oui
Vulnérabilités	Priorisées : exploitation connue, observation, score de probabilité — vulnérabilités	Non
Santé des règles	Rendement et taux de faux positifs des sept règles — santé des règles	Non
Enveloppe de mise en page	Navigation, bandeau, bascule de thème, indicateur de fraîcheur — aucun appel	Sans objet
Connexion (<i>cliente</i>)	Formulaire en deux temps, mot de passe puis code temporel — relais de connexion puis de vérification	Sans objet
Sécurité du compte (<i>cliente</i>)	Enrôlement et retrait du second facteur — relais du second facteur	Sans objet

La colonne de droite est presque toujours mal lue : la portée du filtre par locataire n’est pas un défaut d’interface qu’un développement complémentaire viendrait combler, c’est une **propriété du modèle de données**. Une vue ne peut être filtrée par locataire que si la table qu’elle interroge porte une clé de locataire fiable ; or trois tables seulement de l’entrepôt en portent une, et une seule de ces trois clés est renseignée sur la totalité des lignes (tableau 27). Les vues d’ensemble, de vulnérabilités et de santé des règles restent donc globalement fusionnées quel que soit le locataire sélectionné, ce que le sélecteur affiché à l’écran documente lui-même. La condition de bascule est l’introduction d’une clé de locataire obligatoire à l’ingestion, préalable de tout cloisonnement au stockage.

Point de vigilance

Le filtre par locataire est porté par un témoin déposé côté navigateur, non signé, et le jeton ne porte aucune revendication de locataire. Tout analyste authentifié peut donc changer de locataire ou retirer le filtre. Le mémoire l’énonce comme le code l’énonce : **c’est un raffinement de lecture, pas une frontière de sécurité**. Le transformer en frontière suppose une revendication de locataire dans le jeton et un filtre imposé côté serveur — travail identifié, chiffré, et subordonné au préalable de la clé de locataire.

5.6.3 Authentification, second facteur et contrôle d'accès

Trois rôles sont définis dans le jeton émis par l'API : administrateur, analyste et service — cette dernière identité, non humaine, n'étant référencée par aucun contrôle à ce jour ; aucun rôle n'est prévu pour les utilisateurs de l'application hébergée, qui n'accèdent jamais au tableau de bord. L'écriture d'un verdict illustre l'exception prévue au principe d'intégrité de la preuve (PR3) : elle est possible, mais uniquement dans une table qui lui est propre (tableau 27), jamais dans les tables de preuve, et réservée à l'administrateur — arbitrage plus restrictif que la répartition des tâches d'un centre d'opérations, cohérent avec la règle « une seule identité écrit dans une table donnée », et dont la condition de réévaluation est l'arrivée d'un second analyste. L'interface a été servie à un compte analyste le 23/08/2026 sur des détections réelles de la recette, une alerte R2 y apparaissant rattachée à la technique T1498 et attribuée au locataire concerné.

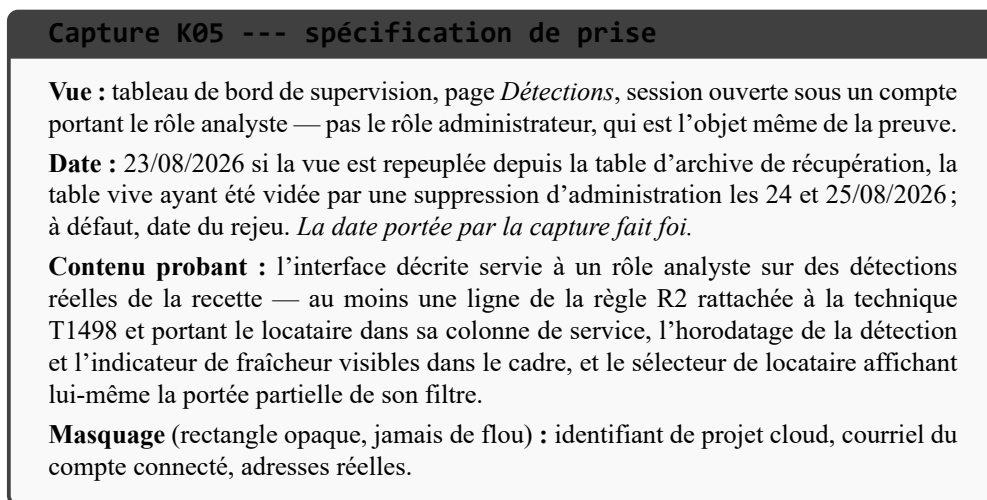


FIG. 23. Tableau de bord de supervision servi à un compte de rôle analyste, page des détections. À y lire : une détection de la règle R2 rattachée à la technique T1498 et attribuée au locataire, l'horodatage de la détection porté par la capture elle-même, et le sélecteur de locataire qui énonce la portée partielle de son filtre.

Le facteur de connaissance. Une longueur minimale de **douze caractères** est imposée par le schéma de validation d'entrée et non par un contrôle écrit à la main : la contrainte est portée par le contrat de l'API et vaut pour tout appelant, sans exigence de complexité, d'expiration ni d'historique, conformément aux recommandations actuelles. La vérification borne en outre la longueur de l'entrée avant la fonction de hachage, faute de quoi un appel *non authentifié* portant un mot de passe très long provoquait une erreur interne au lieu d'un refus — défaut de disponibilité atteignable sans compte, corrigé.

La session. Deux propriétés de la vérification du jeton signé décrit au chapitre 4 méritent d'être relevées. L'algorithme de signature est **figé en constante** et n'est jamais lu depuis l'en-tête du jeton présenté, ce qui immunise contre la confusion d'algorithme — la classe d'attaque où un jeton signé par un autre algorithme, voire par aucun, est accepté parce que le vérificateur croit ce que le jeton déclare de lui-même. La validation exige par ailleurs la présence effective des champs d'échéance et d'émission, un jeton dépourvu d'échéance ayant été auparavant valable indéfiniment.

Le second facteur. La séparation du jeton intermédiaire et du jeton d'accès, conçue au chapitre 4, est **vérifiée à chaque appel** : la dépendance qui identifie l'appelant refuse tout jeton dont le type n'est pas celui d'un jeton d'accès. Le point d'entrée qui reçoit le code temporel n'était par ailleurs couvert que par un limiteur applicatif, non par la limitation de débit du périmètre ; il a été ajouté aux chemins d'authentification protégés le 19/08/2026 et vérifié en conditions réelles le jour même : onze requêtes successives ont produit dix refus de validation, puis un refus pour dépassement de seuil. C'est cette trace qui étaye le test T2.

L'anti-force-brute repose sur deux couches, et le choix de la clé de comptage est un raisonnement d'ingénieur plutôt qu'une configuration. La couche principale est au bord : le filtrage applicatif limite les appels aux chemins d'authentification par adresse source réelle, avec bannissement temporaire au dépassement. La couche applicative ne peut pas utiliser cette clé, le tableau de bord et l'API partageant une **adresse de sortie commune** : lorsque la requête est relayée par le tableau de bord, la seule adresse que voit le limiteur applicatif est celle de cette sortie, de sorte qu'une clé par adresse rendrait le compteur *commun à tous les analystes*. La conséquence est quantifiable : douze requêtes non authentifiées suffisaient à verrouiller le centre d'opérations entier, en refusant la connexion à des analystes qui n'avaient rien fait. La clé porte donc sur le **défi** — le jeton intermédiaire remis à l'issue du mot de passe — ce qui isole chaque tentative dans son propre budget d'essais. Le code énonce lui-même la limite résiduelle : rejouer l'authentification par mot de passe réobtient un jeton intermédiaire, donc un budget, ce qui reporte la charge sur la couche de bord, laquelle voit l'adresse réelle du client. La leçon dépasse ce cas : **un contrôle qui suppose qu'une adresse réseau désigne un utilisateur produit des blocages collectifs dès qu'une agrégation existe entre lui et le client** — la question n'est pas « quel seuil ? » mais « que compte-t-on, et cet objet est-il propre à celui que l'on veut ralentir ? ».

Le secret partagé du second facteur était auparavant stocké en clair. Un **chiffrement authentifié applicatif** a été mis en place le 19/08/2026, avec migration non destructive tolérant les valeurs antérieures et clé conservée au coffre de secrets ; la migration des valeurs déjà en base n'étant pas documentée comme exécutée, l'écart n'est pas clos.

5.6.4 Le logiciel écrit : structure, tests et dette assumée

Les deux composants de cette interface sont les seuls éléments du socle écrits ligne à ligne plutôt que déclarés (tableau 30). Le contrôle d'autorisation conditionne la portée de l'exigence EX5 et appelle une description exacte : les neuf points d'entrée de supervision déclarent tous le *même* composant, qui valide le jeton, en extrait le rôle et refuse l'appel si ce rôle n'est pas attendu — huit admettent l'administrateur et l'analyste, le neuvième, celui qui enregistre un verdict, n'admet que l'administrateur. Il n'y a donc pas neuf contrôles à auditer mais un seul, déclaré neuf fois, ce qui *déplace* le risque : un point d'entrée ajouté sans la déclaration serait ouvert sans qu'aucun test existant ne s'en aperçoive. Le remède, un test d'inventaire vérifiant que toute route déclarée porte son contrôle, est porté au plan de durcissement de l'API.

Deux lignes de ce tableau sont défavorables et appellent leur cause. La couverture de 3,00 % tient à ce que les vues ne sont pas testées : seules des fonctions pures le sont, et deux des quatre suites éprouvent du code recopié dans le fichier de test plutôt que le module lui-même —

TAB. 30. Caractérisation quantifiée des deux logiciels écrits, dépôt vérifié le 25/08/2026.

	API de supervision	Tableau de bord
Langage et cadre	Python 3.12, cadre applicatif asynchrone à validation typée	TypeScript, cadre à rendu serveur
Volume écrit	1 855 lignes, 20 modules	3 408 lignes, 40 fichiers
Points d'entrée	21, dont 9 pour la supervision	douze vues, dont dix rendues au serveur et deux clientes, et sept routes serveur
Modèle de données	4 tables, 3 migrations, 22 schémas de validation	16 types partagés avec l'API
Tests automatisés	31 tests, exécutés à chaque livraison	22 tests unitaires exécutés ; 22 tests de parcours écrits mais jamais exécutés par la chaîne
Couverture mesurée	non mesurée par la chaîne : l'outil est installé, l'option de mesure ne l'est pas	3,00 % des lignes — 11 lignes couvertes sur 367, 22 fichiers instrumentés — pour un seuil de 70 % déclaré et non appliqué
Dette assumée	aucune version portée par les points d'entrée : un client ne peut pas se lier à un contrat stable	375 lignes d'une interface antérieure, non déployée, conservées au dépôt

défaut de méthode plus que défaut de couverture. Le progrès réel est ailleurs : la chaîne *exécute* désormais ces tests, en porte bloquante avant la construction. L'absence de version sur les points d'entrée est sans conséquence tant que le tableau de bord en est le seul client, et sa condition de réévaluation est l'ouverture à un client tiers.

Deux comportements de repli sont visibles à l'exécution et doivent être nommés. L'intergiciel qui écrit le journal d'audit **absorbe toute exception** : une panne d'écriture ne fait jamais échouer la requête de l'analyste. L'arbitrage est délibéré — aveugler le centre d'opérations pendant que la base est en difficulté serait pire — mais il entre en tension avec l'intégrité de la chaîne de preuve, une défaillance d'écriture ne se signalant par rien ; le contrôle compensatoire est identifié, **une alerte sur l'absence d'écriture**, déclenchée lorsque le compteur de lignes d'audit tombe à zéro alors que le service reçoit du trafic. Le tableau de bord **bascule sur un jeu de données de démonstration** lorsque l'API est injoignable : repli signalé par un bandeau visible, désactivé sur le flux d'authentification — aucune session ne peut donc être ouverte sans l'API — et autorisé hors d'une construction de production seulement. Comme il porte un catalogue de règles *fictif*, la règle s'énonce sans détour : aucune démonstration hors de l'image de production, la condition de clôture étant l'alignement du catalogue de repli sur les sept règles réelles.

5.7 Accueil d'un locataire et frontière de responsabilité

Le besoin BF13 exigeait que le socle accueille une nouvelle application sans reconception. Le module d'exécution des services applicatifs a donc été rendu paramétrique en cours de projet : le nom de l'application est une variable, et chaque application reçoit sa propre identité, ses propres secrets et son propre service. Le socle héberge la plateforme MENAL elle-même, API et tableau de bord, et à côté d'elle l'application pilote ELSON du chapitre 1 : c'est cette seconde instance, « le second locataire », qui sert de preuve d'accueil.

5.7.1 La procédure d'accueil et la portée de l'isolation

La procédure a été reconstituée à partir du cas réellement déployé, et non écrite *a priori* : chaque étape correspond à un geste qui a dû être fait. Elle suppose de l'application quatre prérequis non négociables — aucun état sur le disque local, configuration par variables d'environnement, un secret par usage, écoute sur le port fourni avec un point de santé sans

dépendance externe — et se déroule ensuite en six étapes (figure 24). Quatre d’entre elles portent une contrainte que le cas réel a imposée. L’enregistrement de nom de domaine doit exister *avant* tout provisionnement, faute de quoi le certificat géré reste indéfiniment en cours d’émission, et les images doivent avoir été publiées une première fois (étape 1). L’application se fait dans l’ordre, à périmètre restreint d’abord — identité, secrets, base, espace média — puis complète, le plan étant lu intégralement à chaque fois (section 5.8.1, étape 4). La chaîne de livraison dédiée de l’étape 5 est recopiée depuis celle de l’application pilote : cette duplication est l’écart le plus coûteux de la procédure, et sa correction, un flux appellable commun, est identifiée. La quatrième contrainte est la plus traître : les cinq variables d’environnement de l’étape 3 — services collectés, chemins d’authentification protégés, routage au bord, services supervisés, exclusions de règle — doivent être mises à jour *ensemble*, chacune remplaçant un repli historique ; renseigner l’une sans y réinclure les valeurs existantes coupe la collecte ou l’anti-force-brute de la plateforme en croyant ajouter une application.

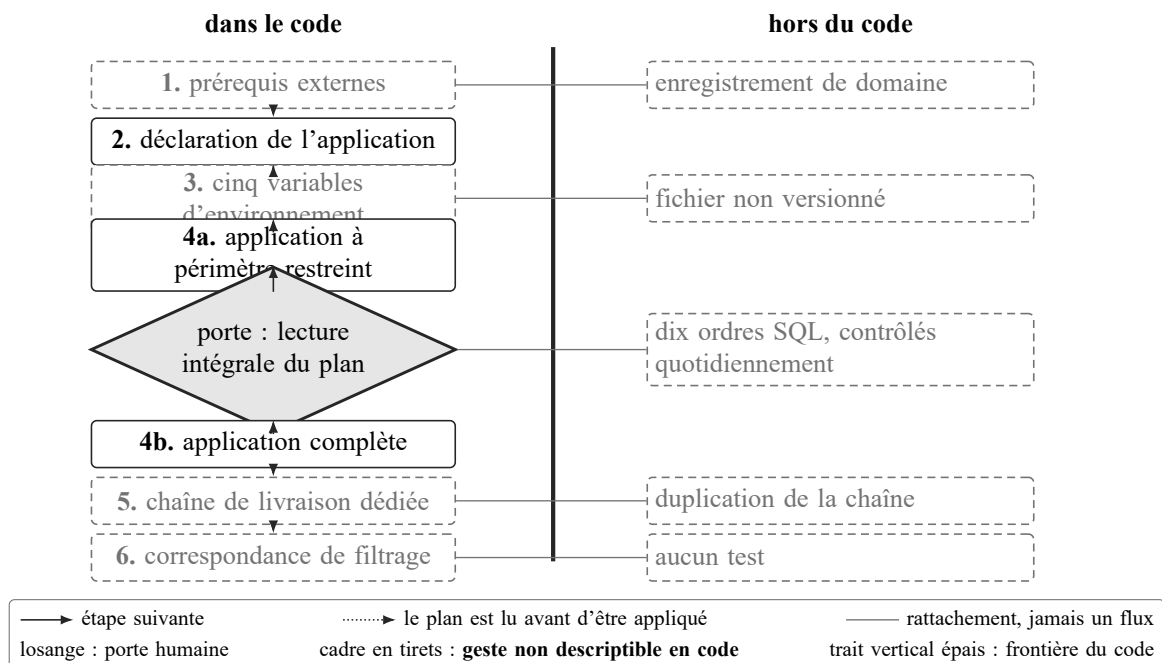


FIG. 24. Accueil d’un locataire : six étapes, et les cinq gestes qui restent hors du code. L’accueil est reproductible sur le plan de l’identité et du déploiement ; les cinq gestes non descriptibles en code sont la mesure exacte de la maturité multi-locataire du socle.

Point de vigilance

S’ajoute à ces six étapes un geste non descriptible en code en l’état : **dix ordres SQL, dont six révocations** qui retirent aux comptes applicatifs l’appartenance au rôle privilégié de l’instance (annexe B). Un contrôle quotidien vérifie qu’ils tiennent toujours : **il détecte la dérive, il ne la prévient pas**. Le chemin par lequel cette frontière se défait n’est pas la restauration elle-même mais la réconciliation qui la suit, et il n’a aucune borne temporelle : le raisonnement complet, sa conséquence sur la conception et la condition de clôture sont établis en section 4.2.6.

Le second locataire a été accueilli en recette le 07/08/2026 par instanciation du module d'exécution paramétrique : compte de service dédié à deux rôles (client base de données, écriture de journaux), base de données et utilisateur séparés, DNS et certificat gérés, six alertes et une sonde de disponibilité; depuis le 08/08/2026, les secrets et l'espace média sont chiffrés par clé gérée dédiée. Le contrôle quotidien d'isolation du 19/08/2026 a produit **six vérifications réussies sur six**, la connexion croisée entre bases étant effectivement refusée.

L'isolation obtenue porte sur quatre plans, dont un seul reste partagé, et cette délimitation vaut mieux qu'une appréciation globale. **L'identité et les secrets** sont isolés sans réserve : le compte de service de l'application hébergée ne détient *aucun droit sur l'entrepôt de supervision*, ce qui lui interdit structurellement de lire les données de sécurité, les siennes comprises. **Les données** sont séparées logiquement — base et utilisateur dédiés — sur une instance partagée, par les ordres décrits ci-dessus. **Le réseau est isolé depuis la migration du 11 au 25/08/2026** (section 5.3.3) : un sous-réseau par locataire, et quatre refus nommés — deux en sortie, deux en entrée — interdisent chaque sens de traversée et journalisent toute tentative sous un nom de règle exploitable comme signal de mouvement latéral. Le connecteur unique, point de défaillance commun aux deux locataires, n'existe plus.

Le plan qui reste partagé est celui du stockage. Les deux locataires demeurent sur *une seule* instance de base de données et *un seul* jeu de tables de supervision : la ségrégation réseau empêche une identité d'atteindre les charges de l'autre locataire, non les deux d'atteindre le même serveur, puisque les deux règles qui l'autorisent visent la même adresse; le contrôle reste au niveau du moteur de base. L'isolation des données est conçue, chiffrée et ordonnancée en section 4.2.6, et non appliquée — la raison en est écrite plutôt que tue : **deux migrations d'infrastructure dans la même quinzaine, conduites par un opérateur unique, ne seraient pas soutenables.**

Point de vigilance

La portée exacte de cette frontière est celle établie en section 4.2.5 : le sélecteur disponible étant l'étiquette réseau et non le compte de service, elle est **opposable à une charge de travail compromise, non à un opérateur capable de déployer**, qui poserait l'étiquette de l'autre locataire. Ce second cas relève du resserrement du droit de déploiement (section 4.6.2), non du réseau; et la conception ne tient pas au-delà de trois ou quatre locataires, les refus croisés croissant comme le carré de leur nombre.

Le seuil de bascule reste l'**accueil d'un troisième locataire** (section 6.7), mais son contenu a changé : sur les quatre travaux qu'il commandait, **deux sont faits** — la sortie par locataire, obtenue par un sous-réseau propre plutôt que par un connecteur dédié, et les règles internes ciblées par identité, portées par la convention d'étiquetage ci-dessus. Les **deux autres subsistent** : une clé de locataire obligatoire à l'ingestion et un cloisonnement au stockage de l'entrepôt, auxquels s'ajoute l'instance de base dédiée au locataire porteur de donnée irréparable (section 4.2.6). Tous relèvent du plan de la donnée, aucun du réseau; le sous-réseau du troisième locataire est déjà créé et adressé, de sorte que son accueil est devenu, côté réseau, une ligne de configuration.

L'expérimentation montre la réutilisabilité partielle du module d'exécution sans qualifier le socle de produit multi-locataire abouti, et son coût de sécurité se dit symétriquement : le périmètre d'usurpation accordé à l'identité de déploiement croît avec chaque application accueillie. Un dernier piège appartient à la pire catégorie, celle des défaillances silencieuses : omettre le nouveau service dans la liste des sources collectées rend l'application *absente de l'entrepôt sans produire la moindre erreur* — l'application tourne, le socle la sert, et le centre d'opérations ne la voit pas.

5.7.2 La frontière de responsabilité

Héberger l'application d'un tiers, fût-il du même groupe, oblige à trancher qui répond de quoi. Le tableau 31 énonce cette frontière sur quatorze domaines ; les cases où le socle n'apporte rien y figurent au même titre que celles où il apporte tout, et un domaine reste laissé à découvert par les deux parties — c'est le plus utile à lire.

TAB. 31. Frontière de responsabilité entre le socle et l'éditeur de l'application hébergée, état au 25/08/2026.

Domaine	Le socle (hébergeur)	L'éditeur de l'application hébergée
Noms de domaine, transit, certificats	Intégral : routage par hôte, certificat géré, politique de chiffrement, transport strict	—
Filtrage applicatif au bord	Intégral : politique unique, limitation de débit, blocage géographique, motifs connus	Déclare ses chemins d'authentification à protéger
Réseau — périmètre et sortie	Intégral : entrée par le seul répartiteur ; en sortie, refus par défaut, cinq autorisations nommées par identité et par port, refus journalisés vers l'entrepôt. <i>Réserve</i> : les interfaces du fournisseur restent une destination autorisée et non inspectée	—
Réseau — segmentation entre locataires	Intégral <i>au plan réseau</i> depuis le 25/08/2026 : un sous-réseau par locataire, refus croisés nommés et journalisés dans les deux sens, plus de connecteur partagé (T20). <i>Réserves</i> : opposable à une charge compromise, non à un opérateur capable de déployer ; deux charges à sortie managée hors du pare-feu (T14) ; instance de base et entrepôt partagés	Déclare ses charges, qui reçoivent l'étiquette de leur compte de service et le sous-réseau de leur locataire
Exécution des conteneurs	Intégral : plateforme, quotas, sondes, mise à l'échelle, révisions, entrée restreinte au répartiteur	Image conforme : exécution non privilégiée, port imposé, point de santé sans dépendance externe
Identité machine et secrets	Intégral : compte de service dédié à moindre privilège, usurpation ciblée, un secret par usage, clé gérée	Consomme les secrets par référence, ne les journalise jamais
Base de données — instance, sauvegarde, restauration	Intégral : instance régionale, adresse privée, restauration à un instant donné ; clé gérée structurellement inapplicable, le champ étant immuable après création. <i>Réserve</i> : une restauration par clonage porte les deux bases	Cohérence applicative après restauration, données hors base
Base de données — schéma et isolation logique	Partiel : vérifie quotidiennement que la séparation tient	Applique le durcissement ; geste non descriptible en code à ce jour
Stockage des médias et chiffrement au repos	Intégral au niveau de l'infrastructure : espace dédié, accès public interdit, clé gérée	Sert les objets, gère les accès temporaires, et répond du chiffrement applicatif des données sensibles , aujourd'hui absent
Code applicatif, logique métier, validation des entrées	Aucune sur la logique ; le filtrage au bord n'arrête que des charges <i>connues</i>	Intégral
Identités des utilisateurs finaux	Aucune : le second facteur du socle ne couvre que les comptes du tableau de bord	Intégral : authentification, autorisation et second facteur des utilisateurs de l'application

TAB. 31. Frontière de responsabilité entre le socle et l'éditeur (suite)

Domaine	Le socle (hébergeur)	L'éditeur de l'application hébergée
Journalisation, détection et notification	Journalisation d'infrastructure, normalisation, conservation, R1–R7, rattachement ATT&CK, enrichissement. <i>Réserve</i> : la journalisation métier est ingérée sans être exploitée, et l'éditeur n'est pas notifié	Émet ses journaux, déclare ses exclusions de règle, conserve son alerte fonctionnelle
Chaîne de livraison et analyse d'image	Intégral : authentification sans clé, registre unique, analyse de vulnérabilité, restitution à l'entrepôt	Corrige les vulnérabilités remontées
Conformité, base légale, droits des personnes	Aucune : des moyens techniques, jamais une gouvernance	Intégral : base légale, information des personnes, exercice des droits, durées de conservation

Le socle sécurise le bord, le réseau, l'exécution, l'identité machine et la chaîne de livraison. La logique métier, les identités des utilisateurs finaux et la conformité restent à la charge de l'éditeur. Cette frontière n'est pas un partage de commodité : elle correspond à ce qu'un hébergeur peut techniquement contrôler.

Une ligne appelle une lecture particulière, car elle est vide des deux côtés : le chiffrement applicatif des données sensibles. Le socle chiffre les supports, il ne chiffre pas les champs, et l'éditeur ne l'a pas fait. Ce vide n'est pas un oubli de rédaction ; c'est l'exigence qu'un contrat d'hébergement devrait porter en premier, et le mémoire la nomme plutôt que de la répartir arbitrairement. La segmentation réseau entre locataires occupait cette même case jusqu'à la migration du 11 au 25/08/2026 (section 5.3.3) : elle a basculé côté hébergeur, seul domaine du tableau à avoir changé de camp. **Un domaine sort du découvert lorsqu'une partie l'assume dans son code, non lorsqu'un contrat le lui attribue.**

5.8 Conduite du projet

J'ai conduit seul toutes les étapes du projet : audit du dépôt existant, rédaction des exigences, conception de l'architecture, écriture des modules d'infrastructure, construction des deux chaînes, traduction des règles de détection, mise en place de la couche d'enrichissement et du tableau de bord, puis exploitation quotidienne du socle en recette — celle qui a produit les cinq incidents ci-dessous. Un assistant de programmation a servi à produire des squelettes répétitifs, des tests et des relectures, jamais à décider d'une option d'architecture ou de sécurité, et aucune production assistée n'a été retenue sans exécution : elle est passée par les portes de la chaîne de livraison puis par une vérification en conditions réelles. Les deux changements de périmètre significatifs — abandon du quatrième projet cloud d'amorçage (section 5.1) et fédération d'identité simplifiée (section 5.2.3) — ont été documentés au moment de leur décision.

5.8.1 Difficultés rencontrées

Chacun des cinq incidents ci-dessous a produit une correction et une leçon transférable.

Indisponibilité liée au démarrage à froid. Le service d'encodage, réduit à zéro instance hors traitement, doit démarrer et charger le modèle lorsqu'une requête arrive après une période d'inactivité. Les mesures rapportées début août ont établi une durée moyenne d'environ vingt-sept secondes, avec un pic à quatre-vingt-quatorze secondes (figure 28) — un tout autre ordre de grandeur que l'estimation initiale, conservée avec la mesure qui la contredit plutôt que corrigée discrètement. Le budget de la sonde de disponibilité a été porté au-dessus du pic

observé ; maintenir une instance active en permanence aurait supprimé le problème, pour un coût disproportionné.

Blocage collectif par la limitation de débit. Le mécanisme initial, un seuil unique par adresse IP, bloquait des utilisateurs légitimes : le tableau de bord et l'API partageant une adresse de sortie commune, l'activité normale de quelques analystes suffisait à franchir le seuil. La correction a introduit la limitation à deux niveaux décrite au chapitre 4, complétée côté applicatif par le compteur indexé sur le défi (section 5.6.3).

État divergent après une application partiellement échouée. Le 08/08/2026, une modification d'infrastructure appliquée sur la recette s'est terminée en échec partiel : une contrainte du fournisseur, non évaluée à la planification, a refusé une partie des changements. L'état local a pourtant enregistré une configuration jamais appliquée, si bien que la planification suivante ne signalait plus aucune différence alors que l'infrastructure réelle en présentait une. L'écart a été détecté par comparaison explicite entre l'état enregistré et les valeurs lues chez le fournisseur, puis corrigé par resynchronisation. Le constat à retenir est factuel : un échec partiel peut laisser l'état local différent de l'état réel, et la planification suivante hérite de cette erreur.

Porte SAST en faux vert. L'action Semgrep utilisée par la chaîne échouait en interne sur une incompatibilité de sévérité, tandis que l'étape apparaissait verte : le 16/08/2026, toutes les tâches de la chaîne étaient en succès alors qu'aucune règle n'avait été évaluée malgré la porte annoncée. Le 19/08/2026, l'action a été remplacée par un appel direct à l'outil en ligne de commande, avec propagation du code de sortie ; la première exécution réelle, numéro 32264602112, a analysé 439 fichiers avec 612 règles, produit 74 constats et terminé avec le code 1. La chaîne en échec prouve ici le rétablissement du contrôle ; elle ne prouve pas la remédiation des 74 constats, dont le triage reste nécessaire.

Capture K23 --- spécification de prise

Vue : historique des exécutions de la chaîne de livraison applicative, filtré sur le flux qui porte la porte d'analyse statique, cadré sur deux lignes voisines et l'en-tête de colonnes.

Dates portées par la capture : 16/08/2026 et 19/08/2026, preuve d'archive.

Contenu probant : la seule chose que ce chapitre ne peut pas écrire — *qu'une porte inerte a l'air de fonctionner*. Ligne du 16/08 : toutes les tâches en succès, alors qu'aucune règle n'a été évaluée. Ligne du 19/08 : la même chaîne en échec après remise en service, exécution 32264602112.

Masquage : nom du dépôt et de l'organisation, courriels des auteurs de *commit*.

FIG. 25. Historique des exécutions de la chaîne de livraison applicative. À y lire, sur deux lignes voisines : le 16/08/2026, toutes les tâches en succès alors que la porte d'analyse statique n'évaluait aucune règle ; le 19/08/2026, la même chaîne en échec après remise en service. Le vert de la première ligne est l'objet de la preuve : c'est lui, et non un journal, qui montre qu'un contrôle inerte est indiscernable d'un contrôle qui passe.

Une règle de sortie qui n'aurait rien gouverné. Le refus par défaut en sortie figurait au plan de correction bien avant d'être posé, et la lecture croisée de la topologie et du paramétrage des charges a montré qu'il aurait été *sans effet*, pour la raison analysée en section 4.2.5 : le trafic ne passait pas là où la règle se serait appliquée. La correction a donc consisté à déplacer d'abord

le trafic, puis à l’observer sept jours, et à n’interdire qu’ensuite (section 5.3.3). La leçon est transférable telle quelle : **un contrôle qui ne voit pas passer le trafic n’est pas un contrôle, c’est une déclaration** — avant de mesurer l’efficacité d’une règle, il faut établir qu’elle est sur le chemin.

5.8.2 Planning de travail

La période de stage s’étend du 3 mars au 7 septembre 2026, et la figure 26 la couvre intégralement. Faute de journal quotidien avant le 29 juillet, ses barres n’affichent pas une fausse précision au jour près ; les losanges M1 à M7 renvoient à des jalons datés par une trace technique.

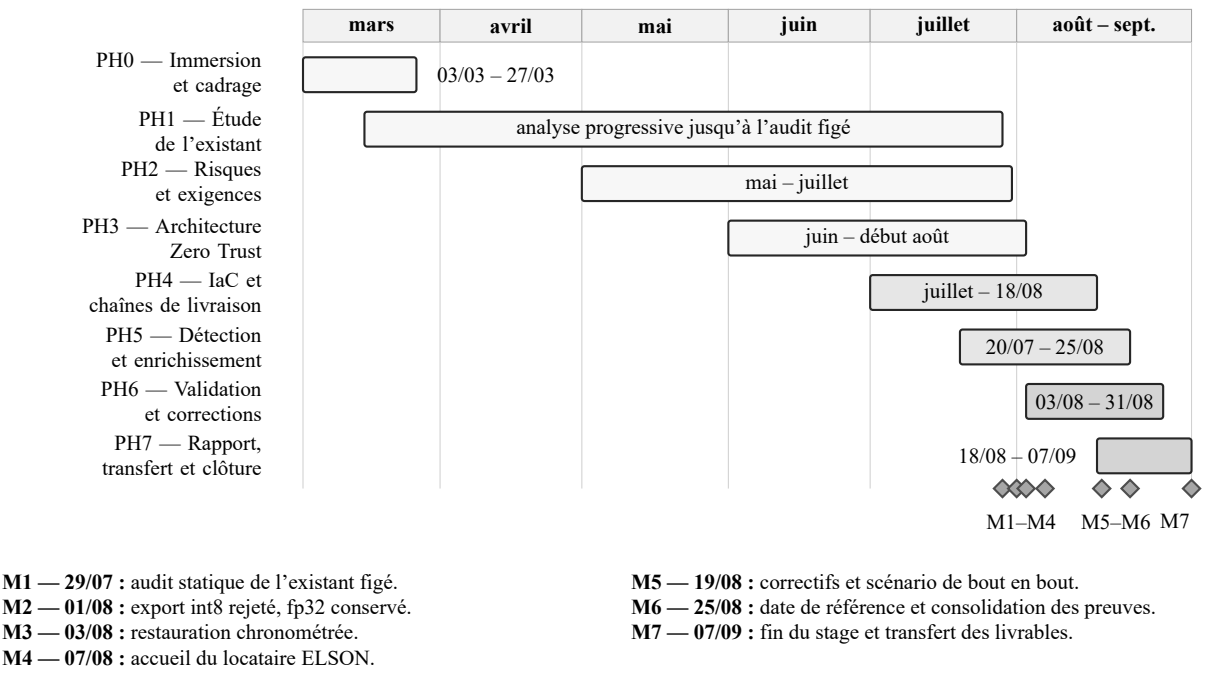


FIG. 26. Planning consolidé du stage, du 03/03/2026 au 07/09/2026. Les trois teintes de barre distinguent le cadrage (PH0–PH3), la construction (PH4–PH5) et la validation et la clôture (PH6–PH7). Les barres sont une reconstruction macroscopique ; les losanges signalent les jalons exactement datés, dont la légende donne la date une à une.

Conclusion du chapitre

L’infrastructure est décrite en code, et la frontière de ce principe est énoncée par six exceptions nommées plutôt que par une revendication d’exhaustivité. La chaîne de livraison compte trois portes bloquantes, cinq familles de contrôles réalisées et trois arbitrages assortis de leur condition de réévaluation ; une seule famille voit son résultat quitter la chaîne, ce qui rend la boucle F6 possible. La chaîne de provisionnement s’arrête volontairement avant l’application, dont l’automatisation exigerait une concentration de privilège que le chapitre 4 refuse, et le tableau de bord ne détient aucune autorisation propre. L’accueil du second locataire isole l’identité, les secrets, les données et, depuis la migration du 11 au 25/08/2026, le réseau ; le stockage reste partagé, faute qu’une seconde migration soit soutenable dans la même quinzaine par un opérateur unique. Deux limites restent assumées : deux charges conservent une sortie managée hors du pare-feu (T14, non conforme), et **l’enrichissement n’alimente pas le score d’incident**.

Chapitre 6 Validation, résultats et démonstration

Campagne de tests adverses, évaluation de la détection et mesures

Les chapitres précédents ont analysé, conçu et construit ; celui-ci mesure : une architecture Zero Trust ne se déclare pas, elle se démontre [27]. Les vingt tests de la section 6.2 sont ceux dérivés de l'analyse de risque du chapitre 3, et chaque mesure rapportée ici est soit une valeur relevée et datée, soit une propriété établie par une preuve nommée, jamais une estimation présentée comme mesurée. Le chapitre suit quatre axes — sécurité, détection, performance et résilience — puis énonce la frontière du service rendu.

6.1 Stratégie de validation

Chaque protocole reçoit l'un de quatre résultats, appliqués sans exception, y compris défavorables. **Conforme** : le critère d'acceptation est couvert *intégralement* par une preuve nommée — le plus souvent un refus effectivement observé, en direct ou par un test automatisé rejoué à chaque livraison ; par exception, un inventaire exhaustif lorsque le critère est lui-même un inventaire. **Partiellement conforme** : le critère est couvert en partie par une preuve nommée, la part non couverte étant écrite comme une borne du dispositif de mesure. **Non conforme** : le critère n'est pas tenu ; l'exigence associée redevient ouverte et le scénario de menace du chapitre 3 se rouvre avec elle. **Planifié** : le protocole relève du plan de validation continue (§6.2.3). **Aucun protocole ne porte ce résultat** à la date de 25/08/2026 ; la convention est néanmoins conservée telle qu'elle a été publiée — la retirer après coup reviendrait à ajuster la méthode au résultat obtenu.

Cette convention repose sur une hiérarchie de preuves déclarée à l'avance, qui tranche les cas limites. Rang 1, le **test automatisé rejoué à chaque livraison** : il établit la propriété *et* sa persistance, un tiers peut le contredire en relançant la chaîne, et il ne vaut que pour le chemin qu'il emprunte. Rang 2, le **refus réellement survenu en exploitation**, plus fort sur le fond puisque le contrôle a arrêté un cas non provoqué, mais non répétable à volonté. Rang 3, la **vérification en direct, datée**, qui établit un état à un instant et ne dit rien de la dérive ultérieure. Rang 4, la **configuration déclarée en code et vérifiée sur la plateforme**, qui établit ce que le système *est*, non ce qu'il *fait* sous contrainte. La capture d'écran ne figure pas dans cette échelle : elle restitue une preuve d'un des quatre rangs, elle n'en est jamais une.

Point de vigilance

Une preuve de rang 4 ne suffit jamais à prononcer « conforme », et le projet en a fait lui-même la démonstration : la porte d'analyse statique de la chaîne de livraison applicative était déclarée bloquante, correctement écrite, et n'évaluait plus aucune règle depuis au moins deux semaines sans jamais faire échouer la livraison (section 5.8.1). Une

porte déclarée n'est pas une porte vérifiée — d'où plusieurs protocoles dont le dispositif est en place et qui restent ici *partiellement* conformes.

Les mesures sont réalisées sur l'environnement de recette, représentatif de la cible décrite mais sans trafic d'utilisateurs réels (section 6.8). Les preuves ponctuelles sont datées jusqu'au 25/08/2026 ; les preuves automatisées sont rejouées à chaque livraison, sans date unique. Les protocoles, leurs critères d'acceptation formulés avant exécution et leurs réserves sont consignés en annexe E.

6.2 Résultats de la campagne de tests

Les vingt tests dérivés du chapitre 3 couvrent les quatre axes, le protocole T_n validant l'exigence EX_n de même rang (tableau 15). Chaque ligne du tableau 32 nomme la preuve invoquée et sa date, ou son mode d'exécution automatisée ; le protocole complet, son critère d'acceptation et la portée exacte de la preuve se lisent test par test en annexe E.

TAB. 32. Synthèse de la campagne de vingt tests, à la date de 25/08/2026. Le protocole T_n valide l'exigence EX_n de même rang ; « Partiel » : partiellement conforme

Test	Résultat	Preuve invoquée
T1	Non conforme	Injections SQL, script inter-sites et inclusion de fichier refusés en 403 le 23/08/2026 ; motif brut de traversée de chemin en 302, alors que le critère exige le refus de <i>toutes</i> les requêtes (§6.2.1)
T2	Conforme	Refus observé le 19/08/2026 : dix réponses 422 puis une 429 à la onzième tentative
T3	Partiel	Balayage tracé, journaux du répartiteur collectés sans filtre. <i>Réserve</i> : essai de charge non documenté
T4	Partiel	Inventaire : aucune adresse publique, accès par voie privée, transport chiffré imposé. <i>Réserve</i> : échec de connexion externe déduit de l'absence de route
T5	Conforme	Deux rôles exacts et usurpation refusée le 23/08/2026 ; test automatisé de lecture interdite d'un secret rejoué à chaque livraison
T6	Partiel	Test automatisé d'appel sans jeton, en porte bloquante ; entrée interne exclusive et invocation nominative. <i>Réserve</i> : l'appel vient de l'extérieur du réseau privé
T7	Conforme	Le critère est un inventaire, et il est vide : aucune clé de compte de service, fédération contrainte sur le dépôt <i>et</i> la branche. Garantie vérifiée, non préventive (écart É7)
T8	Conforme	Refus réellement survenu : la porte d'analyse a bloqué une livraison sur une vulnérabilité critique de <code>node-tar</code> 6.2.1, embarquée par l'image de base (§6.2.2)
T9	Partiel	Registre unique, résolution par empreinte sur le chemin de description en code. <i>Réserve</i> : aucun refus opposé ; application hébergée déployée par étiquette flottante (écart É8)
T10	Partiel	Porte de détection de secrets bloquante à chaque livraison, sur l'historique complet ; indépendance des secrets établie par inventaire. <i>Réserve</i> : aucun refus observé
T11	Conforme	Test de bout en bout automatisé tentant réellement l'écriture interdite dans la table de preuves sous l'identité d'enrichissement, rejoué à chaque livraison ; droits vérifiés table par table le 19/08/2026 (§6.2.2)
T12	Partiel	Alerte d'absence de trafic reçue le 22/08/2026, 36 min 19 s après l'interruption. <i>Réserve</i> : une route de journaux coupée 1 h 08 le même jour n'a ouvert aucune alerte et 1 148 requêtes n'ont laissé aucune trace
T13	Partiel	Journalisation d'audit des accès aux données activée en lecture et en écriture sur quatre services ; activité d'administration non désactivable. <i>Réserve</i> : rétention de trente jours non verrouillée, sans acheminement dédié
T14	Non conforme	Le 25/08/2026, une sonde portant la configuration réseau de la révision déployée atteint une destination externe en 412 ms ; le refus par défaut en sortie, vérifié le même jour sur le sous-réseau, ne s'applique pas au chemin du composant (§6.2.1)
T15	Partiel	22/08/2026 : 350 détections traitées en 7 exécutions, entrées égales aux sorties, durée maximale 96 s, coût dominé par le forfait de balayage. <i>Réserve</i> : 150 des 500 détections injectées sortent de la fenêtre de deux heures avant d'être lues, sans erreur ni trace
T16	Partiel	Mécanisme sollicité en conditions réelles le 08/08/2026, planification sans différence le 19/08/2026, contrôle quotidien de dérive de l'isolation. <i>Réserve</i> : aucune dérive planifiée sur l'infrastructure décrite en code
T17	Conforme	Quatre refus opposés le 20/08/2026 à trois identités de service, chacun nommant le droit manquant, avec contrôle positif. <i>Réserve</i> : emplacement de l'état provisionné hors description en code
T18	Partiel	Revue de fusion et application manuelle par l'administrateur. <i>Réserve</i> : aucune approbation outillée, aucun environnement protégé déclaré

Test	Résultat	Preuve invoquée
T19	Partiel	Deux notifications de budget reçues le 21/08/2026, seuils 90 % et 100 %, sur l’alerte déclarée dans le code d’infrastructure le 20/08/2026. <i>Réserve</i> : délai compris entre 5 h 48 et 8 h 18, et la notification ne nomme pas le poste de consommation
T20	Conforme	Le 24/08/2026, trois sorties refusées — externe, croisée entre locataires, et vers la base — avec les trois lignes de refus retrouvées dans l’entrepôt en 2 min 55 s à 4 min 12 s, les horodatages du refus et de l’échec client se recoupant à 10,3 s près

Bilan à la date de 25/08/2026 : 7 conformes, 11 partiellement conformes et 2 non conformes. Les vingt protocoles portent une preuve nommée, vérifiable et rattachée à une date ou à une exécution automatisée ; le plan de validation continue (section 6.2.3) ne porte plus des protocoles sans résultat, mais la cadence à laquelle six d’entre eux sont rejoués.

Ce bilan appelle une lecture méthodologique : les onze résultats partiels ne sont pas des demi-échecs, ce sont des propriétés établies dont une part précise du critère — le plus souvent la tentative négative depuis l’extérieur du périmètre, borne du dispositif de mesure énoncée en section 6.8.1 — n’a pas encore été mise à l’épreuve, et cette part est nommée ligne à ligne.

Une campagne sans non-conformité serait suspecte

Une campagne de vingt tests dont aucun n’échouerait indiquerait que les tests ont été choisis après coup, pour tomber juste. Ceux-ci ont été dérivés de l’analyse de risque du chapitre 3, *avant* la conception de l’architecture, et publiés avec leur critère d’acceptation. Les deux non-conformités, T1 et T14, sont la conséquence directe de ce choix de méthode : elles sont le prix, et la preuve, de l’antériorité des critères. T14 en est l’illustration la plus nette — son critère, écrit avant la refonte réseau, aurait été trivialement satisfait par une reformulation après coup en « absence de chemin public vers le composant ».

6.2.1 Les deux non-conformités assumées : T1 et T14

Le protocole T1 exige que *toutes* les charges d’attaque correspondant aux familles de règles activées au périmètre soient rejetées avant d’atteindre la charge de travail. Le 23/08/2026, les charges d’injection SQL, de script inter-sites et d’inclusion de fichier local ont bien reçu un refus en 403 ; une forme brute de traversée de chemin a reçu une redirection 302. Le critère n’est pas tenu, et le résultat est prononcé non conforme.

Le mécanisme n’est pas élucidé, et le mémoire le dit plutôt que de lui inventer une cause. L’hypothèse de travail est une normalisation d’URL effectuée en amont de l’évaluation des règles : la requête serait réécrite, puis redirigée, avant que le moteur de filtrage n’ait à se prononcer sur la forme brute qui devait le déclencher. Cette hypothèse est vérifiable, et sa vérification fait partie du correctif.

Le correctif est identifié et son ordre d’application est arrêté : activation des jeux de règles d’anomalie de protocole et d’application de méthode, d’abord en observation seule pour mesurer le volume de faux positifs sur le trafic de recette, puis en blocage une fois ce volume connu. L’ordre importe : passer directement en blocage sur un jeu générique échangerait une lacune de couverture contre une indisponibilité. Tant que ce correctif n’est pas appliqué et T1 rejoué, l’exigence EX1 reste ouverte et le scénario de menace SO1 avec elle.

T14 — une non-conformité produite par la refonte, non masquée par elle. Le protocole exige l'échec d'une connexion sortante émise depuis le composant d'encodage. Le 25/08/2026, deux sondes ne différant que par leur chemin de sortie ont été exécutées sous l'identité du composant : celle qui emprunte le sous-réseau et l'étiquette du composant a été refusée deux fois par la règle de refus par défaut en sortie, avec ses deux lignes de journal ; celle qui emprunte le chemin de la révision réellement déployée — sortie managée par la plateforme d'exécution, sans accès au réseau privé — a reçu un code 204 en 412 ms. La règle refuse ; le composant n'est pas derrière elle. Le composant a été retiré du sous-réseau les 12 au 14/08 au motif, exact, qu'il n'a aucune dépendance privée : ce motif justifiait le retrait pour la sortie *nécessaire*, non pour la sortie *possible*. Le correctif est identifié et son coût est d'une révision sans changement applicatif — réintégrer le composant au sous-réseau et lui poser une étiquette pour laquelle aucune règle d'autorisation de sortie n'existe — au prix de le rendre à nouveau tributaire de la disponibilité du sous-réseau. Il vaut identiquement pour l'interface web de l'application hébergée, seconde charge de travail à sortie managée non gouvernée. Tant qu'il n'est pas appliqué et T14 rejoué, l'exigence EX14 reste ouverte et le scénario de menace SO17 avec elle.

6.2.2 Deux preuves déterminantes et deux réserves levées

Deux des sept résultats conformes reposent sur des preuves d'une nature que le mot « test » recouvre mal, et qui portent plus loin qu'une capture d'écran.

T11 — le meilleur test de la campagne. Le principe cardinal de la chaîne de détection est que le moteur d'enrichissement ne doit pas pouvoir modifier les preuves qu'il analyse. Un test de bout en bout automatisé, rejoué à chaque livraison, le vérifie : sous l'identité de la tâche d'enrichissement obtenue par usurpation contrôlée, il exécute d'abord une lecture des détections — qui doit réussir, puisque la tâche lit pour enrichir — puis tente réellement l'insertion d'une ligne dans la table de preuves, et n'est vert que si cette insertion est refusée.

Aux deux propriétés du rang 1 il en ajoute une troisième, qu'aucune image ne possède : il a une histoire. Il échouait tant que la tâche d'enrichissement partageait son identité avec les requêtes planifiées de détection, qui doivent, elles, écrire dans cette table ; **la séparation des identités a été faite parce que le test échouait.** Un test qui a déjà fait corriger l'architecture qu'il vérifie mesure quelque chose. Sa portée s'énonce aussi précisément : il couvre la table des détections, en lecture autorisée et en écriture refusée, le refus sur les journaux bruts et le cas de la suppression étant établis par la vérification des droits table par table du 19/08/2026 ; et il s'abstient lorsque l'identité courante n'a pas le droit d'usurper l'identité restreinte — choix préféré à un vert obtenu avec les droits de l'opérateur, qui aurait mesuré la mauvaise identité.

T8 — un refus qui n'a pas été provoqué. La porte d'analyse de vulnérabilité de la chaîne de livraison applicative a réellement arrêté une livraison, sur une vulnérabilité critique de la bibliothèque d'archivage *node-tar* en version 6.2.1. Cette bibliothèque n'était pas une dépendance du code écrit : elle était embarquée par le gestionnaire de paquets présent dans l'image de base du tableau de bord, et le correctif retenu est instructif — retirer ce gestionnaire de l'image finale plutôt que tenter de mettre à jour une dépendance transitive dont le projet n'est pas propriétaire. Ce refus n'a pas été mis en scène, il est survenu sur le code de l'auteur, et il a modifié la façon de construire les images. La réserve qui l'accompagne — l'image est publiée au

registre *avant* d’être analysée, de sorte que la porte bloque le déploiement et non la publication — est établie avec son correctif en section 5.2.

Deux réserves de conception levées en cours de campagne. La tâche d’enrichissement a reçu une identité dédiée, limitée en lecture au jeu de données de supervision et en écriture à sa seule table de résultat — correction vérifiée par T11 et par la vérification des droits de T5 ; T14 relève d’une autre propriété, que cette correction ne touche pas (section 6.2.1). La journalisation des refus du pare-feu a été activée et vérifiée le 19/08/2026, ce qui clôt l’écart É1 : c’était la condition de recevabilité de T20, relevé le 24/08/2026 une fois le refus par défaut en sortie posé.

6.2.3 Plan de validation continue

Six protocoles — T12, T14, T15, T17, T19 et T20 — portent un premier relevé daté entre le 20 et le 25/08/2026 et une **cadence de rejeu**. Le plan est distinct de la campagne par sa nature : celle-ci établit qu’un dispositif tient au moment où il est construit, celui-là qu’il tient encore après avoir évolué. Ces six-là y figurent parce que la propriété qu’ils vérifient est celle qui se dégrade — un seuil qui dépend du volume, une règle de pare-feu qu’une révision peut contourner, un droit sur un emplacement provisionné hors code : le plan est structuré par la fréquence de dérive du contrôle vérifié, non par la commodité (tableau 33).

TAB. 33. Plan de validation continue : premier relevé et cadence de rejeu

Test	Propriété vérifiée	Premier relevé	Cadence de rejeu	Déclencheur additionnel
T12	Détection d’une interruption de collecte	22/08/2026	Trimestrielle	Toute modification d’un acheminement de journaux
T14	Absence de sortie réseau du composant d’inférence	25/08/2026	Trimestrielle	Application du correctif : réintégration du composant au sous-réseau
T15	Tenue de la chaîne d’enrichissement sous charge	22/08/2026	Trimestrielle	Changement de modèle, de taille de lot ou de cadence de la tâche
T17	Protection de l’état de l’infrastructure	20/08/2026	Semestrielle	Tout changement d’emplacement ou de droits sur l’état
T19	Détection d’une consommation anormale	21/08/2026	Trimestrielle	Toute révision du montant ou des seuils du budget déclaré
T20	Restriction des sorties réseau	24/08/2026	Trimestrielle	Ajout d’un locataire ou d’une destination externe autorisée

Le premier rejeu de l’ensemble est fixé au quatrième trimestre 2026. Les trois prérequis identifiés avant la campagne ont été levés, et leurs dates comptent autant que les résultats : refus de sortie par défaut posé le 23/08/2026, alerte de budget déclarée en code le 20/08/2026, journalisation des refus réseau acquise depuis le 19/08/2026. L’attendu des six avait été écrit avant exécution (annexe E) et confronté au relevé sans être ajusté : c’est ce qui donne son poids au seul de ces six qui échoue.

6.3 Évaluation de la chaîne de détection et de l’enrichissement

6.3.1 Couverture obtenue

Les deux précautions qu’appelle toute mesure de couverture — dénominateur restreint aux plateformes concernées, taux rapporté à une version précise du référentiel — sont établies en section 2.3.2 [21, 32]. Ce que la mesure ajoute ici est l’**empreinte de l’instantané employé** : 872 vecteurs couvrant 697 techniques et sous-techniques réparties sur **quinze tactiques**, dont

TA0005 renommée « Stealth » et TA0112 « Defense Impairment », issue du découpage de l'ancienne « Defense Evasion » — de quoi retrouver la version Entreprise employée et reproduire le dénominateur. *Réserve* : le script de chargement tire le lot depuis la branche courante du dépôt public de MITRE, sans épingleage, de sorte que l'instantané est daté par son chargement et non fixé par une référence immuable ; le tableau de bord joint par *nom* de tactique, ce qui rend un renommage visible plutôt que muet.

Sept règles de détection sont actives (R1 à R7, chacune adossée à une requête planifiée), plus cinq requêtes de normalisation. Faute d'inventaire versionné des techniques applicables, ni taux ni graphique de couverture ne sont publiés : le nombre de règles actives n'est pas assimilé à un taux de couverture ATT&CK.

6.3.2 Ce que le système ne détecte pas

L'objectif O4 engage explicitement le mémoire à publier ce que le socle ne détecte pas. Le tableau 34 tient cet engagement, cause par cause. Deux de ces lacunes sont structurelles et se retrouvent en section 6.6 : la chaîne de détection n'observe que des signaux de transport, et une seule personne traduit les règles.

TAB. 34. Causes connues de non-couverture, à la date de 25/08/2026

Cause	Origine	Conséquence
Refus réseau tracés mais non qualifiés	Refus en sortie et refus croisés journalisés et retrouvables (T20, 24/08/2026), qu'aucune des sept règles ne lit	Un mouvement latéral refusé est <i>tracé</i> , il n'est pas <i>détecté</i> : ni détection, ni score, ni ligne au tableau de bord
Plafond de traduction manuelle	Une seule personne traduit les règles publiques	Couverture bornée par le volume maintenable ; exhaustivité non revendiquée
Absence de trafic réel	Environnement de recette sans usage réel	Seuils comportementaux non calibrables
Exfiltration	Aucune règle dédiée au canal sortant ; seuls les refus sont journalisés, par décision de coût, et deux charges conservent une sortie managée non gouvernée (T14, 25/08/2026)	Un transfert sortant <i>réussi</i> vers une destination autorisée n'est qualifié par rien, et l'autorisation qui rend l'entrepôt joignable rend joignable tout entrepôt du même fournisseur
Abus des droits et du plan de contrôle	Règles concentrées sur le filtrage applicatif et le transport	Élévation de privilège et modification de politique d'accès non couvertes
Logique métier de l'application hébergée	La chaîne n'observe pas les actions fonctionnelles de l'application	Un abus commis par un compte légitime reste invisible (§6.6)
Seuils codés en dur	Paramètres intégrés aux requêtes	Adaptation au volume réel lente et peu traçable
Absence de test unitaire par règle	Validation surtout par scénarios de bout en bout	Régression d'une règle difficile à isoler

6.3.3 Qualité du signal, délai, et enrichissement sémantique

Le volume d'alertes, le taux de faux positifs et les délais médian et maximal ne sont pas établis par une campagne suffisamment large ; le scénario du 19/08 fournit une observation ponctuelle. La règle R2, exécutée toutes les cinq minutes sur une fenêtre de quinze minutes, a produit une

alerte environ quinze minutes après les requêtes, et la tâche d'enrichissement s'exécute toutes les 15 min — cadences de planification, non bornes garanties du délai de bout en bout. Le délai tient à la nature de la règle (section 5.4) : R2 agrège avant de décider et sa fenêtre absorbe la latence d'ingestion, si bien que le délai attendu est voisin de la fenêtre et non de la cadence de réévaluation. Une conséquence borne l'interprétation de tout délai mesuré : aucune politique d'alerte n'étant branchée sur la table des détections, la chaîne se termine par un écran et le délai perçu dépend de la présence de l'analyste devant le tableau de bord — premier des trois seuils de section 6.7.

L'évaluation de l'enrichissement répond au verrou V3 du chapitre 2 : les modèles de rapprochement sémantique sont habituellement évalués sur des textes bien formés, non sur des alertes courtes et bruitées. Une limite la précède : l'enrichissement n'alimente pas le score d'incident (section 5.5.1), et son effet sur la priorisation n'est donc pas évaluable. Ce qui est mesurable rigoureusement est la qualité du rattachement d'une alerte à une technique, comparée à deux méthodes de référence plus simples — correspondance par mots-clés (M0) et similarité par pondération de termes sans apprentissage de domaine (M1) — face à la méthode retenue (M2) ; protocole, jeu d'évaluation et grille de résultats figurent en annexe F.

L'enrichissement reste utile sans cette jointure, puisqu'il fournit à l'analyste, depuis chaque alerte, une technique candidate et la procédure d'incident associée — seule forme sous laquelle il l'atteint, et que la figure 27 montre à l'écran. En l'absence de mesure comparative, le rapport se garde en revanche d'affirmer ce rattachement assez précis pour être automatisé dans le calcul de priorité — l'objectif O5 avait par avance admis qu'un résultat négatif serait rapporté tel quel. Une validation distincte, déjà exécutée, mérite d'être signalée sans s'y substituer : un export quantifié du modèle a été rejeté après un contrôle d'accord de classement mené le 1^{er} août 2026 — 0 correspondance de premier rang sur 5 requêtes face au modèle de référence — et le format non quantifié a été conservé en recette, au prix d'une empreinte mémoire plus élevée. Ce petit échantillon invalide cet export précis ; il ne démontre ni la qualité générale du modèle retenu ni sa supériorité sur M0, M1 ou M2.

Cadre de capture K33 --- spécification de prise

Vue : fiche d'incident du tableau de bord, une entité agrégée sélectionnée depuis la page *Incidents*, la tâche d'enrichissement ayant tourné sur la fenêtre courante. **Date de prise** : relevée au rejeu, et portée dans la légende.

Ce que le cadre établit : ce que l'enrichissement rend à l'analyste — la technique candidate et son score de similarité affichés à côté de l'alerte, la jauge de score d'incident et la chronologie de l'entité. Il établit du même coup la borne rapportée au même endroit : le score de la jauge ne dépend pas du candidat sémantique affiché.

Masquage : identifiant de projet, adresses réelles.

FIG. 27. Fiche d'incident du tableau de bord. À y lire : la technique candidate et sa similarité affichées à côté de l'alerte — c'est la seule forme sous laquelle l'enrichissement atteint l'analyste — et la jauge de score, calculée sans ce candidat, qui rend visible l'écart d'architecture énoncé au même endroit.

La boucle reliant les vulnérabilités livrées aux techniques observées se mesure par une question unique : l'ordre de priorité qu'elle produit diffère-t-il de l'ordre par gravité théorique seule ? Y répondre suppose un rattachement des vulnérabilités aux techniques, dont le champ est laissé vide par le script de chargement. F6 est donc un prototype dont la chaîne fonctionne de bout en bout — les constats remontent réellement dans l'entrepôt et s'affichent — mais dont la priorisation n'est pas validée : **la boucle transporte la donnée, elle n'en tire pas encore d'ordre.**

6.4 Performance, résilience et coût

6.4.1 Objectifs de service

Quatre objectifs de service sont configurés sur trente jours glissants : disponibilité et latence, pour la plateforme et pour l'application hébergée [14]. La disponibilité est fixée à 99 % — budget d'erreur de 7 h 12 sur 30 jours — et la latence à 95 % des requêtes sous 1 s. Deux décisions de conception les accompagnent, justifiées dans le code : les erreurs clientes sont exclues du numérateur de disponibilité, car compter un refus d'authentification comme une indisponibilité ferait chuter l'objectif précisément quand la plateforme fait son travail ; et le seuil de latence a été relâché de 800 ms à 1 s en conséquence du choix de réduire à zéro le nombre d'instances actives hors trafic — **un seuil que l'on sait déjà intenable ne mesure rien, il apprend seulement à ignorer l'alerte.** Ce sont des objectifs configurés, non atteints, faute de trafic réel (section 6.8) ; la seule observation disponible porte sur 48 heures relevées le 07/08/2026, où la latence au 95^e centile de l'API est restée entre 9,5 ms et 1004 ms, un seul point au-dessus de 800 ms — fenêtre trop courte pour valider l'objectif, ordre de grandeur tenu en recette.

Observabilité de sécurité et observabilité d'exploitation. Les deux ne sont pas au même stade et les confondre serait surestimer le résultat. L'*observabilité de sécurité* est réalisée et démontrée : collecte filtrée F4, sept règles actives, table d'indicateurs agrégés (volume, erreurs, latence, blocages), et un scénario complet vérifié le 19/08/2026. L'*observabilité d'exploitation* est configurée sans être éprouvée : **dix-sept politiques d'alerte réparties en onze familles** — des taux d'erreur et de latence à l'arrêt de l'ingestion et à la dérive de l'isolation entre locataires — déclarées en code et acheminées vers un canal de notification, complétées par **deux sondes de disponibilité** interrogeant les points de santé de l'API et de l'application hébergée, seuls signaux de vivacité indépendants du trafic.

Trois de ces politiques ont depuis été provoquées et portent leur mesure datée au tableau 32 : absence de trafic (T12), retard d'enrichissement ouvert sans avoir été provoqué (T15), budget de facturation (T19). Deux bornes subsistent et portent le même défaut : les quatorze autres politiques n'ont jamais été déclenchées, et les quatre objectifs de service restent mesurés sans être actionnés, faute de politique d'alerte sur la consommation de leur budget d'erreur.

Le démarrage à froid du composant d'encodage sémantique porte une mesure réelle de début août 2026 (figure 28) : moyenne ≈ 27 s, pic ≈ 94 s, très au-dessus de l'estimation de conception, de l'ordre de deux à quatre secondes — conservée plutôt que corrigée en silence, pour que l'écart au mesuré reste lisible (incident et traitement en section 5.8.1). Le tableau de bord présente un

profil plus favorable : environ 10,5 s le 07/08/2026, dominées par l’initialisation de la plateforme d’exécution et non par le code.

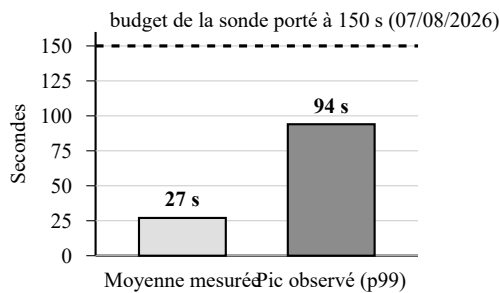


FIG. 28. Démarrage à froid du service d’encodage : moyenne et pic mesurés début août 2026, comparés au budget de la sonde de disponibilité.

6.4.2 Reproductibilité et résilience

La reconstruction complète d’un environnement depuis le seul dépôt répond au constat d’infrastructure non reproductible du chapitre 1, et deux questions s’y distinguent. La **capacité** est acquise : la recette a été construite, puis reconstruite, à partir du seul code d’infrastructure — c’est ce qui fonde la réponse à O2. Sa **mesure**, durée de bout en bout en une exécution continue, relève du plan de validation continue à cadence semestrielle et sera exécutée en direct en soutenance. *Réserve* : le fichier de variables de l’environnement n’est pas versionné, de sorte qu’une reconstruction depuis un poste neuf ne reproduit pas encore l’environnement à l’identique — le versionner, ce fichier ne contenant aucun secret, est le correctif de reproductibilité le plus rentable identifié et le prérequis de la mesure. La restauration de la base, elle, a été exécutée et chronométrée (tableau 35).

TAB. 35. Restauration de la base de données — test réel exécuté le 3 août 2026

Grandeur	Valeur mesurée
RTO (durée de l’opération de restauration)	32 min 45 s (opération de clonage, de 11:16:40 à 11:49:26 UTC, instance d’entrée de gamme, 10 Go)
RPO (perte de données au point demandé)	0
Résultat au point demandé	314 lignes attendues, 314 restaurées, aucune manquante ni en trop ; les trois écritures postérieures au point de restauration correctement absentes
Dispositif de sauvegarde	7 jours de journaux de transactions conservés en continu ; 7 sauvegardes complètes, quotidiennes à 02:00 UTC
Portée de la mesure	Configuration zonale, antérieure au passage en haute disponibilité régionale du 08/08/2026 ; mesure à revalider sur la configuration actuelle

Le RTO déclaré ne couvre que le clonage technique : détection, décision et bascule applicative, non chronométrées séparément, portent l’estimation de bout en bout entre 45 min et 1 h. Une précision d’exploitation a des conséquences contractuelles : la même instance héberge les deux bases, si bien qu’un clone de restauration les restaure ensemble. Le retour arrière applicatif par révision est mesuré le 07/08/2026 sur l’API en recette : **11,6 s** vers la révision précédente, **16,5 s** au retour, l’écart tenant à un démarrage à froid — mesure non répétée, ni le

nombre de séries ni le délai de validation humaine n'étant documentés, donc ordre de grandeur et non objectif de rétablissement.

Le mécanisme de détection de dérive [17] (section 5.1.2) a été sollicité en conditions réelles début août 2026, lors de l'incident de chiffrement géré par le client. Cet épisode ne vaut pas T16 corrigé, une ressource créée hors état échappant à la seule planification. Le seul contrôle de dérive *planifié* est d'une autre nature — la tâche quotidienne qui vérifie la persistance du durcissement de l'isolation entre bases (section 5.7) — et c'est un aveu d'architecture autant qu'un contrôle : une propriété qu'il faut surveiller quotidiennement n'est pas déclarative.

6.4.3 Coût réel

Aucune ventilation mensuelle vérifiable par poste n'existe dans les sources, et aucun relevé de facturation ventilé n'est donc publié. Un fait reste sourcé : le document d'architecture du projet situe le coût au niveau des paliers gratuits, à quelques dizaines d'euros par mois, désigne l'ingestion de journaux comme poste dominant et confirme l'absence de processeur graphique et de base vectorielle facturée séparément — constat interne daté, non relevé de facturation. Trois constats datés le complètent (tableau 36).

TAB. 36. Constats de coût datés, statut à la date de 25/08/2026

Poste et statut	Constat daté	Direction de remédiation
Services d'exécution — corrigé	Instance maintenue active en permanence, donc coût continu sans contrepartie en recette ; réglage hérité jamais déclaré	Nombre minimal d'instances ramené à zéro hors trafic, arbitrage coût contre latence déclaré
Requêtes planifiées de l'entrepôt — ouvert	≈ 78 Go/j facturés pour 24 Mo de données : minimum forfaitaire par table balayée × exécutions quotidiennes	Réduire le nombre d'exécutions facturées plutôt que le volume : fusionner les sept requêtes en une seule passe, restreindre le balayage aux partitions de la fenêtre utile, et n'espacer la cadence qu'en dernier recours, une cadence plus lente dégradant le délai de détection
Haute disponibilité base de données — appliqué	Bascule régionale appliquée et confirmée en direct le 08/08/2026 ; basculement de zone jamais provoqué	Provoquer un basculement de zone en fenêtre maîtrisée et le chronométrer, seul moyen d'établir le gain payé

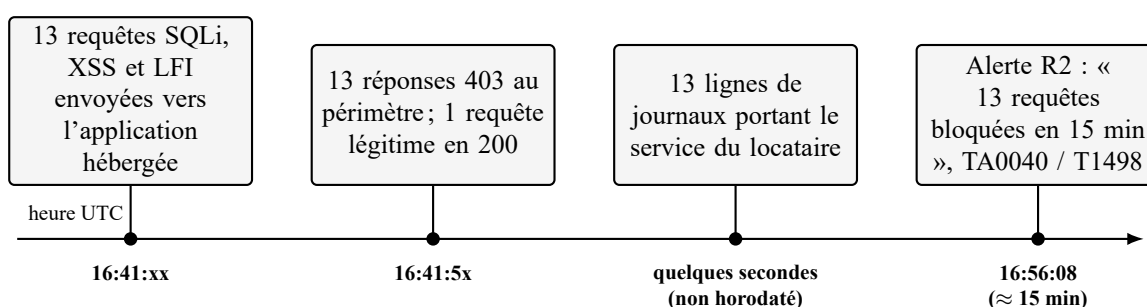
Deux conséquences que le tableau ne porte pas. Le volume facturé venant du minimum forfaitaire et non des données, *une réduction de rétention n'aurait ici aucun effet sur la facture*. Et le dimensionnement est incohérent, ce qui se dit franchement : l'instance retenue est de gamme partagée, déconseillée en production, tout en étant facturée au tarif de la haute disponibilité régionale — appliquée en 11 min 2 s le 08/08/2026, dont la preuve *dynamique* suppose un basculement de zone provoqué, porté par le plan de validation continue. Aucune des trois directions n'est appliquée à la date de 25/08/2026 : elles sont énoncées comme suite à donner, non comme correction acquise.

Faute de volume représentatif et de grille tarifaire datée, l'alternative commerciale étudiée au chapitre 2 n'est pas chiffrée. La comparaison *qualitative* reste instructive : les deux options partagent la même variable dominante, l'ingestion, que la solution commerciale facture avec un abonnement plancher et dont le socle se passe, aux volumes de la recette, dans les paliers

gratuits du fournisseur. **L'écart de structure compte plus que l'écart de montant** : on achète dans un cas un service exploité par un tiers, dans l'autre du temps d'ingénieur et une dette de maintenance — dont le plafond de règles traduisibles par une personne est la contrepartie.

6.5 Démonstration de bout en bout et conformité aux référentiels

Le 19/08/2026, un scénario d'attaque complet a été exécuté en recette : il combine les preuves de cinq domaines — identité, périmètre, cloisonnement des données, supervision et chaîne de livraison — en une démonstration continue que la figure 29 déroule de l'attaque à l'alerte qualifiée ; les treize requêtes mêlaient injections SQL, script inter-sites, inclusion de fichier local et accès à des fichiers sensibles. Cette observation ponctuelle ne mesure pas le taux de faux positifs, qui n'a pas été établi.



Échelle non linéaire. L'étiquetage TA0040 / T1498 est celui produit par la règle ; une qualification par T1190 serait plus plausible pour ces charges et doit être revue par l'analyste. L'enrichissement disponible datait de 12:16:15 : il n'enrichit pas cette alerte.

FIG. 29. Scénario de bout en bout du 19/08/2026 : de l'attaque à l'alerte qualifiée

L'alerte R2 du 19/08/2026 à 16:56:08 UTC est le dernier maillon de la chaîne : elle compte treize requêtes bloquées sur sa fenêtre de 15 min et les attribue au locataire — attribution qui est l'exception plutôt que la règle (section 6.7). Deux contrôles complémentaires ont été relancés en direct le même jour : le contrôle d'isolation entre bases a produit **six vérifications** toutes en échec comme attendu — une connexion croisée depuis l'utilisateur d'un locataire vers la base de l'autre, réellement tentée et rejetée — et le compte de service du second locataire dispose exactement de deux rôles, sans droit sur l'entrepôt. Le dernier rattachement sémantique disponible, daté de 12:16:15 UTC, présente une similarité de 0,698 avec T1556.003 : précédant l'attaque de plus de quatre heures, il atteste le fonctionnement antérieur du composant, pas l'enrichissement de l'alerte R2.

6.5.1 Correspondance avec les preuves de soutenance, et bornes du scénario

Le scénario ne vaut comme démonstration que s'il se rattache aux résultats du rapport, et les cinq preuves attendues en soutenance s'y retrouvent chacune : le **périmètre** par les treize requêtes bloquées en 403 (§4.4, test T1) ; l'**identité** par les deux rôles exacts et l'usurpation refusée (§4.6, test T5) ; le **cloisonnement des données** par les six vérifications d'isolation sur six (section 5.7, test T11) ; la **supervision** par l'alerte R2 de 16:56:08 UTC, dont la qualification doit être revue par l'analyste (section 5.4) ; et la **chaîne de livraison** par l'exécution réelle de l'analyse statique, en échec sur 74 constats (section 5.2, incident de la porte inerte ; test T8). Trois

points restent hors du périmètre du scénario, tous rattachés à des protocoles de la campagne : la ségrégation réseau entre locataires, écart documenté en section 6.7 ; le motif brut de traversée de chemin (§6.2.1) ; et les constats d'analyse statique — 74 constats et une tâche en échec le 19/08, dont la remédiation complète n'est pas démontrée.

6.5.2 Conformité aux référentiels et maturité Zero Trust

Le positionnement par rapport aux principes Zero Trust [10] et au référentiel de configuration est celui du chapitre 4 : ni certification, ni audit exhaustif, et aucun taux global sans grille contrôle par contrôle. Trois des onze écarts du chapitre 4 touchent cette campagne, et les trois sont clos : journalisation des refus réseau (É1) et identité partagée du composant d'encodage (É3), traitées en section 6.2.2 ; deux sous-réseaux inutilisés (É2), retirés le 24/08/2026 (section 5.3.3). Le mémoire prononce en revanche lui-même son niveau de maturité pilier par pilier, avec une justification chiffrée et un résultat *asymétrique* (tableau 37) : **un profil uniformément élevé serait un profil complaisant**, les piliers ne progressant jamais au même rythme parce qu'ils ne coûtent pas le même prix.

TAB. 37. Auto-évaluation sur le modèle de maturité Zero Trust, à la date de 25/08/2026

Pilier	Niveau	Justification chiffrée et borne du niveau
Identités	Avancé	Sept identités de service distinctes, aucun rôle primitif sur 53 fichiers de description d'infrastructure, aucune clé de compte de service, fédération contrainte sur le dépôt <i>et</i> la branche, jetons courts, second facteur temporel sur le tableau de bord. <i>Borne</i> : second facteur résistant à l'hameçonnage, codes de secours, garantie préventive par politique d'organisation
Terminaux	Traditionnel	Aucune notion d'appareil dans toute la chaîne : ni inventaire, ni certificat client, ni signal de posture ; le seul attribut de contexte est le pays d'origine. C'est le pilier vide du modèle , par absence de périmètre administratif et non par oubli
Réseaux	Initial à avancé	Nord-sud solide : filtrage applicatif appliqué, transport chiffré imposé, entrée des services restreinte au répartiteur, base sans adresse publique. Est-ouest refondu du 11 au 25/08/2026 (décision D15, section 4.2.5) : un sous-réseau par locataire, refus par défaut en sortie posé le 23/08/2026, cinq autorisations seulement, chacune ciblée par une identité de service et par un port, aucune plage source ; la règle interne permissive a été supprimée le 24/08/2026 et le connecteur partagé le 15/08/2026. Un refus croisé entre locataires a été réellement opposé et journalisé le 24/08/2026 (T20, conforme). <i>Borne</i> : deux charges de travail détachées du sous-réseau conservent une sortie managée hors de portée du pare-feu (T14, non conforme, 25/08/2026) ; aucune règle de détection ne lit les refus journalisés ; l'instance de base de données reste jointe par les deux locataires
Applications et charges de travail	Avancé	Entrée par le répartiteur seule sur tous les services, composant d'encodage en accès interne strict, contrôle des rôles vérifié en direct sur les sept routes serveur, en-têtes de sécurité durcis, conteneurs sans privilège, porte d'analyse d'image bloquante et <i>éprouvée</i> (T8). <i>Borne</i> : documentation d'interface publique, droit d'invocation anonyme adossé au seul contrôle de périmètre
Données	Initial à avancé	Chiffrement par clé gérée sur l'entrepôt, les secrets et le stockage d'objets ; séparation d'écriture par table <i>vérifiée par test automatisé</i> (T11) ; rétention de 90 jours sur les journaux bruts ; restauration mesurée à 32 min 45 s avec perte nulle. <i>Borne</i> : chiffrement non rétroactif sur les tables de preuves antérieures, aucune protection contre la suppression, et trois seulement des dix tables de l'entrepôt portent une clé d'application, une seule la portant renseignée sur la totalité de ses lignes (tableau 27)
Visibilité et analyse	Avancé	Quatre acheminements de journaux, trafic du répartiteur collecté sans filtre, sept règles de détection avec étiquetage de technique, enrichissement sémantique, et un tableau de bord qui affiche aussi les <i>non</i> -détections
Automatisation et orchestration	Initial à avancé	Infrastructure décrite en code à l'exception du nom de domaine ; chaîne de livraison fédérée sans clé ; requêtes planifiées et contrôle de dérive quotidien de l'isolation. <i>Borne</i> : infrastructure appliquée manuellement, sans planification en chaîne ni détection de dérive programmée — le maillon le moins mature (T16, T18)
Gouvernance	Initial	Dix-sept décisions d'architecture datées et un registre d'écarts tenu sans complaisance. <i>Borne</i> : aucune politique d'organisation, aucun processus de révision périodique des règles de filtrage par pays

La formulation à défendre tient en une phrase : le socle met en œuvre un Zero Trust *nord-sud* mature — identité, périmètre, charges de travail — et un est-ouest gouverné par l'identité *au plan réseau* depuis le 25/08/2026, mais non au plan du stockage, où l'instance de base de données et l'entrepôt restent communs aux deux locataires. Ce qui reste périmétrique l'est par contrainte de périmètre, tracée en décision : sans organisation au sens du fournisseur, ni politique d'organisation, ni périmètre de service, ni accès conditionnel géré ne sont disponibles. Le seuil de rupture de ce compromis est l'accueil d'un troisième locataire.

6.6 Ce que le filtrage applicatif ne protège pas

Un chapitre de validation qui n'énoncerait que ce qui fonctionne validerait mal. Deux limites du socle sont structurelles : elles ne se corrigent pas par un réglage, et elles délimitent exactement ce qu'un hébergeur peut promettre.

6.6.1 Invisibilité d'une faille de logique métier

Le risque le plus concret porté par l'application hébergée est le suivant : le signalement d'une phrase du corpus la désactive aussitôt, sans quorum. Un contributeur authentifié, agissant dans son quota, peut donc désactiver le corpus phrase par phrase — l'actif économique de l'application — en émettant des requêtes parfaitement bien formées.

Ce que voit le socle se résume en un mot : rien. Le filtrage applicatif observe du trafic légitime — méthode autorisée, chemin fonctionnel, charge utile sans motif d'attaque — et aucune des sept règles de détection ne se déclenche : R1 compte les refus d'authentification, or l'utilisateur est authentifié ; R2 compte les blocages du filtrage, or il n'y en a aucun ; R3 cherche des séquences de traversée de chemin, absentes ; R4 cherche des agents utilisateurs scriptés, et le service de l'application hébergée en est de toute façon explicitement exclu ; R5 surveille la latence, inchangée ; R6 cherche des motifs d'injection, absents ; R7 surveille l'accès à des fichiers sensibles, non sollicités.

La conclusion s'écrit telle quelle : **un filtrage applicatif ne corrige pas une faille de logique métier, et une chaîne de détection fondée sur des signaux de transport ne la voit pas**. Le socle n'observe ni les actions fonctionnelles de l'application, ni son modèle d'autorisation, ni ses invariants métier. Le correctif — un quorum avant désactivation — est une migration applicative et appartient à l'éditeur : c'est la justification concrète de la frontière de responsabilité de tableau 31, conséquence de ce qu'un dispositif de transport peut observer.

6.6.2 Portée de la limitation de débit au bord

La seconde limite est du même ordre. La limitation de débit posée au périmètre est indexée sur l'adresse source : efficace contre une salve provenant d'une adresse unique, ce que T2 a vérifié, elle est sans effet contre un adversaire distribué qui répartit le même volume sur assez d'adresses pour que chacune reste sous le seuil.

Le symétrique est plus gênant encore, et il a été rencontré. Là où de nombreux abonnés partagent un petit nombre d'adresses publiques de sortie — situation courante sur les réseaux

mobiles du pays visé par l'application hébergée, et anticipée par son éditeur — un seuil par adresse frappe des utilisateurs légitimes : le compteur agrège des personnes différentes. C'est la généralisation de l'incident rapporté en section 5.6.3, dont la formulation est que *le contrôle mesure la mauvaise entité*. Tant que la limitation reste au bord, la resserrer bloque davantage d'utilisateurs légitimes sans gêner l'adversaire distribué, et la relâcher fait l'inverse : la sortie du compromis n'est pas un meilleur seuil, c'est une limitation portée par l'identité, donc côté application, ou indexée au bord sur un jeton de session — ce qui suppose que le bord sache lire cette session.

6.7 Du socle au service

Le chapitre 1 posait le socle comme un produit potentiel, non comme un exercice. Cette section en tire le bilan avec les mêmes exigences de preuve que le reste du chapitre : ce que le socle apporte sans modification de l'application hébergée, ce qu'il n'apporte pas, ce que coûte l'accueil d'une application supplémentaire, et à quelles conditions l'ensemble deviendrait contractualisable.

6.7.1 Apport du socle et charge de l'éditeur

L'accueil de l'application pilote a servi de test grandeur nature de la proposition de valeur. Sont apportés automatiquement, sans une ligne de code applicatif : le certificat de transport et sa redirection, une adresse d'entrée unique, le filtrage applicatif et sa limitation de débit anti-force-brute avec bannissement, la journalisation centralisée et sa normalisation, les sept règles de détection avec leur étiquetage de technique, l'enrichissement sémantique, la restitution dans le tableau de bord, les alertes d'exploitation, une identité de service dédiée à moindre privilège, un secret par usage chiffré par clé gérée, une base et un espace de stockage dédiés, et une chaîne de livraison avec détection de secrets, analyse statique et double analyse d'image bloquante.

Une preuve précise vaut mieux qu'un argument général. L'application hébergée protégeait ses accès d'administration par une liste d'adresses autorisées, lue depuis un en-tête de proxy propre à son hébergeur précédent ; derrière le répartiteur du socle, cet en-tête devient forgeable par le client, et le contrôle d'administration se serait effondré silencieusement au moment de la migration. Il a été corrigé pendant l'accueil, par un arbitrage explicite de l'en-tête de confiance selon l'hébergeur, et le correctif est protégé par un test unitaire érigé en porte bloquante. **Changer d'hôte peut casser un contrôle de sécurité, et seul un socle qui l'a anticipé le rattrape.**

Ce qui incombe à l'éditeur. La frontière est établie au chapitre 5 (tableau 31) ; ce qu'elle exclut du périmètre de l'hébergeur tient en six domaines : authentification et autorisation des utilisateurs finaux — le second facteur du socle protège les comptes du tableau de bord, pas les utilisateurs de l'application hébergée — validation des entrées, le filtrage ne traitant que les charges connues, sécurité de la logique métier, structurellement invisible (§6.6), chiffrement applicatif des données sensibles, sauvegardes applicatives, et conformité réglementaire, pour laquelle le socle fournit des moyens techniques et non une gouvernance. La ségrégation réseau entre applications hébergées appartient en revanche à l'hébergeur et est couverte au plan réseau

depuis la migration du 11 au 25/08/2026 ; ce qui lui incombe encore est le cloisonnement de la donnée, troisième seuil énoncé plus bas.

6.7.2 Coût d'accueil d'une application supplémentaire

Le coût d'accueil d'une troisième application est mesuré (tableau 38) ; la colonne d'automatisation est la seule qui compte pour un raisonnement de produit, car elle sépare ce qui passe à l'échelle de ce qui exige un geste humain non versionné, donc non auditable.

TAB. 38. Coût d'accueil d'une application hébergée supplémentaire, à la date de 25/08/2026

Nature	Détail	Automatisé ?
Un fichier de description (≈ 120 lignes)	Sur le modèle de celui du locataire existant	Recopie, module réutilisable
Cinq variables d'environnement	À mettre à jour ensemble ; un oubli rend l'application absente de la supervision <i>sans aucune erreur visible</i>	Manuel, et le fichier n'est pas versionné
Un flux de livraison (≈ 296 lignes)	Duplication intégrale, faute de factorisation	Manuel
Sept ordres de base de données <i>pour un locataire supplémentaire</i> (dix pour l'accueil du second, qui incluait la fermeture symétrique)	Durcissement de l'isolation entre bases	Hors description en code, geste appliqué à l'exécution
Une tâche, un ordonnanceur, une alerte	Contrôle quotidien de dérive de l'isolation	À recopier
Deux modifications de code	Table des services du locataire et filtre d'affichage	Manuel, sans test
Un enregistrement de nom de domaine	À poser <i>avant</i> l'application de l'infrastructure	Manuel, hors périmètre du code

C'est la mesure honnête de la distance entre un socle qui *fonctionne* pour deux applications et un socle qui *s'exploite* pour N.

6.7.3 Maturité multi-locataire, axe par axe

L'évaluation axe par axe (tableau 39) est franchement asymétrique, et c'est ce qui la rend utilisable : elle indique où investir. Le socle a résolu le plan de l'identité et du déploiement, et, du 11 au 25/08/2026, celui du réseau (D15) ; celui de la donnée reste ouvert *en exploitation* sans l'être *en conception*, D16 en fixant la cible, le coût et l'ordre (sections 4.2.5 et 4.2.6). Les notes mesurent le système déployé, non la conception qui le corrige, et se lisent sous les conditions de validité du tableau 40 : dispositif mono-opérateur, recette sans trafic réel.

TAB. 39. Maturité multi-locataire, axe par axe, à la date de 25/08/2026

Axe	Note	Justification chiffrée
Isolation des identités	9/10	Une identité dédiée par application, aucun droit sur l'entrepôt de supervision, délégation de la chaîne de livraison ciblée sur cette seule identité, accès aux secrets accordé secret par secret, aucun rôle primitif nulle part
Isolation des secrets	9/10	Un secret par usage, jamais de portée projet, chiffrement par clé gérée sur huit secrets

Axe	Note	Justification chiffrée
Isolation des données applicatives	4/10	Base et utilisateur dédiés sur une instance partagée ; l'isolation repose sur six révocations appliquées à l'exécution, hors description en code, qu'une réconciliation consécutive à un clonage défait sans bruit — d'où le contrôle quotidien, qui la détecte sans la prévenir
Ségrégation réseau	6/10	Cloisonnement réseau par locataire acquis et daté au tableau 37 ; le refus croisé entre locataires a été réellement opposé et journalisé le 24/08/2026, sa ligne retrouvée dans l'entrepôt (T20, conforme). La note s'arrête là pour trois raisons démontrées, non par prudence : deux charges de travail détachées du sous-réseau conservent une sortie managée hors de portée du pare-feu (T14, non conforme, 25/08/2026) ; le sélecteur disponible étant l'étiquette et non le compte de service, la frontière est opposable à une charge compromise et non à un opérateur capable de déployer ; et l'instance de base de données reste jointe par les deux locataires
Cloisonnement de la supervision	2/10	Un seul jeu de données pour tous les locataires, aucune politique d'accès par ligne : le filtre est appliqué par l'API, jamais par le stockage. Côté tableau de bord, le locataire est porté par un témoin de navigation non signé, absent des revendications du jeton — confort de lecture, jamais frontière de sécurité, et la décision d'architecture le dit
Attribution d'un incident à un locataire	5/10	Fiable à 100 % pour R1, dégradée pour R2, R3 et R6, dont la source est le répartiteur : sur les dix tables de l'entrepôt, trois portent une clé d'application et une seule la porte renseignée sur toutes ses lignes (tableau 27), et le champ de service est vide sur 75 à 90 % des détections de ces trois règles. Contre-exemple positif : la détection du 19/08/2026 porte bien le service de l'application hébergée
Reproductibilité de l'accueil	5/10	Module d'application réutilisable et documenté, mais quatre gestes manuels non versionnés subsistent (tableau 38)

Note d'ensemble : 5/10, contre 4/10 avant la refonte réseau du 11 au 25/08/2026 : l'axe réseau est le seul à avoir bougé et il ne rachète ni le stockage ni la supervision, qui bornent la note. Le socle est prêt à héberger plusieurs applications d'un même éditeur — ce qu'il fait, correctement — non les données de deux clients distincts sous engagement contractuel, leur isolation y restant une propriété des droits du moteur de base et du code applicatif, non du stockage.

6.7.4 Modèle cible et seuils d'engagement

Les quatre niveaux d'isolation évalués et le modèle retenu — mutualiser ce qui est coûteux et sans donnée client, cloisonner ce qui porte la donnée — sont arrêtés avec leur coût en section 4.2.6. Ce que la mesure ajoute est le motif de proportion : ce modèle tranche exactement là où passe la frontière de maturité relevée ci-dessus, pour un surcoût de +40 à +60 % et un effort *incrémental*. Une limite l'accompagne : tant qu'il n'existe qu'un seul projet au sens du fournisseur, un droit mal attribué traverse d'un coup toutes les frontières logiques — la séparation par projet reste la seule frontière garantie nativement, et lever la contrainte administrative est le prérequis de toute commercialisation.

Trois seuils avant engagement contractuel. Trois seuils — exactement trois — séparent ces deux états, énoncés dans l'ordre où ils doivent être franchis, celui du rapport entre l'effet et l'effort.

Premier seuil : alerter réellement sur les détections de sécurité. Le socle exploite deux chaînes d'observabilité disjointes — une chaîne d'exploitation qui alerte, une chaîne de sécurité qui n'alerte pas : une détection de sévérité critique n'envoie aucune notification, elle attend qu'un analyste ouvre le tableau de bord (figure 30). **La chaîne se termine par un écran, elle doit se terminer par une notification** ; c'est la lacune la plus lourde du dispositif, et sa remédiation la plus légère des trois.

Deuxième seuil : verrouiller la rétention des journaux d'audit. Les journaux d'accès aux données sont produits mais ne sont acheminés vers aucune destination dédiée ; ils restent dans un

Cadre de capture K34 --- spécification de prise

Vue : page *Vue d'ensemble* du tableau de bord, cadrée sur le bandeau supérieur et la bande des cinq indicateurs, un locataire sélectionné et au moins une détection de gravité élevée dans la répartition. **Date de prise** : relevée sur la révision de recette en service.

Ce que le cadre établit : le premier des trois seuils qui séparent un socle d'un service — la chaîne de sécurité se termine par un écran. Aucune file d'incidents à traiter, aucun accusé de prise en charge, aucun canal de notification : cette absence, au milieu de compteurs vifs, est l'objet même du cadre, et c'est la raison pour laquelle il est ici plutôt qu'une phrase.

Réserve : les compteurs de cette vue incluent le trafic d'auto-consultation (tableau 40); la preuve porte sur leur environnement d'interface, non sur leur niveau. **Masquage** : identifiant de projet, courriel du compte connecté.

FIG. 30. Vue d'ensemble du tableau de bord. À y lire ce qui *n'y est pas* : ni file d'incidents à traiter, ni accusé de prise en charge, ni départ de notification. La chaîne de détection se termine par cet écran, et le délai perçu par un analyste dépend donc de sa présence devant lui.

espace à rétention de trente jours, modifiable. C'est la brique de non-répudiation manquante, et le contexte la rend impérative : la table des détections a réellement été vidée par une suppression administrateur les 24 et 25/08/2026, ce qui est exactement l'événement qu'un journal d'audit verrouillé doit rendre incontestable.

Troisième seuil : cloisonner la donnée entre locataires. C'est le seul des trois qui demande plusieurs jours. La segmentation réseau qui occupait cette place a été appliquée du 11 au 25/08/2026 et mesurée par T20; ce qui reste relève du plan de la donnée : clé de locataire obligatoire à l'ingestion, cloisonnement au stockage de l'entrepôt, instance de base dédiée au locataire porteur de donnée irréparable — conçue, chiffrée et ordonnancée sous D16 (section 4.2.6), non appliquée. S'y ajoute le résidu réseau du correctif T14 (section 6.2.1). Le dépôt pose lui-même ce seuil comme la condition d'accueil d'un troisième client.

6.8 Conditions de validité et réponse aux objectifs

6.8.1 Conditions de validité des résultats

Toute mesure porte les limites de son dispositif. Le tableau 40 recense celles qui conditionnent l'interprétation des résultats, énoncées comme des bornes de validité et non comme des excuses : chacune indique jusqu'où une conclusion peut être portée.

6.8.2 Réponse aux objectifs du projet

Les six objectifs mesurables du chapitre 1 sont confrontés aux résultats obtenus (tableau 41). Une échelle binaire « atteint / non atteint » confondrait un objectif dont le dispositif n'existe pas et un objectif dont le dispositif fonctionne sans être chiffré. Trois niveaux cumulatifs sont donc employés — **conçu** : traduit en exigences, en architecture et en décisions datées ; **réalisé** : déployé et observé en fonctionnement ; **mesuré** : une valeur relevée et datée établit le résultat.

TAB. 40. Conditions de validité des résultats du chapitre

Condition	Portée qu'elle donne aux résultats
Absence de trafic réel	Les résultats valent pour les scénarios exécutés, non pour une exploitation réelle : ni taux de faux positifs ni seuil comportemental n'en est déductible
Attaques simulées, non adverses	Les tests valident les scénarios prévus, pas l'espace des scénarios non prévus
Période d'observation courte	Les phénomènes lents — dérive, saturation, coût — restent hors du champ d'observation ; c'est précisément l'objet du plan de validation continue (§6.2.3)
Isolation portée par les droits au plan du stockage	Les refus observés entre locataires attestent le cloisonnement des identités, des secrets, des bases et — depuis le refus croisé du 24/08/2026, T20 — du réseau ; la conclusion ne s'étend pas au stockage, où l'instance de base de données et l'entrepôt de supervision demeurent communs
Ressource d'infrastructure partagée	L'instance de base de données reste unique, seules les bases et les rôles y étant séparés : point de défaillance unique que la campagne n'éprouve pas, et une restauration restaure les deux bases ensemble. L'autre ressource commune, le connecteur d'accès sans serveur, a été supprimée le 15/08/2026
Compteurs incluant l'auto-consultation	Les volumes affichés par la vue d'ensemble incluent le trafic généré par la consultation du tableau de bord lui-même : ils illustrent le fonctionnement de la chaîne, ils ne mesurent pas une activité
Journal d'audit applicatif sans politique de purge	Aucune durée de conservation n'y est déclarée : sa croissance est non bornée, et une ligne de politique suffirait, mais elle doit exister avant tout engagement de service
Écriture non bloquante de la piste d'audit applicative	L'écriture est enveloppée dans un traitement d'erreur silencieux : une panne ferait perdre la trace sans aucun signal, et les conclusions tirées de cette piste valent sous réserve de sa complétude
Dispositif de mesure mono-opérateur	La reproductibilité est assurée par publication : chaque protocole est écrit avec son critère d'acceptation, formulé avant exécution, de sorte qu'un tiers puisse le rejouer et contredire le résultat (annexe E) — garantie de méthode substituée à une revue croisée indisponible à cette taille
Annotation sémantique par une seule personne	L'évaluation comparative de l'enrichissement n'est donc pas prononcée : le protocole prévoit une seconde annotation et un taux d'accord, et la grille reste vide jusque-là (annexe F)

TAB. 41. Réponse aux six objectifs mesurables du projet

#	Objectif	Acquis, et portée de l'acquis	Niveau
O1	Supprimer la confiance implicite du réseau	Contrôles d'identité et de périmètre déployés, refus observés en recette et rejoués par test automatisé ; refus croisé entre locataires opposé et journalisé le 24/08/2026 (T20). <i>Portée</i> : frontière opposable à une charge compromise, non à un opérateur capable de déployer ; deux charges conservent une sortie managée non gouvernée (T14)	Réalisé, mesuré en partie
O2	Rendre l'infrastructure reproductible	Socle décrit en code, construit puis reconstruit en recette : la capacité est établie, la <i>mesure</i> chronométrée relevant du plan de validation continue, dont le versionnement du fichier de variables est le prérequis	Réalisé
O3	Contrôler la chaîne de livraison	Portes bloquantes et <i>éprouvées</i> : refus réel sur une vulnérabilité critique (T8), fédération sans clé, aucune clé exportée (T7). <i>Portée</i> : le registre de confiance repose sur la construction, non sur un refus (T9)	Réalisé, mesuré en partie
O4	Détecter les événements de sécurité	Sept règles actives, chaîne complète démontrée le 19/08/2026, et publication de ce que le socle <i>ne</i> détecte pas (tableaux 34, 40 et §6.6), comme l'objectif l'exigeait. <i>Portée</i> : couverture, faux positifs et délai médian non chiffrés ; la chaîne se termine par un écran ; une interruption de la route de journaux ne produit aucune alerte (T12)	Réalisé
O5	Enrichir les alertes de façon déterministe	Candidats sémantiques produits, stockés et consultables (figure 27). <i>Portée</i> : comparaison aux méthodes de référence non prononcée et jointure au score d'incident laissée en écart assumé — l'objectif admettait par avance le résultat négatif ; débit plafonné à 200 détections par heure, au-delà desquelles la fenêtre de deux heures écarte les plus anciennes sans erreur (T15, 22/08/2026)	Réalisé en partie

#	Objectif	Acquis, et portée de l'acquis	Niveau
O6	Rester exploitable et soutenable	Restauration exécutée et chronométrée (32 min 45 s, perte nulle, 314 lignes sur 314), retours arrière à 11,6 s et 16,5 s, haute disponibilité régionale appliquée le 08/08/2026 en 11 min 2 s, plafond de charge mesuré le 22/08/2026, état de l'infrastructure protégé par quatre refus le 20/08/2026. <i>Portée</i> : bascule de zone non provoquée, coût non ventilé	Réalisé, mesuré en partie

Aucun des six objectifs n'en reste au stade de la conception : les six dispositifs sont construits et observés en fonctionnement, et ce qui n'est pas encore chiffré est de nature homogène — durée, volume, fréquence — c'est-à-dire exactement le champ du plan de validation continue.

Conclusion du chapitre

Les vingt protocoles portent une preuve nommée, vérifiable et datée ; six portent en outre une cadence de jeu. Les deux preuves les plus fortes ne sont pas des captures d'écran mais un test automatisé qui tente réellement l'écriture interdite sur les tables de preuves à chaque livraison, et un refus non provoqué. Les deux non-conformités, T1 et T14, conservées et expliquées, sont la contrepartie d'une campagne dérivée de l'analyse de risque *avant* la conception. Les points fragiles se nomment aussi : couverture de détection non calculée, chaîne de sécurité se terminant par un écran plutôt que par une notification, deux charges de travail dont la sortie réseau échappe au pare-feu, plan de stockage encore commun aux deux locataires. Le chapitre s'achève sur la frontière du service et sur les trois seuils — alerter, verrouiller la rétention, cloisonner la donnée — qui séparent un socle qui fonctionne d'un service que l'on peut vendre. La question ouverte au chapitre 2 le reste ici : le gain de l'enrichissement sémantique justifiera-t-il son coût ?

Conclusion générale

Récapitulation. Ce mémoire a présenté la conception, la réalisation et la validation d'un socle d'hébergement cloud Zero Trust pour une entreprise émergente. Le point de départ était une application fonctionnelle, mais hébergée sur un serveur unique, avec confiance implicite entre tous ses composants, sans reproductibilité et sans détection de sécurité. Le point d'arrivée est un socle entièrement décrit en code, organisé en sept niveaux L1–L7, soit cinq couches et deux plans transversaux. Il comporte deux chaînes de livraison à portes bloquantes, une chaîne de détection enrichie par un modèle de représentation sémantique, et un tableau de bord destiné à l'analyste.

Résultats chiffrés. Le socle fonctionne avec deux environnements réels, développement et recette ; la production reste une cible non provisionnée, et l'infrastructure durable du périmètre est décrite en code avec ses décisions et ses écarts datés. La restauration de la base de données, mesurée le 03/08/2026 sur la configuration zonale antérieure au passage en haute disponibilité régionale du 08/08/2026, a demandé 32 min 45 s pour 314 lignes restaurées sur 314 au point demandé, sans perte de données. Deux retours arrière applicatifs ont pris 11,6 s et 16,5 s le 07/08/2026 ; le démarrage à froid du service d'encodage est de 27 s en moyenne et de 94 s au pic. Le 19/08/2026, un scénario de bout en bout a produit treize requêtes malveillantes, toutes bloquées, agrégées en une alerte environ quinze minutes plus tard. La campagne de validation établit **sept résultats conformes, onze partiellement conformes et deux non-conformités assumées** : les vingt protocoles portent une preuve nommée, et six d'entre eux une cadence de rejeu au plan de validation continue, dont le premier relevé est daté.

Trois de ces relevés sont postérieurs à la migration du réseau — un refus de sortie réellement opposé et journalisé, un refus croisé entre locataires, et la non-conformité du composant d'inférence, dont la sortie échappe encore au pare-feu. Le compte est volontairement sévère : n'est déclaré conforme qu'un critère couvert intégralement, le plus souvent par un refus réellement observé. La couche sémantique, elle, produit des candidats de rattachement au positionnement informationnel : sa précision comparative et l'effet de la boucle F6 sur l'ordre de priorité relèvent du même plan. La seconde moitié de la problématique attend donc encore sa mesure — le prix payé en faux positifs et en latence de détection demande une période d'observation sous trafic réel, et c'est la première des perspectives.

Problèmes rencontrés. Cinq incidents d'ingénierie ont été documentés au chapitre 5. Le premier est une indisponibilité liée au démarrage à froid. Le deuxième est un blocage collectif d'utilisateurs légitimes par la limitation de débit. Le troisième est un état local divergent après une application partiellement échouée. Le quatrième est une porte d'analyse statique restée verte sans évaluer aucune règle. Le cinquième est une règle de sortie qui n'aurait rien gouverné : inscrite au plan de correction, elle eût été sans effet, le trafic ne passant pas là où elle se serait appliquée — d'où l'ordre de la migration réseau, déplacer le trafic, l'observer sept jours, n'interdire qu'ensuite. Chacun a produit une correction et une leçon transférable ; la dernière est

la plus générale, **un contrôle qui ne voit pas passer le trafic n'est pas un contrôle, c'est une déclaration.**

Deux limites sont énoncées avec leur condition de levée. Le contrôle dynamique des sorties réseau a été mesuré les 24 et 25/08/2026 : il refuse ce qu'il gouverne, et deux charges de travail détachées du sous-réseau lui échappent encore par une sortie managée — non-conformité T14 du 25/08/2026. Surtout, l'enrichissement sémantique occupe un positionnement informationnel assumé : il n'alimente pas le score d'incident, et sa condition d'intégration est nommée — une clé d'entité dans le schéma d'enrichissement, une règle de décision, et la mesure comparative qui l'autorise.

Apports. Pour l'entreprise, le socle fournit une base interne réutilisable, éprouvée partiellement par l'accueil d'un second locataire le 07/08/2026. L'identité, les secrets et les données — et désormais le réseau, le refus croisé ayant été réellement opposé le 24/08/2026 — sont séparés par locataire ; l'instance de base de données et le jeu de tables de supervision, eux, restent partagés. Pour ma part, ce projet a mobilisé l'ensemble des compétences d'un ingénieur en cybersécurité cloud, sans répartition d'équipe : audit, dérivation des exigences, conception de l'architecture, écriture de l'infrastructure en code, construction des deux chaînes de livraison et de la chaîne de détection, puis conduite de la campagne de validation. J'y ai appris à documenter un écart au moment où il apparaît plutôt qu'à le refermer discrètement, et à préférer une mesure défavorable à une estimation flatteuse — le démarrage à froid mesuré à 27 s contre une estimation initiale de quelques secondes, et la porte d'analyse statique découverte en faux vert, en sont les deux exemples les plus formateurs. J'y ai appris enfin qu'un contrôle correctement conçu peut produire un effet non prévu en exploitation, comme cette limitation de débit qui bloquait des utilisateurs légitimes partageant une même adresse.

Perspectives. Quatre axes d'amélioration sont identifiés. Le premier est l'**isolation des données par locataire**, conçue, chiffrée et ordonnancée au chapitre 4 sous la décision D16 : ce qui reste est l'application, non l'instruction — et la raison de l'ordonnancement est écrite, deux migrations d'infrastructure dans la même quinzaine n'étant pas soutenables par un opérateur unique. La segmentation réseau qui l'accompagnait, elle, a été **appliquée du 11 au 25/08/2026** en douze étapes, et mesurée : le protocole T20 est conforme au 24/08/2026 sur un refus croisé entre locataires réellement opposé et journalisé. Le deuxième axe est l'intégration contrôlée de l'enrichissement au score d'incident, avec clé d'entité, règle de décision et mesure comparative. Le troisième est la signature des images par chaîne de provenance. Le quatrième est l'écriture de tests unitaires par règle de détection, vérifiant que chaque règle produit l'alerte attendue sur des données de test. Le gain de l'enrichissement sémantique, une fois mesuré, justifiera-t-il son coût ? C'est la question ouverte du chapitre 2, et elle reste ouverte.

Ce travail ne produit pas un service commercialisable en l'état : il produit un socle reproductible et mesuré, dont les limites sont chiffrées et dont le chemin vers un engagement contractuel est identifié et estimé. C'est précisément parce que ces limites sont écrites que ce chemin est crédible.

Bibliographie/Netographie

- [1] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. *ATT&CK-BERT : modèle de représentation de phrases spécialisé pour la cybersécurité (carte de modèle)*. Hugging Face, dépôt `basel/ATTACK-BERT`. Modèle publié par les auteurs de SMET. 2023. URL : <https://huggingface.co/basel/ATTACK-BERT> (visité le 26 août 2026).
- [2] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. « SMET : Semantic Mapping of CVE to ATT&CK and Its Application to Cybersecurity ». In : *Data and Applications Security and Privacy XXXVII*. T. 13942. Lecture Notes in Computer Science. Springer, 2023, p. 243-260. DOI : [10.1007/978-3-031-37586-6_15](https://doi.org/10.1007/978-3-031-37586-6_15).
- [3] Basel ABDEEN, Ehab AL-SHAER, Anoop SINGHAL, Latifur KHAN et Kevin W. HAMLEN. « SMET : Semantic Mapping of CTI Reports and CVE to ATT&CK for Advanced Threat Intelligence ». In : *Journal of Computer Security* (2024). DOI : [10.3233/JCS-230218](https://doi.org/10.3233/JCS-230218).
- [4] AGENCE NATIONALE DE LA SÉCURITÉ DES SYSTÈMES D'INFORMATION (ANSSI). *La méthode EBIOS Risk Manager — Le Guide*. Rapp. tech. ANSSI-PA-048, version 1.1. ANSSI, déc. 2018. URL : <https://www.ssi.gouv.fr/uploads/2018/10/guide-methode-ebios-risk-manager.pdf> (visité le 26 août 2026).
- [5] Ehsan AGHAEI, Xi NIU, Waseem SHADID et Ehab AL-SHAER. *SecureBERT : A Domain-Specific Language Model for Cybersecurity*. 2022. arXiv : [2204.02685](https://arxiv.org/abs/2204.02685). URL : <https://arxiv.org/abs/2204.02685> (visité le 26 août 2026).
- [6] AMAZON WEB SERVICES. *AWS Global Infrastructure : Regions and Availability Zones*. 2026. URL : https://aws.amazon.com/about-aws/global-infrastructure/regions_az/ (visité le 27 août 2026).
- [7] Oliver BORCHERT, Gema HOWELL, Alper KERMAN, Scott ROSE, Murugiah SOUPPAYA et al. *Implementing a Zero Trust Architecture*. NIST Special Publication 1800-35. National Institute of Standards et Technology (NIST), juin 2025. DOI : [10.6028/NIST.SP.1800-35](https://doi.org/10.6028/NIST.SP.1800-35). URL : <https://csrc.nist.gov/pubs/sp/1800/35/final> (visité le 26 août 2026).
- [8] CENTER FOR INTERNET SECURITY. *CIS Google Cloud Computing Platform Benchmark*. 2026. URL : https://www.cisecurity.org/benchmark/google_cloud_computing_platform (visité le 26 août 2026).

- [9] CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY (CISA). *Advanced Persistent Threat Compromise of Government Agencies, Critical Infrastructure, and Private Sector Organizations*. Cybersecurity Advisory AA20-352A. Mis à jour en avril 2021. CISA, déc. 2020. URL : <https://www.cisa.gov/news-events/cybersecurity-advisories/aa20-352a> (visité le 26 août 2026).
- [10] CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY (CISA). *Zero Trust Maturity Model*. Version 2.0. 2023. URL : <https://www.cisa.gov/zero-trust-maturity-model> (visité le 26 août 2026).
- [11] Jacob DEVLIN, Ming-Wei CHANG, Kenton LEE et Kristina TOUTANOVA. « BERT : Pre-training of Deep Bidirectional Transformers for Language Understanding ». In : *Proceedings of the 2019 Conference of the North American Chapter of the Association for Computational Linguistics : Human Language Technologies*. Association for Computational Linguistics, 2019, p. 4171-4186.
- [12] GITGUARDIAN. *State of Secrets Sprawl*. 2025. URL : <https://www.gitguardian.com/state-of-secrets-sprawl-report-2025> (visité le 26 août 2026).
- [13] GOOGLE CLOUD. *Best Practices for Building Containers*. 2026. URL : <https://cloud.google.com/architecture/best-practices-for-building-containers> (visité le 26 août 2026).
- [14] GOOGLE CLOUD. *Google Cloud Architecture Framework*. 2026. URL : <https://cloud.google.com/architecture/framework> (visité le 26 août 2026).
- [15] GOOGLE CLOUD. *Google Cloud Free Program : Free Tier Usage Limits*. 2026. URL : <https://cloud.google.com/free/docs/free-cloud-features> (visité le 27 août 2026).
- [16] GOOGLE CLOUD. *Regions and Zones*. 2026. URL : <https://cloud.google.com/compute/docs/regions-zones> (visité le 27 août 2026).
- [17] HASHICORP. *Automatically Detect Resource Drift and Health*. 2025. URL : <https://developer.hashicorp.com/well-architected-framework/optimize-systems/monitor-system-health/detect-configuration-drift> (visité le 26 août 2026).
- [18] HETZNER ONLINE GMBH. *Hetzner Data Center Locations*. 2026. URL : <https://www.hetzner.com/unternehmen/rechenzentrum/> (visité le 27 août 2026).
- [19] INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Information Security, Cybersecurity and Privacy Protection — Guidance on Managing Information Security Risks*. Oct. 2022. URL : <https://www.iso.org/standard/80585.html> (visité le 26 août 2026).

- [20] John KINDERVAG. *No More Chewy Centers : Introducing the Zero Trust Model of Information Security*. Rapp. tech. Forrester Research, 2010.
- [21] MITRE CORPORATION. *MITRE ATT&CK*. Version v19. 2026. URL : <https://attack.mitre.org/> (visité le 26 août 2026).
- [22] Kief MORRIS. *Infrastructure as Code : Dynamic Systems for the Cloud Age*. 2^e éd. O'Reilly Media, 2020. ISBN : 978-1-098-11467-1.
- [23] OPEN SOURCE SECURITY FOUNDATION (OPENSSF). *Supply-chain Levels for Software Artifacts (SLSA)*. Version 1.0. 2023. URL : <https://slsa.dev> (visité le 26 août 2026).
- [24] OWASP FOUNDATION. *OWASP Top 10 CI/CD Security Risks*. 2022. URL : <https://owasp.org/www-project-top-10-ci-cd-security-risks/> (visité le 26 août 2026).
- [25] OWASP FOUNDATION. *OWASP Top 10 :2025*. 2025. URL : <https://owasp.org/Top10/> (visité le 26 août 2026).
- [26] Nils REIMERS et Iryna GUREVYCH. « Sentence-BERT : Sentence Embeddings using Siamese BERT-Networks ». In : *Proceedings of EMNLP-IJCNLP 2019*. Association for Computational Linguistics, 2019, p. 3982-3992. DOI : [10.18653/v1/D19-1410](https://doi.org/10.18653/v1/D19-1410). URL : <https://aclanthology.org/D19-1410/> (visité le 26 août 2026).
- [27] Scott ROSE, Oliver BORCHERT, Stu MITCHELL et Sean CONNELLY. *Zero Trust Architecture*. NIST Special Publication 800-207. National Institute of Standards et Technology (NIST), août 2020. DOI : [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207).
- [28] SCALEWAY. *Understanding Regions and Availability Zones*. 2026. URL : <https://www.scaleway.com/en/docs/console/my-account/reference-content/products-availability/> (visité le 27 août 2026).
- [29] Adam SHOSTACK. *Threat Modeling : Designing for Security*. Wiley, 2014. ISBN : 978-1-118-80999-0.
- [30] SIGMAHQ. *Sigma Specification : Generic Signature Format for SIEM Systems*. 2026. URL : <https://sigmahq.io/sigma-specification/> (visité le 26 août 2026).
- [31] Larry SMITH. « Shift-Left Testing ». In : *Dr. Dobb's Journal* 26.9 (2001), p. 56-62.
- [32] Blake E. STROM, Andy APPLEBAUM, Doug P. MILLER, Kathryn C. NICKELS, Adam G. PENNINGTON et Cody B. THOMAS. *MITRE ATT&CK : Design and Philosophy*. Rapp. tech. MP180360R1. MITRE Corporation, 2018.
- [33] Rory WARD et Betsy BEYER. « BeyondCorp : A New Approach to Enterprise Security ». In : *login* : 39.6 (2014), p. 6-11.

Annexe A Études comparatives détaillées

A.1 Audit de l'existant et positionnement (issus du chapitre 1)

Cette section porte le détail de ce que le chapitre 1 condense : le positionnement à quinze critères des trois modèles d'architecture comparés (section 1.3.2). La répartition des 41 critères de l'audit du 29 juillet 2026 par catégorie et par statut n'y est pas redonnée : elle est portée par la figure 5 du corps, qui la publie en entier — fonctionnel prêt à 86 %, technique et conformité à 0 %, sécurité à mi-chemin, portant à la fois les points forts applicatifs et les six constats bloquants.

A.1.1 Positionnement complet à quinze critères

Le tableau 42 reprend l'intégralité de la comparaison introduite au section 1.3.2 entre le modèle A (architecture périmétrique de l'existant), le modèle B (hébergement cloud managé sans démarche de sécurité explicite) et le modèle C (socle Zero Trust visé par le projet). Les sept premiers critères proviennent des principes Zero Trust [27] ; les critères 8 à 11 reprennent les carences C2 à C4 et l'apport original du projet ; les critères 12 à 15 traduisent des contraintes d'ingénierie réelles, sur lesquelles le modèle C ne l'emporte pas systématiquement. Légende : ● couvert par conception, ◐ partiellement couvert ou dépendant de la configuration, ○ non couvert.

TAB. 42. Positionnement complet des trois modèles sur quinze critères

#	Critère	Origine	A	B	C
1	Vérification explicite de l'identité à chaque requête	NIST SP 800-207	○	◐	●
2	Aucune confiance accordée à la position réseau	NIST SP 800-207	○	◐	●
3	Moindre privilège, une identité par charge de travail	NIST SP 800-207	○	◐	●
4	Micro-segmentation, limitation des mouvements latéraux	NIST SP 800-207	○	◐	◐
5	Hypothèse de compromission : tout est journalisé	NIST SP 800-207	○	◐	●
6	Collecte, corrélation et conservation des événements	NIST SP 800-207	○	◐	●
7	Surveillance continue et amélioration	NIST SP 800-207	○	○	◐
8	Infrastructure entièrement décrite en code	Carence C2	○	○	●
9	Contrôles de sécurité bloquants dans la livraison	Carence C3	○	◐	◐
10	Règles de détection écrites, versionnées et mesurées	Carence C4	○	○	◐
11	Priorisation des vulnérabilités par la menace observée	Apport du projet	○	○	◐
12	Coût mensuel d'exploitation	Contrainte projet	●	◐	◐
13	Simplicité initiale, délai de mise en service	Contrainte projet	●	◐	○
14	Mise à l'échelle horizontale	Contrainte projet	○	●	◐
15	Maturité, support éditeur, compétences disponibles	Contrainte projet	◐	●	○

Lecture du tableau. Les onze premières lignes montrent l'apport du modèle retenu, les quatre dernières ce qu'il coûte, et se lisent avec la même attention. Le modèle C perd sur la simplicité initiale (ligne 13), sur la mise à l'échelle (ligne 14, hors objectif du projet) et sur la maturité opérationnelle (ligne 15) ; le coût mensuel (ligne 12) n'est comparable qu'en apparence, la facturation directe du modèle A n'intégrant ni sauvegarde externalisée, ni détection, ni reprise après incident. Ces trois critères perdus sont ce qui rend les onze autres crédibles, et ils sont repris tels quels en section 6.8.1.

La ligne 4 appelle une note : son verdict n’a pas bougé, sa raison a changé du tout au tout. Avant la refonte du plan réseau, le modèle C n’obtenait qu’un ◐ faute de toute segmentation ; celle-ci existe désormais (section 4.2.5) et le verdict reste pourtant intermédiaire, pour un motif entièrement différent : **elle s’arrête au plan du réseau.** Base de données et entrepôt de supervision demeurent partagés, le pare-feu autorisant les deux identités à joindre la même adresse ; l’isolation du plan de la donnée est une conception datée et chiffrée, non un état appliqué.

A.2 État de l’art et choix technologiques (issus du chapitre 2)

Les grilles qui portent directement une justification de choix figurent dans le corps du chapitre 2 ; cette annexe ne conserve que ce qui alourdirait le corps sans y ajouter d’argument.

A.2.1 Comparaison des modes d’exécution

Trois modes d’exécution ont été comparés sur six critères. La conclusion étant déjà portée par le tableau 7 et par la décision D01, le tableau en documente ici le seul détail : l’exécution de conteneurs sans serveur réduit la charge d’administration et le coût à faible trafic, introduit le démarrage à froid mesuré au chapitre 6 et ne donne qu’une isolation réseau intermédiaire.

Cette dernière ligne appelle une précision : son motif a changé sans que son verdict bouge. La sortie réseau directe a levé la réserve initiale, chaque instance portant désormais une interface que les règles nomment (section 4.2.5). Le pictogramme reste intermédiaire pour deux motifs qui subsistent : le sélecteur disponible est l’étiquette réseau et non le compte de service, et trois charges de l’application hébergée partagent un même compte, donc une même étiquette, et restent indiscernables pour une règle — un orchestrateur managé conserve l’avantage sur ce seul critère.

TAB. 43. Comparaison des trois modes d’exécution étudiés

Légende : ● favorable, ◐ intermédiaire, ○ défavorable.

Critère	Machines virtuelles	Orchestrateur managé	Conteneurs sans serveur
Charge d’administration	○	○	●
Coût à faible trafic	◐	○	●
Système de fichiers persistant	●	●	○
Isolation réseau fine	◐	●	◐
Tâches longues	●	●	◐
Démarrage à froid	●	●	○

A.2.2 Alternatives évaluées puis écartées, couche par couche

Cet inventaire complète le tableau 9 : pour chacune des six couches, il nomme les alternatives réellement évaluées avant la brique retenue. Il est publié ici parce qu’il relève du matériel de reproduction — il permet de refaire le choix — et non de l’argumentation, portée par le corps.

N1a — deux autres grands fournisseurs de cloud, un fournisseur européen généraliste, deux hébergeurs à forfait ; le réseau par défaut ou partagé, le connecteur d’accès sans serveur, le mandataire filtrant en sortie, le point de terminaison privé ; orchestrateur de conteneurs managé, machines virtuelles, fonctions à la demande ; répartiteur régional, filtrage auto-hébergé. *N1b* — identité unique partagée et droits au niveau du projet, clé de compte de service exportée, agent et coffre auto-hébergés, chiffrage géré par le fournisseur, module matériel de sécurité, fournisseur d’identité externe, facteur résistant à l’hameçonnage.

Nlc — image mono-étage ou minimale, registre public ou auto-hébergé, cadre synchrone classique, application monopage, migrations à la main. *Nld* — trois autres familles de bases, les quatre autres modèles de supervision du tableau 5, deux ordonnanceurs externes, disque local, agent de collecte tiers. *Nle* — format de règles neutre avec moteur de conversion, moteur du fournisseur, modèle de chaîne d’attaque, modèle généraliste, pondération de termes sans apprentissage de domaine, modèle génératif, inférence managée. *Nlf* — service d’intégration du fournisseur, moteur auto-hébergé, autre analyseur de secrets, analyseur commercial, analyseurs d’images concurrents.

A.2.3 Sources et réserves de la comparaison d’hébergement

Les paliers gratuits (critères 1 et 3 du tableau 7) et les implantations régionales (critère 4) reposent sur la documentation publique des fournisseurs, consultée le 27 août 2026 : paliers gratuits et régions de Google Cloud [15, 16], régions d’Amazon Web Services [6], implantations de Hetzner [18] et régions de Scaleway [28]. Les colonnes « Azure » et « OVH » n’ont pas pu être sourcées à cette date, les pages de documentation correspondantes étant dynamiques et inaccessibles depuis l’environnement de travail ; leurs valeurs relèvent donc de la connaissance générale de l’auteur et non d’une vérification documentaire.

Les deux réserves méthodologiques annoncées au § 2.5 trouvent ici leur justification documentaire : aucune mesure de latence depuis Nouakchott n’ayant été conduite, le critère 4 est apprécié à partir des seules implantations régionales publiées ci-dessus ; et les grilles tarifaires n’ayant pas été relevées à une date unique ni pour un dimensionnement identique, le critère 2 est apprécié à partir des modèles de facturation, non de prix mesurés.

A.3 Fiche de version de chaque brique

Le tableau 44 donne, brique par brique et dans l’ordre de section 2.6.2, la version ou le paramètre retenu et le **mode de verrouillage**. Les valeurs ont été relevées le **28/08/2026**, à deux exceptions signalées en cellule : empreintes des images de base (19/08/2026) et version de l’analyseur statique (24/08/2026).

La colonne décisive est la troisième et non le numéro de version : une version connue ne dit rien de la reproductibilité si rien n’empêche la valeur de changer seule. *Verrouillé* : un fichier de verrouillage suivi dans le dépôt fige la valeur. *Épinglé* : la valeur est écrite dans le code, lisible et revue, mais rien n’en atteste l’intégrité. *Étiquette mobile* : la valeur change sans qu’une ligne du dépôt soit modifiée. **Une seule ligne est dépourvue de version relevable**, en fin de tableau : la configuration de l’environnement de recette — chemins protégés, services collectés, adresses d’administration exemptées — est portée par un fichier de valeurs exclu du dépôt, qui contient des décisions de sécurité et aucun secret. Son versionnement est la mesure de reproductibilité la plus rentable qu’ait identifiée le relevé.

TAB. 44. Fiche de version des trente-trois briques structurantes et mode de verrouillage

Brique	Version ou paramètre retenu	Verrouillage
N1a — Socle et infrastructure		
Fournisseur de cloud public unique	Projet unique, région europe-west1	Épinglé (variables de la racine d’environnement)

Brique	Version ou paramètre retenu	Verrouillage
Infrastructure décrite en code	Outil ≥ 1.7 (borne basse seule); fournisseurs de ressources 5.45.2, aléatoire 3.9.0, forge 6.13.0	Fournisseurs verrouillés par fichier versionné; l'outil n'a pas de borne haute
Exécution de conteneurs sans serveur	Deuxième génération exclusivement; sortie intégrale vers le sous-réseau du locataire, sortie gérée pour les deux charges détachées; entrée limitée au répartiteur	Épinglé (type de ressource et paramètres codés dans le module)
Réseau privé virtuel personnalisé	Trois sous-réseaux en /26, deux occupés; accès privé aux services du fournisseur; douze règles de pare-feu et refus par défaut en priorité 65534 en entrée comme en sortie (section 4.2.5); journaux de flux échantillonnés à 0,1, métadonnées exclues	Épinglé
Sortie réseau directe	Une interface par instance dans le sous-réseau de son locataire; sortie ALL_TRAFFIC; une étiquette réseau par compte de service	Épinglé (sous-réseau et étiquette codés dans le module). La solidarité entre l'étiquette et le compte de service tient à leur déclaration dans le même bloc, donc à une convention d'écriture et non à un contrôle; la bascule vers le sélecteur par compte de service est prévue par une variable du module
Accès privé aux services gérés	Plage réservée de longueur /16	Partiellement épinglé : préfixe déclaré, adresse de début choisie par le fournisseur
Répartiteur de charge global	Variante classique; profil de chiffrement moderne, version minimale de transport 1.2; trois certificats gérés	Épinglé
Filtrage applicatif géré	Neuf règles; cinq jeux de signatures en version v33-stable, sensibilité 1; seuils de 10 et de 1000 requêtes par 60 s	Épinglé quant au nom de version; contenu des signatures maintenu par l'éditeur, non lisible
N1b — Identité, secrets et chiffrement		
Gestion des identités et des accès	Sept identités de service; aucun rôle primitif; aucune clé exportée	Épinglé (liaisons déclarées en code)
Fédération d'identité de la chaîne	Condition d'attribut portant sur le dépôt <i>et</i> sur la branche refs/heads/main	Épinglé
Coffre de secrets géré	Neuf secrets, huit sous clé gérée	Épinglé; versions de secret référencées par latest, donc mobiles
Service de gestion de clés	Deux clés; rotation à 90 jours; niveau de protection logiciel	Épinglé
Authentification par jeton signé et rôles	Algorithme de signature figé en constante; durée de vie 60 min; jeton intermédiaire 5 min sans rôle	Épinglé dans le code applicatif
Second facteur par code temporel	Standard RFC 6238; secret de 160 bits; fenêtre de dérive d'un pas	Épinglé
N1c — Exécution, conteneurisation et applications		
Conteneurisation multi-étage, utilisateur non privilégié	Bases épinglées par empreinte : sha256:a116514e... (interpréteur Python 3.12), sha256:fb4cd12c... (exécution Node 20), sha256:2c941e86... (service d'encodage) — relevé le 19/08/2026	Verrouillé par empreinte dans les fichiers de construction versionnés
Registre d'images privé	Format conteneur, région europe-west1; aucune étiquette immuable déclarée	Épinglé quant au registre; artefacts de l'application hébergée référencés par étiquette mobile
Cadre applicatif de l'API	Couche d'accès aux données 2.0.36; dépendances figées	Verrouillé par fichier de dépendances versionné
Cadre web du tableau de bord	14.2.35	Verrouillé : l'installation se fait à partir du fichier de verrouillage versionné
Connecteur applicatif chiffré vers la base	Type d'adresse privé imposé; réserve de 5 connexions, débordement de 2, recyclage à 1800 s	Épinglé
Outil de migration de schéma	Trois révisions linéaires, de 001 à 003	Verrouillé par fichier versionné : les révisions vivent dans le dépôt
N1d — Données et entrepôt de supervision		
Base relationnelle gérée	PostgreSQL 15; classe de machine à cœur partagé; haute disponibilité régionale; retour à un instant donné sur 7 jours; 100 connexions	Épinglé
Entrepôt de supervision	Un jeu de données, dix tables; partitionnement par jour; expiration à 90 jours sur les deux tables de journaux	Épinglé
Requêtes planifiées comme ordonnanceur	Douze exécutions à cadence de cinq minutes; fenêtre glissante de quinze minutes	Épinglé

Brique	Version ou paramètre retenu	Verrouillage
Stockage objet	Accès uniforme au niveau du dépôt, prévention d'accès public appliquée, clé gérée régionale	Épinglé
Collecte de journaux et exports	Quatre exports ; identité d'écriture unique par export ; tables partitionnées	Épinglé
N1e — Détection et enrichissement sémantique		
Règles de détection versionnées	Sept règles, R1 à R7, définies dans un module unique	Verrouillé par fichier versionné
Référentiel de techniques d'attaque	Version 19 (28/04/2026), quinze tactiques	Consigné dans le mémoire ; le chargement du catalogue ne fige aucune version dans le code
Modèle de représentation de phrases	Export en précision flottante simple, étiquette v1.0, 768 dimensions, seuil de similarité 0,60	Épinglé et vérifié à l'exécution : la tâche refuse de s'exécuter hors développement sur l'étiquette d'un substitut
Moteur d'inférence embarqué	Exécution sur processeur généraliste ; deux giboctets de mémoire ; budget de démarrage de 150 s	Épinglé
N1f — Chaîne de livraison et chaîne de provisionnement		
Forge logicielle et moteur d'exécution	Actions de récupération du dépôt, d'authentification et de déploiement en v4 et v2	Étiquette mobile — dette reconnue, écartée nominativement de l'analyse statique, justification écrite
Détection de secrets versionnés	Action de forge v2 ; jeu de règles par défaut	Étiquette mobile
Analyse statique du code	1.173.0 ; jeu de règles par défaut de l'éditeur ; sept exclusions nominatives — relevé le 24/08/2026	Épinglé pour l'outil ; le jeu de règles est distant et mobile
Analyse de vulnérabilité des images et de la configuration	Action de forge v0.36.0 ; blocage sur criticité maximale corrigeable	Épinglé
Paramétrage transverse des briques ci-dessus		
Configuration de l'environnement de recette (chemins protégés, services collectés, adresses d'administration)	—	Non versionné : fichier de valeurs exclu du dépôt bien qu'il ne contienne aucun secret

Point de vigilance

Ce que le verrouillage des versions ne verrouille pas. Épingler la version d'un outil d'analyse ne fige pas le **jeu de règles distant** qu'il télécharge à l'exécution, comme l'établit le décompte de règles chargées les 20 et 24/08/2026 à version d'outil identique (section 5.2) : la chaîne est reproductible quant aux *outils* qu'elle exécute, non quant aux *critères* qu'ils appliquent. Le contrôle compensatoire est la conservation des journaux d'exécution, qui portent le nombre de règles évaluées ; le seuil de bascule serait l'hébergement du jeu de règles dans le dépôt. Le raisonnement vaut aussi pour les signatures du filtrage applicatif et les versions de secret référencées par étiquette mobile.

Annexe B Extraits techniques de la réalisation

Cette annexe rassemble les extraits de code que le chapitre 5 commente sans les reproduire : courts, localisés, issus du dépôt vérifié le 25/08/2026, et sans aucun secret ni identifiant de projet réel.

B.1 Dépôt d’infrastructure et protection des ressources

```
terraform/
├─ environments/
│   ├── dev/           configuration appliquée
│   ├── staging/       configuration appliquée, second locataire
│   └── prod/          cible vide (.gitkeep)
├─ modules/
│   ├── app-service, cloud-run, dashboard, workflow
│   ├── vpc, load-balancer, cloud-sql, artifact-registry
│   ├── iam, kms, audit, logging, monitoring
│   └── bigquery, detection, ml-pipeline
```

Le découpage transpose les niveaux L1–L7 en modules techniques sans correspondance bijective, plusieurs contrôles traversant plusieurs modules : **app-service** crée les ressources propres à une application, **iam** porte la fédération, **bigquery** et **detection** les données et les règles, **ml-pipeline** l’encodage et l’enrichissement. L’état que ce dépôt produit cartographie le système entier, et c’est à ce titre une donnée sensible.

TAB. 45. Sécurité du fichier d’état d’infrastructure

Élément	Mise en œuvre	Raison
Emplacement	Stockage objet dédié, versionné et non public	L’état cartographie le système
Séparation	Un préfixe d’état par environnement	Limiter le rayon d’impact d’une erreur
Accès	Identité de la chaîne d’infrastructure et administration	Moindre privilège
Verrouillage	Verrou natif du stockage	Éviter deux applications concurrentes
Secrets	Conteneurs créés en code ; valeurs injectées séparément	Éviter les valeurs sensibles dans l’état

Ces cinq mesures réduisent l’exposition de l’état ; leur résistance à une identité non autorisée est éprouvée par le protocole T17, conforme le 20/08/2026 et rejoué à la cadence du plan de validation continue (section 6.2.3).

Prévention de l’accès public au média. L’extrait suivant provient de `terraform/modules/app-service/main.tf`, lignes 133–143. La protection est imposée sur la ressource ; elle ne dépend pas d’une politique d’organisation.

```
resource "google_storage_bucket" "media" {
  name      = "${var.project_id}-${var.app_name}-media"
  project   = var.project_id
  uniform_bucket_level_access = true
  public_access_prevention    = "enforced"
}
```

B.2 Détection, livraison et fédération d'identité

Fenêtre et cadence de la règle R2. L'extrait de terraform/modules/detection/main.tf, lignes 103–114, montre la fenêtre SQL utilisée pour compter les refus du filtrage applicatif.

```
SELECT
JSON_VALUE(json_payload, "$.httpRequest.remoteIp") AS src_ip,
resource_name AS service, COUNT(*) AS waf_blocks
FROM `${local.project}.${local.dataset}.raw_logs`
WHERE timestamp >= TIMESTAMP_SUB(CURRENT_TIMESTAMP(),
INTERVAL 15 MINUTE)
AND log_source = "armor"
AND UPPER(JSON_VALUE(json_payload,
"$$.enforcedSecurityPolicy.outcome")) = "DENY"
GROUP BY src_ip, service
WHERE f.waf_blocks > 10 AND f.src_ip IS NOT NULL
```

La ressource de requête planifiée fixe séparément `schedule = "every 5 minutes"` à la ligne 410 : la fenêtre de quinze minutes n'est donc pas la cadence d'exécution.

Déclenchement et permissions de la chaîne de livraison. Le déclenchement filtré par chemins et la déclaration des permissions figurent en tête du descripteur de la chaîne, et portent deux décisions commentées au chapitre 5.

```
on:
push:
branches: [main]
paths: ["api/**", "dashboard/**", "frontend/**",
"scripts/**", "tests/**",
".github/workflows/ci.yml"]
pull_request:
branches: [main]
permissions:
contents: read      # lecture du depot uniquement
id-token: write     # federation d'identite : aucune cle
```

Condition d'attribut de la fédération d'identité. L'extrait suivant provient du module iam. La condition porte *à la fois* sur le dépôt et sur la référence de branche : sans le second membre, toute branche du dépôt obtenait l'identité de déploiement (section 5.2.3).

```
attribute_mapping = {
"google.subject"      = "assertion.sub"
"attribute.repository" = "assertion.repository"
"attribute.ref"        = "assertion.ref"
}
attribute_condition = <<-EOT
assertion.repository == "${var.github_owner}/${var.repo}"
&& assertion.ref == "${var.allowed_deploy_ref}"
EOT
```

Discipline des exclusions d'analyse statique. L'analyse statique est invoquée par appel direct à l'outil, avec une version épinglée et une propagation fidèle du code de sortie. Les sept exclusions sont nominatives et chacune porte, dans le descripteur, une justification ancrée sur un fichier et une ligne. L'élision en tête d'identifiant remplace le préfixe d'espace de noms : `...path-join-resolve-traversal` vaut pour `javascript.lang.security.audit.path-traversal.path-join-resolve-traversal`.

```

pip install semgrep==1.173.0
semgrep scan --config=p/default --error \
--exclude-rule=...express-path-join-resolve-traversal \
--exclude-rule=...path-join-resolve-traversal \
--exclude-rule=...detect-non-literal-regexp \
--exclude-rule=...unsafe-formatstring \
--exclude-rule=...dynamic-urllib-use-detected \
--exclude-rule=...gcp-sql-database-ssl-insecure-value \
--exclude-rule=...github-actions-mutable-action-tag
# La regle bypass-tls-verification n'est PAS exclue :
# chaque occurrence assumee porte une annotation nominative
# nosemgrep sur sa propre ligne. Toute NOUVELLE occurrence
# ailleurs fait echouer la chaine.

```

B.3 Provisionnement, isolation et tableau de bord

Contrôles de la chaîne de provisionnement. Le descripteur de la chaîne d'infrastructure déclare la seule permission de lecture du dépôt : il ne peut structurellement pas s'authentifier auprès du fournisseur cloud, et la validation s'exécute donc sans accès distant.

```

permissions:
contents: read      # pas de id-token : aucun acces GCP
- run: terraform fmt -check -recursive    # bloquant
- run: for env in dev staging; do cd terraform/environments/$env;
terraform init -backend=false -input=false; terraform validate; done
- uses: aquasecurity/trivy-action@v0.36.0
with:
scan-type: config
scan-ref:  terraform/
severity:  CRITICAL
exit-code: 1          # porte bloquante

```

Isolation logique entre locataires. Les comptes de base créés par le fournisseur héritent d'un rôle privilégié : sans les ordres suivants, chaque application lit la base de l'autre. L'extrait est partiel — huit ordres, dont les six révocations qui portent le cloisonnement, quand le corps en dénombre dix pour l'accueil complet du second locataire.

```

REVOKE CONNECT ON DATABASE menal_db FROM PUBLIC;
REVOKE CONNECT ON DATABASE menal_db FROM app2_user;
REVOKE CONNECT ON DATABASE app2_db  FROM PUBLIC;
REVOKE CONNECT ON DATABASE app2_db  FROM api_user;
GRANT  CONNECT ON DATABASE app2_db  TO  app2_user;
GRANT  ALL ON SCHEMA public TO app2_user;
REVOKE cloudsqlsuperuser FROM app2_user; -- sinon l'accès
-- croise persiste
REVOKE cloudsqlsuperuser FROM api_user;  -- et de meme
-- dans l'autre sens

```

Les deux dernières révocations sont celles qui comptent : sans elles, l'accès croisé subsiste par héritage, et leur symétrie n'est pas décorative. Omettre la seconde produirait une isolation à **sens unique** — la plateforme lirait la base du locataire sans la réciproque — et c'est la direction qui porte le risque : la base du locataire contient un identifiant national, celle de la plateforme seulement des empreintes de mots de passe et un secret de second facteur chiffré.

Chaîne de données d’une vue du tableau de bord. Le motif suivant est identique dans les dix éléments rendus au serveur : lecture du jeton dans le témoin de connexion, appel de l’API, aucun accès direct à une source de données.

```
// app/detections/page.tsx --- composant rendu au serveur
const token = cookies().get("token")?.value;
const data = await getDetections(token, 24, 200, tenant);
// lib/api.ts --- unique point de sortie HTTP
fetch(`${apiUrl()}${path}`, {
  headers: { Authorization: `Bearer ${token}` },
  cache: "no-store",
});
```

Aucun client d’entrepôt de données ni de base relationnelle ne figure parmi les dépendances de production du tableau de bord : la propriété énoncée au chapitre 5 est donc vérifiable par simple inventaire.

Annexe C Modèle de menaces détaillé

Cette annexe porte le détail des ateliers de l'analyse EBIOS Risk Manager du chapitre 3 : codification, échelles de cotation, vingt-quatre scénarios opérationnels et appréciation du risque. Les catégories STRIDE y sont notées S (usurpation d'identité), T (altération), R (répudiation), I (divulgaration), D (déni de service) et E (élévation de privilège).

C.1 Codification, scénarios stratégiques et échelles de cotation

Le corps du chapitre désigne valeurs métier, biens supports et sources de risque par leur nom ; le tableau 46 donne la codification à laquelle renvoient les colonnes des tableaux qui suivent, et le rattachement de chaque valeur métier à ses biens supports.

TAB. 46. Codification des valeurs métier, biens supports et sources de risque

Famille	Codes et désignations
Valeurs métier	VM1 corpus linguistique constitué · VM2 identités et voix des contributeurs · VM3 intégrité de la compétition · VM4 disponibilité du service · VM5 intégrité des preuves de supervision · VM6 crédibilité technique de MENAL
Biens supports	BS1 base applicative · BS2 entrepôt de supervision · BS3 charges de travail · BS4 chaîne de livraison applicative · BS5 coffre de secrets · BS6 identités et autorisations · BS7 dépôt de code et état de l'infrastructure · BS8 tâche d'enrichissement · BS9 point d'entrée public
Sources de risque	SR1 attaquant opportuniste (A7) · SR2 acteur intéressé par le corpus (A8) · SR3 participant fraudeur (A9) · SR4 chaîne d'approvisionnement logicielle (A10) · SR5 interne ou prestataire (A11) · <i>SR6 acteur étatique organisé — écarté par décision explicite, hors proportion avec les moyens du périmètre</i>
Rattachement	VM1 dépend de BS1, BS3, BS4, BS5, BS6 et BS7 · VM2 de BS1, BS5, BS6 et BS7 · VM3 de BS1 et BS6 · VM4 de BS1, BS3, BS4, BS6 et BS9 · VM5 de BS2, BS4, BS6, BS7 et BS8 · VM6 n'a pas de bien support propre : elle est la conséquence transverse de l'atteinte des cinq autres

Le tableau 47 donne les sept scénarios stratégiques de l'atelier 3, avec leur source de risque, la valeur métier atteinte et la gravité retenue.

TAB. 47. Scénarios stratégiques

#	Chemin de haut niveau	Source → valeur	Gravité
SS1	Accès direct à la base de données, copie du corpus et des identités	SR2 → VM1, VM2	G4 critique
SS2	Obtention et téléchargement de l'URL ou du jeton d'export du corpus	SR2 → VM1	G4 critique
SS3	Détournement de l'identité de déploiement, déploiement non revu	SR4, SR5 → VM1, VM4, VM5	G4 critique
SS4	Altération ou effacement des journaux et des détections	SR2, SR5 → VM5	G3 grave
SS5	Contournement des contrôles applicatifs, classement faussé	SR3 → VM3	G3 grave
SS6	Saturation ou détournement d'un service exposé	SR1 → VM4	G2 significative
SS7	Divulgaration d'un secret permettant de reconstituer des accès légitimes	SR1, SR5 → VM1, VM2	G4 critique

Le tableau 48 définit les quatre niveaux de gravité et les quatre niveaux de vraisemblance, avec leur critère de classement. La vraisemblance est appréciée à partir de ce qui est observé sur des systèmes comparables, non d'une probabilité calculée : le périmètre ne fournit pas la base statistique qu'un calcul supposerait.

TAB. 48. Échelles de gravité et de vraisemblance

Gravité	Critère	Vraisemblance	Critère
G1 Mineure	Gêne interne, sans conséquence externe	V1 Minimale	Suppose des moyens ou un accès préalable importants
G2 Significative	Interruption de service ou perte de données limitée et récupérable	V2 Significative	Réalizable par un attaquant motivé disposant d'un accès initial limité
G3 Grave	Perte d'intégrité durable, contestation, perte de confiance	V3 Forte	Régulièrement observé sur des systèmes comparables
G4 Critique	Divulgaration de données personnelles ou perte de l'actif principal	V4 Maximale	Systématique, observé en continu sur tout service exposé

C.2 Scénarios opérationnels

Le tableau 49 liste les vingt-quatre scénarios opérationnels obtenus en appliquant STRIDE aux sept flux, chacun rattaché à la frontière qu'il franchit, à son scénario stratégique d'origine et, lorsque c'est possible, à une technique de la matrice MITRE ATT&CK [21] — qui décrit des comportements observés, non des défauts de conception.

TAB. 49. Scénarios opérationnels, rattachés à leur frontière de confiance

#	Flux / TB	STRIDE	Scénario opérationnel	ATT&CK	G / V	Scén. strat.
SO1	F1 / TB2	I, E	Exploitation d'une vulnérabilité applicative exposée sur Internet	T1190	G3 / V3	SS1
SO2	F1 / TB1	S	Réutilisation d'identifiants valides obtenus ailleurs	T1078	G3 / V3	SS5
SO3	F1 / TB1	S	Recherche exhaustive de mot de passe sur des comptes existants	T1110	G2 / V3	SS5
SO4	F1 / TB1	D	Saturation du service exposé par un volume de requêtes anormal	T1498/99	G2 / V3	SS6
SO5	F1 / TB1	I	Balayage automatisé de la surface exposée	T1595	G1 / V4	SS6
SO6	F2 / TB4	I	Accès direct à la base de données depuis Internet	T1530	G4 / V2	SS1
SO7	F2 / TB5	E	Identité de service applicative lisant hors de son périmètre	T1078.004	G3 / V2	SS1
SO8	F2 / TB4	I	Jeton d'accès aux données non lié à une identité, transmissible	T1550	G4 / V2	SS2
SO9	F3 / TB5	S	Détournement de l'identité de déploiement par une clé exportée	T1552.001	G4 / V2	SS3
SO10	F3 / TB5	T	Code malveillant via une dépendance ou image de base compromise	T1195.002	G4 / V2	SS3
SO11	F3 / TB5	E	Déploiement d'un artefact non contrôlé, portes contournées	T1195	G3 / V2	SS3
SO12	F3 / TB5	I	Divulgaration d'un secret versionné dans le dépôt ou son historique	T1552.001	G4 / V3	SS7
SO13	F4 / TB5	T	Altération ou suppression de journaux pour dissimuler une action	T1070	G3 / V2	SS4
SO14	F4 / TB5	D	Désactivation ou dégradation de la collecte de journaux	T1562	G3 / V2	SS4
SO15	F4 / —	R	Absence de trace permettant d'attribuer une action à un acteur	—	G3 / V2	SS4
SO16	F5 / TB5	T	Écriture du composant d'enrichissement dans les tables qu'il analyse	T1070	G3 / V2	SS4
SO17	F5 / TB3	E	Composant d'encodage utilisé comme rebond vers d'autres ressources	T1078.004	G3 / V1	SS3
SO18	F5 / TB3	D	Saturation du composant d'encodage par un volume d'alertes anormal	T1499	G2 / V2	SS6
SO19	F6 / —	T	Falsification du rattachement d'une vulnérabilité pour la déclasser	—	G2 / V1	SS3
SO20	F7 / TB5	E	Modification de l'infrastructure sans revue, accès direct au fournisseur	T1098	G4 / V2	SS3
SO21	F7 / TB5	I, T	Accès en lecture/écriture à l'état de l'infrastructure	T1530	G4 / V2	SS3, SS7
SO22	F7 / TB5	E	Création d'une identité ou d'un droit par un acteur ayant un premier accès	T1098.001	G4 / V2	SS3
SO23	Tous / TB5	E	Détournement de ressources de calcul pour un usage illégitime	T1496	G2 / V2	SS6

#	Flux / TB	STRIDE	Scénario opérationnel	ATT&CK	G / V	Scén. strat.
SO24	Tous / TB3	I	Exfiltration par un canal sortant autorisé, vers une destination indiscernable de la légitime	T1567	G3 / V2	SS1, SS2

Rattachement des frontières. La règle — la frontière retenue est celle que le scénario franchit indûment, non celle où se trouve le contrôle qui le traite — est énoncée au chapitre 3. Deux cas appellent une précision. **SO12** porte sur un secret déposé dans le dépôt de code, magasin extérieur au socle : la divulgation n’a lieu à l’intérieur d’aucune frontière, mais son exploitation franchit TB5, et c’est elle qui est cotée. **SO16** est rattaché à TB5 bien que la tâche d’enrichissement atteigne l’entrepôt par la route privée (F5b) : le magasin visé appartient au plan managé, et le contrôle qui y répond est un droit d’écriture, non une règle réseau.

Note de version. Les identifiants renvoient à la version 19 de la matrice ATT&CK (section 2.3.2), où deux techniques employées ici ont changé de tactique — T1070 et T1562 —, ce qui conditionne la comparabilité de la couverture du chapitre 6.

C.3 Cartographie et traitement du risque

Cartographie du risque avant traitement, par croisement gravité × vraisemblance, case par case. **G4 critique** : SO6, SO8, SO9, SO10, SO20, SO21 et SO22 en V2 ; SO12 en V3. **G3 grave** : SO17 en V1 ; SO7, SO13, SO14, SO15, SO16 et SO24 en V2 ; SO1 et SO2 en V3. **G2 significative** : SO19 en V1 ; SO18 et SO23 en V2 ; SO3 et SO4 en V3. **G1 mineure** : SO5 en V4. Toute case non nommée est vide.

Lecture. La zone de risque la plus élevée regroupe huit scénarios, dont sept concernent les chaînes de livraison et de provisionnement (F3, F7) ou l’accès direct aux données (F2) ; six franchissent TB5 et deux TB4. SO12, seul scénario critique de vraisemblance forte, correspond exactement au point bloquant B2 de l’audit du chapitre 1. Le tableau 50 récapitule la décision retenue pour chaque scénario.

TAB. 50. Décisions de traitement du risque

Décision	Scénarios	Justification
Réduire	SO1, SO4, SO6 à SO16, SO18, SO20 à SO24	Traités par des contrôles d’architecture, détaillés au chapitre 4
Réduire partiellement	SO2, SO3, SO5	Le socle limite l’exposition et détecte ; le traitement complet relève du code applicatif, hors périmètre
Réduire puis accepter le résiduel	SO17, SO19	Rebond depuis l’encodage sans chemin vers une ressource privée depuis le retrait du composant du réseau ; contrôles posés sur F6 ; résiduel accepté à la date de 25/08/2026, décision datée et révisable
Transférer	—	Aucun transfert (pas d’assurance ni de sous-traitance de sécurité dans le périmètre)

Les vingt-quatre scénarios sont rattachés à une décision, sans exception ; trois appellent une précision. **SO15** — absence de trace attribuant une action — relève de la réduction au titre de l’exigence EX13, la journalisation d’audit des quatre services porteurs de données ; T13 est *partiellement conforme* : ces journaux ne sont acheminés vers aucune destination dédiée ni exploités par une règle, de sorte que l’attribution est possible sans être incontestable. Pour **SO17 et SO19**, l’acceptation du résiduel suit les mesures de réduction au lieu de s’y substituer : SO17 est réduit au plan réseau et son résiduel est la sortie managée du composant d’encodage, dont T14 établit l’étendue ; pour SO19, la condition de réévaluation reste une comparaison sur le flux

F6, dont le mode opératoire est publié pour qu'un tiers l'exécute — elle n'est pas inscrite au plan de validation continue, qui ne porte que six protocoles (T12, T14, T15, T17, T19, T20).

Annexe D Conception détaillée

Cette annexe développe trois ensembles que le chapitre 4 ne porte qu'en synthèse : la justification de chacune des dix-sept décisions d'architecture, le motif de rejet et la condition de réévaluation des sept composants écartés, et l'état de validation des vingt exigences. La conception détaillée couche par couche figure dans le corps (section 4.5) et n'est pas dupliquée ici.

D.1 Registre complet des décisions d'architecture

Les dix-sept décisions D00 à D16 figurent au tableau 51 avec leur statut — *validée* (conservée telle quelle), *retouchée* (ajustée par rapport à la conception initiale), *ajoutée* ou *réserve* — et leur justification. Les deux dernières, dont le corps porte le dossier de décision entier, y renvoient plutôt que de le répéter.

TAB. 51. Registre complet des décisions d'architecture, avec leur statut et leur justification

Décision et statut	Justification
D00 Google Cloud comme fournisseur unique du socle — <i>validée</i>	La contrainte humaine écarte l'auto-hébergement des briques de sécurité, la contrainte économique la facturation au forfait; entre les trois fournisseurs restants, le critère décisif — stockage, langage de détection et recherche vectorielle dans un même entrepôt, ce qui supprime la base vectorielle séparée qu'imposeraient les deux autres — est établi au chapitre 2. Décision la moins réversible du registre, elle conditionne D01 à D07 et D11
D01 Exécution de conteneurs sans serveur comme unique plateforme — <i>validée</i>	Aucun système d'exploitation à durcir, chiffrement interne natif, identité par service, réduction à zéro hors trafic. Un orchestrateur apporterait une souplesse inutile ici, au prix d'un cluster à exploiter
D02 Point d'entrée unique avec filtrage applicatif — <i>validée</i>	Un point d'entrée unique est un point de contrôle unique, et le filtrage managé couvre les risques applicatifs courants sans composant à maintenir. Corollaire assumé : l'évaluation étant premier-match-gagne, l'ordre des règles devient une propriété de sécurité
D03 Base de données managée, adresse privée, restauration à un instant donné — <i>validée</i>	Correspond au besoin de l'application hébergée. L'instance de recette a été basculée en haute disponibilité régionale le 08/08/2026 (voir D13)
D04 Entrepôt de données généraliste comme système de supervision — <i>validée</i>	Le système de supervision est <i>construit</i> , non acheté : c'est l'apport du projet. L'entrepôt fournit le stockage, le langage de détection et — point décisif — la recherche vectorielle nécessaire à L6 sans base spécialisée
D05 Modèle de représentation non génératif pour l'enrichissement — <i>validée</i>	Sortie plus reproductible qu'une génération libre, exécution sur processeur généraliste, surface d'injection par instruction réduite — sans supprimer les risques liés aux entrées, au modèle ou à sa chaîne d'approvisionnement
D06 Recherche vectorielle déportée dans l'entrepôt — <i>validée</i>	Supprime un composant entier; cohérent avec le principe de justification
D07 Registre d'images unique, retrait du second registre — <i>retouchée</i>	Deux registres constituent deux surfaces de chaîne d'approvisionnement et une ambiguïté sur la source de vérité. Les images de base restent accessibles par un dépôt miroir en lecture
D08 Fédération d'identité pour la chaîne de livraison — <i>ajoutée</i>	Évite une clé de longue durée dans le chemin de livraison. La condition d'attribut porte sur le dépôt <i>et</i> sur la branche, pour la raison exposée en section 5.2.3; la politique d'organisation censée interdire toute création de clé est inapplicable dans le périmètre administratif disponible (É7)
D09 Détection de secrets en tête de chaîne — <i>ajoutée</i>	Coût quasi nul, gain élevé; l'audit du chapitre 1 démontre le coût d'un secret mal géré

Décision et statut	Justification
D10 Autorisation applicative par rôles conservée — <i>validée</i>	L'autorisation applicative reste dans l'application, celle d'infrastructure protège l'infrastructure : les deux plans ne se substituent pas l'un à l'autre
D11 Sortie réseau par le chemin contrôlé — <i>réserve, levée par D15</i>	Le routage était décrit en code, mais le contrôle effectif était porté par le paramètre de sortie de la plateforme d'exécution et non par une règle de pare-feu : c'est cet écart entre configuration établie et propriété vérifiée que le statut enregistrait. La refonte du plan réseau l'a levé ; T20 le confirme (conforme, 24/08/2026) et T14 en délimite la portée résiduelle (non conforme, 25/08/2026)
D12 Infrastructure en code comme standard unique de provisionnement — <i>validée, renforcée</i>	Réponse directe au point bloquant B5. Trois gains : reproductibilité, contrôle avant création, détection de dérive
D13 Haute disponibilité régionale appliquée — <i>révision de D03, 08/08/2026</i>	Bascule appliquée en recette et confirmée en direct le 08/08/2026, en 11 min 2 s : le point de défaillance zonal de la base est fermé et le code d'infrastructure décrit cet état. Limite subsistante : le basculement de zone n'a jamais été provoqué ni chronométré en conditions réelles
D14 Réécriture du tableau de bord sur un cadre à rendu serveur avec passerelle applicative — <i>validée</i>	L'interface antérieure exécutait ses requêtes depuis le poste de l'analyste et détenait pour cela un mot de passe de service. La réécriture déplace tous les appels côté serveur : le navigateur ne détient plus qu'un jeton de session, la clé de signature n'est jamais connue du service qui rend les pages, et l'autorité d'autorisation reste l'API de supervision — le secret antérieur devenant un vestige dont le retrait accompagne la clôture de cette décision
D15 Sortie réseau directe, refus par défaut en sortie et pare-feu ciblé par identité — <i>appliquée du 11 au 25/08/2026</i>	Le verrou levé est qu'une règle de refus n'aurait rien bloqué : le trafic ne passait pas là où elle se serait appliquée. Plan d'adressage, douze règles, coût et limites sont établis en section 4.2.5, la conduite de la migration en section 5.3.3. Vérification : protocole T20, conforme le 24/08/2026
D16 Isolation des données proportionnée à la sensibilité — <i>arrêtée le 29/08/2026, non appliquée</i>	Justification, test d'admission d'un locataire, coût et prix payé en section 4.2.6. Le statut est un choix d'ordonnancement énoncé comme tel : deux migrations d'infrastructure dans la même quinzaine ne sont pas soutenables par un opérateur unique

Un second registre, tenu au fil de la réalisation, enregistre les quinze décisions prises du 30/07/2026 au 19/08/2026 : le premier documente le *pourquoi* de l'architecture cible, le second celui de chaque évolution.

D.2 Composants évalués puis écartés

Sept éléments ont été évalués puis écartés en application du principe de justification. Les documenter démontre que leur absence est une décision et non une lacune ; chacun figure au tableau 52 avec son motif de rejet et sa *condition de réévaluation*.

TAB. 52. Composants évalués puis écartés, motif et condition de réévaluation

Composant	Motif de rejet	Condition de réévaluation
Périmètre de protection contre l'exfiltration	Mécanisme puissant mais lourd à exploiter — exceptions, diagnostic complexe — et disproportionné pour un périmètre à projet unique	Passage en production multi-équipes avec données réglementées
Orchestracteur de conteneurs et maillage de services	La plateforme retenue fournit déjà le chiffrement interne et l'identité par service ; un maillage ajouterait un plan de contrôle entier sans couvrir de menace résiduelle identifiée	Besoin de charges longues, à état, ou de politiques fines entre services
Cache distribué	Nécessaire aux seules limitations de débit distribuées et au cache multi-instances, la mise à l'échelle étant hors objectif (BNF7)	Montée en charge réelle
Déploiement multi-région	Coût doublé, complexité triplée, valeur de démonstration nulle ; les sauvegardes couvrent le risque de perte de données	Exigence contractuelle de disponibilité
Vérification de signature des images au déploiement	Contrôle excellent, mais d'apport marginal après le contrôle de vulnérabilité, le registre unique et la fédération d'identité	Première extension recommandée après le projet
Passerelle d'authentification devant le tableau de bord	L'autorisation applicative par rôles couvre le besoin du périmètre ; une passerelle ajouterait une fédération d'entreprise redondante, et son service managé exige une organisation cloud dont le projet ne dispose pas	Ouverture du tableau de bord à des identités d'entreprise

Composant	Motif de rejet	Condition de réévaluation
Modèle de langue génératif pour l'analyse d'incidents	Écart par conception : sortie non déterministe et surface d'injection par le contenu des journaux, inacceptables dans une chaîne de preuve	Aucune

Le dernier rejet est de nature différente des six autres : ceux-là sont des arbitrages de coût ou de complexité, révisables si le contexte change ; celui-ci est un contrôle de sécurité, et sa raison ne dépend pas du contexte.

D.3 Prise en charge des vingt exigences par la conception

Le tableau 53 donne, exigence par exigence, la ou les couches qui la prennent en charge et son état de validation à la date de référence ; le corps (section 4.5.1) n'en retient que la synthèse et les trois réserves — EX7, EX9 et le couple EX16 / EX18. L'intitulé complet de chaque exigence figure dans la matrice de traçabilité du chapitre 3. À la date de 25/08/2026, les vingt protocoles portent tous un résultat daté ; six d'entre eux sont en outre rejoués à la cadence fixée par le **plan de validation continue** (section 6.2.3).

TAB. 53. Prise en charge des exigences par la conception et état de validation

Exigence	Couche(s)	Statut
EX1	L1	Prévue ; T1 non conforme — motif brut traité par redirection
EX2	L1, L5	Prévue ; T2 conforme
EX3	L1, L7	Prévue ; T3 partiellement conforme
EX4	L4, L5	Prévue ; T4 partiellement conforme
EX5	L2	Prévue ; T5 conforme
EX6	L2, L3	Prévue ; T6 partiellement conforme
EX7	L2	Réserve : politique d'organisation inapplicable (écart É7) ; T7 conforme, garantie vérifiée par inventaire et non préventive
EX8	F3	Prévue ; T8 conforme — refus réellement survenu
EX9	L2, F3	Réserve : déploiement par étiquette de commit, empreinte stricte non prouvée (écart É8) ; T9 partiellement conforme
EX10	L2, F3	Prévue ; T10 partiellement conforme
EX11	L2, L5	Prévue ; T11 conforme
EX12	L7	Prévue ; T12 partiellement conforme (22/08/2026)
EX13	L7	Prévue ; T13 partiellement conforme
EX14	L4, L6	Ouverte : T14 non conforme (25/08/2026), sortie managée non gouvernée
EX15	L6	Prévue ; T15 partiellement conforme (22/08/2026)
EX16	F7	Réserve : bornée aux ressources déjà gérées ; T16 partiellement conforme
EX17	F7	Prévue ; T17 conforme (20/08/2026)
EX18	F7	Réserve : revue manuelle, sans porte d'approbation outillée ; T18 partiellement conforme
EX19	L7	Prévue ; T19 partiellement conforme (21/08/2026)
EX20	L4	Journalisation des refus déployée le 19/08/2026 ; T20 conforme (24/08/2026)

Annexe E Protocoles et preuves de validation

Cette annexe est la base de reproduction de la campagne de vingt protocoles dont le chapitre 6 publie les résultats : un tiers disposant du même environnement peut rejouer chacun d’eux, son critère d’acceptation étant formulé avant exécution et publié ici. Elle donne les conditions de mesure, le modèle de fiche appliqué à chaque protocole, et les vingt protocoles avec leur critère, leur résultat et sa date. Deux relevés de recette les complètent sans en fonder aucun — antériorité du dernier rattachement sémantique sur l’attaque du 19/08/2026, durées de retour arrière applicatif du 07/08/2026 — et sont publiés avec leur date en sections 6.3.3 et 6.4.

Conditions de mesure et modèle de fiche. La campagne est exécutée sur l’environnement de recette, de topologie identique à la cible (section 5.1) ; les preuves ponctuelles sont datées jusqu’au 25/08/2026, les preuves automatisées sont rejouées à chaque livraison et n’ont pas de date unique de relevé. Deux paramètres ne sont pas épinglés, et le sont dits : la version du référentiel de configuration d’infrastructure n’est pas consignée, et la matrice de techniques d’attaque non plus — l’instantané employé est identifié par l’empreinte publiée en section 6.3. Aucun taux de conformité ni de couverture n’en est tiré.

Chaque protocole suit le même modèle : un identifiant **Ti** renvoyant à l’exigence **EXi** et à la menace qu’il vérifie ; un **protocole** décrivant l’action tentée ; un **critère d’acceptation** formulé avant l’exécution et non révisé après coup ; un **résultat** selon la convention à quatre valeurs de section 6.1 ; et la **preuve** qui le fonde, avec sa date ou son mode d’exécution. Les six protocoles rattachés au plan de validation continue portaient en outre un **attendu** — ce que la preuve devrait rendre visible, énoncé *avant* l’exécution — reproduit ci-dessous sans révision, à côté du relevé qui l’a confronté : l’écart est nul pour T17 et T20, partiel pour T12, T15 et T19, défavorable pour T14.

Une règle de méthode gouverne enfin la production de ces preuves : **la sortie brute d’exécution est conservée, horodatée dans le cadre même où elle est produite**, et c’est elle qui fait preuve — une date portée par une légende est une affirmation de l’auteur, une date lisible dans la sortie est une propriété de la preuve. Les valeurs sensibles qu’elle porte y sont masquées par rectangle opaque et jamais par floutage, un flou étant réversible par traitement d’image.

Protocoles détaillés.

T1 — Filtrage des attaques applicatives (EX1, SO1). Envoyer, depuis l’extérieur, des charges d’attaque correspondant aux cinq familles de règles activées au périmètre. *Critère* : toutes les requêtes sont rejetées avant d’atteindre la charge de travail, verdict journalisé. *Résultat* : **non conforme**. *Preuve* : le 23/08/2026, les charges d’injection SQL, de script inter-sites et d’inclusion de fichier local ont été refusées en 403, mais une forme brute de traversée de chemin a reçu une redirection 302 — le quantificateur du critère n’est pas tenu ; mécanisme et correctif en section 6.2.1.

T2 — Limitation des tentatives d’authentification (EX2, SO2/SO3). Générer des échecs d’authentification répétés depuis une adresse unique jusqu’au franchissement du seuil. *Critère* :

blocage temporaire déclenché, trace présente dans l'entrepôt. *Résultat* : conforme. *Preuve* : le 19/08/2026, onze requêtes ont produit dix réponses 422 puis une réponse 429.

T3 — Comportement sous charge et traçabilité du balayage (EX3, SO4/SO5). Générer une charge supérieure au seuil global puis un balayage de la surface exposée. *Critère* : le service reste disponible, les deux activités apparaissent dans les journaux. *Résultat* : partiellement conforme. *Preuve* : le balayage est tracé, les journaux du répartiteur étant collectés sans filtre de statut ni de sévérité. *Réserve* : l'essai de charge au-delà du seuil global n'est pas documenté.

T4 — Inaccessibilité des données depuis Internet (EX4, SO6). Depuis un hôte externe, tenter une connexion directe à la base de données ; vérifier par inventaire qu'aucune adresse publique n'est attribuée. *Critère* : aucune adresse publique, connexion en échec. *Résultat* : partiellement conforme. *Preuve* : l'inventaire de l'instance montre l'attribution d'adresse publique désactivée, un raccordement par accès privé aux services et un mode de transport strictement chiffré. *Réserve* : l'échec de connexion est *déduit* de l'absence de route, non relevé depuis un hôte externe — c'est la déduction, non la mesure, qui borne ce résultat.

T5 — Cloisonnement des identités applicatives (EX5, SO7). Avec l'identité d'une application hébergée, tenter une lecture de l'entrepôt de supervision. *Critère* : refus d'autorisation. *Résultat* : conforme. *Preuve* : deux rôles exactement attribués et usurpation refusée en direct le 23/08/2026 ; l'identité du composant d'encodage est dépourvue de tout rôle sur l'entrepôt, vérifié le 19/08/2026. Un test automatisé rejoue à chaque livraison la lecture interdite du secret de base applicative sous l'identité d'enrichissement et exige le refus.

T6 — Authentification des appels entre services (EX6, SO8). Appeler le service d'encodage sans jeton d'identité. *Critère* : refus — être « à côté » ne doit rien accorder. *Résultat* : partiellement conforme. *Preuve* : un test automatisé, en porte bloquante à chaque livraison, émet l'appel sans jeton et vérifie le refus ; l'entrée du service est restreinte aux appels internes et le droit d'invocation à la seule identité d'enrichissement. *Réserve* : l'appel du test vient de l'extérieur du réseau privé, et le refus atteste donc le contrôle de périmètre ; l'appel depuis l'intérieur sans jeton, formulation exacte du critère, reste porté par la configuration.

T7 — Absence de clés de longue durée (EX7, SO9). Inventorier les clés existantes pour toutes les identités de service ; tenter d'en créer une. *Critère* : inventaire vide et absence de clé exportée dans la chaîne. *Résultat* : conforme. *Preuve* : le critère est un inventaire, et l'inventaire est vide — recherche exhaustive sur le dépôt et l'infrastructure, aucune ressource de clé de compte de service, aucun fichier d'identifiants, aucune variable de justificatifs ; la fédération d'identité, contrainte à la fois sur le dépôt et sur la branche, rend la clé inutile. *Qualification* : la garantie est *vérifiée* par inventaire reproductible et non *préventive*, l'interdiction structurelle de créer une clé relevant d'une politique d'organisation hors du périmètre administratif disponible (écart É7). La distinction qualifie le résultat sans l'annuler : le critère ne porte pas sur l'existence d'un contrôle préventif.

T8 — Blocage d'un artefact vulnérable (EX8, SO10). Soumettre à la chaîne une image contenant une vulnérabilité critique connue. *Critère* : arrêt à l'étape d'analyse de vulnérabilité [23]. *Résultat* : conforme, sur un refus réellement survenu et sans mise en scène. *Preuve* et *réserve* — vulnérabilité de node-tar 6.2.1, correctif retenu, ordre publication/analyse à réaligner — en section 6.2.2.

T9 — Registre de confiance unique (EX9, SO11). Tenter un déploiement depuis une source d'images externe, puis par référence mutable au lieu d'une empreinte. *Critère* : les deux tentatives échouent [23] — une étiquette contenant une empreinte de commit ne constitue pas une empreinte d'image immuable. *Résultat* : partiellement conforme. *Preuve* : un registre unique, une résolution par empreinte d'image sur le chemin de description en code, une étiquette par empreinte de commit sur le chemin de livraison — immuable en pratique, mutable en théorie. *Réserve* : aucun contrôle n'oppose de refus, ni étiquettes immuables ni admission d'image n'étant déclarées, et l'application hébergée est déployée par étiquette flottante (écart É8). La propriété tient par construction, non par imposition : c'est la borne exacte de ce résultat.

T10 — Blocage d'un secret versionné (EX10, SO12). Soumettre un secret factice de format reconnaissable ; vérifier séparément qu'aucun secret du système n'est dérivé d'un autre. *Critère* : arrêt à la première étape, indépendance confirmée par inventaire. *Résultat* : partiellement conforme. *Preuve* : la porte de détection de secrets est bloquante à chaque livraison comme à chaque demande de fusion, sur l'historique complet du dépôt, une profondeur de clone complète lui étant explicitement accordée ; l'indépendance est établie par inventaire, chaque secret étant engendré par un tirage aléatoire indépendant, stocké séparément et injecté par référence, aucun mot de passe ne transitant par une variable de configuration. *Réserve* : aucun refus n'a été observé sur un secret factice, et le cas de la porte déclarée bloquante mais inerte (section 5.8.1) est la raison pour laquelle une porte non éprouvée n'est pas comptée conforme.

T11 — Intégrité de la chaîne de preuve (EX11, SO13/SO16) — *test le plus discriminant de la campagne*. Avec l'identité de la tâche d'enrichissement, tenter une écriture puis une suppression dans les tables de journaux bruts et de détections. *Critère* : refus sur ces tables, écriture restant possible sur la seule table d'enrichissement. *Résultat* : conforme. *Preuve* : un test de bout en bout automatisé, rejoué à chaque livraison, tente réellement l'insertion interdite sous l'identité usurpée et n'est vert que si elle est refusée ; la vérification des droits table par table du 19/08/2026 couvre en outre la table des journaux bruts et le cas de la suppression. Le mécanisme, l'histoire de ce test et sa *réserve* — tâche non bloquante, abstention explicite lorsque l'identité courante n'a pas le droit d'usurpation — sont analysés en section 6.2.2.

T12 — Détection d'une interruption de collecte (EX12, SO14). Interrompre volontairement la collecte au-delà du seuil d'alerte. *Critère* : une alerte est émise. *Attendu, écrit avant exécution* : la notification effectivement reçue sur le canal déclaré, avec l'heure d'interruption, l'heure de déclenchement et le délai qui les sépare. *Résultat* : partiellement conforme. *Preuve* : le 22/08/2026, le générateur de trafic de recette a été arrêté à 10:35:00 ; la politique d'absence de signal s'est ouverte à 11:10:44 et la notification a été reçue à 11:11:19, soit 36 min 19 s après l'interruption — 30 min de durée de condition, 300 s de période d'alignement, puis évaluation et acheminement. *Réserve* : exécutée d'abord sur l'autre panne que recouvre le protocole, l'interruption de l'acheminement des journaux, la mesure est défavorable — l'acheminement coupé de 09:12 à 10:20 n'a ouvert aucune alerte, 1 148 requêtes comptées par la métrique d'exécution n'ont produit aucune ligne dans l'entrepôt, et le rétablissement n'a rien rejoué : la politique porte sur la production des journaux, jamais sur leur acheminement ni sur la fraîcheur de la table qui les reçoit.

T13 — Attribution des actions privilégiées (EX13, SO15). Exécuter une action privilégiée identifiable, la retrouver dans les journaux d’audit avec son auteur. *Critère* : action retrouvée, auteur identifié, horodatage cohérent. *Résultat* : partiellement conforme. *Preuve* : la journalisation d’audit des accès aux données est activée en lecture *et* en écriture sur les quatre services porteurs de données — entrepôt, gestionnaire de clés, gestionnaire de secrets, base relationnelle — et le journal d’activité d’administration est produit par construction, sans désactivation possible. *Réserve* : ces journaux ne sont acheminés vers aucune destination dédiée, demeurent dans un espace à rétention de trente jours modifiable, et aucune règle ne les exploite. L’attribution est possible, elle n’est pas rendue incontestable.

T14 — Sortie du composant d’inférence (EX14, SO17). Depuis le composant d’encodage, tenter une connexion sortante vers une destination externe. *Critère* : échec de connexion. *Attendu, écrit avant exécution* : l’échec horodaté d’une connexion sortante émise depuis le composant lui-même, et la trace de refus correspondante. *Résultat* : **non conforme**. *Preuve* : le 25/08/2026, deux sondes ne différant que par leur chemin de sortie ont été exécutées sous l’identité du composant. La sonde A, placée dans le sous-réseau plateforme avec l’étiquette du composant et la sortie directe, a été refusée deux fois — à 10:04:14 vers 203.0.113.10:443 et à 10:04:26 vers 198.51.100.7:443 — par la règle de refus par défaut en sortie, chaque refus portant sa ligne de journal dans l’entrepôt et son code 28 côté client 10,3 s plus tard. La sonde B, portant la configuration réseau exacte de la révision déployée — sortie managée par la plateforme d’exécution, sans accès au réseau privé — a reçu un code 204 en 412 ms à 10:12:38 ; la lecture de la révision à 10:18 confirme l’absence de bloc d’accès au réseau. Sur le chemin réellement emprunté par le composant, la connexion aboutit et aucune règle de pare-feu ne s’applique. Le correctif, son coût et sa portée — il vaut identiquement pour l’interface web de l’application hébergée — sont analysés en section 6.2.1. *Réserve* : le relevé porte sur la capacité de sortie, non sur son usage — la sonde B partage l’identité et le chemin réseau de la révision déployée, non son binaire, et l’absence d’appel sortant dans l’image n’est établie que par lecture du code, preuve de rang 4 qui ne peut fonder aucun verdict de conformité.

T15 — Comportement de la chaîne d’enrichissement sous charge (EX15, SO18). Injecter un volume de détections nettement supérieur au volume nominal. *Critère* : la tâche se termine sans perte, coût et durée mesurés. *Attendu, écrit avant exécution* : le volume injecté, le nombre de détections traitées, la durée de la tâche et l’égalité entre entrées et sorties, relevés sur une même exécution. *Résultat* : partiellement conforme. *Preuve* : le 22/08/2026, 500 détections — environ dix-sept fois le volume nominal — ont été injectées à 14:00:00 ; sept exécutions successives, de 14:15 à 15:45, ont lu 350 détections et écrit 350 lignes dans la table d’enrichissement, entrées égales aux sorties sur chaque exécution, aucune en échec et aucune reprise. La durée maximale est de 96 s, dont 31 s de démarrage à froid du service d’encodage, pour un délai d’expiration de 600 s ; la durée cumulée est de 519 s et le coût marginal reste inférieur à 0,05 euro, dominé par le minimum forfaitaire de balayage par table et non par le volume. *Réserve* : le critère est tenu au niveau de la tâche, non de la chaîne — 150 des 500 détections injectées sont sorties de la fenêtre glissante de deux heures avant d’avoir été lues, sans erreur, sans code de retour non nul et sans trace. Le débit plafond mesuré est de 50 détections par quart d’heure, soit 200 par heure et une capacité d’absorption de 400 détections en attente ; la politique « Enrichissement

en retard » s'est ouverte à 14:35:47 et refermée à 16:05:12, non parce que le retard était résorbé mais parce que les lignes en attente étaient sorties de la fenêtre — l'alerte se referme à l'instant où la perte devient définitive. Le trafic de recette ayant été suspendu pendant la mesure, ce débit est une borne supérieure que le flux nominal, partageant le même lot de 50, abaisse.

T16 — Détection de dérive (EX16, SO20). Modifier hors code un attribut réversible d'une ressource déjà gérée dans l'état, puis exécuter une planification avec rafraîchissement. *Critère* : la planification signale la différence et les journaux d'audit identifient l'auteur [17]; une ressource nouvelle absente de l'état exige un contrôle d'inventaire séparé. *Résultat* : partiellement conforme. *Preuve* : mécanisme sollicité en conditions réelles lors de l'incident de chiffrement du 08/08/2026, planification sans différence obtenue le 19/08/2026, contrôle quotidien de dérive de l'isolation entre locataires doté de sa propre politique d'alerte. *Réserve* : aucune détection de dérive n'est planifiée sur l'infrastructure décrite en code, la chaîne de provisionnement (F7) ne comportant ni planification ni application automatisées, et une ressource créée hors état échapperait à la seule planification.

T17 — Protection de l'état de l'infrastructure (EX17, SO21). Tenter un accès en lecture à l'état avec une identité non autorisée. *Critère* : refus. *Attendu, écrit avant exécution* : le refus d'autorisation horodaté, avec l'identité employée et le droit manquant nommé. *Résultat* : conforme. *Preuve* : le 20/08/2026, quatre refus ont été opposés aux trois identités de service susceptibles d'atteindre l'emplacement de l'état — lecture refusée à 08:41:07 sous l'identité d'API, à 08:42:15 sous celle de la tâche d'enrichissement et à 08:43:02 sous celle du tableau de bord, chacune en erreur 403 nommant le droit `storage.objects.get` manquant, puis énumération du préfixe refusée à 08:43:44 sur `storage.objects.list`. Un contrôle positif à 08:45:20, sous l'identité de la chaîne de livraison, énumère l'objet d'état : sans lui, quatre échecs ne distingueraient pas un refus d'un chemin erroné. *Preuve* de rang 3, vérification en direct datée. *Réserve* : l'emplacement de l'état est provisionné hors description en code — ni son versionnement, ni son mode d'accès uniforme, ni sa politique de conservation ne sont déclarés, de sorte qu'une modification de ces propriétés ne serait signalée par aucun contrôle de dérive; le refus établit un état à un instant, non sa persistance, d'où la cadence de rejeu et le déclencheur sur tout changement d'emplacement ou de droits inscrits au plan. Le verrouillage concurrent est natif à l'emplacement retenu; son versionnement n'a jamais été éprouvé en reprise.

T18 — Revue avant modification de droits (EX18, SO22). Soumettre une modification élargissant les droits d'une identité. *Critère* : blocage en attente d'approbation, aucune application sans validation humaine. *Résultat* : partiellement conforme. *Preuve* : la revue de demande de fusion est en place et l'infrastructure est appliquée manuellement par l'administrateur, ce qui interpose de fait une validation humaine. *Réserve* : cette validation n'est pas outillée — aucun environnement protégé n'est déclaré sur les six tâches de la chaîne de livraison, donc aucune approbation n'est exigée par un mécanisme. Le contrôle tient par la procédure, non par la porte.

T19 — Détection d'une consommation anormale (EX19, SO23). Provoquer une consommation de ressources nettement supérieure au profil habituel. *Critère* : alerte émise. *Attendu, écrit avant exécution* : la notification reçue, le seuil franchi et le poste de consommation qui l'a provoqué. *Résultat* : partiellement conforme. *Preuve* : le prérequis a été levé le 20/08/2026

par la déclaration, dans le code d'infrastructure, d'un budget mensuel de 50,00 euros à seuils de 50 %, 90 % et 100 % de la dépense réelle, acheminé vers les deux canaux déjà déclarés. Le 21/08/2026, le budget a été ramené à 6,50 euros — la dépense du mois s'élevant alors à 6,42 euros, soit 98,8 % — puis une charge de 2 h 30 a porté le générateur de trafic à vingt fois son débit et rejoué 150 fois chacune des douze requêtes planifiées, soit 1 800 exécutions et environ 41 Go balayés. La dépense de fin de journée atteint 6,63 euros, 102,0 % du budget temporaire, pour 0,21 euro de consommation additionnelle ; les notifications des seuils 90 % et 100 % ont été reçues à 12:47 et 17:38. Le critère « alerte émise » est tenu : deux notifications reçues sur le canal déclaré, pour deux seuils distincts, avec leur horodatage. *Réserve* : les deux autres éléments de l'attendu ne le sont pas. Le délai entre franchissement et notification est un *intervalle* compris entre 5 h 48 et 8 h 18 — l'instant du franchissement n'étant connu qu'à l'heure près — et il n'est borné par aucun engagement ; la notification porte le nom du budget, le montant et le pourcentage, jamais le poste de consommation, reconstitué après coup depuis la ventilation de coût. Le dispositif est un signal de coût, non un signal de sécurité : un détournement de ressources fonctionne plusieurs heures avant le départ de la première notification.

T20 — Restriction des sorties réseau (EX20, SO24). Depuis une charge de travail applicative, tenter une connexion sortante vers une destination non autorisée. *Critère* : échec de connexion et trace de refus exploitable. *Attendu, écrit avant exécution* : l'échec de la connexion sortante côté charge de travail, et la ligne de refus correspondante retrouvée dans l'entrepôt de supervision, les deux horodatages se recoupant. *Résultat* : conforme. *Preuve* : la condition de recevabilité était acquise — journalisation des refus réseau activée et vérifiée depuis le 19/08/2026, ce qui clôt l'écart É1. Le 24/08/2026, après la pose du refus par défaut en sortie du 23/08 et avant le démontage de l'ancien chemin de traduction d'adresses, une tâche déployée avec l'identité de service, l'étiquette, le sous-réseau et le mode de sortie d'un locataire réel a émis trois tentatives, toutes refusées : à 09:12:33 vers une adresse externe non autorisée, par la règle de refus par défaut en sortie ; à 09:13:49 vers le sous-réseau de la plateforme, par la règle de refus croisé entre locataires ; à 09:15:02 vers l'adresse privée de l'instance de base sur le port 5432, par la règle nommée qui l'interdit. Les trois lignes de refus ont été retrouvées dans l'entrepôt avec la règle, la source, la destination et le port, interrogeables à 09:18, de 2 min 55 s à 4 min 12 s après l'événement, chacune précédant l'échec client de 10,2 à 10,3 s — le délai d'expiration demandé plus l'acheminement. Un contrôle positif à 09:16:41, la même sonde portant l'étiquette de la tâche d'enrichissement, atteint la destination autorisée par sa règle et reçoit un code 200 : sans lui, trois échecs ne distingueraient pas un refus du pare-feu d'une sortie réseau en panne. Preuve de rang 3, adossée à une configuration déclarée en code. *Réserves* : elles bornent la portée, non la couverture du critère. L'étiquette se pose dans la définition de la révision, de sorte que la frontière est opposable à une charge compromise mais non à un opérateur capable de déployer ; seuls les refus sont journalisés, par décision de coût ; l'exfiltration par les interfaces du fournisseur reste ouverte, l'autorisation qui rend l'entrepôt joignable rendant joignable tout entrepôt du même fournisseur ; et deux charges ne sont pas derrière ces règles — le composant d'encodage et l'interface web de l'application hébergée — ce dont T14 est la conséquence directe.

Annexe F Jeu d'évaluation de l'enrichissement sémantique

Cette annexe donne le détail de l'évaluation condensée au chapitre 6 : constitution du jeu de test, méthodes comparées, grandeurs relevées et condition de publication de chacune.

Jeu d'évaluation et méthodes comparées. Le jeu est prélevé sur les alertes produites par le système durant une période d'observation définie : **100 alertes visées, 50 au minimum**, tirées aléatoirement parmi les alertes distinctes afin d'éviter la sur-représentation des règles bruyantes. Chaque alerte est rattachée à la main à la technique attendue, ou à l'étiquette « aucune technique applicable », dans le catalogue ATT&CK Entreprise chargé dans l'entrepôt — instantané non épinglé, identifié par l'empreinte publiée en section 6.3. Une personne réalise l'annotation initiale et une seconde réannote le sous-ensemble de contrôle : c'est cette seconde annotation qui conditionne la publication.

Trois méthodes de rattachement sont mises en regard sur ce même jeu. **M0**, correspondance par mots-clés adossée à une table écrite à la main entre termes fréquents et techniques, sert de référence basse. **M1**, représentation statistique du texte et similarité cosinus contre les descriptions de techniques, sert de référence intermédiaire, sans apprentissage de domaine. **M2**, modèle de représentation spécialisé retenu par le projet [5, 2], est la méthode évaluée.

Une annotation réalisée par une seule personne, également auteure du système évalué, introduit un biais que le protocole traite plutôt que de l'ignorer (section 6.8.1) : ce sont les deux atténuations exigées — annoter *avant* de consulter les sorties du modèle, et faire réannoter un sous-ensemble par une seconde personne — et non le temps disponible, qui commandent la publication d'un chiffre comparatif. Une exactitude au premier rang produite par un annotateur unique confondu avec l'auteur du système ne mesurerait pas la qualité du rattachement, mais un accord de l'auteur avec lui-même.

Grandeurs relevées et conditions de publication. Quatre grandeurs de qualité sont définies avant tout relevé. L'**exactitude au premier rang** est la part des alertes dont la technique attendue est proposée en première position ; l'**exactitude aux trois premiers rangs** étend le compte aux trois propositions ; le **taux d'abstention** est la part des alertes laissées sans rattachement, sous le seuil de similarité ; le **taux d'erreur silencieuse** est la part des alertes rattachées à une technique *incorrecte* avec un score supérieur au seuil — la métrique la plus importante et la moins souvent rapportée. Une abstention est visible et sans danger, l'analyste sachant que le système ne sait pas ; un rattachement erroné présenté avec un score élevé oriente vers la mauvaise procédure. **Un système qui s'abstient souvent mais se trompe rarement est préférable à l'inverse**, et cette préférence doit rester visible dans la mesure.

Le protocole ne publie aucune valeur avant que ses conditions de validité ne soient réunies, et ces conditions sont écrites à l'avance plutôt que constatées après coup (tableau 54). Les six grandeurs sont relevées pour les trois méthodes sur le *même* échantillon, en une seule exécution, faute de quoi la comparaison porterait sur des jeux différents et ne mesurerait rien.

TAB. 54. Grandeurs relevées et condition de publication de chacune

Grandeur	Relevée pour	Condition de publication
Exactitude au premier rang	M0, M1, M2	Jeu de 50 à 100 alertes annotées, échantillonné aléatoirement parmi les alertes distinctes
Exactitude aux trois premiers rangs	M1, M2 (sans objet pour M0, qui ne classe pas)	Idem
Taux d’abstention	M0, M1, M2	Seuil de similarité déclaré et identique pour les trois méthodes
Taux d’erreur silencieuse	M0, M1, M2	Annotation réalisée <i>avant</i> consultation des sorties du modèle
Latence par alerte	M1, M2	Relevée sur la même machine et le même lot
Coût pour mille alertes	M2	Rapporté au dimensionnement déclaré du composant d’encodage
Toutes	—	Taux d’accord inter-annotateurs calculé sur un sous-ensemble réannoté par une seconde personne

La dernière ligne est la condition dominante : c’est la seule qui ne dépende pas de la machine mais d’un tiers, d’où sa formulation comme exigence de méthode et non comme étape de calendrier. Trois questions guident ensuite l’interprétation, quelle que soit la direction du résultat : le gain de M2 sur M1 existe-t-il — un résultat négatif est admis par avance au titre de l’objectif O5 et serait rapporté tel quel ; ce gain justifie-t-il le coût d’un composant supplémentaire, que mesurent la latence et le coût du tableau 54 ; et sur quel type d’alerte se concentre-t-il, une analyse par type étant plus informative qu’un chiffre global.

Une porte de qualité distincte a déjà été exécutée sur M2 lui-même, avant son emploi en recette : la bascule vers un export quantifié (int8), comparée aux rapprochements du modèle de référence (fp32) sur cinq requêtes de type SOC le 1^{er} août 2026, a rendu 0 correspondance de premier rang sur 5, ce qui a fait rejeter cet export et conserver le format non quantifié au prix d’une empreinte mémoire plus élevée (section 6.3.3). Ce test ne se substitue pas à la comparaison M0/M1/M2 : il montre que cet export int8 précis n’est pas acceptable sur le petit échantillon retenu, il ne valide pas la qualité générale de fp32.



Je valide le dépôt du rapport PFE relatif à l'étudiant nommé ci-dessous
I validate the submission of the student's report :

Nom & Prénom / *Name & Surname* : **Mansour HABIBOULLAH**

Encadrant Entreprise / *Business site Supervisor*

Nom & Prénom / *Name & Surname* : **Houssein Ezzedine**

Cachet & Signature / *Stamp & Signature* :

Encadrant Académique / *Academic Supervisor*

Nom & Prénom / *Name & Surname* : **Rihem Matoussi**

Signature / *Signature* :

*Ce formulaire doit être rempli, signé et scanné
This form must be completed, signed and scanned.*

ECOLE SUPÉRIEURE PRIVÉE D'INGÉNIERIE ET DE TECHNOLOGIES

www.esprit.tn - E-mail : contact@esprit.tn

Siège Social : 18 rue de l'Usine - Charguia II - 2035 - Tél. : +216 71 941 541 - Fax. : +216 71 941 889

Annexe : Z.I. Chotrana II - B.P. 160 - 2083 - Pôle Technologique - El Ghazala - Tél. : +216 70 685 685 - Fax. : +216 70 685 454